

EU Artificial Intelligence Act GRC Compliance Manual

Practical Governance, Risk, Compliance, Control, Evidence, Audit, and
Implementation Guide

Al Leiva, with AI-assisted drafting and review support

30 July 2026

Table of Contents

1 EU Artificial Intelligence Act GRC Compliance Manual.....	7
2 Chapter 1 — Understanding the EU AI Act.....	8
3 Chapter 2 — Scope, Purpose, and Regulatory Approach.....	12
4 Chapter 3 — Territorial and Extraterritorial Applicability.....	14
5 Chapter 4 — Key Definitions in Plain English.....	15
6 Chapter 5 — Regulatory Roles and Accountability.....	18
7 Chapter 6 — Application Timeline and Transitional Rules.....	20
8 Chapter 7 — Relationship to Other EU Laws and Frameworks.....	24
9 Chapter 8 — AI Governance Operating Model.....	25
10 Chapter 9 — Board and Executive Oversight.....	26
11 Chapter 10 — AI Policy Framework.....	27
12 Chapter 11 — Roles, Responsibilities, and the Three-Lines Model.....	28
13 Chapter 12 — AI Literacy, Role-Based Training, and Competence Assurance.....	30
14 Chapter 13 — AI Policy and Standards.....	36
15 Chapter 14 — AI Governance Operating Model.....	38
16 Chapter 15 — AI Governance Roles and Accountability.....	39
17 Chapter 16 — AI System Inventory.....	40
18 Chapter 17 — AI Intake and Initial Triage.....	41
19 Chapter 18 — Provider, Deployer, Importer, Distributor, Authorised Representative, and Product-Manufacturer Analysis.....	42

20 Chapter 19 — Classification Decision and Evidence.....	44
21 Chapter 20 — High-Risk Classification.....	45
22 Chapter 21 — Annex I and Annex III Analysis.....	49
23 Chapter 22 — High-Risk Exception and Scoping Analysis.....	52
24 Chapter 23 — Classification Review and Approval.....	53
25 Chapter 24 — Reclassification and Change Triggers.....	54
26 Chapter 25 — Classification Register and Reporting.....	55
27 Chapter 26 — Prohibited Practices Overview.....	56
28 Chapter 27 — Manipulation and Subliminal Techniques.....	56
29 Chapter 28 — Exploitation of Vulnerabilities.....	57
30 Chapter 29 — Social Scoring.....	58
31 Chapter 30 — Predictive Policing and Risk Inference.....	59
32 Chapter 31 — Facial-Image Scraping and Biometric Databases.....	59
33 Chapter 32 — Emotion-Recognition Restrictions.....	60
34 Chapter 33 — Biometric Categorisation Restrictions.....	61
35 Chapter 34 — New Prohibitions for Non-Consensual Intimate Content and Child Sexual Abuse Material.....	62
36 Chapter 35 — Prohibited-Practice Governance and Assurance.....	66
37 Chapter 36 — High-Risk Quality-Management System.....	67
38 Chapter 37 — Continuous Risk Management.....	69
39 Chapter 38 — Data and Data Governance.....	70
40 Chapter 39 — Technical Documentation.....	72
41 Chapter 40 — Logs and Recordkeeping.....	74
42 Chapter 41 — Transparency and Instructions for Use.....	76
43 Chapter 42 — Human Oversight.....	78
44 Chapter 43 — Accuracy, Robustness, Cybersecurity, and Resilience....	80
45 Chapter 44 — Conformity Assessment.....	82

46 Chapter 45 — EU Declaration of Conformity and CE Marking.....	84
47 Chapter 46 — Registration.....	86
48 Chapter 47 — Fundamental-Rights Impact Assessment.....	88
49 Chapter 48 — DPIA Coordination.....	90
50 Chapter 49 — Post-Market Monitoring.....	91
51 Chapter 50 — Serious-Incident Reporting.....	93
52 Chapter 51 — Corrective Action, Withdrawal, and Recall.....	95
53 Chapter 52 — Change Management and Substantial Modification.....	97
54 Chapter 53 — Understanding GPAI Roles.....	99
55 Chapter 54 — GPAI Documentation and Downstream Information.....	101
56 Chapter 55 — Copyright Policy and Training-Content Summary.....	102
57 Chapter 56 — GPAI Models with Systemic Risk.....	104
58 Chapter 57 — Model Evaluations and Adversarial Testing.....	106
59 Chapter 58 — Systemic-Risk Assessment and Mitigation.....	107
60 Chapter 59 — Cybersecurity and Incident Reporting for Systemic-Risk GPAI.....	109
61 Chapter 60 — Energy and Resource Reporting.....	111
62 Chapter 61 — Open-Source Considerations.....	113
63 Chapter 62 — GPAI Code of Practice.....	114
64 Chapter 63 — Transparency Code for AI-Generated Content.....	116
65 Chapter 64 — Chatbot and Human-Interaction Disclosure.....	118
66 Chapter 65 — AI-Generated and Manipulated Content Marking.....	119
67 Chapter 66 — Deepfake Disclosure.....	120
68 Chapter 67 — AI-Generated Text Disclosures.....	122
69 Chapter 68 — Emotion-Recognition and Biometric-Categorisation Disclosure.....	123
70 Chapter 69 — Accessibility and Understandable Notices.....	124
71 Chapter 70 — Testing and Monitoring Transparency Disclosures.....	125

72 Chapter 71 — AI Vendor Due Diligence.....	126
73 Chapter 72 — Contract Clauses.....	128
74 Chapter 73 — Provider Documentation Review.....	130
75 Chapter 74 — Model Cards, System Cards, and Limitations.....	132
76 Chapter 75 — Audit Rights and Incident Notification.....	133
77 Chapter 76 — Cloud, API, and Model Dependency Risk.....	135
78 Chapter 77 — Open-Source and Component Governance.....	137
79 Chapter 78 — Ongoing Vendor Monitoring.....	139
80 Chapter 79 — Exit, Portability, and Continuity Planning.....	141
81 Chapter 80 — GDPR Integration.....	143
82 Chapter 81 — Privacy by Design and Data Minimisation.....	145
83 Chapter 82 — Special-Category and Sensitive Personal Data.....	147
84 Chapter 83 — Automated Decision-Making.....	148
85 Chapter 84 — Secure AI Development Lifecycle.....	150
86 Chapter 85 — Threat Modelling.....	152
87 Chapter 86 — Prompt Injection and Model Manipulation.....	154
88 Chapter 87 — Data Poisoning and Training Data Risk.....	155
89 Chapter 88 — Model Extraction and Theft.....	157
90 Chapter 89 — Logging, Monitoring, and Vulnerability Management....	159
91 Chapter 90 — Business Continuity and Disaster Recovery.....	160
92 Chapter 91 — Red-Team and Penetration-Testing Governance.....	162
93 Chapter 92 — Inherent Risk Assessment.....	164
94 Chapter 93 — Fundamental Rights Risk.....	166
95 Chapter 94 — Safety Risk.....	167
96 Chapter 95 — Bias and Discrimination Risk.....	169
97 Chapter 96 — Privacy and Data Protection Risk.....	171
98 Chapter 97 — Cybersecurity Risk.....	173

99 Chapter 98 — Explainability and Transparency Risk.....	175
100 Chapter 99 — Human Autonomy Risk.....	176
101 Chapter 100 — Operational and Resilience Risk.....	178
102 Chapter 101 — Third-Party Risk.....	180
103 Chapter 102 — Legal, Financial, and Reputational Risk.....	182
104 Chapter 103 — Residual Risk Acceptance and Exceptions.....	184
105 Chapter 104 — Control Library Design.....	185
106 Chapter 105 — Article-to-Control Mapping.....	187
107 Chapter 106 — Control Ownership and Frequency.....	189
108 Chapter 107 — Evidence Standards.....	191
109 Chapter 108 — Control Testing.....	192
110 Chapter 109 — Deficiency Classification.....	194
111 Chapter 110 — Corrective Action Management.....	196
112 Chapter 111 — Continuous Compliance Monitoring.....	198
113 Chapter 112 — Audit Planning.....	199
114 Chapter 113 — Design Effectiveness Testing.....	201
115 Chapter 114 — Operating Effectiveness Testing.....	203
116 Chapter 115 — Sampling and Evidence Evaluation.....	204
117 Chapter 116 — Technical Validation.....	207
118 Chapter 117 — Bias, Oversight, and Transparency Testing.....	209
119 Chapter 118 — Conformity Readiness Reviews.....	212
120 Chapter 119 — Internal Audit.....	214
121 Chapter 120 — Regulatory Examination Readiness.....	217
122 Chapter 121 — Findings, Remediation, and Closure.....	219
123 Chapter 122 — AI Office and National Authorities.....	220
124 Chapter 123 — Market-Surveillance Authorities.....	222
125 Chapter 124 — Investigations and Information Requests.....	224

126 Chapter 125 — Administrative Fines and Exposure.....	226
127 Chapter 126 — Executive Escalation.....	228
128 Chapter 127 — Regulatory Notification.....	234
129 Chapter 128 — Evidence Preservation and Legal Hold.....	240
130 Chapter 129 — First 30 Days.....	245
131 Chapter 130 — Days 31-90.....	249
132 Chapter 131 — Months 4-6.....	253
133 Chapter 132 — Months 7-12.....	259
134 Chapter 133 — High-Risk Readiness Roadmap.....	265
135 Chapter 134 — GPAI Readiness Roadmap.....	272
136 Chapter 135 — Transparency Readiness Roadmap.....	277
137 Chapter 136 — Multijurisdictional Deployment.....	283
138 Chapter 137 — AI Governance Maturity Model.....	288
139 Chapter 138 — Continuous Improvement.....	294
140 Appendices.....	301
141 Appendix A — AI Inventory Template.....	301
142 Appendix B — AI Intake Form.....	307
143 Appendix C — Applicability Assessment.....	318
144 Appendix D — Prohibited-Practice Checklist.....	328
145 Appendix E — High-Risk Classification Worksheet.....	341
146 Appendix F — Role-Assessment Worksheet.....	354
147 Appendix G — Fundamental-Rights Impact Assessment.....	368
148 Appendix H — AI Risk Assessment.....	379
149 Appendix I — Data-Governance Assessment.....	391
150 Appendix J — Human-Oversight Plan.....	403
151 Appendix K — Technical-Documentation Index.....	413
152 Appendix L — Conformity-Readiness Checklist.....	422

153	Appendix M — Post-Market Monitoring Plan.....	435
154	Appendix N — Serious-Incident Report.....	444
155	Appendix O — AI Vendor Questionnaire.....	453
156	Appendix P — AI Contract-Clause Checklist.....	461
157	Appendix Q — AI-Literacy Matrix.....	470
158	Appendix R — Transparency Notice Templates.....	476
159	Appendix S — Model-Change Assessment.....	481
160	Appendix T — Substantial-Modification Assessment.....	488
161	Appendix U — AI Control Register.....	495
162	Appendix V — AI Evidence Register.....	499
163	Appendix W — Internal-Audit Programme.....	502
164	Appendix X — Corrective-Action Plan.....	507
165	Appendix Y — Board Dashboard.....	513
166	Appendix Z — AI-Governance Implementation Roadmap.....	524

1 EU Artificial Intelligence Act GRC Compliance Manual

Publication status: Controlled English review edition. This edition is not legal advice and is not approved for external release until final owner authorization.

1.1 Legal and educational disclaimer

This manual is an educational and operational governance resource. It does not replace qualified legal advice, conformity assessment, notified-body review, competent-authority direction, sector-specific obligations, or the current consolidated text of applicable law. Legal conclusions must be verified against Regulation (EU) 2024/1689, as amended by Regulation (EU) 2026/1744, and the current consolidated EUR-Lex text.

1.2 How to use this manual

Use each chapter to identify the applicable requirement, understand it in plain English, apply the GlobalWay Travel Services example, define control activity, retain evidence, and perform an audit test. Distinguish binding legal duties from organization-imposed controls, recommended practices, contractual duties, and optional enhancements.

1.3 Controlled legal baseline

- Regulation (EU) 2024/1689, as amended.
- Regulation (EU) 2026/1744.
- Current consolidated EUR-Lex text.
- Official European Commission and EU AI Office material, identified as non-binding guidance unless incorporated through a binding instrument.

2 Chapter 1 — Understanding the EU AI Act

Legal status: Corrected English master. This chapter is an educational and operational introduction. Binding conclusions must be verified against the current consolidated text of Regulation (EU) 2024/1689, as amended, for the relevant actor, system, use, jurisdiction, and application date.

2.1 Requirement

Organizations that develop, provide, import, distribute, integrate, or deploy artificial-intelligence systems or general-purpose AI models must determine whether the EU AI Act applies, identify their legal role, classify the system or model correctly, and implement the obligations that apply to that role and classification.

The Act uses a risk-based and actor-based structure. It does not impose the same obligations on every AI system or every organization. The applicable duties depend on facts such as intended purpose, market placement, deployment context, affected persons, product integration, system or model type, legal entity, jurisdiction, and timing.

2.2 Plain-English explanation

The EU AI Act is not a single checklist for all AI. It creates different legal pathways:

- certain AI practices are prohibited;
- some AI systems are classified as high-risk and are subject to extensive lifecycle controls;
- some systems and outputs trigger transparency duties;
- providers of general-purpose AI models have separate obligations, with additional duties for models presenting systemic risk;
- many other AI uses remain subject to broader governance, privacy, cybersecurity, employment, consumer, product-safety, accessibility, and sector requirements.

A company must therefore answer four questions before deciding what controls are required:

1. Does the capability meet the current statutory definition of an AI system or general-purpose AI model?
2. Which legal entity performs which regulated role?
3. Which prohibited-practice, high-risk, transparency, GPAI, product, or other legal category applies?
4. When does the relevant provision apply, including transitional rules?

Internal risk ratings, vendor labels, marketing descriptions, contract titles, or maturity scores do not replace this legal analysis.

2.3 GlobalWay Travel Services example

GlobalWay Travel Services uses AI for customer-support chatbots, itinerary recommendations, travel-risk alerts, fraud detection, recruitment screening, supplier scoring, and generative assistance for travel consultants.

These uses do not share one legal classification. The customer chatbot may trigger interaction-transparency duties. Recruitment screening may require high-risk analysis under the employment category. Fraud detection may raise profiling, discrimination, privacy, and human-oversight issues. A general-purpose model embedded in a travel-consultant tool creates separate upstream-provider and downstream-system questions.

GlobalWay therefore maintains one inventory record per system and version, maps each involved legal entity and actor role, records the intended purpose, identifies affected persons and jurisdictions, and completes the applicable legal screens before procurement, pilot, deployment, or material change.

2.4 Control activity

Establish an AI applicability and classification gate requiring documented review before an AI system or model is purchased, developed, piloted, materially modified, placed on the market, put into service, or deployed.

The gate should require:

- an inventory record and accountable business and technical owners;
- legal-entity and actor-role analysis;
- intended-purpose and foreseeable-use documentation;
- prohibited-practice screening;
- high-risk classification analysis;

- transparency and GPAI screening;
- application-date and transitional-rule verification;
- identification of privacy, security, employment, consumer, product, accessibility, and sector obligations;
- evidence-based approval, restriction, escalation, or rejection;
- reassessment after material change.

2.5 Evidence

Retain, as applicable:

- AI inventory and intake records;
- system and model descriptions;
- intended-purpose statements;
- legal-entity and value-chain maps;
- actor-role and applicability assessments;
- prohibited-practice and high-risk worksheets;
- transparency and GPAI analyses;
- legal-source and application-date records;
- approvals, conditions, exceptions, and escalation decisions;
- version, change, and reassessment history;
- vendor documentation and contracts.

Evidence must be attributable, current, version-linked, internally consistent, protected from unauthorized alteration, and retrievable for the relevant review purpose.

2.6 Audit test

1. Select a risk-based sample of AI systems and models from procurement, technology, cloud, data, HR, customer-service, and vendor records.
2. Verify that each sampled item appears in the AI inventory with the correct legal entity, owner, intended purpose, version, and jurisdiction.
3. Inspect the actor-role, prohibited-practice, high-risk, transparency, GPAI, and application-date assessments.

4. Compare conclusions with actual system functionality, contracts, branding, deployment, and affected-person context.
5. Confirm that required controls and approvals were completed before deployment or material change.
6. Test whether reassessment occurred after model, purpose, data, supplier, jurisdiction, population, or legal changes.
7. Report missing, unsupported, inconsistent, or outdated classifications as findings and assess whether operation must be restricted or suspended pending resolution.

2.7 Metrics

Useful governance indicators include:

- percentage of identified AI systems recorded in the inventory;
- percentage with completed actor-role and classification reviews;
- unresolved prohibited-practice or high-risk determinations;
- overdue legal-date or reassessment reviews;
- systems operating under temporary restrictions or incomplete evidence;
- repeated classification or ownership findings.

These are internal management indicators, not statutory proof of compliance.

2.8 Implementation checklist

- ☐ Inventory entry completed
- ☐ Legal entities and actor roles identified
- ☐ Intended purpose and foreseeable use documented
- ☐ Prohibited-practice screening completed
- ☐ High-risk classification completed
- ☐ Transparency and GPAI screening completed
- ☐ Application dates and transitional rules verified
- ☐ Related privacy, security, employment, consumer, product, accessibility, and sector duties identified
- ☐ Approval and conditions recorded

- ☐ Evidence repository linked
- ☐ Reassessment triggers established

2.9 Figure 1.1 — EU AI Act decision pathway

Figure description: A linear decision pathway beginning with inventory and applicability, followed by actor-role identification, prohibited-practice screening, high-risk classification, transparency and GPAI screening, application-date verification, control implementation, evidence retention, monitoring, and reassessment.

Alt text: Decision pathway showing that organizations first inventory the AI system or model, determine applicability and actor roles, screen for prohibited and high-risk uses, identify transparency and GPAI duties, verify application dates, implement controls, retain evidence, monitor operation, and reassess after change.

3 Chapter 2 — Scope, Purpose, and Regulatory Approach

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 2 draft language.

3.1 Requirement

Organizations must determine whether Regulation (EU) 2024/1689, as amended, applies to an AI system, model, actor, activity, or output before assigning controls. The assessment must consider the regulated actor, the activity performed, the geographic connection to the Union, exclusions, product-sector interactions, and the intended and reasonably foreseeable use.

3.2 Plain-English explanation

The EU AI Act is not limited to software companies established in the European Union. It regulates defined actors across the AI value chain and can apply where a system or model is placed on the Union market, put into service in the Union, used by a deployer in the Union, or where an output produced outside the Union is used in the Union. Applicability is therefore a legal and operational question, not merely a location question.

The Act uses a risk-based structure. It prohibits specified practices, imposes extensive requirements on high-risk AI systems, applies transparency duties to specified systems and uses, establishes obligations for providers of general-purpose AI models, and leaves other AI subject to broader governance, contract, privacy, safety, security, employment, consumer-protection, and sector-specific law.

3.3 Scope assessment

Document at minimum:

1. the AI system or model and its intended purpose;
2. the legal entities involved;
3. each actor role under the Act;
4. where the system or model is placed on the market, put into service, or used;
5. where affected people and relevant outputs are located or used;
6. whether an exclusion or special rule applies;
7. whether the AI is a safety component of, or itself, a regulated product;
8. whether the use could be prohibited, high-risk, transparency-regulated, or GPAI-related;
9. whether a change in branding, purpose, modification, distribution, or integration changes the role or legal treatment.

3.4 Exclusions and limits

Do not assume that an exclusion is automatic. Claims involving military, defence, national-security, scientific-research, personal non-professional activity, or open-source treatment must be documented against the current statutory conditions. An exclusion from one AI Act obligation does not remove obligations under other law.

3.5 GlobalWay example

GlobalWay Travel Services procures a cloud-based travel-assistance system from a provider outside the Union and deploys it for EU corporate travelers. Even though the provider is not established in the Union, GlobalWay must assess the provider's market activity, GlobalWay's deployer role, use of outputs in the Union, transparency duties, data-protection requirements, and whether later customization or own-brand placement changes GlobalWay's role.

3.6 Control activity

The Legal and AI Governance functions must approve a documented applicability assessment before procurement, development, production deployment, or material modification. The assessment must be linked to the AI inventory and reviewed after changes in purpose, geography, actor, branding, integration, data, functionality, or applicable law.

3.7 Evidence

- applicability assessment;

- entity and jurisdiction map;
- role assessment;
- intended-purpose statement;
- architecture and supply-chain diagram;
- exclusion analysis, where claimed;
- legal approval and review date;
- reassessment history.

3.8 Audit test

Select a sample of AI systems and models. Confirm that applicability was assessed using the current amended legal text, that every relevant actor and geographic connection was considered, that exclusions are supported by written analysis, and that material changes triggered reassessment.

3.9 Primary legal references

- Regulation (EU) 2024/1689, as amended: Articles 1–2 and relevant definitions in Article 3.
- Regulation (EU) 2026/1744 where amended scope or product-sector treatment is material.
- Current consolidated EUR-Lex text controls over older summaries.

4 Chapter 3 — Territorial and Extraterritorial Applicability

Legal status: Corrected English master for consolidation.

4.1 Requirement

Applicability must be assessed by actor, activity, market connection, deployment location, and use of outputs—not by headquarters location alone.

4.2 Legal assessment sequence

Determine whether the matter involves:

- a provider placing an AI system or GPAI model on the Union market;
- a provider putting an AI system into service in the Union;
- a deployer established or located in the Union;

- a provider or deployer outside the Union where output produced by the system is used in the Union;
- an importer, distributor, authorised representative, or product manufacturer with a Union-market role;
- a regulated product or safety component entering the Union market.

For each connection, record the legal entity, role, system or model, activity, jurisdiction, output flow, and affected population.

4.3 Plain-English explanation

A non-EU organization can fall within the Act when it sells, supplies, deploys, or supports covered AI in the Union, or when output produced outside the Union is used there. Conversely, an EU parent company does not automatically make every global affiliate and every global use subject to the same provision. The analysis must follow the actual legal entity and activity.

4.4 GlobalWay example

A U.S.-based provider supplies an AI itinerary tool to GlobalWay's EU affiliate. The provider may have Union-market obligations; the EU affiliate may be a deployer; another GlobalWay entity may become a provider if it markets a materially modified version under its own name. The organization documents each role separately.

4.5 Control activity

Maintain an entity-and-data-flow map for every material AI system. Legal must approve extraterritorial conclusions and reassess them when deployment geography, contracting entity, output use, branding, or system architecture changes.

4.6 Evidence

- entity map;
- contracts and order forms;
- distribution and deployment records;
- output-use analysis;
- data-flow and architecture diagrams;
- legal memorandum;
- reassessment log.

4.7 Audit test

Verify that sampled assessments identify all relevant providers, deployers, intermediaries, market activities, and Union uses of outputs. Confirm conclusions are not based solely on vendor or customer headquarters.

4.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 2 and relevant Article 3 definitions.
- Current consolidated EUR-Lex text.

5 Chapter 4 — Key Definitions in Plain English

Legal status: Corrected English master for consolidation.

5.1 Requirement

Classification and compliance decisions must use the current statutory definitions. Plain-English explanations may support understanding but must not replace or expand the legal text.

5.2 Core definitions to document

5.2.1 AI system

Assess the statutory characteristics of the system as a whole, including machine-based operation, degree of autonomy, possible adaptiveness after deployment, objectives, inference from inputs, and outputs such as predictions, content, recommendations, or decisions that can influence physical or virtual environments.

5.2.2 General-purpose AI model

A GPAI model is legally distinct from an AI system. Assess whether the model displays significant generality, can competently perform a wide range of distinct tasks, and can be integrated into a variety of downstream systems or applications, subject to the statutory exclusions and conditions.

5.2.3 Provider

The actor that develops, or has developed, an AI system or GPAI model and places it on the market or puts an AI system into service under its own name or trademark, whether for payment or free of charge.

5.2.4 Deployer

The actor using an AI system under its authority, except where the system is used in a personal non-professional activity.

5.2.5 Importer and distributor

An importer places on the Union market a system bearing the name or trademark of a person established outside the Union. A distributor makes

an AI system available on the Union market without being the provider or importer.

5.2.6 Authorised representative

A Union-established person that has received and accepted a written mandate from a provider to perform specified obligations and procedures on the provider's behalf.

5.2.7 Product manufacturer

A product manufacturer may acquire provider obligations where an AI system is placed on the market or put into service with the manufacturer's product under the manufacturer's name or trademark, subject to the applicable statutory conditions.

5.2.8 Intended purpose

The use intended by the provider, including the context and conditions specified in instructions, promotional or sales materials, statements, and technical documentation.

5.2.9 Reasonably foreseeable misuse

Use not intended by the provider but resulting from reasonably foreseeable human behaviour or interaction with other systems.

5.2.10 Substantial modification

A post-market change not foreseen or planned in the initial conformity assessment that affects compliance or changes the intended purpose, subject to the statutory definition and applicable guidance.

5.3 Interpretation controls

- Quote or paraphrase definitions conservatively.
- Cite the exact Article 3 point when a decision depends on a definition.
- Do not treat commercial labels such as "platform," "assistant," "copilot," or "foundation model" as legal classifications.
- Assess multiple roles separately; one entity may hold more than one role.
- Reassess definitions after changes in branding, intended purpose, modification, integration, distribution, or contracting structure.

5.4 GlobalWay example

GlobalWay buys a GPAI-powered travel assistant from a vendor and uses it internally and for customers. The model provider, system provider, cloud intermediary, and GlobalWay may hold different roles. If GlobalWay materially modifies the system and markets it under its own brand, it must reassess whether it has become a provider.

5.5 Control activity

Legal and AI Governance maintain a controlled glossary that links each operational term to the current statutory definition, article reference, owner, and review date.

5.6 Evidence

- controlled glossary;
- role and classification worksheets;
- contract and branding records;
- intended-purpose statement;
- modification assessment;
- legal approval history.

5.7 Audit test

Confirm that sampled decisions use the current statutory definition, identify the exact legal reference, and distinguish legal terms from commercial terminology.

5.8 Primary legal reference

- Regulation (EU) 2024/1689, as amended: Article 3 and related provisions.
- Current consolidated EUR-Lex text.

6 Chapter 5 — Regulatory Roles and Accountability

Legal status: Corrected English master for consolidation.

6.1 Requirement

Every material AI system and GPAI model must have a documented actor-role determination. Obligations attach to the role actually performed, not merely to the label used in a contract.

6.2 Role analysis

Assess separately whether each legal entity acts as:

- provider of an AI system;
- provider of a GPAI model;
- deployer;
- importer;

- distributor;
- authorised representative;
- product manufacturer;
- downstream provider integrating a GPAI model;
- another actor acquiring provider obligations through own-brand placement, substantial modification, or change of intended purpose.

An entity may hold several roles for one product or different roles across jurisdictions and lifecycle stages.

6.3 Accountability principles

1. **Role follows conduct.** Contracts support the analysis but cannot erase statutory responsibility.
2. **Legal entities matter.** Record which affiliate performs each activity.
3. **Lifecycle changes matter.** Branding, modification, repurposing, integration, and distribution can change roles.
4. **Model and system roles differ.** A GPAI-model provider and an AI-system provider are not automatically the same actor.
5. **Responsibilities must be operationalized.** Assign accountable owners for documentation, monitoring, incident response, human oversight, supplier management, and regulatory cooperation.

6.4 GlobalWay example

GlobalWay deploys a vendor's travel assistant for customer service. The vendor remains the system provider, while GlobalWay is ordinarily the deployer. If GlobalWay modifies the system beyond the provider's planned changes, changes its intended purpose, or markets it under GlobalWay branding, Legal must reassess whether GlobalWay has acquired provider obligations.

6.5 Control activity

Before approval, Legal completes a role matrix by entity and jurisdiction. Procurement ensures contracts reflect the operational allocation of responsibilities, required information exchange, audit rights, change notification, incident cooperation, and exit support. The business owner must trigger reassessment after material changes.

6.6 Evidence

- actor-role matrix;
- organization and affiliate map;

- contracts and written mandates;
- branding and market-placement records;
- intended-purpose and modification assessments;
- RACI and accountable-owner approvals;
- reassessment log.

6.7 Audit test

For sampled systems, compare the documented role determination with actual development, branding, contracting, market-placement, deployment, modification, and distribution activities. Confirm that role changes trigger updated obligations and controls.

6.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 3 definitions and actor-specific obligations throughout the Regulation.
- Current consolidated EUR-Lex text.

7 Chapter 6 — Application Timeline and Transitional Rules

7.1 Publication status

Legally corrected English master text. This chapter supersedes conflicting timeline language in earlier drafts, figures, appendices, or translation working files until those materials are updated and verified.

7.2 Purpose

This chapter explains when the EU Artificial Intelligence Act applies, how Regulation (EU) 2026/1744 changed the timetable, and why organizations must assess the effective date of each obligation rather than rely on a single general compliance date.

7.3 Requirement

Organizations must maintain a current, source-controlled implementation calendar that maps each applicable AI Act obligation to the relevant legal actor, system category, transition rule, and effective date.

The controlling sources are:

- Regulation (EU) 2024/1689, as amended;
- Regulation (EU) 2026/1744;
- the current consolidated EUR-Lex text;

- official European Commission implementation guidance, treated as non-binding unless it reflects binding legislation.

7.4 Plain-English explanation

The AI Act does not begin applying all at once. Some provisions already apply, some apply from 2 August 2026, and specific high-risk requirements have later dates. A company can be late for one duty even though another duty has not yet begun.

The date analysis must answer four questions:

1. Which legal provision is involved?
2. Which actor and system category does it cover?
3. Is there a specific transition rule?
4. Has later legislation amended the original timetable?

7.5 Verified implementation baseline

Date	Requirement or milestone
1 August 2024	Regulation (EU) 2024/1689 entered into force.
2 February 2025	The original Article 5 prohibited practices and Article 4 AI-literacy duties began applying.
2 August 2025	Governance provisions and obligations for providers of general-purpose AI models began applying, subject to the Act's transition rules.
27 July 2026	Regulation (EU) 2026/1744 entered into force. Its amendments must be reflected in the organization's legal baseline.
2 August 2026	Most remaining AI Act provisions apply, except where the Act as amended provides another date or transitional rule.
2 December 2026	The newly added Article 5 prohibitions concerning AI systems that generate non-consensual sexually explicit or intimate content or child sexual abuse material apply.
2 December 2026	The amended transition for

Date	Requirement or milestone
	specified providers of AI systems, including GPAI systems, that generate synthetic audio, image, video, or text content and were placed on the market before 2 August 2026 must be assessed for Article 50(2) compliance.
2 August 2027	Providers of GPAI models placed on the market before 2 August 2025 must comply, subject to the applicable transition rules.
2 December 2027	The requirements governing high-risk systems under Article 6(2) and Annex III apply under the amended timetable.
2 August 2028	The requirements governing high-risk systems under Article 6(1) and Annex I product legislation apply under the amended timetable.

7.6 Critical interpretation rule

The later dates for high-risk AI must be stated narrowly. They do not mean that every provision touching high-risk AI, every governance duty, every enforcement power, or every related legal obligation is postponed to the same date.

For each system, document separately:

- classification and scoping provisions;
- Chapter III, Sections 1–3 requirements;
- provider, deployer, importer, distributor, and representative duties;
- transparency obligations;
- GPAI obligations;
- governance and enforcement provisions;
- system-specific transition rules;
- obligations arising under GDPR, employment, consumer, safety, cybersecurity, and sector law.

7.7 GlobalWay Travel Services example

GlobalWay operates a recruitment-screening system, a traveler chatbot, and a fraud-detection service. Its compliance calendar does not assign one date to all three systems.

The chatbot team prepares for Article 50 transparency duties, the recruitment team maps the Annex III high-risk timetable to 2 December 2027, and legal counsel separately tracks GDPR, employment-law, AI-literacy, incident, and governance duties that may already apply.

7.8 Control activities

- Maintain a legal implementation calendar owned by Legal or Compliance.
- Link each date to the exact article, paragraph, annex, actor, and system category.
- Record amendments and the date they entered into force.
- Require legal review before relying on a delayed implementation date.
- Reconcile dates across chapters, policies, controls, contracts, appendices, graphics, training, and translations.
- Configure project plans and system gates to prevent deployment based on an outdated date.
- Reverify the timetable immediately before publication and before material deployment decisions.

7.9 Evidence

- legal implementation calendar;
- article-to-date mapping;
- legal memoranda and amendment assessments;
- system classification and role records;
- project plans and readiness milestones;
- policy and training updates;
- corrected graphics and appendices;
- publication verification record.

7.10 Audit tests

1. Select material AI obligations and trace each date to the current amended legal text.

2. Confirm delayed high-risk dates are limited to the provisions covered by the amendment.
3. Verify legal, operational, and technical project plans use the same dates.
4. Inspect whether earlier summaries or graphics remain in circulation.
5. Confirm the organization reassesses dates after legislative amendments or official corrections.
6. Verify system owners understand which duties already apply.

7.11 Management checklist

- Are we using the current amended legal text?
- Do we distinguish entry into force from application?
- Are high-risk delays stated narrowly?
- Have all graphics, appendices, and translations been reconciled?
- Can every implementation date be traced to a binding source?

7.12 Figure specification — EU AI Act Application Timeline

Create an accessible horizontal timeline showing the milestones from 1 August 2024 through 2 August 2028. Visually distinguish general application dates, GPAI transitions, new Article 5 prohibitions, Annex III high-risk requirements, and Annex I product-embedded high-risk requirements. Include a prominent note that system-specific analysis is required.

Alt text: EU AI Act implementation timeline showing entry into force in August 2024, prohibited-practice and AI-literacy duties in February 2025, GPAI governance in August 2025, the 2026 AI Omnibus amendment, general application in August 2026, new prohibitions in December 2026, GPAI transition in August 2027, Annex III high-risk requirements in December 2027, and Annex I product-embedded requirements in August 2028.

8 Chapter 7 — Relationship to Other EU Laws and Frameworks

Legal status: Corrected English master. The EU AI Act operates alongside other applicable Union and national law. Compliance with the AI Act does not replace obligations under data protection, cybersecurity, product safety, employment, consumer, competition, accessibility, intellectual-property, or sector-specific law.

8.1 Requirement

Identify every legal regime that applies to the organization, actor, AI system, use case, affected persons, data, product context, jurisdiction, and lifecycle stage. Resolve overlaps explicitly rather than assuming that one assessment satisfies all legal duties.

8.2 Plain-English explanation

An AI system can be lawful under one regime and still fail another. For example, a use may fall outside the AI Act high-risk category but still require a data-protection impact assessment, worker consultation, accessibility controls, consumer disclosures, cybersecurity measures, or sector approval.

8.3 GlobalWay example

GlobalWay Travel Services deploys an AI-supported recruitment tool in several EU Member States. The team assesses the AI Act classification, GDPR lawful basis and automated-decision rules, employment-law consultation duties, accessibility, discrimination risk, vendor obligations, security, and local labor requirements separately and records how the controls interact.

8.4 Control activity

Maintain a legal-interface register covering:

- applicable law and provision;
- regulated actor and trigger;
- system, version, use, jurisdiction, and population;
- responsible legal or compliance owner;
- required assessment, notice, control, approval, or reporting action;
- evidence location and retention basis;
- conflicts, dependencies, and unresolved interpretation.

8.5 Evidence

Retain applicability analyses, legal memoranda, DPIAs, FRIAs, security assessments, worker-consultation records, accessibility reviews, product or sector approvals, notices, contracts, and decision records.

8.6 Audit test

Select a sample of AI systems and verify that the legal-interface analysis is current, actor- and jurisdiction-specific, linked to the deployed version, and supported by evidence. Confirm that no team treated AI Act readiness as a substitute for another applicable legal obligation.

8.7 Key control warning

Where legal regimes overlap or conflict, obtain qualified legal review and document the resolution. Do not present organizational policy or voluntary standards as binding law.

9 Chapter 8 — AI Governance Operating Model

Legal status: Corrected English master. An enterprise AI-governance operating model is generally an organization-imposed control framework. It supports compliance but does not replace actor-specific statutory duties.

9.1 Requirement

Establish a documented operating model that assigns accountability, decision rights, lifecycle gates, escalation, and evidence responsibilities for AI systems and models.

9.2 Plain-English explanation

Governance must show who decides, who performs controls, who challenges decisions, and who can stop deployment. A committee name alone is not an operating model.

9.3 GlobalWay example

GlobalWay creates an AI Governance Council supported by Legal, Compliance, Privacy, Security, Data, Procurement, HR, Accessibility, Internal Audit, and business owners. Each AI system has a named owner, technical owner, risk owner, and human-oversight owner.

9.4 Control activity

Document:

- governance forums and mandates;
- actor-role and legal-accountability mapping;
- intake, classification, approval, release, monitoring, change, incident, and retirement gates;
- escalation and stop authority;
- segregation of duties and conflicts;
- required records and evidence repositories;
- reporting cadence and exception management.

9.5 Evidence

Charters, RACI matrices, meeting records, approvals, lifecycle procedures, decision logs, exception records, escalation records, and board or executive reports.

9.6 Audit test

Sample governance decisions and verify that required functions participated, decision rights were followed, evidence was retained, conflicts were addressed, and unresolved legal or technical issues were escalated before deployment.

10 Chapter 9 — Board and Executive Oversight

Legal status: Corrected English master. Board and executive oversight requirements depend on corporate, sector, fiduciary, risk-management, and organizational obligations. The EU AI Act does not impose one universal board-reporting template.

10.1 Requirement

Provide governing bodies and executives with accurate, timely, decision-useful information on material AI risk, legal obligations, incidents, control failures, dependencies, and remediation.

10.2 Plain-English explanation

Senior leaders need enough information to challenge management, fund controls, set risk tolerance, and stop unacceptable uses. Dashboards must disclose uncertainty and evidence limitations.

10.3 GlobalWay example

GlobalWay's executive committee receives quarterly reporting on prohibited-use screening, unresolved classifications, high-risk and GPAI exposure, serious incidents, complaints, vendor concentration, overdue remediation, and AI-literacy completion. Critical events are escalated immediately.

10.4 Control activity

Define:

- reporting thresholds and cadence;
- accountable report owners;
- metrics, source systems, validation, and limitations;
- decisions reserved for executives or the board;
- immediate escalation triggers;

- treatment of privilege, confidentiality, and regulator-sensitive information;
- evidence of challenge and decision follow-through.

10.5 Evidence

Board and committee packs, minutes, decisions, management attestations, metric definitions, source reconciliations, escalation records, and remediation funding approvals.

10.6 Audit test

Inspect a sample of reports and minutes. Verify completeness, accuracy, disclosure of limitations, timely escalation, documented challenge, and follow-up of required decisions and actions.

11 Chapter 10 — AI Policy Framework

Legal status: Corrected English master. An AI policy framework is an organization-imposed governance control. It should translate applicable legal, contractual, risk, security, privacy, accessibility, and ethical requirements into enforceable internal rules.

11.1 Requirement

Maintain approved, version-controlled policies and standards governing AI acquisition, development, deployment, use, monitoring, change, incident response, and retirement.

11.2 Plain-English explanation

Policies set the rules; procedures explain how to follow them. They must match actual operations, identify accountable owners, and distinguish binding law from internal requirements and recommended practices.

11.3 GlobalWay example

GlobalWay issues an enterprise AI policy supported by standards for approved tools, confidential data, prohibited uses, procurement, human oversight, transparency, testing, monitoring, incidents, records, and generative-AI use. Local addenda address jurisdiction and employment requirements.

11.4 Control activity

The framework should define:

- scope, entities, systems, models, users, and jurisdictions;
- prohibited and restricted uses;
- intake, classification, approval, and release requirements;

- data, privacy, security, accessibility, and human-oversight rules;
- vendor, contract, change, monitoring, incident, and evidence requirements;
- exception authority, duration, interim controls, and escalation;
- review triggers and communication responsibilities.

11.5 Evidence

Approved policies, standards, procedures, version history, legal review, training records, attestations, exception records, communications, and compliance-monitoring results.

11.6 Audit test

Verify that policies are current, approved, accessible, internally consistent, mapped to applicable obligations, communicated to relevant personnel, and operating in practice. Sample exceptions and confirm authorization, expiry, compensating controls, and closure.

12 Chapter 11 — Roles, Responsibilities, and the Three-Lines Model

Legal status: Corrected English master. The three-lines model is a governance and assurance practice, not a universal statutory structure. Legal accountability remains with the actor and entity identified by applicable law.

12.1 Requirement

Assign clear responsibilities for owning AI use, operating controls, providing specialist oversight, and delivering independent assurance without obscuring statutory actor duties.

12.2 Plain-English explanation

Business and technical teams own the system and its risks. Specialist functions set requirements, advise, challenge, and monitor. Internal audit or another independent assurance function evaluates governance and controls. Independence and accountability must be real, not merely shown on an organization chart.

12.3 GlobalWay example

GlobalWay assigns business and technical owners as the first line; Legal, Compliance, Privacy, Security, Data Governance, Accessibility, HR, and Vendor Risk as the second line; and Internal Audit as the third line. The AI Governance Council coordinates decisions but does not absorb the responsibilities of system owners or regulated actors.

12.4 Control activity

Document:

- actor-specific legal responsibilities;
- business, technical, risk, oversight, and evidence owners;
- authority to approve, challenge, restrict, suspend, or escalate;
- independence, conflict, and segregation requirements;
- competence and backup coverage;
- handoffs among lifecycle stages and functions;
- accountability for findings and remediation.

12.5 Evidence

Role descriptions, RACI matrices, committee charters, delegations, competence records, conflict disclosures, approvals, challenge records, assurance plans, and remediation assignments.

12.6 Audit test

Trace a sample of AI decisions and incidents through the assigned roles. Confirm that ownership was clear, required challenge occurred, independent assurance was not performed by control operators, and unresolved conflicts or capability gaps were escalated.

13 Chapter 12 — AI Literacy, Role-Based Training, and Competence Assurance

13.112.1 Purpose

This chapter establishes a practical governance framework for meeting the EU AI Act's AI-literacy obligation and for demonstrating that people who operate, supervise, procure, approve, monitor, audit, or rely on AI systems are prepared for their responsibilities.

The objective is not to turn every employee into a data scientist. It is to ensure that each person understands enough about the AI systems they encounter to use them safely, question them appropriately, recognize limits, escalate concerns, and preserve human accountability.

Core principle: AI may support human decision-making, but it must not remove human responsibility, judgment, or accountability.

13.212.2 Legal Requirement

Article 4 requires providers and deployers of AI systems to take measures supporting AI literacy for staff and other persons who operate or use AI systems on their behalf. The measures should reflect the person's technical knowledge, experience, education and training, the context in which the AI system is used, and the people or groups affected by that use.

The obligation is contextual. A traveler-support agent, developer, procurement manager, human reviewer, executive sponsor, and internal auditor do not need identical training. Each needs competence appropriate to the role, system, decision authority, risk, and affected population.

13.312.3 Plain-Language Explanation

A defensible program must answer five questions:

1. Who interacts with each AI system?
2. What decisions or actions can that person take?
3. What can go wrong in that use case?
4. What must the person know and be able to do?
5. What evidence shows that the person remains competent?

Training attendance alone is not competence. Competence requires understanding, application, judgment, and the ability to recognize when normal use must stop.

13.412.4 GlobalWay Travel Services Example

GlobalWay Travel Services uses a traveler-facing virtual assistant, agent-assistance tools, disruption prediction, fraud screening, internal generative AI, supplier-risk analysis, and AI-supported recruitment screening.

GlobalWay therefore maintains a role-based AI literacy matrix.

Readable record format (4 source columns):

Record 1

- **Role:** Traveler-support agent
- **What AI may do:** Suggest itineraries and draft messages
- **Human responsibility:** Verify facts, approve communications, protect travelers, escalate exceptions
- **Required competence:** Hallucination recognition, source checking, accessibility, override, escalation

Record 2

- **Role:** Operations manager
- **What AI may do:** Prioritize disruption cases
- **Human responsibility:** Approve operational decisions and monitor impact
- **Required competence:** Bias, drift, thresholds, incident response, documentation

Record 3

- **Role:** Procurement manager
- **What AI may do:** Summarize vendor responses
- **Human responsibility:** Validate evidence and assess contractual risk
- **Required competence:** Due diligence, model limits, data rights, audit rights, subcontractor risk

Record 4

- **Role:** Developer or integrator
- **What AI may do:** Configure and connect AI components
- **Human responsibility:** Implement safeguards and preserve controls
- **Required competence:** Testing, logging, security, marking, change control

Record 5

- **Role:** Human reviewer
- **What AI may do:** Review AI-supported decisions
- **Human responsibility:** Approve, correct, reject, or escalate
- **Required competence:** Automation bias, meaningful review, challenge rights, evidence quality

Record 6

- **Role:** Executive sponsor
- **What AI may do:** Approve objectives, funding, and risk acceptance
- **Human responsibility:** Own business accountability

- **Required competence:** Governance duties, residual risk, human impact, stop-use criteria

Record 7

- **Role:** Legal and compliance
- **What AI may do:** Interpret obligations and challenge controls
- **Human responsibility:** Confirm regulatory treatment and evidence sufficiency
- **Required competence:** Role classification, transparency, prohibited practices, documentation

Record 8

- **Role:** Internal audit
- **What AI may do:** Independently test controls
- **Human responsibility:** Report deficiencies and verify remediation
- **Required competence:** Audit criteria, sampling, traceability, operating effectiveness

13.512.5 Control Objective

GlobalWay shall maintain a risk-based AI literacy and competence program ensuring that personnel and third parties understand:

- the purpose and limits of the AI systems they use;
- their authority and accountability;
- what AI may and may not do;
- when human review is mandatory;
- how to identify unreliable, biased, unsafe, or manipulated outputs;
- how to stop, override, correct, challenge, and escalate;
- how to protect personal, confidential, and regulated information;
- how to document decisions and preserve evidence;
- how affected people may obtain help, correction, or human review.

13.612.6 Role-Based Learning Architecture

13.6.1 Foundation level

Required for all personnel with access to AI-enabled tools. Topics include approved and prohibited uses, confidentiality, hallucinations, synthetic media, bias, human accountability, incident reporting, and the right to stop and seek help.

13.6.2 Practitioner level

Required for routine users. Topics include system-specific purpose and limits, input and output handling, source validation, override procedures, accessibility, documentation, and known failure modes.

13.6.3 Owner and reviewer level

Required for system owners, human reviewers, risk owners, and managers. Topics include meaningful human oversight, automation bias, performance thresholds, incidents, complaints, change management, affected-person impact, and stop-use criteria.

13.6.4 Specialist level

Required for developers, integrators, security, privacy, legal, procurement, compliance, and audit. Topics may include data governance, adversarial misuse, model evaluation, vendor risk, technical documentation, transparency marking, logging, conformity, and evidence.

13.6.5 Executive and board level

Required for leaders approving AI strategy, material systems, or risk acceptance. Topics include organizational accountability, legal exposure, human-rights impact, limits of assurance, residual-risk acceptance, and suspension or withdrawal conditions.

13.712.7 Competence Assurance

GlobalWay shall not rely only on completion certificates. It shall use scenario-based assessments, supervised practice, tabletop exercises, observed task performance, challenge-and-override simulations, periodic knowledge checks, manager confirmation, and remedial training.

Personnel should be able to demonstrate what they would do when:

- AI output conflicts with authoritative information;
- a recommendation appears unfair or unsafe;
- required data is missing;
- a traveler is vulnerable or needs accessibility support;
- confidential information is exposed;

- a system behaves differently after an update;
- an affected person challenges an AI-supported outcome.

13.812.8 Human Decision Boundary

For each AI-enabled role, GlobalWay documents:

Required element	Example
What AI may do	Draft a rebooking recommendation
What remains human	Approve the final itinerary and communication
Review requirement	Verify fare rules, visa constraints, accessibility, and traveler preference
Stop condition	Conflicting data, vulnerable traveler, unclear policy, or unsafe recommendation
Escalation route	Senior agent, duty manager, legal, security, or emergency response
Accountable owner	Director of Traveler Operations
Challenge right	Traveler may request correction or human review

13.912.9 Third Parties and Contractors

Relevant contractors, consultants, temporary staff, managed-service personnel, and outsourced providers must complete role-appropriate training before access is granted. Contracts should address competence, approved use, confidentiality, incident notification, subcontractors, evidence retention, retraining, and access suspension.

13.10 12.10 Training Triggers

Training must be assigned or refreshed when a new AI system is introduced, a role changes, the model or workflow materially changes, a new affected population is introduced, an incident or complaint occurs, monitoring reveals recurring error, law changes, a vendor changes a material feature, or an audit identifies insufficient competence.

13.11 12.11 Stop and Escalation Conditions

Personnel must stop normal use and escalate when output may cause significant harm, the system appears compromised, mandatory human review cannot be performed, information is insufficient to validate output, content is discriminatory or unsafe, confidential information is exposed, a required notice or log is missing, or an affected person requests human intervention that the workflow cannot provide.

13.12 12.12 Evidence

Retain the AI literacy policy, role inventory, training-needs analysis, curriculum, version history, completion records, assessment results, competence demonstrations, remedial actions, contractor evidence, training-trigger records, exception approvals, management review minutes, and links between incidents and training improvements.

13.13 12.13 Metrics

Management should review assignment and completion rates, assessment pass rates, overdue training, retraining after changes, incidents involving misuse or misunderstanding, override and escalation rates, repeated validation failures, contractor compliance, remediation time, and employee confidence in challenging AI output.

Metrics must not reward blind acceptance. Appropriate increases in overrides or escalations may show that personnel are exercising judgment.

13.14 12.14 Audit Test

An auditor should sample AI systems across risk levels and functions; identify all operating, reviewing, approving, procuring, maintaining, and auditing roles; compare learning with actual authority and risk; verify system-specific training; inspect competence evidence; test knowledge of limits and stop conditions; trace system changes to retraining; review incidents for literacy-related root causes; verify contractor coverage; and confirm management remediation.

13.15 12.15 Formal Process Graphic Specification

Figure 12-1 — Role-Based AI Literacy and Competence Lifecycle

AI system identified → roles and affected people mapped → competence requirements defined → role-based learning delivered → realistic competence tested → access approved → performance monitored → change or incident triggers retraining

Use two aligned tracks:

- **Organization track:** inventory, requirements, training, monitoring, evidence.
- **Human track:** understand, practice, question, override, escalate, improve.

Human concern:

“Does the person reviewing this system actually know when it is wrong?”

Alt text: A two-track lifecycle showing how an organization maps AI roles, delivers role-based training, tests competence, grants access, monitors performance, and retrains people after changes or incidents. The human

track emphasizes questioning, overriding, and escalating rather than merely completing a course.

13.16 12.16 Original Workplace-Satire Graphic

Figure 12-2 — “Everyone Passed the Training”

Scene: A manager points proudly to a dashboard showing 100% training completion. Beside it, an employee asks an AI system whether a traveler needs a visa, receives three contradictory answers, and clicks “Approve All.”

Caption:

“The course completion rate was excellent. The competence rate was still loading.”

Control lesson: Completion statistics do not prove that personnel can identify unreliable outputs, exercise judgment, or protect affected people.

Alt text: An office manager celebrates full AI-training completion while an employee blindly approves contradictory AI answers about a traveler’s visa.

13.17 12.17 Key Takeaway

AI literacy is not a one-time awareness exercise. It is a governance control connecting each person’s knowledge and judgment to the real system, decision, risk, and people affected.

13.18 12.18 Official Sources

- Regulation (EU) 2024/1689, Article 4 — AI literacy.
- European Commission, AI literacy questions, answers, and practice materials.

Legal update note: Verify the regulatory baseline and official Commission implementation materials immediately before publication.

14 Chapter 13 — AI Policy and Standards

Legal status: Corrected English master. Organizational AI policies and standards operationalize governance decisions but do not replace binding law, contract, sector rules, conformity obligations, or authority directions.

14.1 Requirement

Organizations should maintain approved, version-controlled AI policies and supporting standards that define scope, roles, permitted and prohibited uses, lifecycle controls, escalation, evidence, exceptions, and review triggers.

14.2 Plain-English explanation

A policy explains what the organization requires and who is accountable. Standards explain the minimum control conditions that systems, models, vendors, and users must meet. Each requirement should identify whether it comes from law, contract, internal policy, or recommended practice.

14.3 GlobalWay example

GlobalWay adopts an enterprise AI policy covering customer, workforce, procurement, security, privacy, and generative-AI use. Supporting standards define inventory, classification, human oversight, transparency, security, testing, vendor due diligence, incident response, and evidence retention.

14.4 Control activity

- approve policy and standards through defined governance;
- map requirements to actor roles, systems, jurisdictions, and dates;
- publish role-specific procedures and exceptions;
- monitor adoption and noncompliance;
- review after legal, system, vendor, incident, audit, or organizational change.

14.5 Evidence

Approved policy, standards, ownership matrix, version history, communications, attestations, exception register, control mappings, and review records.

14.6 Audit test

Verify approval, scope, currency, source traceability, communication, implementation evidence, exception handling, and consistency with actual operations.

15 Chapter 14 — AI Governance Operating Model

Legal status: Corrected English master. The operating model is an organizational governance mechanism. It must support, but does not replace, actor-specific duties under applicable law.

15.1 Requirement

The organization should define how AI decisions are made, challenged, escalated, documented, and monitored across legal entities, business units, technologies, and jurisdictions.

15.2 Plain-English explanation

An operating model turns policy into repeatable work. It identifies forums, decision rights, lifecycle gates, accountable owners, second-line challenge, independent assurance, escalation routes, and required evidence.

15.3 GlobalWay example

GlobalWay establishes an AI governance council, business-system owners, legal and compliance review, privacy and security review, procurement controls, human-oversight owners, and internal-audit coverage. High-impact decisions require documented cross-functional approval.

15.4 Control activity

- define governance bodies and decision rights;
- assign accountable, responsible, consulted, and informed roles;
- establish intake, classification, approval, monitoring, change, incident, and retirement gates;
- define escalation thresholds and decision records;
- test whether governance forums operate as designed.

15.5 Evidence

Charters, RACI matrices, meeting records, decision logs, approvals, escalation records, lifecycle gate outputs, and assurance reports.

15.6 Audit test

Sample material AI decisions and verify that the correct forum, roles, evidence, challenge, approval, and escalation were applied.

16 Chapter 15 — AI Governance Roles and Accountability

Legal status: Corrected English master. Internal role assignments support accountability but do not alter statutory actor roles or transfer legal duties merely by policy or contract.

16.1 Requirement

The organization should assign named accountability for AI systems, models, data, risk, compliance, privacy, security, human oversight, vendors, incidents, evidence, and audit response.

16.2 Plain-English explanation

Every material AI activity needs a responsible owner with authority, competence, resources, and a clear escalation route. Shared responsibility must not become unowned responsibility.

16.3 GlobalWay example

GlobalWay assigns a business owner and technical owner to each AI system, with separate risk, legal, privacy, security, data, human-oversight, and supplier responsibilities. The governance council resolves conflicts and approves residual risk within lawful authority.

16.4 Control activity

- document role descriptions and decision rights;
- identify statutory and contractual responsibilities separately;
- verify competence, independence, authority, and resources;
- prevent conflicts and incompatible duties;
- reassess roles after organizational, system, supplier, branding, or intended-purpose changes.

16.5 Evidence

Role descriptions, RACI matrices, delegations, training records, conflict assessments, approvals, succession plans, and escalation logs.

16.6 Audit test

Select systems and decisions, then confirm named owners existed, understood their duties, exercised authority, retained evidence, and escalated issues appropriately.

17 Chapter 16 — AI System Inventory

Legal status: Corrected English master. An AI inventory is a governance and evidence mechanism. Its required fields and retention depend on applicable law, actor role, system, use, contract, and organizational policy.

17.1 Requirement

The organization should maintain a complete, current, version-linked inventory of AI systems, models, use cases, legal entities, actor roles, intended purposes, affected persons, jurisdictions, suppliers, data, owners, classifications, and lifecycle status.

17.2 Plain-English explanation

An organization cannot govern what it cannot identify. The inventory is the controlled record connecting each AI use to ownership, legal analysis, risk, controls, evidence, monitoring, and change history.

17.3 GlobalWay example

GlobalWay inventories customer chatbots, itinerary recommendations, fraud analytics, workforce tools, supplier scoring, and generative-AI assistants.

Each record identifies the deployed version, provider, business owner, legal role, EU exposure, classification, data categories, oversight, and review date.

17.4 Control activity

- require inventory entry before procurement, development, pilot, or deployment;
- reconcile procurement, cloud, security, data, finance, and business records;
- link systems to models, versions, vendors, and downstream uses;
- track status from concept through retirement;
- review after material change, incident, audit, or legal development.

17.5 Evidence

Inventory records, reconciliation reports, ownership attestations, discovery results, change history, exception logs, and retirement records.

17.6 Audit test

Reconcile a sample of known AI-related purchases, applications, APIs, repositories, and business processes to the inventory and investigate omissions or stale records.

18 Chapter 17 — AI Intake and Initial Triage

Legal status: Corrected English master. Intake and triage are organizational controls used to identify applicable legal, risk, security, privacy, procurement, and operational reviews before an AI activity proceeds.

18.1 Requirement

The organization should require a documented intake and triage process before developing, buying, configuring, piloting, materially changing, or deploying an AI system or model.

18.2 Plain-English explanation

The intake process captures enough information to decide which reviews and approvals are needed. It should identify unresolved facts early rather than allowing a project to proceed on assumptions.

18.3 GlobalWay example

Before a business team pilots an AI travel assistant, GlobalWay records its intended purpose, provider, model, users, affected persons, jurisdictions, data, automation level, human oversight, supplier dependencies, and

planned launch. Triage routes the use to legal, privacy, security, procurement, accessibility, risk, and technical review as applicable.

18.4 Control activity

- require intake before commitment or deployment;
- screen for prohibited practices, high-risk use, transparency duties, GPAI exposure, privacy, security, employment, consumer, accessibility, and sector requirements;
- document missing information and interim restrictions;
- assign reviewers, deadlines, and evidence requirements;
- prevent progression until mandatory gates are satisfied or a lawful exception is approved.

18.5 Evidence

Completed intake forms, triage decisions, reviewer assignments, screening outputs, restrictions, approvals, rejected requests, and escalation records.

18.6 Audit test

Sample new and changed AI initiatives and verify timely intake, complete triage, appropriate routing, documented decisions, and enforcement of required gates.

19 Chapter 18 — Provider, Deployer, Importer, Distributor, Authorised Representative, and Product-Manufacturer Analysis

Legal status: Corrected English master for consolidation.

19.1 Requirement

The AI intake process must determine every applicable actor role by legal entity, jurisdiction, lifecycle stage, system, and model. The assessment must be approved before procurement, development, market placement, deployment, distribution, or material change.

19.2 Assessment method

19.2.1 Step 1 — Map the value chain

Identify who:

- develops or commissions development;
- owns or controls the model and system;
- places the system or model on the market;

- puts the system into service;
- uses it under its authority;
- imports or distributes it in the Union;
- integrates it into a regulated product;
- markets it under a name or trademark;
- modifies it or changes its intended purpose;
- provides documentation, monitoring, and incident support.

19.2.2 Step 2 — Assess each role

Record Yes, No, or Uncertain for provider, deployer, importer, distributor, authorised representative, product manufacturer, GPAI-model provider, downstream provider, and any provider-role transfer trigger.

19.2.3 Step 3 — Test provider-role transfer triggers

Escalate when an actor:

- places a system on the market or puts it into service under its own name or trademark;
- makes a substantial modification;
- changes the intended purpose so that the system becomes high-risk or otherwise materially changes its legal treatment;
- integrates an AI system into a product under conditions that assign provider responsibilities.

19.2.4 Step 4 — Allocate obligations

For each confirmed role, map applicable duties, accountable owners, required information, contractual dependencies, evidence, and review triggers.

19.3 Important controls

- Do not rely solely on the contract's role labels.
- Separate the GPAI model from the downstream AI system.
- Assess each affiliate independently.
- Record uncertainties and obtain legal review.
- Reassess after branding, integration, modification, repurposing, entity, provider, or distribution changes.

19.4 GlobalWay example

GlobalWay deploys a vendor-built travel assistant in the Union. GlobalWay is ordinarily the deployer. A non-EU vendor may be the provider, an EU affiliate may be the importer, and a reseller may be the distributor. If GlobalWay substantially modifies and markets the assistant under its own name, it performs a fresh provider-role assessment before release.

19.5 Control activity

The AI Governance Office maintains a role matrix integrated with the inventory, intake, vendor review, contract review, change-management process, and regulatory-obligation register.

19.6 Evidence

- value-chain map;
- role worksheet;
- contracts and mandates;
- branding and marketing evidence;
- technical and modification records;
- intended-purpose statement;
- legal approval;
- obligation-to-owner mapping;
- reassessment log.

19.7 Audit test

Select a sample of internally developed, procured, modified, integrated, and distributed AI. Confirm that each relevant entity and role was assessed, that actual conduct supports the conclusion, and that role-transfer triggers are monitored.

19.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 3 and applicable actor obligations.
- Current consolidated EUR-Lex text.

20 Chapter 19 — Classification Decision and Evidence

Legal status: Corrected English master. Classification conclusions must be based on the current consolidated law, the system's intended purpose, actor role, affected use, and applicable date.

20.1 Requirement

Document whether each AI system is prohibited, high-risk, subject to transparency duties, a general-purpose AI model or downstream integration, or outside those categories.

20.2 Plain-English explanation

A label is not enough. The decision record must show the facts, legal provisions, assumptions, exclusions, reviewer, and date used.

20.3 GlobalWay example

GlobalWay records why a recruitment-screening system is treated differently from an itinerary-recommendation tool and routes uncertainty to legal review.

20.4 Control activity

Require a version-controlled classification memorandum before approval, material change, or deployment in a new jurisdiction.

20.5 Evidence

Inventory record, intended-purpose statement, role assessment, legal mapping, decision memorandum, approvals, and review history.

20.6 Audit test

Sample classification decisions and verify that the stated facts, provisions, actor roles, versions, and application dates support the conclusion.

21 Chapter 20 — High-Risk Classification

21.1 Publication status

Legally corrected English master text. This chapter supersedes conflicting high-risk classification language in earlier drafts until all source files are reconciled.

21.2 Purpose

This chapter explains how to determine whether an AI system is high-risk under Article 6 of Regulation (EU) 2024/1689, as amended by Regulation (EU) 2026/1744.

21.3 Requirement

Organizations must perform and document a current high-risk classification for each material AI system before deployment and after relevant changes.

Classification must distinguish:

- Article 6(1) systems connected to products covered by Annex I Union harmonisation legislation;
- Article 6(2) systems used for Annex III purposes;
- systems that appear within Annex III but may qualify for the Article 6(3) exception, where applicable;
- systems outside Article 6 that may still have transparency, GPAI, privacy, employment, consumer, safety, cybersecurity, or sector obligations.

21.4 Plain-English explanation

“High-risk” is a legal classification, not a general description of a system that seems important or dangerous. The analysis must follow the Article 6 pathway and the relevant annex.

A system may be operationally critical without being high-risk under Article 6. Conversely, a system may be legally high-risk even when the organization believes its internal risk score is moderate.

21.5 Classification pathway

21.5.1 Step 1 — Confirm the system and intended purpose

Document:

- the AI system and model components;
- intended purpose;
- users and affected persons;
- decisions or outputs supported;
- deployment countries and sectors;
- provider and deployer roles;
- product integration;
- material vendor dependencies.

21.5.2 Step 2 — Test Article 6(1) and Annex I

Assess whether the AI system:

- is intended to be used as a safety component of a product covered by Annex I; or
- is itself a product covered by Annex I;
- and is required to undergo a third-party conformity assessment under the applicable product legislation.

The amended application date for the Chapter III, Sections 1-3 requirements governing Article 6(1)/Annex I systems is **2 August 2028**. This delayed date must not be used to postpone independently applicable obligations.

21.5.3 Step 3 — Test Article 6(2) and Annex III

Assess whether the intended purpose falls within an Annex III category, including the current amended categories and conditions.

The amended application date for the Chapter III, Sections 1-3 requirements governing Article 6(2)/Annex III systems is **2 December 2027**.

21.5.4 Step 4 — Assess any Article 6(3) exception

Where legally available, determine whether the system does not pose a significant risk of harm to health, safety, or fundamental rights because it does not materially influence the outcome of decision-making and meets the statutory conditions.

Do not apply this exception when the system performs profiling of natural persons where the Act excludes reliance on the exception.

The organization must retain a reasoned assessment and be prepared to provide it to a competent authority.

21.5.5 Step 5 — Record the outcome

Use one of these controlled outcomes:

- Article 6(1)/Annex I high-risk;
- Article 6(2)/Annex III high-risk;
- Annex III use with documented Article 6(3) exception;
- not high-risk under Article 6 but subject to other AI Act duties;
- classification deferred pending legal or technical evidence;
- deployment prohibited or suspended.

21.6 Effective-date rule

The later high-risk dates apply narrowly to the relevant Chapter III, Sections 1–3 requirements. They do not automatically delay:

- AI-literacy duties;
- prohibited-practice restrictions;
- GPAI obligations;
- transparency obligations;
- governance and authority provisions;
- GDPR, employment, equality, consumer, safety, cybersecurity, or sector-law duties;
- contractual commitments;
- internal risk controls required to prevent harm.

21.7 GlobalWay Travel Services example

GlobalWay assesses a recruitment-screening system intended to rank applicants for employment decisions. The intended purpose falls within an Annex III employment category. GlobalWay classifies the system as Article 6(2) high-risk and maps the amended 2 December 2027 date to the applicable Chapter III requirements.

GlobalWay does not treat the date as permission to defer privacy, discrimination, employment-law, AI-literacy, vendor, security, or human-review controls. Those controls remain governed by their own legal and operational dates.

21.8 Control activities

- Require a documented Article 6 classification before approval.
- Link the assessment to the current Annex I and Annex III text.
- Require Legal approval for Article 6(3) exceptions.
- Record intended purpose and prevent unapproved repurposing.
- Reassess after model, data, workflow, vendor, jurisdiction, product, or user changes.
- Map classification outcomes to the correct implementation date.
- Retain evidence supporting non-high-risk determinations.

21.9 Evidence

- intended-purpose statement;
- Article 6 worksheet;
- Annex I and Annex III mapping;
- product-law analysis;
- Article 6(3) assessment, if applicable;
- legal approval;
- deployment restrictions;
- change and reassessment history;
- article-to-control mapping.

21.10 Audit tests

1. Trace selected systems through each Article 6 classification step.
2. Verify Annex I and Annex III references use the amended text.
3. Review Article 6(3) exception evidence and legal approval.
4. Confirm profiling systems are not incorrectly excluded.
5. Verify the 2027 and 2028 dates are applied only to the relevant requirements.
6. Confirm non-high-risk systems are still assessed for other obligations.
7. Test whether changes trigger reclassification.

21.11 Management checklist

- Is the intended purpose documented accurately?
- Have Article 6(1) and Article 6(2) both been tested?
- Is any Article 6(3) exception fully supported?
- Are the 2027 and 2028 dates used narrowly?
- Are other legal duties tracked independently?

21.12 Figure specification — High-Risk Classification Path

Create a decision tree beginning with intended purpose, then separate Article 6(1)/Annex I and Article 6(2)/Annex III paths, followed by the Article

6(3) exception analysis, controlled classification outcomes, and reassessment triggers.

Alt text: High-risk AI classification decision tree testing Article 6(1) and Annex I product systems, Article 6(2) and Annex III use cases, the Article 6(3) exception, final classification outcomes, implementation dates, and reassessment triggers.

22 Chapter 21 — Annex I and Annex III Analysis

22.1 Publication status

Legally corrected English master text. This chapter supersedes conflicting annex-analysis language in earlier drafts until all affected chapters, appendices, graphics, and translations are reconciled.

22.2 Purpose

This chapter provides a structured method for analysing Annex I product-related systems and Annex III use cases under Article 6 of Regulation (EU) 2024/1689, as amended by Regulation (EU) 2026/1744.

22.3 Requirement

Organizations must analyse Annex I and Annex III separately, document the exact legal pathway, and avoid treating the two annexes as interchangeable lists of high-risk systems.

22.4 Plain-English explanation

Annex I and Annex III reach high-risk AI through different legal routes:

- **Annex I** concerns AI connected to products governed by listed Union harmonisation legislation and the conditions in Article 6(1).
- **Annex III** concerns listed use cases in sensitive areas and the conditions in Article 6(2), subject where applicable to the Article 6(3) exception.

The analysis must be based on intended purpose and actual deployment, not only the vendor's marketing label.

22.5 Annex I analysis

For each potentially relevant system, document:

- the product or safety component involved;
- the applicable Annex I Union harmonisation legislation;
- whether the AI system is itself the regulated product or a safety component;

- whether third-party conformity assessment is required under that product legislation;
- the manufacturer, provider, importer, distributor, and other product-chain roles;
- the conformity-assessment route;
- technical-documentation dependencies;
- post-market and incident obligations;
- changes that could alter the classification.

The amended application date for the relevant Chapter III, Sections 1-3 requirements for Article 6(1)/Annex I systems is **2 August 2028**.

22.6 Annex III analysis

For each potentially relevant use case, document:

- the exact Annex III point and subpoint;
- the intended purpose;
- the decision, recommendation, ranking, classification, or access determination supported;
- the population affected;
- whether the system materially influences the outcome;
- whether profiling of natural persons occurs;
- the provider and deployer roles;
- any Article 6(3) exception analysis;
- fundamental-rights, safety, discrimination, and human-oversight implications;
- jurisdiction and sector overlays.

The amended application date for the relevant Chapter III, Sections 1-3 requirements for Article 6(2)/Annex III systems is **2 December 2027**.

22.7 Article 6(3) exception control

Where the exception is legally available, the assessment must:

- identify the exact statutory condition relied upon;

- explain why the system does not pose a significant risk of harm to health, safety, or fundamental rights;
- explain why it does not materially influence the decision outcome;
- confirm whether profiling occurs;
- document supporting technical and operational evidence;
- receive Legal approval;
- be retained and reviewed after changes.

A superficial statement that the system is “only assistive” is insufficient.

22.8 Effective-date caution

The amended 2027 and 2028 dates apply to the specified high-risk requirements. They do not postpone independently applicable obligations, including:

- prohibited-practice restrictions;
- AI-literacy requirements;
- GPAI duties;
- Article 50 transparency duties;
- GDPR and data-protection requirements;
- employment, equality, consumer, safety, cybersecurity, and sector law;
- contractual and internal-control obligations.

22.9 GlobalWay Travel Services example

GlobalWay reviews two systems:

1. a recruitment-ranking tool used to shortlist candidates; and
2. an AI-enabled safety component embedded in a regulated airport mobility product.

The recruitment system follows the Article 6(2)/Annex III path and the 2 December 2027 timetable for the relevant high-risk requirements. The product-embedded safety component follows Article 6(1)/Annex I and the 2 August 2028 timetable.

GlobalWay keeps separate legal analyses, owners, conformity dependencies, evidence packages, and project plans for the two systems.

22.10 Control activities

- Maintain separate Annex I and Annex III assessment sections.
- Cite the exact article, annex point, and product legislation.
- Require product-safety specialists for Annex I assessments.
- Require Legal approval for Annex III exceptions.
- Link the classification to the correct implementation date.
- Reassess after intended-purpose, product, model, data, workflow, vendor, or jurisdiction changes.
- Reconcile the analysis with technical documentation, contracts, risk assessments, and deployment controls.

22.11 Evidence

- Annex I product-law mapping;
- Annex III use-case mapping;
- intended-purpose statement;
- conformity-assessment analysis;
- Article 6(3) exception record;
- profiling assessment;
- legal and product-safety approvals;
- system architecture and workflow records;
- implementation calendar;
- reassessment history.

22.12 Audit tests

1. Verify Annex I and Annex III analyses are separated.
2. Trace Annex I conclusions to the applicable product legislation and conformity conditions.
3. Trace Annex III conclusions to the exact point and intended purpose.
4. Review Article 6(3) exceptions for complete evidence and profiling analysis.
5. Confirm the 2 December 2027 and 2 August 2028 dates are assigned correctly.

6. Verify other applicable laws and AI Act duties are not deferred incorrectly.
7. Test whether system changes trigger reassessment.

22.13 Management checklist

- Are Annex I and Annex III treated as different legal pathways?
- Is the exact annex point documented?
- Does the assessment reflect actual intended purpose and deployment?
- Is any exception fully supported and approved?
- Are the implementation dates mapped correctly?
- Are other duties tracked independently?

22.14 Figure specification — Annex I and Annex III Comparison

Create a two-column comparison. The Annex I side should show regulated product, safety component, product legislation, third-party conformity assessment, and the 2 August 2028 date. The Annex III side should show sensitive use case, intended purpose, Article 6(3) exception analysis, profiling restriction, and the 2 December 2027 date. Join both paths at governance, evidence, monitoring, and reassessment.

Alt text: Comparison of Annex I product-related high-risk AI and Annex III sensitive-use high-risk AI, showing their different legal tests, conformity and exception pathways, implementation dates, evidence requirements, and reassessment controls.

23 Chapter 22 — High-Risk Exception and Scoping Analysis

Legal status: Corrected English master. High-risk scoping and any exception analysis must be verified against the current consolidated text, including the specific legal trigger and application date.

23.1 Requirement

Assess whether an AI system falls within a high-risk category and whether any legally available exclusion, limitation, or exception applies.

23.2 Plain-English explanation

A business description alone is insufficient. The analysis must connect the intended purpose and actual use to the relevant article and annex entry.

23.3 GlobalWay example

GlobalWay separately assesses a recruitment-ranking tool, a travel-risk alert, and a customer-support assistant because their purposes and effects differ.

23.4 Control activity

Require legal and compliance review of high-risk scoping before production use and after material change.

23.5 Evidence

Intended-purpose record, use-case description, annex mapping, exception rationale, approvals, and review date.

23.6 Audit test

Verify that sampled decisions identify the correct legal provision, actor, facts, and evidence supporting the outcome.

24 Chapter 23 — Classification Review and Approval

Legal status: Corrected English master. Classification approval is an organizational control that supports compliance; it does not replace the legal test.

24.1 Requirement

Establish independent review and documented approval for AI classification decisions.

24.2 Plain-English explanation

The person proposing a use should not be the only person deciding its legal category.

24.3 GlobalWay example

GlobalWay requires business, legal, privacy, security, and AI-governance review for material systems.

24.4 Control activity

Use defined approval thresholds, escalation rules, and conflict-of-interest controls.

24.5 Evidence

Reviewer comments, approval record, unresolved issues, conditions, and re-review date.

24.6 Audit test

Confirm that sampled systems received the required review before deployment.

25 Chapter 24 — Reclassification and Change Triggers

Legal status: Corrected English master. Reclassification must be based on current facts and law; internal trigger thresholds are governance controls.

25.1 Requirement

Reassess classification when intended purpose, functionality, model, data, user population, jurisdiction, supplier, or legal requirements change.

25.2 Plain-English explanation

A correct decision can become outdated after a material change.

25.3 GlobalWay example

GlobalWay reopens classification when a customer-service assistant is adapted to rank job applicants.

25.4 Control activity

Connect change management to mandatory classification review and release blocking.

25.5 Evidence

Change request, impact analysis, revised classification, approvals, and release decision.

25.6 Audit test

Trace sampled material changes to completed reclassification before deployment.

26 Chapter 25 — Classification Register and Reporting

Legal status: Corrected English master. The register is an organizational control and must not overstate legal conclusions.

26.1 Requirement

Maintain a current register of AI classifications, owners, legal bases, conditions, and review dates.

26.2 Plain-English explanation

Management needs one reliable view of what was decided, why, and when it must be revisited.

26.3 GlobalWay example

GlobalWay reports unresolved classifications and overdue reviews to its AI governance committee.

26.4 Control activity

Reconcile the register to procurement, architecture, privacy, security, and production inventories.

26.5 Evidence

Register extracts, reconciliation records, exceptions, dashboards, and approvals.

26.6 Audit test

Verify completeness, accuracy, and timely review of sampled register entries.

27 Chapter 26 — Prohibited Practices Overview

Legal status: Corrected English master. Prohibited-practice conclusions must be verified against the current consolidated Article 5 text and applicable dates.

27.1 Requirement

Screen AI uses for practices prohibited by the EU AI Act before acquisition, development, testing, or deployment.

27.2 Plain-English explanation

Some uses cannot be approved through ordinary risk acceptance or compensating controls.

27.3 GlobalWay example

GlobalWay requires prohibited-practice screening for employee analytics, biometric tools, customer scoring, and behavioral influence use cases.

27.4 Control activity

Apply a release-blocking checklist with mandatory legal escalation for uncertainty.

27.5 Evidence

Use-case description, screening result, legal analysis, decision, restrictions, and monitoring record.

27.6 Audit test

Verify that sampled systems were screened before use and that prohibited uses were blocked or discontinued.

28 Chapter 27 — Manipulation and Subliminal Techniques

Legal status: Corrected English master. Assess the current consolidated Article 5 criteria, including the technique, intent or effect, affected persons, and legally relevant harm threshold.

28.1 Requirement

Prevent AI uses that employ prohibited manipulative, deceptive, or subliminal techniques.

28.2 Plain-English explanation

Marketing, personalization, or interface design must not cross into legally prohibited influence.

28.3 GlobalWay example

GlobalWay reviews recommendation and pricing interfaces for deceptive pressure or exploitation.

28.4 Control activity

Require behavioral-design review, testing, legal escalation, and release blocking.

28.5 Evidence

Design records, test results, legal review, approvals, and monitoring.

28.6 Audit test

Inspect sampled interfaces and verify that prohibited influence risks were assessed and controlled.

29 Chapter 28 — Exploitation of Vulnerabilities

Legal status: Corrected English master. Apply the current consolidated Article 5 test to vulnerability, exploitation, material distortion, and harm.

29.1 Requirement

Prevent AI uses that unlawfully exploit vulnerabilities associated with age, disability, or social or economic circumstances.

29.2 Plain-English explanation

A system must not take advantage of a person's vulnerability in a way the law prohibits.

29.3 GlobalWay example

GlobalWay reviews offers and support tools used with stranded travelers, minors, and persons requiring accessibility assistance.

29.4 Control activity

Require vulnerable-person impact review, accessible design, monitoring, and legal escalation.

29.5 Evidence

Impact assessment, design review, testing, complaints, approvals, and corrective actions.

29.6 Audit test

Verify that sampled use cases identify vulnerable groups and address prohibited exploitation risk.

30 Chapter 29 — Social Scoring

Legal status: Corrected English master. Apply the current consolidated Article 5 criteria to scoring purpose, data context, treatment, and resulting detriment.

30.1 Requirement

Prevent prohibited social-scoring practices.

30.2 Plain-English explanation

Organizations must not use broad behavior or characteristic scores to impose legally prohibited unrelated or disproportionate treatment.

30.3 GlobalWay example

GlobalWay prohibits combining unrelated customer behavior, employee conduct, and travel history into a generalized trust score used across contexts.

30.4 Control activity

Require purpose limitation, data-context review, consequence testing, and legal approval.

30.5 Evidence

Scoring logic, data inventory, use restrictions, impact assessment, approvals, and monitoring.

30.6 Audit test

Trace sampled scores to their inputs, purposes, consequences, and controls.

31 Chapter 30 — Predictive Policing and Risk Inference

Legal status: Corrected English master. Apply the current consolidated Article 5 rules and any lawful-scope distinctions to the specific actor, purpose, data, and decision.

31.1 Requirement

Prevent prohibited predictive-policing or individual risk-inference uses.

31.2 Plain-English explanation

The legal assessment depends on who uses the system, what it predicts, the evidence considered, and how the output affects a person.

31.3 GlobalWay example

GlobalWay does not repurpose traveler-risk analytics for law-enforcement prediction without separate legal authority and review.

31.4 Control activity

Block secondary use outside the approved purpose and require legal review for government or law-enforcement requests.

31.5 Evidence

Purpose statement, access controls, request records, legal review, approvals, and monitoring.

31.6 Audit test

Verify that outputs are not repurposed for prohibited individual risk prediction.

32 Chapter 31 — Facial-Image Scraping and Biometric Databases

Legal status: Corrected English master. Apply the current consolidated Article 5 prohibition and any relevant scope limits to the collection method, source, purpose, and actor.

32.1 Requirement

Prevent prohibited untargeted scraping of facial images to create or expand facial-recognition databases.

32.2 Plain-English explanation

A convenient data source does not make indiscriminate facial-image collection lawful.

32.3 GlobalWay example

GlobalWay prohibits vendors from scraping public websites or surveillance footage to build traveler or employee face databases.

32.4 Control activity

Require biometric-data sourcing review, contractual restrictions, technical blocking, and vendor evidence.

32.5 Evidence

Data-source records, contracts, due diligence, architecture controls, approvals, and monitoring.

32.6 Audit test

Verify the provenance and lawful collection basis for any facial-image dataset.

33 Chapter 32 — Emotion-Recognition Restrictions

Legal status: Corrected English master. Apply the current consolidated Article 5 rules, sector context, exceptions, transparency duties, and application dates.

33.1 Requirement

Prevent prohibited emotion-recognition use and control any use that remains legally permitted.

33.2 Plain-English explanation

Inferring emotion from biometric or behavioral signals is legally sensitive and context dependent.

33.3 GlobalWay example

GlobalWay blocks emotion analysis in employee performance monitoring and requires legal review for any safety-related proposal.

33.4 Control activity

Require purpose, sector, exception, accuracy, necessity, privacy, and transparency review before use.

33.5 Evidence

Use-case record, technical description, legal analysis, impact assessment, approvals, and monitoring.

33.6 Audit test

Verify that sampled emotion-recognition uses are not prohibited and meet all applicable conditions.

34 Chapter 33 — Biometric Categorisation Restrictions

Legal status: Corrected English master. Apply the current consolidated Article 5 rules to the inferred category, biometric basis, purpose, actor, and any legally relevant exception.

34.1 Requirement

Prevent prohibited biometric categorisation, particularly where sensitive or protected characteristics are inferred.

34.2 Plain-English explanation

A system must not infer legally protected characteristics from biometric data where the law prohibits that practice.

34.3 GlobalWay example

GlobalWay prohibits classifying travelers or employees by ethnicity, religion, political opinion, sexual orientation, or similar sensitive traits from facial or voice data.

34.4 Control activity

Require biometric feature review, prohibited-category blocking, vendor restrictions, and legal approval.

34.5 Evidence

Feature inventory, model documentation, test results, contracts, approvals, and monitoring.

34.6 Audit test

Verify that biometric systems do not generate or expose prohibited sensitive-category outputs.

35 Chapter 34 — New Prohibitions for Non-Consensual Intimate Content and Child Sexual Abuse Material

35.1 Publication status

Legally corrected English master text. This chapter supersedes conflicting Chapter 34 draft language until the original draft, figures, appendices, and translations are reconciled.

35.2 Purpose

This chapter explains the additional prohibited AI practices introduced by Regulation (EU) 2026/1744 concerning AI systems that generate non-

consensual sexually explicit or intimate content and child sexual abuse material.

35.3 Binding legal baseline

Regulation (EU) 2026/1744 amended Regulation (EU) 2024/1689 by adding new Article 5 prohibitions. These provisions entered into force with the amending regulation but apply from **2 December 2026**.

Organizations must distinguish:

- adoption and entry into force of the amendment;
- the date the new prohibitions begin applying;
- the separate legal elements of each prohibited category;
- related criminal, child-protection, privacy, platform, employment, and content-safety laws that may already apply independently.

35.4 Requirement

An organization must not place on the market, put into service, or use an AI system in a manner prohibited by the amended Article 5. It must perform an element-by-element legal assessment rather than rely on a broad label such as “harmful content.”

35.5 Plain-English explanation

The amendment targets AI systems used to generate two especially serious categories of material:

1. non-consensual sexually explicit or intimate content; and
2. child sexual abuse material.

The organization must keep these categories legally distinct, document the facts supporting its conclusion, and avoid implying that every offensive, sexualized, or privacy-invasive output automatically falls within the same statutory element.

35.6 Effective-date control

Before 2 December 2026, the new AI Act prohibitions must be treated as adopted but not yet applicable under their specific AI Act application date. This does not authorize the conduct. Other EU, Member State, criminal, privacy, child-safety, platform, employment, or contractual rules may already prohibit or restrict it.

From 2 December 2026, the amended Article 5 prohibitions apply directly according to their statutory wording.

35.7 Screening questions

For every relevant system or use case, determine:

- whether the system can generate or materially transform sexual, intimate, or child-related content;
- whether the use involves an identifiable or reasonably identifiable person;
- whether consent exists, is valid, and covers the specific generation and use;
- whether the content is sexually explicit or intimate within the applicable legal context;
- whether the content constitutes or may constitute child sexual abuse material;
- whether prompts, fine-tuning, tools, retrieval sources, image editing, or agent actions enable the prohibited conduct;
- whether employees, contractors, users, customers, or vendors can bypass safeguards;
- whether the organization is a provider, deployer, distributor, importer, or another relevant actor;
- whether immediate suspension, preservation, reporting, or law-enforcement escalation is required.

35.8 Mandatory escalation triggers

Immediately escalate when:

- a system is designed, marketed, or configured for AI “nudification” or equivalent non-consensual intimate-content generation;
- a system can generate sexualized depictions of a real person without verified consent;
- any output may depict a child in sexual abuse material;
- safeguards are bypassed repeatedly;
- a vendor refuses to provide adequate controls, logs, or incident support;
- the legal classification is uncertain but potential harm is severe;
- evidence suggests criminal conduct, child endangerment, coercion, extortion, harassment, or exploitation.

35.9 GlobalWay Travel Services example

GlobalWay's marketing team proposes an image-editing tool for personalized travel campaigns. Testing shows that users can upload photographs and prompt the tool to remove clothing or generate sexualized versions of real people.

GlobalWay immediately blocks the feature, preserves test evidence, escalates to Legal, Security, Privacy, and executive management, and requires the vendor to demonstrate effective technical restrictions. The system is not approved for deployment. The decision record separately analyzes non-consensual intimate content, possible child-safety exposure, privacy, employment, and criminal-law concerns.

35.10 Control activities

- Add the two amended prohibited categories to intake and prohibited-practice screening.
- Block high-risk prompts, transformations, models, tools, and workflows at multiple control layers.
- Prohibit marketing or product descriptions that encourage prohibited uses.
- Require verified consent controls where relevant, without treating consent as sufficient for child sexual abuse material.
- Implement age-related and child-safety controls proportionate to the use case.
- Preserve prompts, outputs, logs, model versions, user identifiers, and control events after an incident.
- Define immediate suspension, account restriction, vendor escalation, and legal-hold procedures.
- Train personnel on the 2 December 2026 application date and on independently applicable laws.
- Reassess open-source, fine-tuned, image-editing, video-generation, and agentic capabilities after changes.

35.11 Evidence

- prohibited-practice assessment;
- article and amendment citation;
- consent and identity-control design records;
- safety policies and model configurations;

- prompt and output test results;
- red-team and abuse-case testing;
- blocked-event logs;
- incident and escalation records;
- vendor correspondence and remediation evidence;
- suspension, rejection, or decommissioning approval;
- legal-hold and reporting records.

35.12 Audit tests

1. Confirm the organization distinguishes the two amended prohibited categories.
2. Verify the 2 December 2026 application date is stated consistently.
3. Test whether users can bypass safeguards through prompts, uploads, editing, tools, or APIs.
4. Review whether child-safety events receive immediate escalation and evidence preservation.
5. Confirm consent controls are not treated as a defense for child sexual abuse material.
6. Trace rejected or suspended uses to documented legal and executive decisions.
7. Verify related appendices, training, graphics, and vendor controls are aligned.

35.13 Management checklist

- Have we screened all generative image, audio, video, and editing systems?
- Can the system sexualize or expose a real person without valid consent?
- Could any workflow generate child sexual abuse material?
- Are bypass attempts detected and escalated?
- Is the 2 December 2026 application date correctly recorded?
- Are other already-applicable laws assessed separately?

35.14 Figure specification — Prohibited Intimate-Content Decision Path

Create a decision flow beginning with system capability and intended use, then separate branches for non-consensual sexually explicit or intimate content and child sexual abuse material. Show consent analysis only on the adult intimate-content branch, immediate stop and escalation for possible child sexual abuse material, and evidence preservation for both branches.

Alt text: Decision path for AI systems capable of generating sexual or intimate content, separating non-consensual adult intimate-content analysis from immediate stop and escalation for possible child sexual abuse material, with evidence preservation and legal review.

36 Chapter 35 — Prohibited-Practice Governance and Assurance

Legal status: Corrected English master. Governance controls support compliance but cannot authorize a prohibited practice or replace current legal analysis.

36.1 Requirement

Maintain enterprise controls to identify, block, escalate, monitor, and remediate prohibited AI practices.

36.2 Plain-English explanation

Prohibited-practice compliance must operate across intake, procurement, development, change, deployment, monitoring, and incident response.

36.3 GlobalWay example

GlobalWay combines release gates, vendor clauses, employee training, complaint channels, and executive escalation to prevent prohibited uses.

36.4 Control activity

Assign accountable owners, maintain a prohibition checklist, test controls, preserve evidence, and require immediate suspension where necessary.

36.5 Evidence

Policies, screenings, training, contracts, system blocks, monitoring results, incidents, corrective actions, and audit reports.

36.6 Audit test

Test design and operating effectiveness across a sample of systems, changes, vendors, and reported concerns.

37 Chapter 36 — High-Risk Quality-Management System

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 36 draft language.

37.1 Requirement

Providers of high-risk AI systems must establish, document, implement, maintain, and continually improve a quality-management system proportionate to the organization and the system. The system must cover the elements required by Article 17 of Regulation (EU) 2024/1689, as amended.

37.2 Plain-English explanation

A quality-management system is the operating framework that makes compliance repeatable. It connects policy, accountability, design, testing, data governance, documentation, risk management, monitoring, incidents, corrective action, supplier controls, and recordkeeping. It cannot be reduced to a policy statement or a one-time review.

Certification to ISO/IEC 42001 or another standard may support the organization's control environment, but certification alone does not establish conformity with the AI Act. The organization must still demonstrate that the statutory requirements applicable to the specific high-risk AI system are satisfied.

37.3 Required system elements

The documented system should address, as applicable:

1. regulatory-compliance strategy;
2. design, development, and design-control procedures;
3. examination, testing, and validation before, during, and after development;
4. technical specifications and standards used;
5. data-management systems and procedures;
6. risk management under Article 9;
7. post-market monitoring under Article 72;
8. serious-incident and malfunction reporting;
9. communication with authorities, notified bodies, operators, customers, and other interested parties;
10. recordkeeping and document control;

11. resource management, competence, and accountability;
12. corrective action and effectiveness verification;
13. mechanisms for management review and continual improvement.

37.4 GlobalWay example

GlobalWay develops a high-risk recruitment-screening system for use under its own brand. Its quality-management system links legal classification, approved development standards, data reviews, bias and accuracy testing, technical documentation, human-oversight design, release approval, vendor controls, post-market monitoring, incident escalation, and corrective-action records.

37.5 Control activity

The accountable provider must maintain an approved quality-management manual and system-specific compliance plan. Each required process must have an owner, procedure, evidence requirement, review frequency, escalation route, and management-review mechanism.

37.6 Evidence

- quality-management manual;
- process map and RACI;
- regulatory-compliance plan;
- design and test procedures;
- risk-management records;
- data-governance records;
- technical-documentation index;
- post-market monitoring plan;
- incident and corrective-action procedures;
- management-review minutes;
- competence and training records.

37.7 Audit test

Select a high-risk AI system. Trace each Article 17 quality-management element to an approved process, accountable owner, operating evidence, and management review. Confirm that the system is maintained in practice and not merely documented.

37.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 17.
- Regulation (EU) 2026/1744 for amended application dates and related simplification provisions.
- Current consolidated EUR-Lex text controls over older summaries.

38 Chapter 37 — Continuous Risk Management

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 37 draft language.

38.1 Requirement

A provider of a high-risk AI system must establish, implement, document, and maintain the continuous, iterative risk-management system required by Article 9 throughout the system lifecycle.

38.2 Plain-English explanation

Risk management is not a launch checklist. The provider must repeatedly identify, estimate, evaluate, control, test, monitor, and reassess risks to health, safety, and fundamental rights. The analysis must address intended use, reasonably foreseeable misuse, information from post-market monitoring, and whether residual risk is acceptable when weighed against the system's intended benefits.

38.3 Required process

The process must include:

1. identification and analysis of known and reasonably foreseeable risks during intended use;
2. estimation and evaluation of risks arising during intended use and reasonably foreseeable misuse;
3. evaluation of additional risks identified through post-market monitoring;
4. adoption of targeted risk-control measures;
5. testing to identify the most appropriate controls and verify effectiveness;
6. review of residual risk and overall residual risk;
7. consideration of effects on children and other vulnerable groups where relevant;
8. regular systematic review and update throughout the lifecycle.

Risk controls should follow a defensible hierarchy: eliminate or reduce risk through design where feasible, implement technical and organizational safeguards, and provide information and training for remaining risk.

38.4 GlobalWay example

GlobalWay's recruitment-screening system may create discrimination, automation-bias, data-quality, privacy, and cybersecurity risks. The provider documents risk scenarios, tests alternative controls, limits automated ranking, requires trained human review, monitors selection-rate disparities, and reopens the assessment after model, data, threshold, or job-family changes.

38.5 Control activity

The system owner and risk function must maintain a version-controlled risk file linked to requirements, testing, human oversight, post-market monitoring, incidents, and change management. Release approval is prohibited when required risk controls are absent or residual risk lacks authorized acceptance.

38.6 Evidence

- lifecycle risk-management plan;
- hazard and fundamental-rights risk register;
- intended-use and foreseeable-misuse analysis;
- control-selection rationale;
- test plans and results;
- residual-risk decision;
- vulnerable-group analysis;
- post-market updates;
- change-triggered reassessments;
- approvals and exceptions.

38.7 Audit test

For a sample high-risk AI system, confirm that risk management began before deployment, addresses all Article 9 steps, is linked to testing and post-market evidence, and was updated after relevant changes, incidents, or emerging risks.

38.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 9.

- Article 72 for post-market information feeding risk management.
- Current consolidated EUR-Lex text controls over older summaries.

39 Chapter 38 — Data and Data Governance

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 38 draft language.

39.1 Requirement

Where a high-risk AI system uses training, validation, or testing datasets, the provider must apply the data and data-governance requirements of Article 10 of Regulation (EU) 2024/1689, as amended.

39.2 Plain-English explanation

The legal objective is not perfect data. It is disciplined, documented data governance appropriate to the intended purpose and risk. The provider must understand where the data came from, why it is suitable, how it was prepared, what limitations or errors exist, whether affected groups are adequately represented, and whether the system could create or reinforce bias.

Article 10 does not independently create a lawful basis to process personal data or special-category data. GDPR and other applicable privacy requirements must be assessed separately.

39.3 Required governance areas

The provider should document, as applicable:

1. data-design choices and collection processes;
2. data origin, provenance, and original purpose;
3. data preparation, annotation, labelling, cleaning, enrichment, and aggregation;
4. assumptions about what the data measures or represents;
5. availability, quantity, and suitability of datasets;
6. examination of possible bias and its effects on health, safety, or fundamental rights;
7. measures to detect, prevent, and mitigate bias;
8. relevance, representativeness, completeness, and error characteristics;

9. statistical properties and suitability for the persons, groups, geography, context, and conditions of intended use;
10. controls for data gaps, drift, leakage, duplication, contamination, and unauthorized use;
11. separation and governance of training, validation, and testing datasets where appropriate;
12. documented exceptions, limitations, and residual risks.

39.4 GlobalWay example

GlobalWay develops a recruitment-screening system using historical application and hiring data. The data-governance review identifies underrepresentation in certain job families, inconsistent historical labels, proxy variables for protected characteristics, and geographic differences. GlobalWay removes inappropriate features, improves documentation, tests subgroup performance, limits the intended use, and requires human review.

39.5 Control activity

The provider must approve a system-specific data-governance plan before model development or material retraining. Dataset versions, transformations, quality checks, bias analyses, access controls, and approvals must be traceable to the released model or system version.

39.6 Evidence

- data-governance plan;
- dataset register and provenance records;
- data-processing and annotation procedures;
- data-quality and representativeness analysis;
- bias and subgroup testing;
- privacy and lawful-basis assessment;
- dataset version history;
- access and change logs;
- limitations and residual-risk record;
- approval records.

39.7 Audit test

Select a released high-risk AI-system version and trace it to the exact training, validation, and testing datasets. Confirm that suitability,

provenance, quality, representativeness, bias, privacy, transformations, and limitations were assessed and approved before release.

39.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 10.
- GDPR and applicable Member State or sector law remain independently applicable.
- Current consolidated EUR-Lex text controls over older summaries.

40 Chapter 39 — Technical Documentation

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 39 draft language.

40.1 Requirement

Before a high-risk AI system is placed on the market or put into service, the provider must prepare and maintain technical documentation demonstrating compliance with the applicable requirements. The documentation must address Article 11 and Annex IV of Regulation (EU) 2024/1689, as amended, and remain current throughout the lifecycle.

40.2 Plain-English explanation

Technical documentation is the evidence package that explains what the system is, how it was developed, what data and methods were used, how it performs, what risks and limitations exist, how human oversight works, and why the provider believes the legal requirements are met. It must be specific enough for authorities, notified bodies where applicable, and internal reviewers to assess conformity.

Model cards, system cards, architecture documents, and test reports can support the package, but none of them alone necessarily satisfies Annex IV.

40.3 Required documentation areas

The package should cover, as applicable:

1. a general description, intended purpose, system version, and provider information;
2. system architecture, components, dependencies, interfaces, and computational resources;
3. design and development methods;
4. data requirements, datasets, provenance, preparation, and governance;
5. model or algorithm choices, parameters, and relevant assumptions;

6. validation and testing methods, metrics, thresholds, environments, and results;
7. risk-management process and residual-risk conclusions;
8. human-oversight measures;
9. accuracy, robustness, cybersecurity, and foreseeable limitations;
10. logging capabilities and recordkeeping arrangements;
11. conformity-assessment pathway, standards, common specifications, and deviations;
12. post-market monitoring, incident, and corrective-action arrangements;
13. changes, updates, and version history;
14. instructions for use and other information supplied to operators.

40.4 GlobalWay example

For its high-risk recruitment-screening system, GlobalWay maintains an Annex IV index linking the intended purpose, architecture, datasets, subgroup testing, performance limits, human-review workflow, cybersecurity testing, risk controls, conformity records, and post-market monitoring plan to the exact production release.

40.5 Control activity

The provider must maintain a controlled technical-documentation repository with an approved Annex IV index. No release may proceed unless required documents are complete, internally consistent, version-linked, reviewed, and approved. Material changes must trigger documentation review and update.

40.6 Evidence

- Annex IV documentation index;
- system description and architecture;
- development and data documentation;
- test plans, metrics, and results;
- risk-management file;
- human-oversight plan;
- cybersecurity and robustness evidence;

- instructions for use;
- conformity records;
- post-market monitoring plan;
- version and change history;
- review and approval records.

40.7 Audit test

Select a production high-risk AI-system version. Confirm that the technical-documentation package existed before release, addresses the applicable Annex IV elements, agrees with the deployed configuration, and was updated after relevant changes or new post-market information.

40.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 11 and Annex IV.
- Current consolidated EUR-Lex text controls over older summaries.

41 Chapter 40 — Logs and Recordkeeping

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 40 draft language.

41.1 Requirement

High-risk AI systems must be designed to enable automatic recording of events over the system lifetime to the extent appropriate to the intended purpose. Providers and deployers must retain logs and related records for the periods required by Regulation (EU) 2024/1689, as amended, and other applicable law.

41.2 Plain-English explanation

Logs are the operational evidence trail for how a high-risk AI system behaved. They support monitoring, incident investigation, human oversight, conformity assessment, corrective action, and regulatory review. Logging must be useful, proportionate, secure, and linked to the correct system version.

The AI Act does not create one universal retention period for every record. Retention must be determined by actor role, record type, applicable article, sector law, data-protection requirements, contractual obligations, limitation periods, and litigation or regulatory holds.

41.3 Logging requirements

The logging design should address, as applicable:

1. system and model version;
2. date and time of operation;
3. input source and relevant processing context;
4. output, score, recommendation, or decision;
5. confidence or threshold information where relevant;
6. human-review, intervention, override, or escalation;
7. errors, anomalies, failed controls, and security events;
8. configuration, prompt, retrieval, and dependency changes;
9. identity or role of authorized operators where lawful and necessary;
10. linkages to complaints, incidents, corrective actions, and monitoring records.

41.4 Data-protection and security controls

Logging must not become uncontrolled surveillance or excessive personal-data collection. The organization must define lawful purpose, data minimisation, access restrictions, integrity protection, retention, deletion, and secure export procedures.

41.5 GlobalWay example

GlobalWay's high-risk recruitment system records the production model version, candidate-processing timestamp, relevant scoring outcome, threshold applied, reviewer identity, reviewer decision, override reason, and any system error. Access is restricted to authorized HR, compliance, audit, and security personnel.

41.6 Control activity

The provider must define logging capabilities during design, and the deployer must ensure logs are enabled, protected, reviewed, and retained according to an approved schedule. Any logging gap that prevents effective monitoring, oversight, investigation, or regulatory response must block deployment or trigger corrective action.

41.7 Evidence

- logging specification;
- data dictionary;
- sample event records;
- access-control configuration;

- retention schedule;
- deletion and legal-hold procedures;
- integrity and tamper-evidence controls;
- monitoring and review records;
- incident and corrective-action linkages;
- privacy assessment.

41.8 Audit test

Select a sample of high-risk system events and confirm that logs are generated, complete, version-linked, protected from unauthorized change, accessible to authorized reviewers, retained under an approved schedule, and used in monitoring and incident investigation.

41.9 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 12 and applicable actor obligations concerning log retention and access.
- GDPR and sector-specific retention rules where personal data or regulated records are involved.
- Current consolidated EUR-Lex text controls over older summaries.

42 Chapter 41 — Transparency and Instructions for Use

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 41 draft language.

42.1 Requirement

High-risk AI systems must be sufficiently transparent to enable deployers to interpret system output and use the system appropriately. Providers must supply clear, complete, correct, and accessible instructions for use containing the information required by Regulation (EU) 2024/1689, as amended.

42.2 Plain-English explanation

A deployer cannot operate a high-risk AI system responsibly without understanding what the system is designed to do, how well it performs, where it may fail, what human oversight is required, and what technical and organizational conditions must be maintained. Instructions for use are therefore part of the compliance evidence, not ordinary marketing material.

42.3 Required content

Instructions should address, as applicable:

1. provider identity and contact information;
2. system identity, version, intended purpose, and prohibited or unsupported uses;
3. characteristics, capabilities, limitations, and foreseeable misuse;
4. accuracy, robustness, cybersecurity, and known performance constraints;
5. relevant data, input, environment, hardware, software, and dependency requirements;
6. human-oversight measures, operator competence, intervention, override, and stop conditions;
7. interpretation of outputs, scores, confidence measures, warnings, and thresholds;
8. logging, monitoring, maintenance, update, and incident procedures;
9. expected lifetime and necessary servicing or support;
10. changes requiring reassessment, revalidation, or provider consultation.

42.4 Usability and accessibility

Instructions must be understandable to the intended professional users. Dense legal or technical language must be supplemented by operational guidance, workflow examples, warnings, and escalation instructions. Accessibility and language needs must be considered for the actual deployment population.

42.5 GlobalWay example

GlobalWay's recruitment team receives controlled instructions describing the permitted hiring-support use, excluded uses, validated data inputs, subgroup-performance limitations, human-review requirements, override procedures, complaint escalation, monitoring expectations, and actions required after vendor updates.

42.6 Control activity

The provider must maintain version-controlled instructions linked to each released system version. The deployer must confirm before use that the instructions are complete, understood, operationally implemented, and reflected in training, procedures, access controls, and monitoring.

42.7 Evidence

- approved instructions for use;
- version and release linkage;
- limitation and warning register;
- operator procedures;
- training and competence records;
- acknowledgement or acceptance records;
- accessibility review;
- change notifications;
- monitoring and incident procedures.

42.8 Audit test

Select a deployed high-risk AI system. Confirm that current instructions were supplied before use, address the applicable legal content, match the deployed version, are understandable to operators, and are implemented in operating procedures, training, oversight, and monitoring.

42.9 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 13 and related provider and deployer obligations.
- Current consolidated EUR-Lex text controls over older summaries.

43 Chapter 42 — Human Oversight

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 42 draft language.

43.1 Requirement

High-risk AI systems must be designed and developed so that natural persons can effectively oversee them during use. The oversight measures must be proportionate to the system's risks, autonomy, context, and foreseeable consequences.

43.2 Plain-English explanation

Human oversight is not satisfied by placing a person near the process or requiring a final click. The assigned person must have enough information, competence, authority, time, system access, and practical ability to detect problems, challenge outputs, intervene, override, stop use, and escalate concerns.

Oversight must also address automation bias. Operators must not be pressured to accept an AI output merely because the system produced it or because rejecting it is inconvenient.

43.3 Oversight design

The oversight plan should define, as applicable:

1. the decisions or actions requiring human review;
2. who performs oversight and what qualifications are required;
3. information available to the reviewer;
4. thresholds, warnings, confidence indicators, and known limitations;
5. intervention, override, rejection, suspension, and stop authority;
6. escalation paths and response times;
7. dual-review or specialist-review requirements for severe cases;
8. workload, staffing, and time needed for meaningful review;
9. controls against automation bias and rubber-stamping;
10. logging of review, override, rationale, and escalation;
11. periodic testing of whether oversight remains effective.

43.4 Special biometric safeguard

Where the Act requires verification by at least two competent natural persons for specified biometric-identification uses, the manual must preserve that statutory safeguard and any applicable exception. It must not be generalized to every biometric system or omitted where legally required.

43.5 GlobalWay example

GlobalWay's recruitment system may rank applications, but it cannot reject a candidate automatically. A trained recruiter reviews the relevant evidence, may disregard the score, records the reason for the decision, and escalates anomalous or potentially discriminatory results to HR compliance.

43.6 Control activity

The provider must design effective oversight capabilities and document them in the instructions for use. The deployer must assign competent reviewers, grant them authority, establish workable procedures, monitor override and escalation patterns, and suspend use where oversight cannot be performed effectively.

43.7 Evidence

- human-oversight plan;

- role and competence requirements;
- training and assessment records;
- operator procedures;
- interface and warning design;
- override and stop controls;
- workload and staffing analysis;
- review and escalation logs;
- automation-bias testing;
- periodic effectiveness review.

43.8 Audit test

Observe a sample of real or simulated decisions. Confirm that reviewers understand system limitations, can independently assess the output, have authority and time to intervene, use override and escalation mechanisms correctly, and produce records showing meaningful rather than nominal oversight.

43.9 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 14 and related deployer obligations.
- Current consolidated EUR-Lex text controls over older summaries.

44 Chapter 43 — Accuracy, Robustness, Cybersecurity, and Resilience

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 43 draft language.

44.1 Requirement

High-risk AI systems must achieve an appropriate level of accuracy, robustness, and cybersecurity and perform consistently throughout their lifecycle. The design must address errors, faults, inconsistencies, malicious interference, feedback loops, and reasonably foreseeable misuse in light of the intended purpose and risk.

44.2 Plain-English explanation

Compliance does not require perfect performance. It requires defensible performance targets, risk-based testing, transparent limitations, secure

design, monitoring, and corrective action. Metrics must reflect the real deployment context rather than only laboratory averages.

44.3 Required control areas

The provider should address, as applicable:

1. defined accuracy and performance metrics linked to intended purpose;
2. acceptance thresholds and decision limits;
3. subgroup and context-specific performance;
4. robustness to noise, missing data, distribution shift, and component failure;
5. resilience to errors, faults, outages, and dependency failures;
6. protection against data poisoning, adversarial examples, prompt injection, model manipulation, extraction, and unauthorized access;
7. secure development, testing, vulnerability management, and change control;
8. feedback-loop risks for systems that continue learning or influence future data;
9. fallback, degradation, rollback, and safe-stop behavior;
10. monitoring, incident response, and corrective-action triggers.

44.4 Metrics and disclosure

Accuracy and robustness metrics must be documented in the technical file and instructions for use where required. Aggregate scores must not conceal material failure modes, affected-group disparities, unsafe operating conditions, or uncertainty.

44.5 GlobalWay example

GlobalWay validates its recruitment system using role-relevant datasets and measures false-positive and false-negative patterns across relevant applicant groups. It also tests missing information, unusual résumé formats, malicious prompt content, vendor outages, model changes, and rollback procedures.

44.6 Control activity

The provider must approve measurable performance, robustness, and cybersecurity requirements before release and repeat testing after material changes or emerging threats. The deployer must monitor real-world

performance, maintain required operating conditions, report serious anomalies, and suspend use when defined thresholds are breached.

44.7 Evidence

- performance requirements and thresholds;
- validation and test plans;
- subgroup and edge-case results;
- robustness and stress-test results;
- threat model and security architecture;
- vulnerability and penetration-test records;
- dependency and resilience testing;
- monitoring dashboards;
- incident and corrective-action records;
- release and rollback approvals.

44.8 Audit test

Select a high-risk system and verify that performance and security requirements are documented, tests reflect the intended deployment context, material failure modes are disclosed, vulnerabilities and anomalies are tracked, and threshold breaches trigger investigation, correction, restriction, or suspension.

44.9 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 15 and related lifecycle, monitoring, and provider/deployer obligations.
- Current consolidated EUR-Lex text controls over older summaries.

45 Chapter 44 — Conformity Assessment

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 44 draft language.

45.1 Requirement

Before a high-risk AI system is placed on the market or put into service, the provider must complete the applicable conformity-assessment procedure and retain evidence that the system satisfies the relevant requirements of Regulation (EU) 2024/1689, as amended.

45.2 Plain-English explanation

Conformity assessment is the structured process used to demonstrate that a high-risk AI system meets the legal requirements before release. The correct assessment route depends on the classification basis, product-sector legislation, use of harmonised standards or common specifications, and whether third-party assessment by a notified body is required.

The manual must not assume that every high-risk system follows the same route. It must distinguish standalone Annex III systems from AI that is a safety component of, or itself, a product governed by Annex I legislation.

45.3 Assessment pathway

The provider should document:

1. the high-risk classification basis;
2. the applicable conformity-assessment route;
3. interaction with relevant product-sector legislation;
4. whether internal control, notified-body involvement, or another procedure applies;
5. standards, common specifications, and technical methods used;
6. technical-documentation completeness;
7. quality-management-system readiness;
8. testing and validation evidence;
9. identified deviations, nonconformities, and corrective actions;
10. approval of the final assessment outcome.

45.4 Change and reassessment

A new conformity assessment may be required after a substantial modification or another change that affects compliance. Providers must maintain a documented change-screening process and must not rely indefinitely on the assessment of an earlier version.

45.5 GlobalWay example

Before releasing a high-risk recruitment system under its own name, GlobalWay confirms the applicable Annex III pathway, validates the technical file and quality-management system, resolves identified gaps, documents the conformity decision, and links the decision to the exact production version.

45.6 Control activity

The provider must establish a conformity-readiness gate before release. Legal, compliance, technical, and quality owners must approve the classification, procedure, evidence package, deviations, and final result. No system may be placed on the market or put into service before the applicable procedure is complete.

45.7 Evidence

- classification decision;
- conformity pathway analysis;
- applicable product-sector assessment;
- technical-documentation index;
- quality-management-system evidence;
- test and validation results;
- standards and specification mapping;
- notified-body records where applicable;
- nonconformity and corrective-action records;
- final assessment approval;
- version linkage and reassessment history.

45.8 Audit test

Select a released high-risk system. Confirm that the correct conformity route was identified, the required evidence existed before release, any notified-body involvement was completed where required, unresolved nonconformities were addressed, and material changes triggered reassessment.

45.9 Primary legal references

- Regulation (EU) 2024/1689, as amended: Articles 43–44 and related provisions.
- Relevant Annex I product legislation and applicable harmonised standards or common specifications.
- Current consolidated EUR-Lex text controls over older summaries.

46 Chapter 45 — EU Declaration of Conformity and CE Marking

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 45 draft language.

46.1 Requirement

Where required, the provider must draw up a written EU declaration of conformity for each high-risk AI system and affix the CE marking in accordance with Regulation (EU) 2024/1689, as amended, and applicable product legislation.

46.2 Plain-English explanation

The declaration of conformity is the provider's formal statement that the identified system complies with the applicable legal requirements. CE marking communicates that the required conformity steps have been completed. Neither item is a marketing award, quality score, or guarantee that the system can be used safely in every context.

46.3 Declaration controls

The declaration should:

1. identify the AI system and version unambiguously;
2. identify the provider and, where applicable, authorised representative;
3. state that the declaration is issued under the provider's sole responsibility;
4. identify the applicable Union legislation;
5. reference relevant standards, common specifications, or assessment methods;
6. identify any notified body and certificate where applicable;
7. include the place, date, authorized signatory, and signature;
8. remain accurate after changes and be retained for the required period.

46.4 CE-marking controls

The provider must ensure that the CE marking is affixed visibly, legibly, and indelibly where required, or is presented digitally where the legal framework permits. Product-sector rules must be coordinated so that markings and declarations are not duplicated or applied inconsistently.

46.5 GlobalWay example

For a high-risk system that GlobalWay places on the Union market under its own name, the compliance team verifies that the conformity assessment is complete, prepares the declaration for the exact release, confirms required references and signatures, and applies the CE marking through the approved product-release process.

46.6 Control activity

No declaration or CE marking may be issued until conformity evidence is complete and approved. The provider must maintain controlled templates, authorized signatories, version linkage, retention, withdrawal, and correction procedures.

46.7 Evidence

- signed EU declaration of conformity;
- system and release identification;
- conformity-assessment record;
- standards and specification references;
- notified-body certificate where applicable;
- CE-marking approval and placement evidence;
- signatory authorization;
- retention and correction history.

46.8 Audit test

Select a marked high-risk AI system. Confirm that the declaration identifies the correct legal entity and version, cites the applicable legislation and assessment evidence, was signed by an authorized person, and that the CE marking was applied only after conformity approval.

46.9 Primary legal references

- Regulation (EU) 2024/1689, as amended: Articles 47–48 and relevant annexes.
- Applicable Annex I product legislation.
- Current consolidated EUR-Lex text controls over older summaries.

47 Chapter 46 — Registration

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 46 draft language.

47.1 Requirement

Providers and, where applicable, deployers must complete the registrations required by Regulation (EU) 2024/1689, as amended, before the relevant high-risk AI system is placed on the market, put into service, or used. Registration duties depend on the system category, actor role, and applicable confidentiality or law-enforcement provisions.

47.2 Plain-English explanation

Registration supports regulatory visibility and traceability. It is not a substitute for classification, conformity assessment, technical documentation, or monitoring. The organization must determine who registers, what information must be submitted, when the registration must occur, and how later changes are reflected.

47.3 Registration controls

The registration process should address:

1. system classification and applicable registration basis;
2. responsible legal entity and actor role;
3. database or authority through which registration is made;
4. required system, provider, deployer, and conformity information;
5. confidentiality, security, and restricted-access treatment where applicable;
6. approval before submission;
7. linkage to the exact system version and conformity record;
8. updates after changes, suspension, withdrawal, or decommissioning;
9. retention of submission, acknowledgement, and amendment evidence.

47.4 GlobalWay example

Before deploying a qualifying high-risk recruitment system, GlobalWay confirms whether provider and deployer registration duties apply, assigns the responsible legal entity, validates the information against the technical file, records the submission acknowledgement, and updates the registration after a material version change.

47.5 Control activity

The AI Governance function must maintain a registration register linked to the enterprise AI inventory. Deployment gates must prevent use where required registration is incomplete, inaccurate, expired, or inconsistent with the deployed system.

47.6 Evidence

- registration applicability decision;
- approved submission data;
- database submission and acknowledgement;
- responsible-entity approval;
- system-version linkage;
- confidentiality assessment;
- update and amendment history;
- suspension or withdrawal records.

47.7 Audit test

Select a sample of registered high-risk systems and confirm that the correct actor completed registration before the legally relevant event, the submitted information agrees with the technical documentation and deployed version, and later material changes were updated promptly.

47.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 49 and relevant provisions concerning the EU database and restricted registration arrangements.
- Current consolidated EUR-Lex text controls over older summaries.

48 Chapter 47 — Fundamental-Rights Impact Assessment

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 47 draft language.

48.1 Requirement

Before first use of specified high-risk AI systems, deployers that fall within Article 27 must perform a fundamental-rights impact assessment and meet the associated documentation, notification, and review requirements.

48.2 Plain-English explanation

A fundamental-rights impact assessment examines how a high-risk AI use may affect people in practice. It is broader than a technical risk review and must consider the deployment context, affected groups, possible harms, human oversight, complaints, mitigation, and residual risk.

The duty does not automatically apply to every deployer or every high-risk system. The organization must first determine whether Article 27 applies to the actor and use case. Even where it does not, a voluntary assessment may still be prudent for significant rights impacts.

48.3 Assessment content

The assessment should document, as applicable:

1. the deployer, system, intended purpose, and deployment process;
2. the period and frequency of use;
3. categories of natural persons and groups likely to be affected;
4. specific risks to fundamental rights, including equality, dignity, privacy, data protection, expression, due process, worker rights, and access to services;
5. foreseeable misuse, exclusion, discrimination, chilling effects, and cumulative impacts;
6. human-oversight, complaint, contestability, and remedy arrangements;
7. technical, organizational, contractual, and procedural mitigation;
8. residual risk and approval decision;
9. consultation with relevant internal functions, representatives, experts, or affected stakeholders where appropriate;
10. required notification to the market-surveillance authority and coordination with the data-protection impact assessment where applicable.

48.4 GlobalWay example

Before deploying a high-risk recruitment system, GlobalWay evaluates how ranking and screening could affect applicants, including people with disabilities, nontraditional career histories, language differences, and protected characteristics. It documents mitigations, human review, appeal routes, monitoring, and the relationship to its GDPR data-protection impact assessment.

48.5 Control activity

The deployer must determine Article 27 applicability during intake and complete the assessment before first use. Legal, privacy, HR or business ownership, AI governance, and relevant worker or stakeholder representatives must review the assessment according to the deployment context. Material changes or new harms must trigger reassessment.

48.6 Evidence

- Article 27 applicability decision;
- completed fundamental-rights impact assessment;
- affected-person and group analysis;
- rights-risk register;
- mitigation and residual-risk approval;
- human-oversight and complaint procedures;
- DPIA coordination record;
- authority-notification evidence where required;
- consultation records;
- review and reassessment history.

48.7 Audit test

Select an applicable high-risk deployment. Confirm that the assessment was completed before first use, covers the actual affected groups and deployment context, identifies concrete rights risks, includes operational mitigation and remedy mechanisms, coordinates with privacy assessment, and was updated after material changes or emerging impacts.

48.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 27 and related deployer obligations.
- GDPR Article 35 where a data-protection impact assessment is required.
- Current consolidated EUR-Lex text controls over older summaries.

49 Chapter 48 — DPIA Coordination

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 48 draft language.

49.1 Requirement

Where the processing of personal data is likely to result in a high risk to the rights and freedoms of natural persons, the controller must complete a data protection impact assessment under the GDPR. Where a fundamental-rights impact assessment is also required under Article 27 of Regulation (EU) 2024/1689, as amended, the assessments should be coordinated so that

shared facts, affected-person analysis, risks, safeguards, consultation, approvals, and residual-risk conclusions are consistent.

49.2 Plain-English explanation

The AI Act does not replace the GDPR. A high-risk AI use may require both an AI Act fundamental-rights impact assessment and a GDPR DPIA. The two instruments have different legal bases and scopes, but they should not contradict each other or duplicate evidence unnecessarily.

49.3 Coordination requirements

The organization should:

1. identify the controller, processor, deployer, provider, and other relevant actors;
2. document the intended purpose, data flows, categories of personal data, affected people, and decision consequences;
3. determine whether Article 27 AI Act and Articles 35–36 GDPR apply;
4. align risk scenarios, likelihood and severity analysis, safeguards, human oversight, transparency, security, and monitoring;
5. retain separate legal conclusions where the statutory tests differ;
6. consult the data protection officer and legal counsel where required;
7. escalate residual high risk for supervisory-authority consultation where Article 36 GDPR applies;
8. update both assessments after material changes.

49.4 GlobalWay example

GlobalWay deploys a high-risk recruitment-screening system. The privacy team completes a DPIA covering applicant data, profiling, retention, automated decision-making, and security. The AI governance team coordinates the Article 27 analysis for affected groups, power imbalance, human oversight, complaint routes, and mitigation. Both assessments use the same system description and deployment facts but retain their distinct legal conclusions.

49.5 Control activity

The privacy and AI governance functions must operate a joint assessment intake and cross-reference process. No deployment may proceed until required DPIA and fundamental-rights impact-assessment approvals are complete and contradictory assumptions are resolved.

49.6 Evidence

- DPIA;

- fundamental-rights impact assessment;
- data-flow map;
- role and legal-basis analysis;
- DPO consultation;
- mitigation plan;
- residual-risk approval;
- supervisory-authority consultation records, where applicable;
- reassessment history.

49.7 Audit test

Select a sample of high-risk AI deployments processing personal data. Confirm that DPIA applicability was assessed, Article 27 applicability was separately assessed, overlapping evidence is consistent, required consultations occurred, and material changes triggered reassessment.

49.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 27.
- Regulation (EU) 2016/679: Articles 35–36 and, where relevant, Article 22.
- Current consolidated official texts control over older summaries.

50 Chapter 49 — Post-Market Monitoring

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 49 draft language.

50.1 Requirement

Providers of high-risk AI systems must establish and document a proportionate post-market monitoring system that actively and systematically collects, documents, and analyses relevant performance and risk data throughout the system lifetime. The system must be based on a post-market monitoring plan that forms part of the technical documentation.

50.2 Plain-English explanation

Compliance does not end when the system is released. Providers must continue checking whether the system performs as intended, remains compliant, interacts safely with other systems, and creates new or changed risks in real use.

50.3 Monitoring design

The plan should define:

1. scope, owners, and system versions;
2. data sources, including deployer feedback, complaints, incidents, overrides, drift, and technical telemetry;
3. performance, safety, bias, robustness, cybersecurity, and human-oversight indicators;
4. thresholds and escalation criteria;
5. review frequency and sampling;
6. methods for trend, subgroup, and interaction analysis;
7. corrective-action and notification triggers;
8. links to risk management, technical documentation, serious-incident reporting, and change control;
9. retention, confidentiality, and evidence requirements.

Where sector legislation already requires a post-market system, the provider may integrate the AI Act elements into that system where the statutory conditions are met and equivalent protection is preserved.

50.4 GlobalWay example

GlobalWay's provider monitors the production recruitment system for selection-rate disparities, false-positive and false-negative trends, override rates, user complaints, model drift, security events, and deviations from the intended purpose. Quarterly reviews are supplemented by immediate escalation when thresholds are exceeded.

50.5 Control activity

The provider must approve a version-linked post-market monitoring plan before release, operate the plan throughout the system lifetime, document findings, and feed relevant results into risk management, corrective action, incident reporting, and technical-documentation updates.

50.6 Evidence

- approved monitoring plan;
- metric definitions and thresholds;
- monitoring data and dashboards;
- deployer feedback and complaints;

- trend and subgroup analysis;
- escalation and corrective-action records;
- technical-documentation updates;
- management review minutes.

50.7 Audit test

Select a sample of high-risk AI systems and verify that monitoring is active rather than purely reactive, covers the deployed lifetime and actual production version, uses defined thresholds, analyses relevant data, and triggers documented risk, incident, and corrective-action processes.

50.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 72 and Annex IV.
- Current consolidated EUR-Lex text controls over older summaries.

51 Chapter 50 — Serious-Incident Reporting

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 50 draft language.

51.1 Requirement

Providers of high-risk AI systems placed on the Union market must report serious incidents to the market-surveillance authorities of the Member States where the incident occurred. Reporting must follow the applicable statutory deadlines, preserve evidence, support investigation, and lead to risk assessment and corrective action.

51.2 Plain-English explanation

A serious incident cannot wait for the normal monthly governance meeting. The provider needs an operating process that identifies reportable events, establishes or reasonably suspects causal linkage, submits timely initial information when facts remain incomplete, and coordinates with deployers, authorities, notified bodies where relevant, privacy teams, security teams, and sector regulators.

51.3 Reporting deadlines

The incident process must distinguish at least:

1. the general deadline: immediately after establishing a causal link or reasonable likelihood of a link and, in any event, no later than 15 days after awareness;

2. widespread infringement or the serious-incident category referenced in Article 3(49)(b): immediately and no later than two days after awareness;
3. death of a person: immediately after establishing or suspecting a causal relationship and no later than 10 days after awareness;
4. incomplete initial reports followed by complete reports where needed for timeliness.

Deadlines must be reverified against the current amended text and applicable sector rules before publication and operation.

51.4 GlobalWay example

A high-risk employee-screening system produces a defect that systematically excludes applicants with a protected characteristic across several Member States. GlobalWay suspends the affected workflow, preserves system and decision logs, informs the provider, begins impact assessment, determines the relevant authority and reporting timeline, and documents the basis for every notification decision.

51.5 Control activity

The provider and deployer must maintain a serious-incident response procedure with 24/7 escalation, role allocation, legal triage, deadline calculation, evidence preservation, regulator contact information, initial and supplemental report templates, investigation controls, and corrective-action linkage.

The provider must not alter the affected system in a manner that could compromise later evaluation of the incident causes before informing the competent authorities of that action.

51.6 Evidence

- incident intake and classification record;
- awareness and deadline timestamps;
- causal-link assessment;
- preserved logs, versions, data, and configuration;
- initial and final regulatory reports;
- authority communications;
- investigation and risk assessment;
- corrective-action records;
- deployer, provider, and notified-body coordination;

- management and board escalation.

51.7 Audit test

Select reported and near-threshold incidents. Recalculate the applicable reporting deadline, verify the awareness date and causal-link analysis, confirm evidence preservation and authority coordination, and test whether corrective action and post-market monitoring were updated.

51.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 3(49) and Article 73.
- Applicable Union harmonisation and sector legislation where relevant.
- Current consolidated EUR-Lex text controls over older summaries.

52 Chapter 51 — Corrective Action, Withdrawal, and Recall

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 51 draft language.

52.1 Requirement

Where a provider has reason to consider that a high-risk AI system is not in conformity with Regulation (EU) 2024/1689, as amended, it must immediately take the corrective actions necessary to bring the system into conformity, withdraw it, disable it, or recall it, as appropriate. Relevant distributors, importers, deployers, authorised representatives, and competent authorities must be informed where required.

52.2 Plain-English explanation

A defect or compliance failure requires more than documenting a finding. The organization must determine the affected versions and deployments, contain the risk, protect affected people, correct the system where feasible, and remove or disable it where correction cannot provide adequate protection.

52.3 Corrective-action process

The process should include:

1. intake and classification of the nonconformity;
2. immediate containment and affected-version identification;
3. risk, safety, fundamental-rights, privacy, and security assessment;
4. decision criteria for correction, suspension, disablement, withdrawal, or recall;

5. communications to value-chain actors, affected persons, and authorities where required;
6. root-cause analysis;
7. validation of the corrective action before redeployment;
8. technical-documentation, conformity, risk-management, and monitoring updates;
9. effectiveness testing and formal closure;
10. recurrence prevention.

52.4 GlobalWay example

GlobalWay learns that a recruitment-screening release incorrectly weights a proxy variable and materially disadvantages a protected group. The affected version is disabled, pending decisions are routed to trained human reviewers, the provider identifies all impacted deployments, preserves evidence, corrects and retests the model, communicates with relevant actors, and evaluates whether regulatory and affected-person notifications are required.

52.5 Control activity

The provider must maintain a documented nonconformity and corrective-action procedure with defined authority to suspend production use. Corrective actions must be risk-based, version-specific, validated independently of the implementation team where appropriate, and linked to incident, complaint, post-market, and change-management processes.

52.6 Evidence

- nonconformity record;
- affected-system and version inventory;
- containment and suspension decision;
- root-cause analysis;
- corrective-action plan;
- retest and validation results;
- withdrawal or recall communications;
- authority and affected-person notifications, where applicable;
- updated conformity and technical records;
- effectiveness review and closure approval.

52.7 Audit test

Select a sample of significant nonconformities. Confirm that containment was timely, affected versions and deployments were identified, the selected remedy was proportionate, communications were complete, corrective action was validated before redeployment, and closure evidence demonstrates effectiveness.

52.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: provider, importer, distributor, deployer, post-market, market-surveillance, and corrective-action provisions, including Articles 20–26 and Chapter IX as applicable.
- Applicable Union harmonisation and sector legislation.
- Current consolidated EUR-Lex text controls over older summaries.

53 Chapter 52 — Change Management and Substantial Modification

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 52 draft language.

53.1 Requirement

Changes to a high-risk AI system must be assessed before implementation to determine whether they affect intended purpose, regulatory classification, conformity, risk controls, performance, data, human oversight, cybersecurity, documentation, or actor roles. A substantial modification can transfer provider obligations to the modifying actor and may require renewed conformity assessment and related compliance actions.

53.2 Plain-English explanation

Not every patch is a substantial modification, but no material change should be assumed harmless. The legal question is whether the change was foreseen and assessed by the original provider and whether it affects compliance or intended purpose. Technical, business, contractual, data, and operational changes can all matter.

53.3 Change-assessment criteria

Assess at minimum:

1. change to intended purpose, users, affected population, jurisdiction, or decision consequence;
2. retraining, fine-tuning, model replacement, parameter changes, or new retrieval sources;

3. material dataset, feature, threshold, interface, or workflow changes;
4. new integrations, autonomous functions, or downstream uses;
5. changes to accuracy, robustness, cybersecurity, bias, safety, or fundamental-rights risk;
6. changes to human oversight, logging, instructions, or transparency;
7. changes to provider branding, contractual allocation, or operational control;
8. whether the change was foreseen in the original conformity assessment and technical documentation;
9. whether renewed conformity assessment, registration, declaration, marking, notification, or provider-role reassessment is required.

53.4 GlobalWay example

GlobalWay fine-tunes a vendor recruitment model using its own historical applicant data, changes ranking thresholds, and deploys the result under its own brand. The change board does not treat this as routine configuration. It performs a substantial-modification and provider-role assessment, updates the risk and data-governance files, and blocks release until legal and conformity decisions are documented.

53.5 Control activity

Every production change must pass a documented AI change assessment before approval. High-impact changes require legal, compliance, privacy, security, model-risk, and business-owner review. Release tooling must prevent deployment where substantial-modification, role-transfer, conformity, or registration questions remain unresolved.

53.6 Evidence

- change request and technical description;
- before-and-after intended-purpose analysis;
- substantial-modification assessment;
- provider-role reassessment;
- updated risk, data, oversight, and cybersecurity evidence;
- regression, subgroup, and safety testing;
- conformity and registration decisions;
- updated technical documentation and instructions;

- release approval and rollback plan;
- post-change monitoring results.

53.7 Audit test

Select a sample of significant changes. Confirm that the organization assessed intended purpose, foreseeability, compliance impact, role transfer, and conformity consequences before release; verify that testing and documentation match the deployed version; and confirm that post-change monitoring was performed.

53.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 3 definition of substantial modification, Article 25, and applicable conformity, registration, technical-documentation, and post-market provisions.
- Current consolidated EUR-Lex text controls over older summaries.
- Commission guidance on substantial modification must be identified as non-binding unless and until formally adopted with binding effect.

54 Chapter 53 — Understanding GPAI Roles

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 53 draft language.

54.1 Requirement

Organizations must determine whether they are providers of a general-purpose AI model, providers of an AI system built on such a model, downstream providers, deployers, authorised representatives, or actors whose modification of a model creates provider obligations. Role classification must reflect actual conduct, not only contractual labels.

54.2 Plain-English explanation

A company that uses a third-party model in an internal tool is not automatically the provider of that model. A company that develops, commissions, places on the Union market, or significantly modifies a GPAI model may carry provider duties. A company may also be a system provider or deployer at the same time. Each role must be assessed separately.

54.3 Role assessment

Document at minimum:

1. who developed or had the model developed;
2. under whose name or trademark the model is placed on the market;

3. who controls model architecture, weights, training, fine-tuning, and release;
4. whether a modification is minor or significant under the current Commission interpretation;
5. who provides documentation and information to downstream actors;
6. who maintains the copyright policy and training-content summary;
7. whether an authorised representative is required;
8. whether the model meets or may meet systemic-risk criteria;
9. whether a separate system-provider or deployer role also applies.

54.4 GlobalWay example

GlobalWay procures access to a third-party GPAI model through an API and uses it in a travel-consultant assistant. GlobalWay is ordinarily a downstream system provider and deployer, not the model provider. If GlobalWay later performs significant fine-tuning, controls a new model release, and markets it under its own name, the role analysis must be reopened.

54.5 Control activity

The Legal and AI Governance functions must approve a GPAI role assessment before procurement, model modification, public release, or material contract change. The assessment must be repeated after changes to branding, training, fine-tuning, distribution, licensing, or operational control.

54.6 Evidence

- model and system architecture;
- contracts and licence terms;
- branding and market-placement records;
- development and modification history;
- role-assessment worksheet;
- legal analysis;
- provider and downstream documentation;
- reassessment records.

54.7 Audit test

Select a sample of GPAI-enabled systems. Confirm that model-provider, system-provider, downstream-provider, deployer, and authorised-representative roles were assessed separately and that significant modifications triggered reassessment.

54.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Articles 3, 51–56 and related annexes.
- European Commission Guidelines for providers of GPAI models, identified as non-binding guidance.
- Current consolidated EUR-Lex text controls over older summaries.

55 Chapter 54 — GPAI Documentation and Downstream Information

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 54 draft language.

55.1 Requirement

Providers of general-purpose AI models must prepare, maintain, and provide the documentation and information required by Article 53 and the applicable annexes so downstream providers can understand the model's capabilities and limitations and comply with their own obligations.

55.2 Plain-English explanation

Downstream users need more than a marketing description. They need controlled, current, technically meaningful information about the model, its intended and foreseeable uses, limitations, training and evaluation approach, interfaces, dependencies, and conditions of use. Information must be sufficient for a downstream provider to perform risk, conformity, transparency, security, and human-oversight work.

55.3 Documentation controls

The provider should maintain, as applicable:

1. model identity, version, release date, and provider details;
2. architecture, modality, capabilities, and intended uses;
3. prohibited, unsupported, and high-risk use limitations;
4. training, fine-tuning, evaluation, and testing information;
5. known performance limits, failure modes, and foreseeable misuse;

6. cybersecurity and resilience information;
7. integration requirements and interface controls;
8. documentation required for the AI Office and competent authorities;
9. information required for downstream providers;
10. change history and update notices.

55.4 GlobalWay example

Before integrating a GPAI model into its traveler assistant, GlobalWay obtains the provider's controlled model documentation, release notes, limitations, safety information, technical interface requirements, and downstream compliance information. A new model version cannot be deployed until the changed documentation is reviewed.

55.5 Control activity

The provider must operate a version-controlled GPAI documentation process. Downstream information must be reviewed for completeness, accuracy, confidentiality, and usability before release. Material model changes must trigger updated documentation and timely communication to affected downstream providers.

55.6 Evidence

- model technical documentation;
- downstream information package;
- version and release records;
- change notices;
- evaluation and limitation records;
- distribution logs;
- recipient acknowledgements where used;
- review and approval records.

55.7 Audit test

Select a model version and confirm that the required documentation existed when the model was placed on the market, matches the released version, was supplied to relevant downstream providers, and was updated after material changes.

55.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 53 and applicable annexes.

- European Commission GPAI provider guidelines, identified as non-binding guidance.
- Current consolidated EUR-Lex text controls over older summaries.

56 Chapter 55 — Copyright Policy and Training-Content Summary

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 55 draft language.

56.1 Requirement

Providers of general-purpose AI models must maintain a policy to comply with Union copyright and related-rights law, including the identification and observance of rights reservations expressed under Article 4(3) of Directive (EU) 2019/790, and must make publicly available a sufficiently detailed summary of the content used to train the model using the Commission template where applicable.

56.2 Plain-English explanation

The copyright policy and the public training-content summary are separate controls. The policy governs how training content is sourced, screened, documented, and handled when rights holders reserve their rights. The public summary gives meaningful visibility into categories and sources of training content without requiring disclosure of protected trade secrets or every individual item.

56.3 Control requirements

The provider should document:

1. training-content source categories and acquisition methods;
2. licence, permission, public-domain, exception, and rights-reservation analysis;
3. measures for detecting and respecting machine-readable rights reservations;
4. complaint, challenge, and remediation processes;
5. supplier and dataset-provider controls;
6. the method used to prepare the public summary;
7. review for accuracy, confidentiality, personal data, and trade secrets;
8. versioning and update triggers after material retraining or dataset changes.

56.4 GlobalWay example

GlobalWay does not assume that a GPAI vendor's statement that it uses "publicly available data" resolves copyright risk. Procurement requires the provider's copyright policy, public training-content summary, rights-reservation process, complaint route, and change-notification commitments.

56.5 Control activity

The provider must approve and maintain a copyright-compliance policy and publish the required training-content summary. Legal, data-governance, and model-development functions must review material dataset changes before training or retraining proceeds.

56.6 Evidence

- copyright policy;
- source and licence records;
- rights-reservation detection controls;
- dataset-provider contracts;
- complaint and remediation records;
- Commission-template training summary;
- publication record;
- update and approval history.

56.7 Audit test

Select a model and sample training-content sources. Confirm that the provider applied its copyright policy, documented the basis for use, respected applicable rights reservations, published the required summary, and updated it after material training changes.

56.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 53.
- Directive (EU) 2019/790, including Article 4(3).
- Current Commission template and guidance, identified according to legal status.

57 Chapter 56 — GPAI Models with Systemic Risk

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 56 draft language.

57.1 Requirement

A general-purpose AI model must be classified as a GPAI model with systemic risk when it has high-impact capabilities under Article 51 or when the Commission designates it as presenting equivalent capabilities or impact. Providers must monitor the classification criteria, notify the Commission when required, and comply with the additional obligations applicable to systemic-risk models.

57.2 Plain-English explanation

Systemic-risk status can arise through a statutory presumption or a Commission decision. The current regulation presumes high-impact capabilities when cumulative training computation exceeds 10^{25} floating-point operations, subject to future amendment. The threshold is not the only route: the Commission may designate a model based on the broader Annex XIII criteria.

57.3 Classification and notification process

The provider must:

1. measure and document cumulative training computation;
2. assess model capabilities and impact using appropriate tools, benchmarks, and Annex XIII criteria;
3. monitor whether the threshold will be met before training completes;
4. notify the Commission without delay and no later than two weeks after the criterion is met or the provider knows it will be met;
5. include the information necessary to support the notification;
6. document any exceptional, substantiated argument that the model does not present systemic risk despite meeting the presumption;
7. track Commission designation, rejection, reassessment, or removal decisions;
8. activate Article 55 controls when systemic-risk classification applies.

57.4 GlobalWay example

GlobalWay is not the provider of the third-party GPAI model used in its travel platform, but vendor due diligence confirms whether the provider has assessed systemic-risk status, completed required notifications, and supplied appropriate safety and security information to downstream customers.

57.5 Control activity

The GPAI provider must maintain a documented systemic-risk classification process linked to training plans, compute records, evaluation results, Commission communications, and release gates. No qualifying model may be placed on the Union market while a required notification or Article 55 readiness action remains unresolved.

57.6 Evidence

- training-compute calculation;
- capability and impact evaluations;
- Annex XIII analysis;
- threshold-monitoring records;
- Commission notification and timestamp;
- rebuttal submission, where used;
- Commission decision or correspondence;
- Article 55 readiness and compliance evidence.

57.7 Audit test

Select a major GPAI model release. Recalculate or validate the training-compute figure, inspect the Annex XIII analysis, confirm the notification date where required, and verify that systemic-risk obligations were activated before release.

57.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Articles 51–52 and Annex XIII.
- European Commission GPAI provider guidelines, identified as non-binding guidance.
- Current consolidated EUR-Lex text controls over older summaries.

58 Chapter 57 — Model Evaluations and Adversarial Testing

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 57 draft language.

58.1 Requirement

Providers of general-purpose AI models with systemic risk must perform model evaluations in accordance with standardised protocols and tools

reflecting the state of the art, including adversarial testing where appropriate, to identify and mitigate systemic risks.

58.2 Plain-English explanation

Evaluation is not a one-time benchmark exercise. The provider must test what the model can do, where it fails, how it can be misused, how safeguards can be bypassed, and whether new releases or fine-tuning materially change risk. Adversarial testing should include realistic attempts to defeat controls and expose dangerous or unintended capabilities.

58.3 Evaluation programme

The provider should define:

1. evaluation objectives linked to identified systemic risks;
2. capability, safety, security, robustness, misuse, and autonomy test domains;
3. pre-release, post-release, and change-triggered evaluation points;
4. independent or functionally separated testing where proportionate;
5. representative and stress-test scenarios;
6. red-team qualifications, conflict controls, and rules of engagement;
7. severity, exploitability, reproducibility, and residual-risk criteria;
8. remediation, retesting, and release-blocking thresholds;
9. confidential handling of sensitive findings;
10. documentation sufficient for oversight and regulatory review.

58.4 GlobalWay example

Before integrating a systemic-risk GPAI model into its travel-assistance platform, GlobalWay reviews the provider's evaluation summary, tests prompt-injection resistance, harmful travel-document generation, sensitive-data leakage, false emergency guidance, and safeguards around prohibited content, and records downstream limitations and compensating controls.

58.5 Control activity

The GPAI provider must maintain a documented evaluation and adversarial-testing programme tied to release governance. A release must not proceed where unresolved findings exceed approved risk thresholds or where testing does not cover material identified systemic risks.

58.6 Evidence

- evaluation plan and test catalogue;

- benchmark and scenario rationale;
- adversarial-testing reports;
- red-team qualifications and independence records;
- findings and severity ratings;
- remediation and retest evidence;
- release decision and residual-risk approval;
- post-release evaluation results.

58.7 Audit test

Select a systemic-risk model release. Confirm that evaluations addressed the current risk assessment, included realistic adversarial testing, used defined acceptance criteria, resulted in tracked remediation, and were completed before release approval.

58.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 55(1)(a).
- Current consolidated EUR-Lex text controls over older summaries.
- Applicable Commission and AI Office guidance must be identified as non-binding unless legally adopted.

59 Chapter 58 — Systemic-Risk Assessment and Mitigation

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 58 draft language.

59.1 Requirement

Providers of general-purpose AI models with systemic risk must assess and mitigate possible systemic risks at Union level, including their sources, pathways, affected sectors, foreseeable misuse, and materialisation across the model lifecycle.

59.2 Plain-English explanation

Systemic risk concerns harm that can spread broadly, affect many people or sectors, undermine public interests, or create serious cross-border effects. The provider must identify how model capabilities, distribution, integrations, dependencies, and misuse could create such harm and must implement safeguards proportionate to the risk.

59.3 Assessment structure

The assessment should address:

1. model capabilities, limitations, and foreseeable evolution;
2. access conditions, distribution scale, and downstream integration;
3. misuse and circumvention pathways;
4. cyber, biological, chemical, radiological, information-integrity, discrimination, safety, autonomy, and critical-infrastructure risks where relevant;
5. concentration, dependency, and cascading-failure risks;
6. affected populations, sectors, rights, and geographic reach;
7. likelihood, severity, speed, reversibility, and detectability;
8. existing safeguards and residual risk;
9. mitigation owners, deadlines, validation, and monitoring;
10. reassessment triggers, including new capabilities, incidents, evaluations, and material changes.

59.4 GlobalWay example

GlobalWay evaluates whether a systemic-risk GPAI model used across booking, disruption management, fraud, and employee-assistance workflows could propagate false emergency guidance, expose sensitive traveler data, enable large-scale social engineering, or create correlated operational failures. It applies downstream controls while requiring provider evidence for upstream systemic-risk mitigation.

59.5 Control activity

The provider must maintain a version-specific systemic-risk register linked to model evaluations, incident information, cybersecurity controls, release decisions, and post-market monitoring. Material unmitigated risks must block release or require documented restriction, staged deployment, access limitation, or other validated safeguards.

59.6 Evidence

- systemic-risk methodology;
- risk register and scenario analysis;
- affected-sector and dependency mapping;
- misuse and threat assessments;

- mitigation plan and owners;
- validation and residual-risk approval;
- release restrictions and access controls;
- monitoring and reassessment records.

59.7 Audit test

Select a systemic-risk model release and verify that the assessment covers relevant capability, misuse, dependency, and cross-sector pathways; that mitigations are validated and traceable; and that residual risks were approved at the appropriate level before release.

59.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 55(1)(b) and related systemic-risk provisions.
- Current consolidated EUR-Lex text controls over older summaries.
- Applicable Commission and AI Office guidance must be identified as non-binding unless legally adopted.

60 Chapter 59 — Cybersecurity and Incident Reporting for Systemic-Risk GPAI

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 59 draft language.

60.1 Requirement

Providers of general-purpose AI models with systemic risk must ensure an adequate level of cybersecurity protection for the model and its physical infrastructure and must track, document, and report relevant serious incidents and possible corrective measures to the AI Office and, where appropriate, national competent authorities.

60.2 Plain-English explanation

A systemic-risk model can create broad harm if model weights, training infrastructure, deployment systems, or safety controls are compromised. Security must cover the full model lifecycle, including development, training, evaluation, release, access, updates, incident detection, and recovery.

60.3 Cybersecurity control areas

The provider should address:

1. secure development and training environments;

2. identity, access, privilege, and secrets management;
3. protection of model weights, datasets, code, and evaluation assets;
4. software, hardware, cloud, and supply-chain vulnerabilities;
5. adversarial machine-learning threats, including poisoning, extraction, evasion, and prompt-based abuse;
6. logging, monitoring, anomaly detection, and forensic readiness;
7. segmentation, resilience, backup, and recovery;
8. vulnerability disclosure and remediation;
9. third-party and infrastructure-provider coordination;
10. incident classification, escalation, reporting, and corrective action.

60.4 Incident process

The process must define awareness and escalation criteria, causal and impact assessment, preservation of model and infrastructure evidence, reporting responsibilities, authority contacts, initial and supplemental reporting, corrective measures, and post-incident risk reassessment.

60.5 GlobalWay example

GlobalWay requires its systemic-risk GPAI supplier to provide evidence of weight protection, privileged-access controls, security testing, incident notification commitments, and recovery procedures. GlobalWay separately monitors its own API keys, retrieval stores, plugins, prompts, logs, and downstream integrations.

60.6 Control activity

The provider must operate an integrated model-security and incident-management programme with defined severity thresholds, round-the-clock escalation for critical events, protected evidence, and release or service restrictions when risk cannot be adequately controlled.

60.7 Evidence

- cybersecurity architecture and risk assessment;
- access and privilege records;
- model-weight and data-protection controls;
- security and adversarial test results;
- vulnerability and remediation records;
- monitoring and detection evidence;

- incident reports and authority communications;
- corrective-action and recovery evidence;
- post-incident reassessment.

60.8 Audit test

Select a systemic-risk model and a sample of security events. Confirm that controls cover the model and physical infrastructure, events were classified and escalated consistently, evidence was preserved, required reports were submitted, and corrective measures were validated.

60.9 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 55(1)(c) and (d).
- Current consolidated EUR-Lex text controls over older summaries.
- Applicable Commission and AI Office guidance must be identified as non-binding unless legally adopted.

61 Chapter 60 — Energy and Resource Reporting

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 60 draft language.

61.1 Requirement

Providers of general-purpose AI models must maintain and provide the technical information required by Regulation (EU) 2024/1689, as amended, including information concerning the energy consumption of the model where applicable. Providers of systemic-risk GPAI models must also integrate resource impacts into their broader risk, monitoring, and governance processes.

61.2 Plain-English explanation

Energy reporting should be based on measurable and reproducible data, not marketing estimates. The provider should explain what was measured, over which lifecycle stage, using which method, and with what limitations. Training, fine-tuning, evaluation, and inference can have different resource profiles and should not be combined without explanation.

61.3 Reporting framework

The provider should document, where applicable:

1. model version and scope of measurement;
2. training and fine-tuning compute;
3. energy consumed during relevant development and evaluation stages;

4. estimated or measured inference energy under defined usage conditions;
5. hardware, datacentre, cloud, and geographic assumptions;
6. measurement methodology, tools, boundaries, and uncertainty;
7. material changes between model versions;
8. resource-efficiency controls and optimisation measures;
9. information supplied to downstream providers and authorities;
10. retention and review of supporting records.

61.4 GlobalWay example

GlobalWay asks its GPAI supplier for version-specific energy and compute information that can support internal sustainability reporting and procurement decisions. GlobalWay does not represent supplier estimates as exact measurements unless the methodology and boundaries are documented.

61.5 Control activity

The GPAI provider must maintain a controlled resource-reporting methodology and evidence repository. Public or downstream disclosures must be reviewed for consistency with the underlying measurement scope, assumptions, and uncertainty.

61.6 Evidence

- energy and compute methodology;
- measurement logs and source data;
- hardware and infrastructure records;
- model-version comparison;
- assumptions and uncertainty statement;
- downstream technical information;
- review and approval records;
- resource-efficiency improvement actions.

61.7 Audit test

Select a GPAI model version and trace reported energy or resource figures to source data, methodology, infrastructure assumptions, and calculation records. Confirm that estimates are labelled, changes are version-linked, and disclosures do not overstate precision.

61.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 53 and applicable annexed technical-information requirements.
- Current consolidated EUR-Lex text controls over older summaries.
- Applicable Commission and AI Office templates or guidance must be identified as non-binding unless legally adopted.

62 Chapter 61 — Open-Source Considerations

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 61 draft language.

62.1 Requirement

Open-source status does not create a blanket exemption from Regulation (EU) 2024/1689, as amended. Organizations must assess the exact statutory conditions, the actor's role, the model or system category, whether monetisation or related services are involved, whether systemic risk applies, and which obligations remain applicable.

62.2 Plain-English explanation

A public licence or downloadable model does not by itself determine legal treatment. The Act provides limited special treatment in specified circumstances, but important obligations may still apply, especially for systemic-risk GPAI models, prohibited practices, high-risk uses, transparency duties, and downstream providers that integrate, modify, rebrand, or deploy open components.

62.3 Assessment questions

Document:

1. the licence and access conditions;
2. whether source code, architecture, weights, and usage information are genuinely available as required;
3. whether the provider receives monetary or other consideration, including platform, support, hosting, or data-related benefits;
4. whether the model presents systemic risk;
5. whether the organization modifies, fine-tunes, integrates, rebrands, or changes intended purpose;
6. whether the resulting system is prohibited, high-risk, or transparency-regulated;

7. which documentation, copyright, security, incident, and downstream-information duties remain;
8. how vulnerabilities, updates, provenance, and component dependencies are governed.

62.4 GlobalWay example

GlobalWay downloads an openly licensed model and fine-tunes it for employee-screening support. The licence does not remove the need to assess high-risk classification, provider-role transfer, data governance, conformity, human oversight, security, and documentation obligations.

62.5 Control activity

Open-source components must pass legal, security, provenance, licence, and role assessment before use. The inventory must record version, source, licence, maintainers, dependencies, modifications, intended purpose, known limitations, and reassessment triggers.

62.6 Evidence

- licence and repository records;
- statutory open-source analysis;
- monetisation and service assessment;
- model and system classification;
- role and substantial-modification assessment;
- component inventory and provenance;
- vulnerability and update records;
- downstream documentation and approvals.

62.7 Audit test

Select open-source AI components in production. Confirm that the organization did not rely on a blanket exemption, assessed the statutory conditions and remaining duties, tracked modifications and dependencies, and reassessed classification and role after material changes.

62.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: relevant provisions concerning free and open-source AI systems and GPAI models, including Articles 2 and 53-55 as applicable.
- Current consolidated EUR-Lex text controls over older summaries.

- Applicable Commission and AI Office guidance must be identified as non-binding unless legally adopted.

63 Chapter 62 — GPAI Code of Practice

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 62 draft language.

63.1 Requirement

A general-purpose AI provider may use an officially assessed code of practice to support demonstration of compliance with applicable GPAI obligations, but participation does not remove the provider's responsibility to satisfy the Regulation. The legal obligations remain controlling, and the provider must identify any gaps between the code, its implementation, and the provider's actual model and risk profile.

63.2 Plain-English explanation

A code of practice can provide an organized route for documentation, copyright, safety, security, evaluation, and risk controls. It is not a substitute for the law, a guarantee of compliance, or a reason to ignore model-specific weaknesses. Organizations must implement commitments in practice and retain evidence.

63.3 Governance approach

The provider should:

1. identify which code commitments apply to its role and model category;
2. map each commitment to the relevant legal obligation;
3. document adoption, reservations, exclusions, and interpretation;
4. assign accountable owners and deadlines;
5. integrate commitments into policies, release gates, testing, incident handling, and monitoring;
6. retain evidence of operating effectiveness;
7. assess whether additional controls are needed beyond the code;
8. track revisions, official assessments, Commission guidance, and enforcement developments;
9. communicate accurately about participation and avoid implying regulatory approval of the model.

63.4 GlobalWay example

GlobalWay asks a GPAI supplier whether it has signed and implemented the official GPAI Code of Practice, but it also reviews the underlying documentation, copyright process, systemic-risk controls, security evidence, and incident commitments rather than relying only on a participation statement.

63.5 Control activity

The provider must maintain a code-to-obligation control matrix and periodically test whether commitments are implemented. Any deviation, non-applicable commitment, or alternative compliance method must be documented and approved.

63.6 Evidence

- signed code participation or adoption record;
- code-to-article mapping;
- implementation plan and owners;
- policy and procedure updates;
- testing and monitoring evidence;
- deviations and alternative-means analysis;
- management review and remediation records;
- external statements and supplier communications.

63.7 Audit test

Select a sample of code commitments and trace each to the legal obligation, implemented control, operating evidence, and identified gaps. Confirm that external claims do not overstate the legal effect of code participation.

63.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Articles 53-56 and related GPAI provisions.
- Official GPAI Code of Practice and Commission assessment, treated according to their legal status.
- Current consolidated EUR-Lex text controls over older summaries.

64 Chapter 63 — Transparency Code for AI-Generated Content

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 63 draft language.

64.1 Requirement

Organizations may use an officially assessed transparency code of practice to support implementation of applicable Article 50 obligations for AI-generated or manipulated content. The code does not replace the Regulation, and the organization must determine which statutory duties apply to its provider or deployer role, content type, publication context, and effective date.

64.2 Plain-English explanation

Transparency controls should help people recognize when content is generated or manipulated by AI without making the content unusable or inaccessible. Different duties apply to technical marking by providers and disclosures by deployers. Exceptions and presentation requirements must be assessed separately.

64.3 Implementation approach

The organization should:

1. classify the content and relevant Article 50 obligation;
2. identify whether it acts as provider, deployer, publisher, editor, or another relevant actor;
3. implement machine-readable marking where required and technically feasible;
4. provide clear human-facing disclosure where required;
5. ensure disclosures are timely, prominent, accessible, and understandable;
6. document exceptions involving lawful authorization, artistic, satirical, fictional, or editorial contexts where applicable;
7. test persistence across export, compression, reposting, and platform transformations;
8. monitor false positives, false negatives, removal, and circumvention;
9. map code commitments to binding legal duties and document any alternative implementation.

64.4 GlobalWay example

GlobalWay uses generative AI to produce destination imagery and travel-advisory drafts. It requires provider-side marking where applicable, labels externally published synthetic images, retains human editorial responsibility for public-interest travel information, and tests whether labels and metadata survive its content-management and social-media workflows.

64.5 Control activity

The content owner must complete a transparency assessment before public release of applicable AI-generated or manipulated content. Release controls must verify the required technical marking, disclosure wording, accessibility, exception analysis, and evidence retention.

64.6 Evidence

- Article 50 classification;
- actor-role analysis;
- marking and disclosure specifications;
- screenshots and machine-readable test results;
- accessibility testing;
- exception and editorial-responsibility analysis;
- code-to-obligation mapping;
- monitoring and corrective-action records.

64.7 Audit test

Select a sample of AI-generated or manipulated content. Confirm that the applicable provider and deployer duties were distinguished, marking and disclosure were implemented and tested, exceptions were documented, and external claims about code participation do not overstate compliance.

64.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 50 and related transparency provisions.
- Official transparency code of practice and Commission assessment, treated according to their legal status.
- Current consolidated EUR-Lex text controls over older summaries.

65 Chapter 64 — Chatbot and Human-Interaction Disclosure

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 64 draft language.

65.1 Requirement

Providers must ensure that AI systems intended to interact directly with natural persons are designed and developed so that the persons concerned are informed that they are interacting with an AI system, unless that fact is obvious to a reasonably well-informed, observant, and circumspect person in the relevant context. Applicable exceptions must be interpreted narrowly and documented.

65.2 Plain-English explanation

People should not have to guess whether they are dealing with a human or an AI system. The disclosure should appear early enough to influence the interaction and should be understandable, accessible, and proportionate to the context.

65.3 GlobalWay example

GlobalWay's travel-support assistant identifies itself as an AI assistant at the beginning of the conversation and provides a visible route to a human travel consultant for refunds, safety issues, accessibility needs, or low-confidence answers.

65.4 Control activity

The product owner must implement an approved disclosure before production release, test it across supported channels and languages, and reassess it after interface, branding, or use-case changes.

65.5 Evidence

- approved disclosure text;
- screenshots and channel captures;
- accessibility and localization testing;
- release approval;
- exception analysis where relied upon;
- monitoring and complaint records.

65.6 Audit test

Select customer-facing AI systems and verify that the disclosure appears at the correct point, remains understandable in context, is accessible, and is not removed by downstream configuration.

65.7 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 50(1).
- European Commission Article 50 transparency guidelines, identified as non-binding guidance.
- Current consolidated EUR-Lex text controls over older summaries.

66 Chapter 65 — AI-Generated and Manipulated Content Marking

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 65 draft language.

66.1 Requirement

Providers of AI systems, including general-purpose AI systems, that generate synthetic audio, image, video, or text content must ensure that outputs are marked in a machine-readable format and detectable as artificially generated or manipulated, subject to the statutory exceptions and technical-feasibility standard.

66.2 Plain-English explanation

The provider must build provenance or detection-supporting signals into the system output. A visible label can help users, but it does not by itself replace the provider-level machine-readable marking duty where Article 50(2) applies.

66.3 GlobalWay example

GlobalWay uses a generative system to create destination images and itinerary summaries. The provider supplies machine-readable provenance metadata, and GlobalWay verifies that its publishing workflow does not strip the marking.

66.4 Control activity

The provider and downstream publisher must maintain controls for output marking, preservation through export and transformation, effectiveness testing, documented exceptions, and remediation when markings are lost or ineffective.

66.5 Evidence

- technical marking specification;
- detection and robustness test results;
- export and transformation tests;
- provider documentation;

- exception analysis;
- monitoring and corrective-action records.

66.6 Audit test

Generate representative outputs, process them through normal publishing workflows, and verify that the machine-readable marking remains detectable and that any claimed exception is documented and valid.

66.7 Effective-date control

Article 50 generally applies from 2 August 2026. Systems placed on the market before that date receive only the limited transition applicable to Article 50(2), ending 2 December 2026.

66.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 50(2).
- Regulation (EU) 2026/1744 transitional provision for pre-existing systems.
- European Commission Article 50 guidelines and transparency code, identified according to their legal status.

67 Chapter 66 — Deepfake Disclosure

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 66 draft language.

67.1 Requirement

Deployers of AI systems that generate or manipulate image, audio, or video content constituting a deepfake must disclose that the content has been artificially generated or manipulated. The disclosure must be clear, timely, and appropriate to the medium, subject to the statutory accommodations for artistic, creative, satirical, fictional, or analogous works.

67.2 Plain-English explanation

People should be able to recognize when realistic media has been created or altered by AI. Artistic or fictional context can affect how the disclosure is presented, but it does not justify concealing the artificial nature of the content.

67.3 GlobalWay example

GlobalWay publishes an AI-generated promotional video featuring a fictional traveler. The video and accompanying page clearly state that the footage was artificially generated, while preserving the creative presentation.

67.4 Control activity

The content owner must classify deepfake content before publication, apply an approved disclosure, preserve provider-level machine-readable markings, and obtain legal review for any claimed exception or modified presentation.

67.5 Evidence

- content-classification record;
- approved disclosure;
- publication screenshots;
- provenance metadata;
- legal analysis for special presentation;
- monitoring and takedown records.

67.6 Audit test

Review a sample of synthetic or manipulated media and verify that deepfake classification, disclosure placement, accessibility, and provenance preservation are supported by evidence.

67.7 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 50(4).
- European Commission Article 50 transparency guidelines, identified as non-binding guidance.

68 Chapter 67 — AI-Generated Text Disclosures

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 67 draft language.

68.1 Requirement

Deployers that use an AI system to generate or manipulate text published for the purpose of informing the public on matters of public interest must disclose that the text was artificially generated or manipulated, unless the content has undergone human review or editorial control and a person holds editorial responsibility for publication.

68.2 Plain-English explanation

The obligation is aimed at public-interest information, not every internal draft or routine commercial message. The human-review exception requires genuine editorial control and accountable responsibility, not a superficial approval click.

68.3 GlobalWay example

GlobalWay uses AI to draft a public travel-security bulletin. If a qualified editor reviews, verifies, revises, and accepts responsibility for the final publication, the Article 50(4) text-disclosure exception may apply. The editorial record is retained.

68.4 Control activity

The communications function must classify public-interest text, document whether AI materially generated or manipulated it, apply a disclosure unless the editorial-control conditions are met, and retain the review record.

68.5 Evidence

- content-purpose classification;
- AI-generation record;
- disclosure or editorial-control decision;
- named responsible editor;
- fact-check and revision evidence;
- publication capture.

68.6 Audit test

Sample AI-assisted public communications and verify that public-interest classification, disclosure decisions, human review, and editorial responsibility are documented and credible.

68.7 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 50(4).
- European Commission Article 50 transparency guidelines, identified as non-binding guidance.

69 Chapter 68 — Emotion-Recognition and Biometric-Categorisation Disclosure

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 68 draft language.

69.1 Requirement

Deployers of emotion-recognition or biometric-categorisation systems must inform exposed natural persons of the operation of the system and process personal data in accordance with applicable Union data-protection law. This transparency duty does not legalize a use that is prohibited under Article 5 or otherwise unlawful.

69.2 Plain-English explanation

A notice is necessary where Article 50(3) applies, but notice alone is not sufficient. The organization must first determine whether the use is prohibited, high-risk, or restricted by data-protection, employment, equality, consumer, or sector law.

69.3 GlobalWay example

GlobalWay considers using an emotion-recognition tool during employee training. The proposal is screened first against the workplace prohibition. Because the intended use does not fit a documented medical or safety exception, it is rejected rather than treated as permissible merely because a notice could be displayed.

69.4 Control activity

The deployer must complete prohibited-practice screening, legal-basis analysis, data-protection review, and transparency design before deployment. Notices must explain the system's operation in clear and accessible terms and be provided before exposure where practicable.

69.5 Evidence

- prohibited-practice assessment;
- purpose and legal-basis analysis;
- DPIA or privacy assessment;
- approved notice;
- accessibility and localization tests;
- deployment and monitoring records.

69.6 Audit test

Sample emotion-recognition and biometric-categorisation uses and verify that legality was established before disclosure design, notices were timely and understandable, and personal-data controls were implemented.

69.7 Primary legal references

- Regulation (EU) 2024/1689, as amended: Articles 5 and 50(3).
- GDPR and other applicable Union or Member-State law.
- European Commission Article 50 transparency guidelines, identified as non-binding guidance.

70 Chapter 69 — Accessibility and Understandable Notices

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 69 draft language.

70.1 Requirement

Transparency notices required by the AI Act must be provided in a clear and distinguishable manner and, where applicable, no later than the first interaction or exposure. Organizations must also comply with applicable accessibility, consumer-protection, equality, and language requirements.

70.2 Plain-English explanation

A technically present notice can still fail if it is hidden, unreadable, poorly timed, inaccessible, or written in language the intended audience cannot understand.

70.3 GlobalWay example

GlobalWay tests AI disclosures for screen-reader compatibility, keyboard navigation, contrast, mobile presentation, plain language, and supported traveler languages. Critical notices are not buried solely in terms and conditions.

70.4 Control activity

The notice owner must apply a documented accessibility and comprehension standard, test notices with representative channels and users, and remediate failures before release.

70.5 Evidence

- approved notice standard;
- accessibility test results;
- readability and comprehension review;
- localization records;
- screenshots and interaction recordings;
- defect and remediation history.

70.6 Audit test

Inspect representative notices across channels and verify timing, prominence, accessibility, language quality, and consistency with the actual AI function.

70.7 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 50(5) and applicable Article 50 duties.
- Applicable Union accessibility, equality, and consumer-protection law.
- European Commission Article 50 transparency guidelines, identified as non-binding guidance.

71 Chapter 70 — Testing and Monitoring Transparency Disclosures

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 70 draft language.

71.1 Requirement

Organizations must test and monitor required transparency measures throughout the lifecycle to confirm that disclosures, labels, and machine-readable markings remain accurate, timely, accessible, and effective after changes to the system, interface, content workflow, language, channel, or provider dependency.

71.2 Plain-English explanation

A disclosure can degrade after launch. Interface redesigns can hide notices, export tools can strip provenance metadata, translations can change meaning, and downstream integrations can bypass required labels.

71.3 GlobalWay example

GlobalWay runs release tests and quarterly monitoring across its chatbot, itinerary generator, marketing-content workflow, and public travel bulletins. Failures create tracked defects and can block publication or trigger rollback.

71.4 Control activity

The control owner must define test cases, sampling, success criteria, escalation thresholds, and retest triggers for each Article 50 obligation. Material failures must lead to containment, correction, evidence preservation, and regulatory assessment where appropriate.

71.5 Evidence

- disclosure and marking test plan;
- automated and manual test results;
- channel and language coverage;
- provenance-preservation tests;

- monitoring metrics and complaints;
- defects, remediation, and retest evidence;
- change-management linkage.

71.6 Audit test

Select representative transparency controls and verify that testing covers the actual production workflow, failures are detected and remediated, and changes trigger reassessment and regression testing.

71.7 Effective-date control

Article 50 applies from 2 August 2026, subject to the limited transition ending 2 December 2026 for qualifying pre-existing systems under Article 50(2).

71.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 50.
- Regulation (EU) 2026/1744 transitional provisions.
- European Commission Article 50 transparency guidelines and transparency code, identified according to their legal status.

72 Chapter 71 — AI Vendor Due Diligence

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 71 draft language.

72.1 Requirement

Organizations must perform proportionate due diligence before procuring, integrating, or materially expanding a third-party AI system or general-purpose AI model. The review must determine the supplier's legal role, the customer's role, applicable AI Act obligations, evidence availability, operational limitations, and the supplier's ability to support compliance throughout the lifecycle.

72.2 Plain-English explanation

Buying AI does not transfer accountability away from the customer. A deployer still needs enough information to use the system lawfully and safely, while a provider, importer, distributor, or product manufacturer may have additional duties. Due diligence must test claims rather than rely on marketing material.

72.3 Due-diligence areas

Assess at minimum:

1. legal entity, ownership, jurisdictions, and AI Act role;

2. intended purpose, prohibited-use restrictions, and supported use cases;
3. high-risk, transparency, and GPAI classification;
4. technical documentation, instructions, model or system cards, and conformity evidence;
5. data provenance, governance, quality, privacy, and intellectual-property controls;
6. accuracy, robustness, cybersecurity, bias, accessibility, and human-oversight capabilities;
7. logging, monitoring, incident reporting, vulnerability handling, and corrective action;
8. subcontractors, cloud services, open-source components, and concentration dependencies;
9. change-notification, audit, assurance, data-access, retention, and exit rights;
10. financial, operational, and regulatory capacity to support the product.

72.4 GlobalWay example

Before purchasing an AI recruitment platform, GlobalWay verifies the vendor's intended-purpose statement, Annex III classification analysis, instructions for use, subgroup testing, human-review controls, incident process, data sources, subcontractors, and contractual change-notification obligations.

72.5 Control activity

Procurement may not approve a material AI supplier until Legal, Compliance, Security, Privacy, and the business owner complete a documented risk-tiered review and resolve or formally accept identified gaps. Due diligence must be refreshed after material change, incident, adverse assurance result, regulatory action, or contract renewal.

72.6 Evidence

- completed vendor questionnaire;
- role and classification analysis;
- supplier documentation and attestations;
- test and assurance reports;
- security and privacy review;

- legal and compliance analysis;
- gap-remediation or risk-acceptance record;
- approval and reassessment history.

72.7 Audit test

Select a sample of AI suppliers. Confirm that due diligence preceded use, addressed the supplier's actual role and system classification, tested key claims with evidence, documented unresolved gaps, and was refreshed after relevant triggers.

72.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable provider, deployer, importer, distributor, product-manufacturer, high-risk, GPAI, transparency, and supply-chain provisions.
- Current consolidated EUR-Lex text controls over older summaries.

73 Chapter 72 — Contract Clauses

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 72 draft language.

73.1 Requirement

Contracts for material AI systems, models, data, and services must allocate responsibilities clearly enough to support compliance, evidence access, operational control, incident response, change management, and exit. Contract language cannot override statutory actor roles or eliminate obligations imposed by law.

73.2 Plain-English explanation

A contract should make the operating model enforceable. It should define what the supplier will provide, what the customer must do, which evidence is available, how changes and incidents are handled, and what happens when the system becomes noncompliant or no longer supportable.

73.3 Minimum clause areas

Address as applicable:

1. system or model description, intended purpose, permitted uses, and prohibited uses;
2. party roles and acknowledgement that legal classification depends on actual conduct;
3. compliance with applicable AI, privacy, cybersecurity, product, employment, and consumer law;

4. technical documentation, instructions, conformity records, transparency information, and audit evidence;
5. data provenance, permitted processing, retention, deletion, confidentiality, and intellectual property;
6. accuracy, service levels, robustness, security, accessibility, and human-oversight requirements;
7. logging, monitoring, complaint, vulnerability, serious-incident, and corrective-action cooperation;
8. advance notice and approval rights for model, data, feature, subcontractor, location, and terms changes;
9. audit, testing, regulator-access, record-preservation, and remediation rights;
10. suspension, disablement, withdrawal, transition assistance, portability, and secure exit.

73.4 GlobalWay example

GlobalWay's contract for a recruitment-screening system requires the vendor to provide current instructions and conformity evidence, notify GlobalWay before material model or data changes, preserve relevant logs, support incident investigation, restrict prohibited uses, and provide export and transition support if the service is suspended.

73.5 Control activity

Legal and Procurement must use approved AI clauses based on risk tier and role. Deviations affecting evidence, audit, incident, change, data, or exit rights require documented Legal, Compliance, Security, Privacy, and business approval.

73.6 Evidence

- executed agreement and schedules;
- clause checklist;
- role and responsibility matrix;
- approved deviations;
- data-processing and security terms;
- change and incident notices;
- audit and remediation records;
- exit and transition plan.

73.7 Audit test

Select material AI contracts and verify that clauses match the actual service, actor roles, risk classification, and operational dependencies; confirm that required notices, evidence deliveries, audits, and remediation rights are exercised in practice.

73.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable value-chain cooperation, documentation, information, monitoring, incident, corrective-action, and record-access provisions.
- Contract terms do not displace statutory obligations.

74 Chapter 73 — Provider Documentation Review

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 73 draft language.

74.1 Requirement

Organizations must review provider-supplied documentation before deployment and after material change to determine whether it is complete, current, internally consistent, applicable to the intended use, and sufficient to support the organization's legal and operational obligations.

74.2 Plain-English explanation

Receiving documents is not the same as reviewing them. Instructions for use, technical summaries, conformity records, model cards, test reports, and security materials must be checked against the deployed version, actual configuration, and use case.

74.3 Review criteria

Confirm as applicable:

1. provider identity, role, system or model version, and intended purpose;
2. applicability of the documents to the exact product and release;
3. high-risk, transparency, GPAI, and systemic-risk classification statements;
4. instructions, limitations, performance metrics, thresholds, and foreseeable misuse;
5. human-oversight, logging, monitoring, and incident procedures;
6. data, privacy, security, robustness, bias, and accessibility evidence;

7. conformity assessment, declaration, registration, and marking evidence where required;
8. material assumptions, exclusions, unresolved limitations, and customer responsibilities;
9. document-control, approval, language, accessibility, and update status;
10. contradictions between contractual, technical, assurance, and marketing claims.

74.4 GlobalWay example

GlobalWay receives a vendor's model card and conformity package for a recruitment system. The review identifies that the model card covers an earlier version and omits the threshold configuration used by GlobalWay. Deployment remains blocked until corrected, version-specific documentation is supplied.

74.5 Control activity

The system owner must maintain a provider-documentation index and obtain approval from Legal, Compliance, Security, Privacy, and relevant technical reviewers before production use. Missing, stale, or contradictory documentation must result in remediation, restricted use, compensating controls, or rejection.

74.6 Evidence

- provider-documentation index;
- version and configuration mapping;
- completed review checklist;
- identified gaps and contradictions;
- supplier clarifications and replacements;
- risk decisions and approvals;
- update and reassessment history.

74.7 Audit test

Select a sample of third-party AI systems and confirm that provider documents match the deployed release and intended use, that gaps were resolved before approval, and that material changes triggered renewed review.

74.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable provider information, instructions, technical documentation, conformity, transparency, GPAI, and value-chain provisions.
- Current consolidated EUR-Lex text controls over older summaries.

75 Chapter 74 — Model Cards, System Cards, and Limitations

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 74 draft language.

75.1 Requirement

Organizations should use model cards, system cards, and equivalent documentation as structured evidence about intended purpose, capabilities, limitations, evaluation, risks, and responsible use. These artifacts must not be treated as substitutes for statutory technical documentation, instructions for use, conformity records, or risk-management evidence where those are required.

75.2 Plain-English explanation

A model card describes the model. A system card describes the wider deployed system, including integrations, prompts, data flows, safeguards, and human processes. Both are useful only when they are accurate, version-specific, and explicit about limitations.

75.3 Required content

Document as applicable:

1. model and system identity, owner, provider, version, and release date;
2. intended and excluded uses;
3. training, tuning, evaluation, and relevant data information;
4. supported languages, populations, environments, and jurisdictions;
5. performance metrics, thresholds, uncertainty, and known failure modes;
6. bias, safety, privacy, security, robustness, and misuse risks;
7. human-oversight, fallback, escalation, and monitoring requirements;
8. dependencies, integrations, and downstream assumptions;

9. legal classification and applicable transparency or high-risk obligations;
10. change history and unresolved limitations.

75.4 GlobalWay example

GlobalWay's travel-assistant system card documents the third-party GPAI model, retrieval sources, languages, booking integrations, prohibited autonomous actions, human escalation rules, hallucination risks, monitoring metrics, and the exact production configuration.

75.5 Control activity

Product and Model Risk owners must approve version-controlled model and system cards before release and update them after material changes, significant incidents, new evaluation findings, or changed intended use. Limitations must be reflected in instructions, training, user interfaces, and monitoring.

75.6 Evidence

- approved model and system cards;
- version mapping;
- evaluation reports;
- limitation and risk register;
- user instructions and training;
- change history;
- monitoring and incident records.

75.7 Audit test

Select a deployed AI system and verify that its cards match the actual version and architecture, describe material limitations and dependencies, and are consistent with technical documentation, instructions, controls, and observed production performance.

75.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable technical-documentation, transparency, instructions, GPAI-information, risk-management, and post-market provisions.
- Model and system cards are supporting artifacts unless binding law or contract gives them a specific legal function.

76 Chapter 75 — Audit Rights and Incident Notification

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 75 draft language.

76.1 Requirement

Material AI supplier arrangements must provide sufficient audit, assurance, information-access, incident-notification, investigation-support, and remediation rights to enable each party to meet its legal and operational responsibilities. Rights must be proportionate to risk and workable in practice.

76.2 Plain-English explanation

An audit clause that cannot produce evidence is not an effective control. The customer needs timely access to relevant records and cooperation when a significant event occurs, while protecting legitimate confidentiality, security, and intellectual-property interests.

76.3 Control requirements

Contracts and procedures should define:

1. audit scope, frequency, notice, triggering events, and qualified reviewers;
2. access to policies, technical evidence, test results, logs, certifications, and remediation records;
3. reliance conditions for independent assurance reports;
4. rapid notice of serious incidents, security events, regulatory investigations, material nonconformity, and significant service degradation;
5. required content, timestamps, updates, root-cause analysis, and corrective-action reporting;
6. evidence preservation and cooperation with authorities, affected persons, and other value-chain actors;
7. emergency rights to restrict, suspend, disable, or isolate the service;
8. remediation deadlines, validation, escalation, and termination rights;
9. confidentiality, privilege, secure review, and data-minimisation safeguards;
10. subcontractor flow-down and accountability.

76.4 GlobalWay example

After a vendor reports anomalous recruitment outcomes, GlobalWay invokes its incident-information rights, obtains version and configuration records, preserves relevant logs, validates the affected population, confirms whether regulatory reporting is required, and tracks corrective action before service restoration.

76.5 Control activity

Vendor Management must maintain a risk-based audit and incident-notification schedule. High-risk suppliers require tested notification routes, current contacts, evidence-access procedures, and escalation authority. Contractual rights must be exercised periodically rather than left untested.

76.6 Evidence

- executed audit and notification clauses;
- supplier assurance reports;
- audit plans and reports;
- incident notices and timestamps;
- preserved evidence and investigation records;
- remediation plans and validation;
- escalation, suspension, and closure decisions;
- subcontractor assurance evidence.

76.7 Audit test

Select material suppliers and incidents. Confirm that contractual rights cover the relevant evidence and events, notification deadlines were met, investigations received adequate cooperation, remediation was validated, and unresolved access limitations were escalated.

76.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable documentation, recordkeeping, monitoring, serious-incident, corrective-action, authority-access, and value-chain cooperation provisions.
- Applicable privacy, cybersecurity, product-safety, and sector-notification law.

77 Chapter 76 — Cloud, API, and Model Dependency Risk

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 76 draft language.

77.1 Requirement

Organizations must identify and manage material cloud, API, model, data, software-component, and subprocessor dependencies that affect their AI systems. The EU AI Act does not create a standalone dependency-risk programme for every operator, but applicable provider, deployer, importer, distributor, product-manufacturer, quality-management, risk-management, cybersecurity, monitoring, incident, documentation, and cooperation duties require sufficient visibility and control over relevant dependencies.

77.2 Plain-English explanation

An AI service may depend on several external components even when it appears to users as a single system. A provider change, outage, model substitution, API deprecation, regional routing change, undocumented subprocessor, or loss of logs can alter legal classification, safety, accuracy, accessibility, privacy, security, human oversight, or continuity. Contracting out a component does not remove the organization's own legal duties.

77.3 Dependency-governance requirements

For each material dependency, document and assess:

1. component, provider, subprocessor, purpose, owner, and criticality;
2. model, API, software, data, and configuration versions;
3. processing and support locations, data flows, retention, and transfer arrangements;
4. availability, service levels, recovery capability, quotas, and rate limits;
5. change-notification, release, deprecation, and emergency-change processes;
6. security, privileged access, secrets, tenant separation, and vulnerability management;
7. logging, monitoring, evidence access, and incident-notification capability;
8. concentration, lock-in, substitution, and single-point-of-failure risk;
9. tested fallback, safe-mode, human-only, or controlled-suspension arrangements;

10. triggers for reassessment, revalidation, transparency review, or substantial-modification analysis.

77.4 GlobalWay example

GlobalWay's traveler-assistance service relies on a hosted model, cloud platform, translation API, identity provider, retrieval database, and monitoring service. After an unannounced model update reduces multilingual accuracy and omits accessibility constraints, GlobalWay restricts affected functions, routes cases to trained consultants, preserves version and output evidence, requires provider investigation, and revalidates the service before restoration.

77.5 Control activity

Material dependencies must be recorded in the AI inventory and architecture documentation. High or critical dependencies must be monitored for change and outage, tested before material production changes, and supported by approved continuity and escalation arrangements. Unknown critical dependencies or unavailable mandatory evidence are release or continued-operation blockers.

77.6 Evidence

- dependency and architecture inventory;
- provider and subprocessor records;
- version and configuration history;
- contracts, service levels, and change notices;
- data-location and transfer assessments;
- security and access reviews;
- test, regression, and revalidation results;
- monitoring, outage, and incident records;
- fallback and continuity exercises;
- risk acceptance and accountable-owner decisions.

77.7 Audit test

Select high and critical AI systems. Confirm that material dependencies are complete and current; versions, regions, subprocessors, and owners are known; material changes triggered appropriate review and testing; continuity arrangements were exercised; evidence remained accessible; and unresolved dependency risks were escalated to authorized decision-makers.

77.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable Articles 9–17, 20–26, 72–74, 78–82, and related annexes, depending on role and system classification.
- Regulation (EU) 2016/679 and other applicable privacy, cybersecurity, product-safety, consumer-protection, and sector requirements.
- Dependency-management practices in this chapter are governance and assurance methods used to support applicable legal duties; they are not a standalone statutory control catalogue.
- Current consolidated official texts control over older summaries.

78 Chapter 77 — Open-Source and Component Governance

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 77 draft language.

78.1 Requirement

Organizations must assess open-source AI models, systems, software, datasets, and components against the specific conditions of Regulation (EU) 2024/1689, as amended, rather than treating open-source status as a blanket exclusion. The assessment must consider actor role, commercialisation, downstream integration, high-risk use, GPAI treatment, cybersecurity, substantial modification, licensing, provenance, and supportability.

78.2 Plain-English explanation

Open-source distribution can affect which obligations apply, but it does not automatically remove legal responsibility. Once an open component is integrated into a product, modified, placed on the market, used under an organisation's name, or deployed in a regulated context, different duties may arise.

78.3 Governance requirements

Maintain controls for:

1. component and model provenance;
2. licence terms, restrictions, attribution, and compatibility;
3. maintainer identity, release history, and support status;
4. known vulnerabilities, incidents, and security advisories;
5. training-data, dataset, and documentation availability;

6. intended purpose, limitations, and prohibited or unsupported uses;
7. downstream modification and integration consequences;
8. provider-role and substantial-modification assessment;
9. high-risk, transparency, and GPAI classification;
10. version pinning, testing, monitoring, replacement, and exit.

78.4 GlobalWay example

GlobalWay integrates an open-source language model into an internal travel-support workflow. Before production use, it records the model version and licence, reviews provenance and limitations, tests security and performance, assesses whether fine-tuning or own-brand deployment changes its legal role, and documents an exit path if the project becomes unsupported.

78.5 Control activity

No open-source AI component may enter production without inventory registration, legal and security review, licence approval, version-specific testing, role and classification analysis, and an accountable maintenance owner. Material forks, fine-tuning, retraining, or repurposing must trigger reassessment.

78.6 Evidence

- software and model bill of materials;
- licence and attribution record;
- provenance and maintainer review;
- vulnerability and security assessment;
- intended-purpose and limitation record;
- role and classification assessment;
- testing and approval evidence;
- monitoring and replacement plan.

78.7 Audit test

Select open-source AI components in production. Confirm that the exact versions are inventoried, licence and provenance were reviewed, legal role and classification were assessed, vulnerabilities and limitations are monitored, and material modifications triggered reassessment.

78.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable scope, open-source, GPAI, provider-role, substantial-modification, cybersecurity, and high-risk provisions.
- Current consolidated EUR-Lex text controls over older summaries.

79 Chapter 78 — Ongoing Vendor Monitoring

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 78 draft language.

79.1 Requirement

Organizations must monitor material AI suppliers throughout the relationship to confirm that legal role, system or model classification, documentation, conformity status, performance, security, incidents, changes, and service capability remain acceptable. Monitoring must be proportionate to risk and linked to reassessment, corrective action, suspension, and exit.

79.2 Plain-English explanation

A vendor that passed due diligence last year may no longer present the same risk. Models change, providers reorganize, subprocessors are added, guidance evolves, incidents occur, and support quality can decline. Ongoing monitoring is therefore a lifecycle control rather than a one-time procurement task.

79.3 Monitoring areas

Monitor at minimum:

1. legal entity, ownership, jurisdiction, and AI Act role changes;
2. high-risk, transparency, GPAI, and systemic-risk classification changes;
3. model, system, data, intended-purpose, and service changes;
4. conformity, registration, certification, and assurance status;
5. technical documentation, instructions, limitations, and release notes;
6. performance, bias, robustness, cybersecurity, availability, and support indicators;
7. incidents, complaints, vulnerabilities, regulatory actions, and corrective measures;
8. subcontractor, hosting, region, concentration, and continuity changes;

9. contract compliance, audit findings, remediation, and unresolved exceptions;
10. end-of-support, financial deterioration, acquisition, or service discontinuation risk.

79.4 GlobalWay example

GlobalWay reviews its recruitment-platform vendor quarterly and after any material event. The review includes model-release notices, subgroup performance, incidents, security advisories, documentation changes, subcontractors, service levels, and regulatory developments. Threshold breaches trigger enhanced review or suspension.

79.5 Control activity

Vendor Management must assign a monitoring tier and review cadence to each material AI supplier. Monitoring results must be documented, risk-rated, approved, and linked to issue management. Critical changes or events must trigger immediate reassessment without waiting for the next scheduled review.

79.6 Evidence

- supplier monitoring plan and tier;
- periodic review records;
- change and incident notices;
- service, performance, and security metrics;
- assurance and regulatory updates;
- risk reassessments and issue records;
- remediation, suspension, or exit decisions;
- management review and approval.

79.7 Audit test

Select material AI suppliers and confirm that monitoring occurred at the defined cadence, covered legal and operational changes, identified threshold breaches, triggered timely reassessment, and produced documented action through closure.

79.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable provider, deployer, value-chain, monitoring, incident, corrective-action, documentation, and change provisions.
- Current consolidated EUR-Lex text controls over older summaries.

80 Chapter 79 — Exit, Portability, and Continuity Planning

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 79 draft language.

80.1 Requirement

Organizations must plan for the safe suspension, replacement, migration, or termination of material AI services without losing required evidence, disrupting regulated processes, exposing affected persons to unmanaged risk, or preventing continued compliance. Exit planning must address portability, continuity, retention, deletion, validation, and accountability.

80.2 Plain-English explanation

A supplier relationship can end because of performance failure, regulatory action, security events, commercial disputes, acquisition, insolvency, or strategic change. The organization must be able to stop or replace the service in a controlled manner rather than becoming dependent on an unsafe or unsupported system.

80.3 Exit requirements

The exit plan should address:

1. suspension and emergency shutdown authority;
2. service, model, configuration, data, prompt, and workflow inventory;
3. export of required logs, decisions, documentation, and audit evidence;
4. retention required for conformity, incidents, complaints, investigations, and legal obligations;
5. return, transfer, and verified deletion of data;
6. migration mapping, testing, validation, and rollback;
7. continuity of human oversight and affected-person safeguards;
8. reassessment of the replacement provider, role, classification, and intended purpose;
9. user, authority, customer, and affected-person communications where required;
10. residual dependency, licence, intellectual-property, and subcontractor issues;
11. final access revocation and security closure;
12. post-exit monitoring and lessons learned.

80.4 GlobalWay example

GlobalWay decides to replace a recruitment-screening vendor after unresolved performance disparities. It suspends automated ranking, routes decisions to trained human reviewers, exports required logs and documentation, validates the replacement system against approved criteria, preserves investigation evidence, and verifies deletion of data no longer required.

80.5 Control activity

Every material AI supplier must have a documented and periodically tested exit plan before production approval. High-risk services require defined emergency workarounds, evidence-export testing, replacement validation criteria, and executive authority to suspend or terminate use.

80.6 Evidence

- approved exit and continuity plan;
- inventory and dependency map;
- evidence-export and retention record;
- data return and deletion certification;
- migration and validation results;
- communications and approvals;
- access-revocation evidence;
- post-exit review and residual-risk decision.

80.7 Audit test

Select exited suppliers and continuity exercises. Confirm that required records were preserved, data handling was verified, replacement controls were validated before production use, affected processes remained protected, and access and dependencies were closed appropriately.

80.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable documentation, recordkeeping, monitoring, incident, corrective-action, deployer, provider, value-chain, and authority-access provisions.
- Applicable privacy, cybersecurity, product-safety, employment, consumer-protection, and sector-retention requirements.

81 Chapter 80 — GDPR Integration

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 80 draft language.

81.1 Requirement

Organizations processing personal data through AI systems must comply with the EU AI Act and applicable data-protection law in parallel. Compliance with one regime does not establish compliance with the other. The organization must identify the relevant controller, processor, joint-controller, provider, deployer, importer, distributor, or other role and map each obligation to the same system, model, processing purpose, data flow, and production version.

81.2 Plain-English explanation

The EU AI Act governs AI-system and model risks, roles, market access, prohibited practices, high-risk requirements, transparency, and oversight. The GDPR governs lawful processing of personal data, data-subject rights, accountability, security, international transfers, and automated decision-making. A single AI deployment can trigger both regimes and additional national or sector law.

81.3 Integrated assessment

Document at minimum:

1. the AI Act role and GDPR role of each legal entity;
2. the intended purpose and each personal-data processing purpose;
3. lawful basis and, where applicable, Article 9 or Article 10 conditions;
4. data sources, categories, recipients, locations, retention, and transfers;
5. transparency duties under both regimes;
6. data-subject rights and affected-person complaint or explanation routes;
7. DPIA, fundamental-rights impact assessment, conformity, and risk-management dependencies;
8. automated-decision-making analysis under GDPR Article 22;
9. security, logging, monitoring, breach, and serious-incident coordination;
10. change triggers requiring reassessment.

81.4 GlobalWay example

GlobalWay deploys an AI recruitment system in several EU Member States. It separately documents its deployer obligations under the AI Act, its controller responsibilities under the GDPR, the vendor's provider and processor roles, the lawful basis for applicant-data processing, Article 22 safeguards, retention limits, human review, and the relationship between the DPIA and the AI Act fundamental-rights impact assessment.

81.5 Control activity

Legal, Privacy, and AI Governance must jointly approve an integrated regulatory map before production use. The map must link each requirement to an accountable owner, control, evidence source, and review trigger. Conflicts or uncertainty must be escalated to qualified counsel rather than resolved by assuming one law overrides the other.

81.6 Evidence

- integrated role and obligation map;
- records of processing activities;
- lawful-basis and special-category analysis;
- DPIA and fundamental-rights impact assessment;
- privacy notices and AI transparency notices;
- data-subject rights procedure;
- contracts and data-processing terms;
- security, incident, and breach procedures;
- review and change history.

81.7 Audit test

Select a sample of AI systems processing personal data. Verify that AI Act and GDPR roles were separately identified, legal bases and Article 22 treatment were documented, notices and rights processes are consistent, and changes in purpose, data, model, vendor, or jurisdiction triggered reassessment.

81.8 Primary legal references

- Regulation (EU) 2024/1689, as amended, including Articles 2, 10, 13, 26, 27, and 50 as applicable.
- Regulation (EU) 2016/679, including Articles 5, 6, 9, 12–22, 25, 30, 32–36, and 44–49 as applicable.

- Current consolidated EUR-Lex texts control over summaries and earlier drafts.

82 Chapter 81 — Privacy by Design and Data Minimisation

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 81 draft language.

82.1 Requirement

AI systems that process personal data must embed privacy and data-protection principles into design, development, configuration, deployment, monitoring, and retirement. Personal data must be adequate, relevant, and limited to what is necessary for the documented purpose, while AI Act data-governance, accuracy, risk-management, and evidence requirements are met.

82.2 Plain-English explanation

More data is not automatically better or lawful. Teams must justify why each data element, feature, prompt field, log, annotation, and retention period is needed. Privacy-enhancing design must be considered before collection and before model or workflow changes, not added only after deployment.

82.3 Design controls

The organization should implement:

1. documented purpose and necessity tests for each personal-data element;
2. feature and proxy-variable review;
3. collection and retention limits;
4. role-based access and least privilege;
5. pseudonymisation, aggregation, masking, or synthetic data where appropriate;
6. separation of training, validation, testing, and production data;
7. privacy-preserving logging and monitoring;
8. controls against unintended memorisation, disclosure, or re-identification;
9. deletion, correction, restriction, and portability workflows where applicable;

10. reassessment after new data sources, features, model updates, integrations, or purposes.

82.4 GlobalWay example

GlobalWay's travel-assistance system does not retain passport numbers, payment-card data, or health information in prompts merely because those fields exist in upstream systems. The design review confirms which attributes are necessary, masks sensitive values, limits log content, and sets retention periods aligned with legal and operational needs.

82.5 Control activity

Privacy Engineering and AI Governance must approve a privacy-by-design review before production release and after material changes. The review must document necessity, proportionality, minimisation decisions, technical safeguards, residual risks, and unresolved trade-offs.

82.6 Evidence

- data inventory and flow map;
- purpose and necessity assessment;
- feature-selection rationale;
- retention schedule;
- access-control design;
- pseudonymisation or masking evidence;
- privacy test results;
- deletion and rights-handling procedures;
- design-review approvals and change history.

82.7 Audit test

Select a sample of AI data elements, features, prompts, and logs. Confirm that necessity was documented, excessive or stale data was removed, safeguards operate as designed, and material changes triggered renewed review.

82.8 Primary legal references

- Regulation (EU) 2016/679: Articles 5(1)(c), 25, and 32, with other provisions as applicable.
- Regulation (EU) 2024/1689, as amended: Articles 9, 10, 12, 15, 26, and Annex IV as applicable.

- Current consolidated EUR-Lex texts control over summaries and earlier drafts.

83 Chapter 82 — Special-Category and Sensitive Personal Data

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 82 draft language.

83.1 Requirement

Organizations must identify and control processing of special categories of personal data, biometric data, criminal-offence data, and other sensitive information used by or exposed to AI systems. Processing requires a valid legal basis under the GDPR, an applicable Article 9 or Article 10 condition where relevant, appropriate safeguards, and compliance with AI Act restrictions and conditions.

83.2 Plain-English explanation

Sensitive data may create heightened discrimination, privacy, security, and fundamental-rights risks. The EU AI Act does not create a general permission to use such data. Its limited provisions for bias detection and correction in high-risk AI systems must be interpreted narrowly and operated with the safeguards required by both the AI Act and data-protection law.

83.3 Control requirements

The assessment must address:

1. exact data categories and whether inferred attributes are involved;
2. lawful basis and Article 9 or Article 10 condition;
3. necessity and proportionality;
4. whether the AI Act permits, restricts, or prohibits the relevant practice;
5. access limitation, segregation, encryption, pseudonymisation, and deletion;
6. bias-detection purpose, scope, duration, and safeguards where Article 10(5) of the AI Act is relied upon;
7. biometric categorisation, emotion recognition, remote biometric identification, or other prohibited/high-risk triggers;
8. transparency and affected-person rights;

9. cross-border transfers and vendor access;
10. auditability and reassessment after change.

83.4 GlobalWay example

GlobalWay evaluates whether health-related travel-assistance data and inferred disability information are necessary for a proposed service. It prevents use for employee ranking, restricts access, documents the GDPR condition, separates operational assistance from analytics, and rejects any attempt to reuse the data for an incompatible purpose.

83.5 Control activity

No AI use involving special-category, biometric, or criminal-offence data may proceed without written Legal and Privacy approval. The decision must identify the exact statutory condition, safeguards, retention period, access model, prohibited secondary uses, and review triggers.

83.6 Evidence

- sensitive-data inventory;
- lawful-basis and Article 9/10 analysis;
- necessity and proportionality assessment;
- AI Act classification and prohibited-practice review;
- access, encryption, and segregation evidence;
- retention and deletion records;
- notices and rights procedures;
- vendor and transfer assessments;
- approvals and reassessment history.

83.7 Audit test

Select AI systems using or inferring sensitive data. Confirm that the data category, legal condition, AI Act treatment, safeguards, access, retention, and secondary-use restrictions are documented and operating effectively.

83.8 Primary legal references

- Regulation (EU) 2016/679: Articles 5, 6, 9, 10, 25, 32, and 35.
- Regulation (EU) 2024/1689, as amended: Articles 5, 9, 10, 26, and relevant biometric and transparency provisions.
- Current consolidated EUR-Lex texts control over summaries and earlier drafts.

84 Chapter 83 — Automated Decision-Making

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 83 draft language.

84.1 Requirement

Organizations must assess whether an AI-supported or AI-generated decision is based solely on automated processing and produces legal effects or similarly significant effects on a natural person. Where GDPR Article 22 applies, the organization must identify a valid exception, implement suitable safeguards, and ensure that the actual decision process matches the documented human-review model.

84.2 Plain-English explanation

Calling a process “human-in-the-loop” does not remove it from Article 22 if the human reviewer routinely accepts the system output without meaningful authority, information, time, or competence to change the result. The assessment must examine operational reality, not labels.

84.3 Assessment criteria

Document at minimum:

1. the decision, affected persons, and consequences;
2. whether processing is solely automated in practice;
3. the role and substance of any human intervention;
4. whether the effect is legal or similarly significant;
5. the Article 22(2) exception relied upon, where applicable;
6. restrictions involving special-category data;
7. information provided about the logic, significance, and envisaged consequences;
8. rights to human intervention, express a view, and contest the decision;
9. testing for accuracy, discrimination, consistency, and override effectiveness;
10. interaction with AI Act high-risk, transparency, human-oversight, and fundamental-rights obligations.

84.4 GlobalWay example

GlobalWay uses an AI system to rank job applicants. Recruiters must review relevant application evidence, understand system limitations, record reasons for decisions, and have authority to depart from the ranking.

GlobalWay tests whether reviewers exercise genuine judgment rather than rubber-stamping recommendations.

84.5 Control activity

Legal, Privacy, and the business owner must approve an automated-decision assessment before deployment. Where Article 22 applies, the release must be blocked unless the legal exception and safeguards are documented, notices are complete, contest and human-review channels are operational, and monitoring demonstrates meaningful human involvement where claimed.

84.6 Evidence

- automated-decision assessment;
- Article 22 legal analysis;
- workflow and decision-rights map;
- reviewer instructions and competence evidence;
- notices and explanation materials;
- contest, appeal, and human-intervention records;
- override and outcome monitoring;
- bias, accuracy, and consistency testing;
- approvals and reassessment history.

84.7 Audit test

Observe a sample of decisions and interview reviewers. Confirm that the documented process matches actual practice, human intervention is meaningful where relied upon, affected-person rights are operational, and high-risk or significant decisions receive appropriate oversight and testing.

84.8 Primary legal references

- Regulation (EU) 2016/679: Articles 13–15 and 22, with Recital 71 and applicable case law.
- Regulation (EU) 2024/1689, as amended: Articles 13, 14, 26, 27, and relevant Annex III provisions.
- Current consolidated EUR-Lex texts and authoritative Court of Justice interpretations control over summaries.

85 Chapter 84 — Secure AI Development Lifecycle

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 84 draft language.

85.1 Requirement

Providers and organizations developing, integrating, configuring, or materially modifying AI systems must embed security, safety, privacy, robustness, data governance, human oversight, documentation, and change control throughout the lifecycle. Controls must be proportionate to the system's intended purpose, risk classification, foreseeable misuse, value-chain dependencies, and production environment.

85.2 Plain-English explanation

Security review cannot be postponed until the end of development. AI-specific threats can enter through data, models, prompts, tools, APIs, integrations, logs, deployment pipelines, and downstream use. The lifecycle must produce evidence that controls were designed, tested, approved, monitored, and updated for the actual production version.

85.3 Lifecycle controls

The secure lifecycle should include:

1. intake, intended-purpose, role, and risk classification;
2. security and abuse-case requirements;
3. architecture, data-flow, and trust-boundary review;
4. data provenance, integrity, quality, and access controls;
5. secure coding, dependency, model, and infrastructure controls;
6. prompt, retrieval, agent, tool, and API safeguards;
7. privacy, bias, safety, robustness, and human-oversight testing;
8. adversarial testing and vulnerability management;
9. release criteria, segregation of duties, approvals, and rollback;
10. logging, monitoring, incident response, and post-market feedback;
11. version-linked documentation and evidence retention;
12. retirement, data deletion, model disposal, and continuity planning.

85.4 GlobalWay example

GlobalWay develops an AI travel-policy assistant that can query booking systems and draft traveler recommendations. The secure lifecycle limits tool

permissions, validates retrieval sources, tests prompt injection and data leakage, requires human approval for consequential actions, records production versions, and blocks release until security and compliance gates are complete.

85.5 Control activity

Engineering must operate a documented secure-AI lifecycle with mandatory gates appropriate to risk. High-risk or material systems require independent security, privacy, legal, and AI-governance approval. Exceptions must identify the owner, rationale, compensating controls, expiration date, and residual risk.

85.6 Evidence

- lifecycle standard and control gates;
- threat model and abuse cases;
- architecture and data-flow reviews;
- secure-development and dependency records;
- test plans and results;
- vulnerability and remediation records;
- release approvals and exception records;
- version-linked technical documentation;
- monitoring and post-release review evidence;
- retirement and disposal records.

85.7 Audit test

Select a sample of production AI releases. Trace each release through intake, design, development, testing, approval, deployment, and monitoring. Confirm that required gates were completed, exceptions were authorised and time-bound, and evidence matches the deployed version.

85.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Articles 9-15, 17, 20, 24-26, 55, 72-73, and Annex IV as applicable.
- Regulation (EU) 2016/679: Articles 25, 32, 35, and related accountability provisions where personal data are processed.
- Current consolidated EUR-Lex texts control over summaries and earlier drafts.

86 Chapter 85 — Threat Modelling

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 85 draft language.

86.1 Requirement

Organizations must perform proportionate threat modelling for AI systems and general-purpose AI components where security, safety, resilience, privacy, fundamental-rights, or operational risks could be materially affected by malicious or accidental misuse.

86.2 Plain-English explanation

AI threat modelling identifies how attackers, insiders, users, dependencies, data pipelines, prompts, models, tools, and interfaces could cause harmful outcomes. It should cover the full lifecycle and be updated when the system, model, intended purpose, data, deployment environment, or threat landscape changes.

86.3 Threat-modelling scope

Assess at minimum:

1. assets, trust boundaries, actors, and attack surfaces;
2. training, fine-tuning, retrieval, prompt, and inference pipelines;
3. data poisoning, prompt injection, model manipulation, extraction, and theft;
4. unauthorized tool use, privilege escalation, and agentic abuse;
5. supply-chain, API, plugin, open-source, and cloud dependencies;
6. privacy leakage, memorisation, confidential-information exposure, and model inversion;
7. safety bypass, harmful-content generation, evasion, and misuse;
8. logging, monitoring, detection, containment, rollback, and recovery;
9. affected-person, operational, and regulatory consequences;
10. residual risk, assumptions, and required controls.

86.4 GlobalWay example

Before releasing an AI travel-assistance agent that can access booking systems, GlobalWay maps the agent's tool permissions, prompt channels, external APIs, user inputs, data stores, and escalation paths. The review identifies prompt injection, unauthorized itinerary changes, data leakage, and supplier-model substitution as priority scenarios.

86.5 Control activity

Security and system owners must complete a version-linked threat model before production release and after material change. High-risk findings must be assigned controls, owners, deadlines, validation tests, and release-blocking criteria.

86.6 Evidence

- approved threat model;
- architecture and data-flow diagrams;
- asset and trust-boundary inventory;
- abuse cases and attack trees;
- control mapping and residual-risk decisions;
- validation and red-team results;
- change-triggered reassessment records.

86.7 Audit test

Select a sample of material AI systems and verify that threat models reflect the deployed architecture, current dependencies, realistic misuse scenarios, assigned mitigations, tested control effectiveness, and documented residual-risk acceptance.

86.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable risk-management, accuracy, robustness, cybersecurity, post-market, incident, and systemic-risk provisions.
- Current consolidated EUR-Lex text controls over older summaries.
- Recognized security frameworks and guidance are non-binding unless incorporated through another binding requirement.

87 Chapter 86 — Prompt Injection and Model Manipulation

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 86 draft language.

87.1 Requirement

AI systems that process instructions, retrieved content, tool outputs, files, web content, or user-supplied data must implement proportionate controls against prompt injection, instruction hijacking, jailbreaks, context

manipulation, unsafe tool execution, and related model-manipulation attacks.

87.2 Plain-English explanation

An AI system may treat hostile content as trusted instructions. Controls must prevent untrusted input from changing the system's intended purpose, overriding safeguards, exposing confidential information, or causing unauthorized actions.

87.3 Control requirements

Implement as appropriate:

1. separation of system, developer, user, retrieved, and tool-generated content;
2. least-privilege tool and data access;
3. allowlists, policy enforcement, and action confirmation;
4. content provenance and trust labeling;
5. input and output filtering with known limitations documented;
6. isolation or sandboxing of untrusted content;
7. human approval for consequential or irreversible actions;
8. anomaly detection, logging, rate limits, and session controls;
9. adversarial testing for direct and indirect injection;
10. safe failure, rollback, incident response, and vendor escalation.

87.4 GlobalWay example

GlobalWay's travel assistant reads external hotel descriptions and emails. A malicious page contains hidden instructions asking the agent to reveal traveler data and change a booking. The system treats external content as untrusted, blocks access to unrelated data, requires user confirmation for booking changes, and logs the attempted manipulation.

87.5 Control activity

Prompt-enabled systems must pass documented injection and manipulation testing before release and after material model, prompt, tool, retrieval, or integration changes. Unresolved high-impact paths must block production use.

87.6 Evidence

- prompt and tool architecture;
- trust-boundary and privilege design;

- test cases and adversarial results;
- policy and filtering configuration;
- action-confirmation records;
- attack logs and incident records;
- remediation and retest evidence.

87.7 Audit test

Select prompt-enabled systems and verify that direct and indirect injection scenarios were tested, privileges are constrained, consequential actions require appropriate authorization, attack attempts are detectable, and remediation was validated.

87.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable risk-management, human-oversight, accuracy, robustness, cybersecurity, logging, monitoring, and incident provisions.
- Current consolidated EUR-Lex text controls over older summaries.

88 Chapter 87 — Data Poisoning and Training Data Risk

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 87 draft language.

88.1 Requirement

Organizations must protect training, validation, testing, fine-tuning, retrieval, and feedback data against unauthorized alteration, malicious contamination, provenance failure, quality degradation, and hidden bias that could undermine compliance, safety, security, or performance.

88.2 Plain-English explanation

Data poisoning can be deliberate or accidental. A small amount of manipulated data may create hidden behaviors, biased outcomes, degraded accuracy, or security weaknesses. Controls must cover data sources, transformations, labels, access, lineage, approvals, and post-deployment feedback loops.

88.3 Control requirements

Implement as appropriate:

1. approved-source and provenance controls;
2. access control, segregation of duties, and change logging;

3. integrity checks, hashes, versioning, and reproducible pipelines;
4. anomaly, duplication, outlier, and label-quality testing;
5. subgroup and representativeness analysis;
6. supplier and open-source dataset due diligence;
7. quarantine and review of user feedback or production data before reuse;
8. backdoor, trigger, and targeted-poisoning tests;
9. rollback, retraining, and affected-version identification;
10. retention of datasets, decisions, transformations, and validation evidence.

88.4 GlobalWay example

GlobalWay fine-tunes a recruitment model using historical application data. Before use, the team validates provenance, detects duplicate and manipulated records, reviews protected-group representation, separates production feedback from approved retraining data, and blocks unreviewed data from entering the pipeline.

88.5 Control activity

No dataset may enter a material AI training or fine-tuning pipeline without documented ownership, provenance, integrity, quality, legal-use, and risk approval. Material changes require retesting and version-linked release authorization.

88.6 Evidence

- dataset inventory and provenance records;
- access and change logs;
- integrity and quality test results;
- subgroup and representativeness analysis;
- supplier dataset assurance;
- poisoning and backdoor test results;
- retraining and rollback records;
- approval and release evidence.

88.7 Audit test

Select a sample of datasets used in production models. Verify approved provenance, controlled access, reproducible transformations, integrity and poisoning tests, documented quality limitations, and linkage between dataset version, model version, and release decision.

88.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable data and data-governance, risk-management, accuracy, robustness, cybersecurity, technical-documentation, and post-market provisions.
- Current consolidated EUR-Lex text controls over older summaries.

89 Chapter 88 — Model Extraction and Theft

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 88 draft language.

89.1 Requirement

Organizations must implement proportionate safeguards against unauthorized model copying, extraction, inversion, weight theft, confidential-system disclosure, and abusive querying that could compromise intellectual property, security, privacy, safety, or regulatory compliance.

89.2 Plain-English explanation

Attackers may recreate model behavior through repeated queries, steal weights or artifacts, infer sensitive training information, or exploit privileged access. Protection requires technical, contractual, monitoring, and incident controls matched to the model's value and risk.

89.3 Control requirements

Implement as appropriate:

1. least-privilege access to weights, checkpoints, code, prompts, and configuration;
2. strong authentication, secrets management, encryption, and environment isolation;
3. query-rate, volume, pattern, and account-abuse controls;
4. anomaly detection for extraction and inversion behavior;
5. output minimisation and confidence-information controls where justified;
6. watermarking, fingerprinting, canary, or provenance techniques where effective;

7. secure distribution and supplier access controls;
8. employee and contractor monitoring consistent with applicable law;
9. evidence preservation, containment, credential rotation, and breach response;
10. legal, contractual, and regulatory escalation.

89.4 GlobalWay example

GlobalWay operates a proprietary travel-pricing model through an API. Monitoring identifies a newly created account making systematic boundary queries at high volume. The account is rate-limited and suspended, logs are preserved, credentials and access paths are reviewed, and the incident is assessed for model theft, privacy exposure, and supplier notification.

89.5 Control activity

Material models must have documented protection requirements before release. Security owners must monitor for extraction indicators, test privileged-access controls, and maintain an incident playbook covering stolen artifacts, exposed endpoints, and suspicious querying.

89.6 Evidence

- model asset classification;
- access-control and privilege records;
- API and rate-limit configuration;
- anomaly-detection rules and alerts;
- extraction test results;
- incident and forensic records;
- credential rotation and containment evidence;
- contractual and legal response records.

89.7 Audit test

Select high-value models and verify that weights and artifacts are access-controlled, endpoints are monitored for extraction behavior, abnormal activity is investigated, incident procedures are tested, and residual risk is documented.

89.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable cybersecurity, robustness, confidentiality, risk-management, monitoring, incident, and systemic-risk provisions.

- Current consolidated EUR-Lex text controls over older summaries.

90 Chapter 89 — Logging, Monitoring, and Vulnerability Management

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 89 draft language.

90.1 Requirement

Organizations must maintain proportionate logging, monitoring, vulnerability identification, triage, remediation, disclosure, and verification processes for AI systems and their supporting infrastructure throughout the lifecycle.

90.2 Plain-English explanation

AI security depends on seeing what happened, detecting abnormal behavior, understanding affected versions and dependencies, and correcting weaknesses quickly. Logging must support accountability without collecting unnecessary personal or confidential data.

90.3 Control requirements

Implement as appropriate:

1. version-linked event, decision, access, change, error, override, and security logs;
2. time synchronization, integrity protection, retention, and access control;
3. monitoring for misuse, drift, anomalous outputs, attack patterns, and control failure;
4. model, dependency, API, container, library, prompt, and configuration vulnerability intake;
5. severity, exploitability, exposure, affected-person, and regulatory-impact triage;
6. remediation deadlines, compensating controls, and exception approval;
7. coordinated disclosure and supplier notification procedures;
8. validation, regression testing, and closure evidence;
9. linkage to incidents, post-market monitoring, corrective action, and change control;
10. metrics and escalation for overdue or systemic weaknesses.

90.4 GlobalWay example

GlobalWay monitors a travel-assistance platform for abnormal tool calls, repeated safeguard bypass attempts, model-version changes, access anomalies, and vulnerable third-party components. A critical API vulnerability triggers isolation, supplier escalation, compensating controls, patch validation, and post-incident review.

90.5 Control activity

Security, engineering, and system owners must operate a documented vulnerability-management process covering the complete AI service stack. Critical unresolved exposure must block release or trigger suspension unless formally approved under an exceptional, time-bound risk decision.

90.6 Evidence

- logging standard and retention schedule;
- monitored event catalogue;
- alert and investigation records;
- vulnerability inventory and severity rationale;
- remediation and exception records;
- supplier notifications;
- patch and regression test results;
- closure validation and metrics.

90.7 Audit test

Select systems, alerts, and vulnerabilities. Confirm that logs are complete and protected, monitoring covers relevant AI-specific behavior, vulnerabilities were risk-ranked and remediated within approved timelines, and closure was independently supported by evidence.

90.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable logging, risk-management, accuracy, robustness, cybersecurity, monitoring, incident, corrective-action, and systemic-risk provisions.
- Current consolidated EUR-Lex text controls over older summaries.

91 Chapter 90 — Business Continuity and Disaster Recovery

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 90 draft language.

91.1 Requirement

Organizations must maintain proportionate continuity and recovery arrangements for material AI systems so that outages, corruption, supplier failure, cyber incidents, unsafe behavior, or loss of supporting services do not create unmanaged harm or prevent compliance.

91.2 Plain-English explanation

Continuity is not limited to restoring servers. The organization must preserve safe decision-making, human oversight, records, model and data integrity, approved configurations, and affected-person protections while the AI service is degraded or unavailable.

91.3 Continuity requirements

The plan should address:

1. critical processes, dependencies, recovery priorities, and impact tolerances;
2. safe degradation, manual fallback, suspension, and emergency shutdown;
3. recovery-time and recovery-point objectives;
4. model, prompt, configuration, data, log, and documentation backup;
5. integrity validation before restoration;
6. cloud, API, model-provider, identity, network, and data-source dependencies;
7. alternate suppliers, regions, endpoints, or human processes;
8. incident command, communications, authority, and affected-person notifications where required;
9. recovery testing, rollback, reconciliation, and post-restoration monitoring;
10. lessons learned and corrective action.

91.4 GlobalWay example

GlobalWay's recruitment-screening service becomes unavailable after a supplier outage. Automated ranking is suspended, trained reviewers use an approved manual process, pending decisions are tracked, required evidence is preserved, and the AI workflow is restored only after version, data, configuration, and control validation.

91.5 Control activity

Every material AI system must have a version-linked continuity and recovery plan before production approval. High-risk systems require tested manual alternatives, defined suspension authority, evidence-preservation procedures, and recovery exercises covering supplier and cyber-failure scenarios.

91.6 Evidence

- business-impact and dependency analysis;
- continuity and recovery plan;
- backup and restoration records;
- manual fallback procedure;
- exercise scenarios and results;
- integrity and reconciliation testing;
- communications and escalation records;
- remediation and lessons-learned actions.

91.7 Audit test

Select material systems and continuity exercises. Verify that plans cover AI-specific assets and dependencies, manual fallback protects affected persons, recovery objectives were tested, restored systems were validated before use, and identified gaps were remediated.

91.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable risk-management, human-oversight, accuracy, robustness, cybersecurity, logging, monitoring, incident, corrective-action, and systemic-risk provisions.
- Applicable sector resilience and continuity law.
- Current consolidated EUR-Lex text controls over older summaries.

92 Chapter 91 — Red-Team and Penetration-Testing Governance

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 91 draft language.

92.1 Requirement

Organizations must govern AI red-team, adversarial, and penetration-testing activities so that testing is authorized, proportionate, competent, evidence-based, legally compliant, and connected to remediation and release decisions.

92.2 Plain-English explanation

Testing AI systems can reveal security, safety, bias, privacy, manipulation, misuse, and oversight failures. Poorly governed testing can itself expose data, disrupt services, create harmful content, or violate law and contract. Scope, authority, safeguards, evidence, and follow-through must therefore be explicit.

92.3 Governance requirements

Define at minimum:

1. objectives, scope, systems, versions, environments, and prohibited actions;
2. written authorization, rules of engagement, and stop conditions;
3. tester independence, competence, conflicts, and confidentiality;
4. privacy, safety, employment, intellectual-property, and data-handling safeguards;
5. scenarios covering prompt injection, poisoning, evasion, extraction, unsafe tool use, harmful outputs, bias, and control bypass;
6. production-testing restrictions and monitoring;
7. evidence capture, severity criteria, reproducibility, and affected-version identification;
8. remediation ownership, deadlines, compensating controls, and retesting;
9. escalation of critical findings, incidents, or reportable events;
10. closure approval and lessons learned.

92.4 GlobalWay example

GlobalWay authorizes an independent red team to test a travel-assistance agent in an isolated environment. The team evaluates indirect prompt injection, unauthorized booking changes, data leakage, privilege escalation, and safeguard bypass. Critical findings block release until remediation and independent retesting are complete.

92.5 Control activity

Material AI systems must undergo risk-based adversarial testing before release and after significant change. Testing must be governed by approved rules of engagement and linked to vulnerability management, incident response, risk management, technical documentation, and release gates.

92.6 Evidence

- approved test plan and authorization;
- tester qualifications and independence assessment;
- rules of engagement and stop conditions;
- scenarios, methods, and test data;
- findings and severity rationale;
- remediation and compensating controls;
- retest and closure evidence;
- executive escalation records.

92.7 Audit test

Select a sample of red-team and penetration tests. Confirm authorization, scope, competence, safeguards, realistic AI-specific scenarios, evidence quality, timely remediation, independent retesting, and release decisions consistent with unresolved risk.

92.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable risk-management, data-governance, human-oversight, accuracy, robustness, cybersecurity, model-evaluation, adversarial-testing, monitoring, and incident provisions.
- Current consolidated EUR-Lex text controls over older summaries.
- Security testing standards and guidance are non-binding unless incorporated through another binding requirement.

93 Chapter 92 — Inherent Risk Assessment

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 92 draft language.

93.1 Requirement

Organizations must assess the inherent risk of each AI system or model before relying on mitigating controls. The assessment must be specific to

the intended purpose, legal role, production version, affected population, jurisdiction, decision consequence, deployment context, and lifecycle stage.

93.2 Plain-English explanation

Inherent risk is the exposure that exists before controls are considered. It is an enterprise risk-management concept, not an AI Act legal classification. A system can be legally outside the high-risk category and still present significant privacy, discrimination, security, operational, or reputational risk.

93.3 Assessment dimensions

Assess at minimum:

1. severity and likelihood of harm;
2. scale and number of affected persons;
3. reversibility and detectability;
4. vulnerability of affected groups;
5. impact on fundamental rights, safety, privacy, security, equality, autonomy, and access to services;
6. decision consequence and degree of automation;
7. model complexity, opacity, uncertainty, and dependency;
8. data sensitivity, provenance, quality, and representativeness;
9. foreseeable misuse, abnormal conditions, and interaction effects;
10. geographic, sector, legal, and supplier dependencies;
11. uncertainty, evidence gaps, and assumptions.

93.4 GlobalWay example

GlobalWay assesses an AI recruitment-screening system before reviewing existing controls. The inherent assessment considers employment consequences, applicant vulnerability, potential proxy discrimination, data sensitivity, automation bias, vendor dependency, explainability limits, and the number of Member States where the system will operate.

93.5 Control activity

The AI risk function must maintain an approved inherent-risk methodology and require a completed assessment before procurement, development approval, pilot, or material expansion. The inherent rating must not be reduced because controls are planned but not yet implemented or tested.

93.6 Evidence

- approved methodology and rating criteria;
- system and version identifier;
- intended-purpose and legal-role record;
- impact, likelihood, scale, reversibility, and uncertainty analysis;
- affected-person and vulnerable-group analysis;
- reviewer, approval date, and assumptions;
- reassessment triggers and history.

93.7 Audit test

Select a sample of AI systems. Confirm that inherent risk was assessed before controls, matches the actual version and use context, covers all material risk dimensions, documents uncertainty, and was reassessed after relevant change.

93.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable risk-management, fundamental-rights, data-governance, human-oversight, robustness, monitoring, and actor-obligation provisions.
- Applicable equality, employment, privacy, cybersecurity, product-safety, consumer-protection, and sector law.
- Enterprise inherent-risk terminology is a management practice and must not be presented as a statutory AI Act classification.

94 Chapter 93 — Fundamental Rights Risk

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 93 draft language.

94.1 Requirement

Organizations must identify, assess, mitigate, monitor, and document risks that an AI system may create for fundamental rights. Where Article 27 applies, the deployer must complete the required fundamental-rights impact assessment before first use and update it when relevant conditions materially change.

94.2 Plain-English explanation

Fundamental-rights analysis asks how the system may affect people, not only whether the model is technically accurate. The review should consider dignity, privacy, data protection, equality, non-discrimination, freedom of

expression and information, workers' rights, consumer protection, access to services, effective remedy, and the rights of children and persons with disabilities where relevant.

94.3 Assessment requirements

Assess at minimum:

1. affected persons and vulnerable groups;
2. relevant rights and potential interferences;
3. severity, scale, duration, reversibility, and likelihood;
4. degree of automation and human dependency;
5. data, proxy, accessibility, and representativeness risks;
6. notice, contestability, explanation, complaint, and remedy mechanisms;
7. mitigation, residual risk, and monitoring;
8. consultation and stakeholder input where appropriate;
9. links to DPIA, equality, labour, consumer, safety, and sector assessments;
10. change triggers and reassessment.

94.4 GlobalWay example

Before deploying recruitment screening across several Member States, GlobalWay assesses risks to equality, privacy, worker rights, access to employment, disability accommodation, and effective contestability. It documents mitigations, human-review authority, applicant notices, complaint routes, and monitoring thresholds.

94.5 Control activity

The deployer must complete a rights-impact review before production use, using the statutory Article 27 process where applicable and a proportionate equivalent process for other material systems. Unresolved severe rights risks must block release or trigger executive and legal escalation.

94.6 Evidence

- rights-impact assessment;
- Article 27 applicability decision;
- affected-person and vulnerable-group analysis;
- consultation records;

- mitigation and residual-risk record;
- notices, explanation, complaint, and remedy procedures;
- approval and reassessment history.

94.7 Audit test

Select systems with significant human impact. Verify that relevant rights and groups were identified, Article 27 applicability was assessed correctly, mitigations were implemented before use, residual risk was approved within authority, and reassessment occurred after material change.

94.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 27 and applicable risk-management, data-governance, human-oversight, transparency, deployer, monitoring, and explanation provisions.
- Charter of Fundamental Rights of the European Union.
- Applicable equality, employment, disability, consumer-protection, privacy, and sector law.

95 Chapter 94 — Safety Risk

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 94 draft language.

95.1 Requirement

Organizations must identify, evaluate, control, and monitor safety risks arising from intended use, reasonably foreseeable misuse, system interaction, component failure, human reliance, environmental conditions, and lifecycle change. Safety analysis must be coordinated with applicable AI Act, product-safety, sector, occupational, and consumer-protection duties.

95.2 Plain-English explanation

Safety risk is broader than physical injury. Depending on context, AI can contribute to physical, psychological, operational, societal, or service-access harm. The analysis must examine the complete sociotechnical system rather than the model in isolation.

95.3 Assessment requirements

Assess at minimum:

1. hazards, hazardous situations, and reasonably foreseeable misuse;
2. severity, likelihood, exposure, detectability, and reversibility;
3. human-machine interaction and automation bias;

4. failure modes, degraded modes, edge cases, and dependency failures;
5. data, model, software, hardware, network, and integration risks;
6. emergency stop, fallback, recovery, and safe-state behavior;
7. affected populations and vulnerable persons;
8. validation under representative and adverse conditions;
9. incident, complaint, and post-market signals;
10. change-control and reassessment triggers.

95.4 GlobalWay example

GlobalWay reviews an AI travel-disruption tool that recommends rerouting vulnerable travelers during severe weather. The safety assessment covers inaccurate recommendations, inaccessible alternatives, stale transport data, automation bias, system outages, emergency escalation, and the ability of trained staff to override recommendations.

95.5 Control activity

Safety-critical and high-impact AI systems must have documented hazard analysis, acceptance criteria, verification, validation, human-oversight measures, fallback procedures, and post-market monitoring before production release. Severe unresolved safety risks must block deployment.

95.6 Evidence

- hazard and risk analysis;
- failure-mode and misuse assessment;
- validation and stress-test results;
- human-factors review;
- emergency and fallback procedures;
- incident and post-market records;
- safety acceptance and reassessment decisions.

95.7 Audit test

Select systems with material safety consequences. Verify that hazards and misuse were identified, controls were tested under realistic and degraded conditions, fallback and override mechanisms work, monitoring detects emerging risk, and material changes trigger reassessment.

95.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable Articles 9, 14, 15, 72, and 73 and relevant actor obligations.
- Applicable Union harmonisation, product-safety, occupational-safety, consumer-protection, and sector legislation.
- Current consolidated EUR-Lex text controls over older summaries.

96 Chapter 95 — Bias and Discrimination Risk

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 95 draft language.

96.1 Requirement

Organizations must identify and mitigate risks that an AI system may produce unlawful discrimination, unjustified disadvantage, exclusion, inaccessible outcomes, or systematically poorer performance for protected or vulnerable groups. Assessment must reflect the applicable legal and factual context rather than rely on a single statistical metric.

96.2 Plain-English explanation

Bias can arise from data, labels, sampling, proxies, objectives, model behavior, thresholds, user practices, accessibility barriers, feedback loops, or the surrounding decision process. Equal aggregate accuracy does not prove equal treatment, while a numerical disparity does not by itself determine legal unlawfulness.

96.3 Assessment requirements

Assess at minimum:

1. protected and vulnerable groups relevant to the jurisdiction and use case;
2. representation, measurement, labeling, and historical-bias risks;
3. proxy variables and correlated features;
4. subgroup performance, error rates, calibration, and intersectional effects;
5. accessibility and reasonable-accommodation requirements;
6. threshold, ranking, and workflow consequences;
7. human-review quality and automation bias;
8. complaint, challenge, explanation, and remedy mechanisms;

9. feedback loops and post-deployment drift;
10. legal review of proposed metrics, mitigations, and residual disparities.

96.4 GlobalWay example

GlobalWay tests a recruitment-ranking system across relevant applicant groups and job families. It reviews false-negative rates, proxy variables, disability-access barriers, ranking thresholds, human override patterns, and whether accommodations are available. A statistically improved result is not accepted until Legal and HR confirm that the process remains lawful and operationally fair.

96.5 Control activity

High-impact systems must undergo documented pre-deployment and recurring subgroup testing using legally and technically appropriate methods. Material disparities require root-cause analysis, mitigation, validation, and approval. Severe unresolved discrimination risk must block or suspend use.

96.6 Evidence

- protected-group and legal-context analysis;
- data and proxy-variable review;
- subgroup and intersectional testing;
- accessibility and accommodation assessment;
- mitigation and validation results;
- human-review and override analysis;
- complaints and monitoring trends;
- legal and management approvals.

96.7 Audit test

Select systems affecting employment, education, credit, insurance, essential services, or other consequential decisions. Verify that relevant groups and legal requirements were identified, testing covered meaningful subgroups and outcomes, mitigations were validated, accessibility was addressed, and monitoring detects emerging disparity.

96.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable prohibited-practice, high-risk, data-governance, human-oversight, accuracy, monitoring, and fundamental-rights provisions.
- Charter of Fundamental Rights of the European Union.

- Applicable Union and Member State equality, employment, disability, consumer-protection, and sector law.

97 Chapter 96 — Privacy and Data Protection Risk

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 96 draft language.

97.1 Requirement

Organizations must identify, assess, mitigate, and monitor privacy and data-protection risks arising from AI development and use. AI Act compliance and GDPR compliance must be coordinated but assessed separately because the two regimes impose different roles, triggers, duties, and evidence requirements.

97.2 Plain-English explanation

An AI system may comply with its AI Act obligations and still violate data-protection law. Privacy review must examine why personal data is processed, whose data is involved, whether the data is necessary, how long it is retained, who receives it, how people exercise rights, and whether automated decision-making restrictions or safeguards apply.

97.3 Assessment requirements

Assess at minimum:

1. controller, joint-controller, processor, and recipient roles;
2. purpose, lawful basis, compatibility, necessity, and proportionality;
3. special-category and criminal-offence data;
4. data minimisation, accuracy, provenance, and retention;
5. transparency and data-subject rights;
6. profiling and solely automated decisions with legal or similarly significant effects;
7. DPIA applicability, consultation, and residual high risk;
8. international transfers, subprocessors, and data location;
9. security, confidentiality, re-identification, model memorisation, and leakage;
10. training, fine-tuning, prompt, log, output, and feedback-loop data;
11. deletion, correction, restriction, objection, and contestability processes;

12. alignment with AI Act technical documentation, data governance, logging, monitoring, and incident controls.

97.4 GlobalWay example

GlobalWay evaluates a recruitment-screening service that processes applicant profiles and interview transcripts. It documents controller and processor roles, lawful basis, minimisation, retention, special-category-data controls, DPIA conclusions, automated-decision safeguards, international transfers, applicant notices, and deletion workflows.

97.5 Control activity

No AI system processing personal data may enter production until Privacy confirms the role analysis, lawful basis, required DPIA, data minimisation, retention, transparency, rights handling, security, and contractual controls. Material model, data, purpose, supplier, or jurisdiction changes require reassessment.

97.6 Evidence

- data-flow and role map;
- lawful-basis and purpose assessment;
- DPIA and consultation records;
- records of processing activities;
- privacy notices and rights procedures;
- retention and deletion schedule;
- transfer and processor agreements;
- security and leakage testing;
- change and reassessment history.

97.7 Audit test

Select AI systems processing personal data. Verify that roles and lawful basis match actual processing, the DPIA decision is supportable, special-category and automated-decision issues were addressed, rights can be exercised in practice, retention is enforced, and material changes triggered reassessment.

97.8 Primary legal references

- Regulation (EU) 2016/679, including Articles 5, 6, 9, 12–22, 25, 28, 30, 32, 35–36, and Chapter V as applicable.

- Regulation (EU) 2024/1689, as amended: applicable data-governance, transparency, logging, deployer, monitoring, and fundamental-rights provisions.
- Current consolidated official texts control over older summaries.

98 Chapter 97 — Cybersecurity Risk

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 97 draft language.

98.1 Requirement

Organizations must identify, assess, mitigate, test, and monitor cybersecurity risks affecting AI systems, models, data, interfaces, infrastructure, users, and dependent services throughout the lifecycle. Controls must address both conventional security threats and AI-specific attack paths.

98.2 Plain-English explanation

AI systems expand the attack surface. Attackers may manipulate prompts, poison data, evade detection, extract models, steal credentials, exploit APIs, compromise dependencies, or induce unsafe tool actions. Security therefore requires coordinated controls across software, models, data, identity, infrastructure, vendors, and operations.

98.3 Assessment requirements

Assess at minimum:

1. assets, trust boundaries, users, privileges, and data flows;
2. prompt injection, indirect prompt injection, jailbreaks, and unsafe tool use;
3. training-data poisoning, retrieval-source manipulation, and feedback-loop abuse;
4. adversarial examples, evasion, model extraction, inversion, and membership inference;
5. secrets, credentials, APIs, plugins, agents, and privileged integrations;
6. confidentiality, integrity, availability, authenticity, and resilience;
7. model, library, container, cloud, and supplier vulnerabilities;
8. logging, detection, incident response, rollback, and evidence preservation;

9. denial of service, capacity exhaustion, and dependency failure;
10. secure development, change control, patching, and vulnerability disclosure;
11. data leakage, model memorisation, output filtering, and access control;
12. material-change and post-incident reassessment triggers.

98.4 GlobalWay example

GlobalWay threat-models a travel-assistance agent that can read itineraries and initiate booking changes. It identifies indirect prompt injection through external content, overprivileged service accounts, sensitive-data leakage, malicious plugins, and model-provider outages. Release is blocked until privilege reduction, content isolation, transaction confirmation, monitoring, and fallback controls are validated.

98.5 Control activity

Material AI systems must pass risk-based security architecture review, threat modelling, secure development, adversarial testing, vulnerability management, and incident-readiness checks before production and after significant change. Critical unresolved findings require documented executive escalation and release prohibition unless a lawful, time-limited exception is approved.

98.6 Evidence

- threat model and attack-surface inventory;
- security architecture and data-flow diagrams;
- secure-development and code-review records;
- vulnerability scans and dependency inventories;
- adversarial and penetration-test results;
- identity, access, and secrets-management evidence;
- monitoring and incident-response procedures;
- remediation, retest, and closure records.

98.7 Audit test

Select material AI systems and verify that threat models cover AI-specific and conventional attacks, controls match actual architecture and privileges, critical findings were remediated and retested, monitoring detects relevant events, and material changes triggered reassessment.

98.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable risk-management, data-governance, accuracy, robustness, cybersecurity, monitoring, incident, and GPAI provisions.
- Applicable Union and Member State cybersecurity and sector requirements.
- Current consolidated official texts control over older summaries.

99 Chapter 98 — Explainability and Transparency Risk

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 98 draft language.

99.1 Requirement

Organizations must identify and manage risks arising when AI behavior, limitations, outputs, disclosures, or decision logic are insufficiently understandable for providers, deployers, operators, affected persons, auditors, or authorities to perform their responsibilities.

99.2 Plain-English explanation

Transparency is not one document or one explanation. Different audiences need different information. Providers may owe instructions and technical information; deployers may owe notices or explanations; operators need usable oversight information; affected persons may need clear communication and routes to challenge decisions.

99.3 Risk assessment requirements

Assess at minimum:

1. intended audience and decision context;
2. Article 13 instructions and provider information;
3. Article 50 interaction, synthetic-content, deepfake, and public-interest text disclosures where applicable;
4. Article 86 explanation rights where applicable;
5. model or system limitations, uncertainty, confidence, and unsupported uses;
6. traceability from input, version, configuration, and output to the resulting action;
7. accessibility, language, timing, prominence, and comprehension;

8. risk of misleading summaries, false precision, or unsupported causal claims;
9. trade-secret and security limits that must be balanced without defeating legal duties;
10. consistency among technical documentation, notices, interfaces, training, and actual operation.

99.4 GlobalWay example

GlobalWay uses an AI recruitment tool to support candidate screening. Applicants receive a clear notice that AI is used, while trained reviewers receive instructions on limitations, subgroup performance, override authority, and prohibited reliance. When an explanation right applies, GlobalWay provides meaningful information about the system's role and the principal factors relevant to the decision without presenting an invented or misleading rationale.

99.5 Control activity

Each material AI system must have an audience-specific transparency plan approved before release. Notices, instructions, explanation procedures, interface labels, and training must be version-controlled, tested for comprehension and accessibility, and updated after material change.

99.6 Evidence

- audience and transparency assessment;
- approved instructions and notices;
- explanation procedure and templates;
- accessibility and comprehension testing;
- interface screenshots and disclosure logs;
- operator training and limitation records;
- complaints, requests, and response records;
- version and change history.

99.7 Audit test

Select systems with transparency duties or significant decision impact. Verify that each audience receives accurate, timely, accessible information; explanations match actual system operation; disclosures are prominent and version-current; and complaints or explanation requests are handled consistently.

99.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: Articles 13, 50, and 86 and related provisions as applicable.
- Applicable GDPR transparency and automated-decision provisions.
- Current consolidated official texts control over older summaries.

100 Chapter 99 — Human Autonomy Risk

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 99 draft language.

100.1 Requirement

Organizations must identify and mitigate risks that AI systems impair meaningful human choice, judgment, dignity, agency, contestability, or control. Effective human oversight must be real, competent, timely, and supported by authority and system design.

100.2 Plain-English explanation

A person is not meaningfully in control merely because a human appears somewhere in the workflow. Operators may defer automatically to outputs, lack time or information to challenge them, or be unable to stop the system. Affected persons may not understand that AI influenced an outcome or may have no practical way to contest it.

100.3 Assessment requirements

Assess at minimum:

1. the degree of automation and decision consequence;
2. risk of automation bias, overreliance, deskilling, and complacency;
3. operator competence, workload, time, information, and independence;
4. authority to disregard, reverse, override, suspend, or stop the system;
5. coercion, manipulation, deception, dark patterns, and exploitative personalization;
6. meaningful notice, choice, alternative channels, and consent where relevant;
7. contestability, complaint, review, and remedy routes;
8. impacts on dignity, privacy, equality, expression, association, and due process;
9. vulnerable persons and power imbalances;

10. safe fallback and continuity when automation is limited or disabled.

100.4 GlobalWay example

GlobalWay's recruitment system ranks applicants but cannot reject candidates automatically. Reviewers receive the underlying evidence, limitations, and override authority, and must document reasons for adverse decisions. Applicants can request human review through an accessible channel, and GlobalWay monitors whether reviewers merely follow rankings without independent judgment.

100.5 Control activity

Material AI workflows must define decision rights, mandatory human-review points, competence requirements, override and stop mechanisms, contestability routes, and indicators of automation bias. Controls must be tested under realistic workload and time-pressure conditions.

100.6 Evidence

- human-oversight plan;
- decision-rights and escalation matrix;
- operator training and competence assessment;
- override, reversal, and stop logs;
- workload and usability testing;
- notices, alternatives, and complaint procedures;
- human-review and remedy records;
- automation-bias monitoring and corrective actions.

100.7 Audit test

Observe selected workflows and sample decisions. Confirm that reviewers have adequate information, competence, time, and authority; overrides are technically effective; affected persons can contest outcomes; and monitoring detects rubber-stamping or other loss of meaningful human control.

100.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable prohibited-practice, human-oversight, transparency, deployer, fundamental-rights, and explanation provisions.
- Applicable employment, equality, consumer-protection, accessibility, and data-protection law.
- Current consolidated official texts control over older summaries.

101 Chapter 100 — Operational and Resilience Risk

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 100 draft language.

101.1 Requirement

Organizations must identify and manage operational and resilience risks that could cause an AI system or dependent process to fail, degrade, produce unreliable outcomes, or become unavailable. Controls must support continuity, safe fallback, recovery, and evidence preservation.

101.2 Plain-English explanation

An AI system can fail even without a cyberattack. Capacity limits, bad data feeds, model-provider outages, configuration drift, latency, dependency failures, or weak change control can disrupt operations or produce harmful decisions. Resilience requires tested alternatives and clear recovery priorities.

101.3 Assessment requirements

Assess at minimum:

1. critical processes, service levels, and impact tolerances;
2. model, API, cloud, data, network, identity, and supplier dependencies;
3. capacity, latency, throughput, timeout, and rate-limit risks;
4. data-pipeline failure, stale data, schema change, and integrity degradation;
5. configuration, version, prompt, and retrieval-source drift;
6. monitoring coverage and alert thresholds;
7. manual workarounds, alternative channels, and safe degraded modes;
8. backup, restoration, rollback, failover, and recovery objectives;
9. operator readiness, communications, and decision authority;
10. evidence retention, incident coordination, and post-recovery validation.

101.4 GlobalWay example

GlobalWay's AI travel-assistance service depends on a third-party model, booking APIs, identity services, and customer-profile data. GlobalWay defines a safe read-only mode, blocks automated booking changes during dependency failure, routes urgent requests to human agents, and tests recovery before restoring normal service.

101.5 Control activity

Material AI services must have documented continuity and recovery plans aligned to business impact. Plans must include safe shutdown, fallback, dependency monitoring, recovery validation, and periodic exercises covering realistic AI-specific failure scenarios.

101.6 Evidence

- business-impact and dependency assessment;
- service-level and impact-tolerance definitions;
- continuity, fallback, and recovery plans;
- backup, rollback, and failover test results;
- monitoring and capacity records;
- exercise reports and corrective actions;
- outage communications and recovery approvals;
- post-recovery validation evidence.

101.7 Audit test

Select material AI services and review recent incidents or exercises. Confirm that critical dependencies are known, fallback processes are usable, recovery objectives are tested, restored versions and data are validated, and unresolved resilience gaps are escalated.

101.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable risk-management, accuracy, robustness, cybersecurity, human-oversight, monitoring, incident, and corrective-action provisions.
- Applicable operational-resilience, cybersecurity, product-safety, and sector requirements.
- Current consolidated official texts control over older summaries.

102 Chapter 101 — Third-Party Risk

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 101 draft language.

102.1 Requirement

Organizations must identify and manage risks created by AI suppliers, model providers, cloud services, data providers, integrators, subprocessors, open-source components, and other dependencies. Third-party

arrangements must support each regulated actor's own legal and operational responsibilities.

102.2 Plain-English explanation

A supplier contract does not remove the customer's accountability. The organization still needs sufficient evidence, control, notice, cooperation, continuity, and exit rights to use the AI system lawfully and safely. Risk can also arise from subcontractors or hidden dependencies several layers below the direct supplier.

102.3 Assessment requirements

Assess at minimum:

1. exact legal entity, jurisdiction, ownership, and AI Act role;
2. intended purpose, classifications, supported uses, and prohibited uses;
3. technical documentation, instructions, conformity, registration, and assurance evidence;
4. data sources, provenance, privacy, intellectual property, and retention;
5. security, robustness, accuracy, bias, accessibility, and oversight controls;
6. subcontractors, cloud, APIs, models, components, and concentration dependencies;
7. change notification, version transparency, and substantial-modification triggers;
8. incident notification, investigation, evidence preservation, and corrective action;
9. audit, information-access, authority-cooperation, and remediation rights;
10. continuity, portability, suspension, termination, and verified data deletion.

102.4 GlobalWay example

GlobalWay procures an AI recruitment platform. It identifies the vendor's provider role and GlobalWay's deployer role, reviews documentation and testing, maps subprocessors and model dependencies, negotiates change and incident notice, and establishes a manual fallback and evidence-export process before production use.

102.5 Control activity

Material AI suppliers must undergo risk-tiered due diligence, contracting, approval, monitoring, and reassessment. Procurement must block production use when required evidence is absent, legal roles are unresolved, critical risks remain unmitigated, or continuity and exit controls are inadequate.

102.6 Evidence

- supplier inventory and dependency map;
- role and classification assessment;
- due-diligence questionnaire and supporting evidence;
- security, privacy, legal, and compliance reviews;
- executed contract and flow-down terms;
- monitoring, incident, and change records;
- assurance and audit reports;
- continuity and exit test results.

102.7 Audit test

Select material suppliers and verify that due diligence preceded use, roles and dependencies are accurate, evidence is version-linked, contractual rights are operational, changes and incidents triggered reassessment, and unresolved risks were escalated or blocked.

102.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable provider, deployer, importer, distributor, authorised-representative, product-manufacturer, GPAI, documentation, monitoring, incident, corrective-action, and value-chain provisions.
- Applicable data-protection, cybersecurity, product-safety, consumer, employment, and sector law.
- Current consolidated official texts control over older summaries.

103 Chapter 102 — Legal, Financial, and Reputational Risk

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 102 draft language.

103.1 Requirement

Organizations must identify and manage legal, regulatory, contractual, financial, and reputational exposures arising from AI development, procurement, deployment, operation, change, incident, and retirement. Risk estimates must be evidence-based and must not replace legal analysis.

103.2 Plain-English explanation

AI failures can create several distinct forms of harm at once. A discriminatory decision may lead to regulatory action, litigation, remediation costs, contract claims, operational disruption, and loss of trust. These exposures should be assessed separately before being aggregated.

103.3 Assessment requirements

Assess at minimum:

1. applicable AI Act duties, actor roles, and enforcement exposure;
2. data-protection, employment, equality, consumer, product-safety, intellectual-property, cybersecurity, accessibility, and sector law;
3. civil liability, contractual breach, indemnity, warranty, and insurance considerations;
4. investigation, notification, remediation, recall, withdrawal, and monitoring costs;
5. business interruption, lost revenue, rework, replacement, and continuity costs;
6. fines and penalties using current legal ceilings and fact-specific assumptions;
7. customer, employee, partner, regulator, investor, and public trust impacts;
8. media, complaint, litigation, and stakeholder escalation scenarios;
9. concentration, supplier insolvency, and exit costs;
10. uncertainty, assumptions, confidence, and counsel-review needs.

103.4 GlobalWay example

GlobalWay assesses a recruitment-system disparity incident. It separately estimates investigation and remediation cost, potential employment and data-protection claims, regulator engagement, supplier recovery, business disruption, and reputational impact. It does not present the maximum statutory fine as the expected loss.

103.5 Control activity

Material AI risks and incidents must receive documented Legal, Compliance, Finance, Risk, Communications, and business-owner assessment. High-impact estimates must state assumptions, sources, uncertainty, and decision use. Public statements and regulator communications require appropriate review and approval.

103.6 Evidence

- legal and regulatory applicability analysis;
- exposure and scenario assessment;
- financial assumptions and calculation support;
- contract and insurance review;
- incident and remediation cost records;
- stakeholder and communications plan;
- counsel advice or escalation record;
- executive and board decisions.

103.7 Audit test

Select significant AI risks and incidents. Confirm that exposure categories were assessed separately, calculations use supportable assumptions, legal conclusions received qualified review, maximum penalties were not presented as expected outcomes, and decisions reflect uncertainty and mitigation.

103.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable enforcement, penalty, market-surveillance, incident, corrective-action, and actor-obligation provisions.
- Applicable Union and Member State civil, contractual, data-protection, employment, equality, consumer, product-safety, intellectual-property, cybersecurity, and sector law.
- Current consolidated official texts control over older summaries.

104 Chapter 103 — Residual Risk Acceptance and Exceptions

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 103 draft language.

104.1 Requirement

Residual AI risk may be accepted only through a documented, authorized, time-limited process that identifies the remaining risk, affected persons, legal constraints, compensating controls, monitoring, escalation, and closure conditions. Mandatory legal duties cannot be waived through internal risk acceptance.

104.2 Plain-English explanation

Risk acceptance is not permission to ignore the law or leave a serious problem unresolved indefinitely. It is a governance decision to tolerate a defined remaining risk for a limited period or purpose after required controls and legal obligations have been addressed.

104.3 Acceptance requirements

The record must identify:

1. system or model, version, use case, owner, actor role, and jurisdiction;
2. original risk, implemented controls, and residual risk;
3. affected persons, potential harm, likelihood, severity, and uncertainty;
4. applicable legal duties and confirmation that none are being waived;
5. compensating controls and operational restrictions;
6. acceptance authority matched to risk level;
7. start date, expiry date, review frequency, and closure criteria;
8. monitoring indicators, thresholds, and escalation triggers;
9. remediation owner, milestones, resources, and target date;
10. conditions requiring immediate suspension or reassessment.

Risk acceptance must not replace prohibited-practice controls, required conformity assessment, registration, serious-incident reporting, corrective action, authority cooperation, or other mandatory obligations.

104.4 GlobalWay example

GlobalWay identifies a temporary limitation in subgroup performance for a low-volume language in a non-automated support tool. Use is restricted, outputs require trained human verification, monitoring thresholds are established, remediation is funded, and a senior risk owner approves a 60-day exception. The exception expires automatically unless independently re-evaluated.

104.5 Control activity

The organization must maintain a centralized exception register with approval thresholds, legal review criteria, automatic expiry, monitoring, escalation, and closure validation. High or fundamental-rights-sensitive residual risks require executive review and may require suspension rather than acceptance.

104.6 Evidence

- residual-risk assessment;
- legal and compliance review;
- compensating-control design and testing;
- signed acceptance and authority evidence;
- exception register entry;
- monitoring and threshold results;
- remediation plan and progress records;
- expiry, renewal, suspension, or closure decision.

104.7 Audit test

Select active and expired exceptions. Confirm that acceptance authority matched risk, legal duties were not waived, compensating controls operated, monitoring occurred, expiry was enforced, remediation progressed, and closure or renewal received independent review.

104.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable prohibited-practice, risk-management, conformity, registration, monitoring, incident, corrective-action, authority-cooperation, and actor-obligation provisions.
- Applicable Union and Member State law relevant to the use case.
- Current consolidated official texts control over older summaries.

105 Chapter 104 — Control Library Design

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 104 draft language.

105.1 Requirement

Organizations must maintain a structured AI control library that translates applicable legal obligations, risk treatments, governance decisions,

technical safeguards, and operational practices into clear, assignable, testable, and evidence-producing controls.

105.2 Plain-English explanation

A control library is the operational bridge between law, policy, risk, and day-to-day execution. Controls must state who performs the activity, what must be done, when it must occur, which systems and versions are covered, what evidence is retained, and how failures are escalated.

105.3 Design requirements

Each control record should include:

1. unique control identifier and title;
2. linked legal, regulatory, contractual, policy, and risk sources;
3. objective and risk addressed;
4. regulated actor, business owner, control owner, and operator;
5. scope by system, model, version, geography, supplier, and lifecycle stage;
6. control activity, trigger, frequency, and timing;
7. preventive, detective, corrective, or governance classification;
8. manual, automated, or hybrid execution method;
9. required inputs, outputs, systems, and dependencies;
10. evidence standard, retention, and access requirements;
11. exception, escalation, and compensating-control process;
12. design and operating-effectiveness test procedures;
13. change history, approval, and next-review date.

105.4 GlobalWay example

GlobalWay creates a control for high-risk recruitment systems requiring pre-release classification confirmation, approved human-oversight procedures, validation results, provider documentation, logging readiness, and executive release approval. The control record identifies evidence, frequency, owners, and testing steps.

105.5 Control activity

The AI Governance function must maintain a controlled master library, map every material AI obligation and risk to one or more controls, prevent

duplicate or contradictory controls, and require review after regulatory, system, model, supplier, purpose, or organizational change.

105.6 Evidence

- approved control-library methodology;
- master control register;
- source-to-control mappings;
- ownership and RACI records;
- control narratives and procedures;
- evidence specifications;
- testing scripts and results;
- exception and change records.

105.7 Audit test

Select a sample of legal obligations and material AI risks. Trace each to an approved control, responsible owner, operating procedure, retained evidence, and test method. Confirm that obsolete controls are retired and material changes trigger reassessment.

105.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable governance, quality-management, risk-management, documentation, recordkeeping, monitoring, incident, corrective-action, and actor-specific provisions.
- Current consolidated EUR-Lex text controls over older summaries.
- Control frameworks and standards are non-binding unless incorporated through law, contract, certification, or organizational policy.

106 Chapter 105 — Article-to-Control Mapping

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 105 draft language.

106.1 Requirement

Organizations must maintain traceable mappings from applicable EU AI Act provisions and other binding requirements to the controls, procedures, evidence, systems, models, actors, and responsible owners used to demonstrate compliance.

106.2 Plain-English explanation

A citation list is not a compliance map. A useful mapping shows how each applicable legal element is implemented, who is accountable, where evidence is stored, and how gaps are identified. The mapping must also distinguish mandatory law from guidance, standards, and voluntary practices.

106.3 Mapping requirements

For each applicable requirement, record:

1. legal source, article, paragraph, annex, and amendment status;
2. effective date and transitional treatment;
3. trigger, scope, exception, and regulated actor;
4. plain-language obligation statement;
5. linked policy, standard, procedure, and control identifiers;
6. covered systems, models, versions, suppliers, and jurisdictions;
7. accountable owner and operational performer;
8. required evidence and retention location;
9. test procedure, frequency, and latest result;
10. gap, interpretation, dependency, or counsel-review status;
11. change history and next-review trigger.

106.4 GlobalWay example

GlobalWay maps Article 14 human-oversight requirements for its high-risk recruitment system to approved oversight procedures, user training, interface controls, stop authority, override logging, effectiveness testing, and retained release evidence.

106.5 Control activity

Legal and AI Governance must jointly maintain the mapping. New or amended requirements, system changes, actor-role changes, intended-purpose changes, incidents, audit findings, and supplier changes must trigger review. Unmapped applicable requirements are release blockers.

106.6 Evidence

- approved legal-obligation inventory;
- article-to-control matrix;
- actor and applicability assessments;

- effective-date register;
- linked procedures and evidence indexes;
- testing and gap records;
- legal-review and approval history;
- regulatory-change updates.

106.7 Audit test

Select a sample of applicable articles and annex elements. Trace each legal element through the mapping to controls, evidence, owners, systems, and test results. Confirm that exclusions and non-applicability decisions are documented and supportable.

106.8 Primary legal references

- Regulation (EU) 2024/1689, as amended, including applicable articles and annexes.
- Regulation (EU) 2026/1744 where relevant.
- Current consolidated EUR-Lex text controls over earlier versions and secondary summaries.

107 Chapter 106 — Control Ownership and Frequency

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 106 draft language.

107.1 Requirement

Every material AI control must have clearly assigned accountability, operational responsibility, escalation authority, execution frequency, triggering events, evidence obligations, and backup coverage. Ownership and frequency must reflect legal duties, system risk, lifecycle stage, change velocity, and control criticality.

107.2 Plain-English explanation

A control without an owner is unlikely to operate, and a control performed at the wrong interval may not manage the risk. Annual review is not sufficient for rapidly changing models, high-risk systems, active incidents, or supplier-driven changes.

107.3 Ownership requirements

Define for each control:

1. accountable executive or function;

2. control owner responsible for design and performance;
3. operator responsible for execution;
4. reviewer or approver where segregation is required;
5. evidence custodian;
6. escalation and risk-acceptance authority;
7. qualified backup owner and continuity arrangements;
8. conflict-of-interest and independence safeguards.

107.4 Frequency requirements

Control timing may be:

- continuous or event-driven;
- per transaction, decision, release, model, or dataset;
- daily, weekly, monthly, quarterly, or annual;
- before deployment, after change, after incident, or at contract renewal.

Frequency must be reassessed when risk, law, system behavior, scale, supplier conditions, or monitoring results change.

107.5 GlobalWay example

GlobalWay assigns recruitment-system log review to the operational owner weekly, bias and performance review monthly, supplier assurance review quarterly, and classification and release controls before every material version change. Serious incidents trigger immediate escalation outside the routine schedule.

107.6 Control activity

AI Governance must approve the ownership and frequency model, monitor missed or late executions, require documented delegation, and escalate orphaned, overdue, ineffective, or repeatedly failing controls. Critical controls may not rely on a single individual without backup coverage.

107.7 Evidence

- control ownership register;
- RACI and delegation records;
- approved frequency rationale;
- execution calendar and automated schedules;

- completion and review evidence;
- overdue-control reports;
- escalation and backup records;
- frequency-change history.

107.8 Audit test

Select controls across risk tiers and lifecycle stages. Confirm that owners are current and competent, frequencies match risk and triggers, executions occurred on time, evidence was reviewed, and missed controls were escalated and remediated.

107.9 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable quality-management, risk-management, human-oversight, monitoring, recordkeeping, incident, corrective-action, and actor-accountability provisions.
- Current consolidated EUR-Lex text controls over older summaries.

108 Chapter 107 — Evidence Standards

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 107 draft language.

108.1 Requirement

Compliance evidence must be authentic, complete, accurate, timely, attributable, version-linked, protected, retrievable, and sufficient to demonstrate the design and operation of the relevant AI controls and legal duties.

108.2 Plain-English explanation

A screenshot, certificate, or policy title is not automatically reliable evidence. Evidence must show what happened, for which system and version, who performed and reviewed the activity, when it occurred, what criteria were applied, and whether exceptions or failures were resolved.

108.3 Evidence-quality criteria

Evidence should satisfy:

1. relevance to the exact requirement and control;
2. identification of system, model, dataset, configuration, release, and jurisdiction;
3. reliable source and accountable creator;

4. date, time, period, and execution frequency;
5. completeness, including exceptions and negative results;
6. integrity protection and change history;
7. reviewer approval and segregation where required;
8. retention aligned with legal, contractual, incident, and audit needs;
9. confidentiality, privacy, privilege, and access controls;
10. reproducibility or independent validation where appropriate;
11. searchable indexing and timely retrieval;
12. documented treatment of estimates, samples, assumptions, and limitations.

108.4 GlobalWay example

GlobalWay retains the approved test plan, dataset version, model version, subgroup results, reviewer sign-off, exception decisions, remediation evidence, and release approval for its recruitment system. A vendor marketing claim is not accepted as evidence without supporting documentation or testing.

108.5 Control activity

The organization must publish an AI evidence standard, define acceptable evidence by control type, maintain an evidence register, protect records from unauthorized alteration or deletion, and reject unsupported attestations or unverifiable summaries.

108.6 Evidence

- approved evidence standard;
- evidence register and metadata;
- source-system records;
- approvals and reviewer sign-offs;
- integrity and access logs;
- retention schedules;
- exception and deficiency records;
- retrieval-test results.

108.7 Audit test

Select evidence supporting high-risk and material controls. Verify source reliability, completeness, attribution, version linkage, timestamps, approvals, integrity protection, retention, accessibility, and consistency with the claimed control result.

108.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable technical-documentation, recordkeeping, quality-management, monitoring, incident, corrective-action, conformity, and authority-access provisions.
- Applicable privacy, cybersecurity, employment, product-safety, and sector-retention requirements.
- Current consolidated official texts control over older summaries.

109 Chapter 108 — Control Testing

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 108 draft language.

109.1 Requirement

AI controls must be tested using documented, risk-based procedures that evaluate both design effectiveness and operating effectiveness. Testing must be sufficiently independent, competent, evidence-based, reproducible, and linked to remediation and release decisions.

109.2 Plain-English explanation

A control may look adequate on paper but fail in practice. Testing must confirm that the control is properly designed, implemented for the correct systems and versions, performed by authorized personnel, supported by reliable evidence, and effective over the period reviewed.

109.3 Testing requirements

A control test should define:

1. control objective and linked requirement or risk;
2. population, scope, systems, versions, actors, and period;
3. design-effectiveness criteria;
4. operating-effectiveness criteria;
5. sampling method and rationale;
6. expected evidence and source reliability;

7. tester competence, independence, and conflicts;
8. procedures, re-performance, observation, inquiry, inspection, or technical validation;
9. exception and severity criteria;
10. root-cause, impact, compensating-control, and remediation expectations;
11. retest and closure requirements;
12. reporting and escalation thresholds.

109.4 GlobalWay example

GlobalWay tests its human-oversight control by reviewing procedure design, training records, interface permissions, override and stop logs, sampled decisions, supervisor review, and evidence that unresolved high-severity exceptions blocked release or continued use.

109.5 Control activity

The assurance function must maintain an approved AI control-testing methodology, prioritize critical and high-risk controls, prevent self-review where independence is required, and track all exceptions through validated closure.

109.6 Evidence

- approved testing methodology;
- annual and event-driven test plans;
- populations and sample selections;
- workpapers and technical outputs;
- exception and severity records;
- management responses;
- remediation and retest evidence;
- final reports and closure approvals.

109.7 Audit test

Inspect a sample of completed control tests. Confirm that scope, population, sampling, evidence, procedures, conclusions, severity, remediation, and retesting were supportable and that unresolved critical failures affected deployment or risk decisions.

109.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable quality-management, risk-management, conformity, human-oversight, robustness, cybersecurity, monitoring, incident, and corrective-action provisions.
- Internal testing does not replace conformity assessment, notified-body involvement, or authority review where legally required.
- Current consolidated EUR-Lex text controls over older summaries.

110 Chapter 109 — Deficiency Classification

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 109 draft language.

110.1 Requirement

AI control deficiencies, legal nonconformities, documentation gaps, incidents, and adverse outcomes must be classified consistently according to impact, likelihood, legal significance, affected persons, system criticality, duration, scope, detectability, and remediation urgency.

110.2 Plain-English explanation

Not every issue has the same consequence. A missing document label differs from a failed safeguard affecting employment decisions. Classification must support prompt escalation, proportionate remediation, regulatory analysis, release decisions, and transparent management reporting.

110.3 Classification factors

Assess at minimum:

1. applicable legal obligation and regulated actor;
2. affected system, model, version, process, and jurisdiction;
3. actual and potential harm to health, safety, fundamental rights, privacy, or other protected interests;
4. number and vulnerability of affected persons;
5. duration, recurrence, and geographic reach;
6. control criticality and availability of compensating controls;
7. data integrity, security, bias, performance, or transparency consequences;

8. incident-reporting, corrective-action, conformity, or authority-notification implications;
9. probability of continued or expanded impact;
10. remediation complexity and time sensitivity;
11. management awareness, prior occurrence, and overdue status;
12. evidence quality and residual uncertainty.

110.4 Severity model

The organization may use categories such as critical, high, moderate, and low, but definitions must be approved, consistently applied, and linked to mandatory escalation, remediation, validation, and risk-acceptance rules.

110.5 GlobalWay example

GlobalWay classifies a recruitment-system subgroup disparity combined with ineffective human review as high severity because it may affect employment opportunities and fundamental rights. The system is restricted while the affected population, root cause, and remediation are assessed.

110.6 Control activity

AI Governance, Legal, Risk, Security, Privacy, and relevant business owners must use a common deficiency taxonomy. Critical and high issues require prompt executive escalation, documented interim safeguards, legal reporting analysis, and independent closure validation.

110.7 Evidence

- approved severity methodology;
- deficiency and nonconformity register;
- impact and legal analysis;
- affected-system and population records;
- compensating-control decisions;
- escalation and notification records;
- remediation plans and due dates;
- retest and closure approvals.

110.8 Audit test

Select deficiencies across severity levels. Confirm that classification considered the required factors, similar issues received consistent treatment, escalation and deadlines matched severity, legal reporting was assessed, and closure was independently validated where required.

110.9 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable noncompliance, risk-management, monitoring, incident, corrective-action, market-surveillance, and penalty provisions.
- Applicable privacy, cybersecurity, product-safety, employment, consumer-protection, and sector-notification law.
- Current consolidated official texts control over older summaries.

111 Chapter 110 — Corrective Action Management

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 110 draft language.

111.1 Requirement

Organizations must manage AI corrective actions through a documented process that contains immediate risk, determines root cause and affected scope, assigns accountable owners, establishes deadlines, validates remediation, updates related controls and documentation, and prevents recurrence.

111.2 Plain-English explanation

Closing an issue means more than recording that work was completed. The organization must show that harm or exposure was contained, the true cause was addressed, affected systems and people were considered, the fix worked, and related processes were updated.

111.3 Corrective-action requirements

Each action record should include:

1. deficiency, incident, complaint, audit finding, or regulatory trigger;
2. affected systems, models, versions, data, suppliers, decisions, and jurisdictions;
3. immediate containment and interim safeguards;
4. legal, reporting, conformity, and affected-person analysis;
5. root-cause and contributing-factor analysis;
6. remediation tasks, accountable owners, resources, and deadlines;
7. validation criteria and independent reviewer;
8. regression, bias, safety, privacy, security, and performance testing as relevant;

9. updates to risk assessments, technical documentation, controls, procedures, training, notices, and contracts;
10. residual-risk and risk-acceptance decision;
11. retest, closure approval, and monitoring period;
12. lessons learned and recurrence prevention.

111.4 GlobalWay example

After identifying unexplained ranking disparities in a recruitment system, GlobalWay suspends automated recommendations, preserves evidence, assesses affected applicants, corrects data and model issues, strengthens human review, retests subgroup outcomes, updates documentation and training, and monitors the remediated release before full restoration.

111.5 Control activity

The corrective-action process must prioritize issues by severity, prohibit unsupported deadline extensions, escalate overdue high-risk actions, require evidence-based closure, and reopen actions when validation fails or recurrence occurs.

111.6 Evidence

- corrective-action register;
- containment and impact records;
- root-cause analysis;
- remediation plan and ownership;
- test and validation evidence;
- updated documentation and controls;
- risk-acceptance and approval records;
- closure and post-remediation monitoring.

111.7 Audit test

Select corrective actions, including overdue and closed items. Confirm that containment was timely, root cause was supportable, scope was complete, remediation addressed the cause, testing verified effectiveness, related artifacts were updated, and closure authority was appropriate.

111.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable provider, deployer, monitoring, serious-incident, corrective-action, withdrawal,

recall, market-surveillance, quality-management, and documentation provisions.

- Applicable privacy, cybersecurity, product-safety, employment, consumer-protection, and sector requirements.
- Current consolidated official texts control over older summaries.

112 Chapter 111 — Continuous Compliance Monitoring

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 111 draft language.

112.1 Requirement

Organizations must continuously monitor material AI systems, models, controls, suppliers, legal obligations, and operational outcomes so that emerging nonconformity, degradation, incidents, rights impacts, security weaknesses, and regulatory changes are identified and addressed promptly.

112.2 Plain-English explanation

Compliance is not a one-time approval. AI systems, data, models, users, vendors, and laws change. Monitoring must therefore detect when the approved assumptions no longer match actual operation.

112.3 Monitoring requirements

The monitoring framework should cover:

1. system and model version, configuration, and intended-purpose changes;
2. performance, accuracy, robustness, safety, bias, and subgroup outcomes;
3. human-oversight activity, overrides, escalations, and override effectiveness;
4. transparency notices, user understanding, complaints, and contestability;
5. privacy, data quality, retention, security, vulnerabilities, and access anomalies;
6. supplier changes, incidents, assurance results, and service deterioration;
7. logging completeness, evidence integrity, and record retention;
8. legal, regulatory, standards, and guidance changes;

9. control operation, exceptions, overdue actions, and repeated failures;
10. post-market data, incidents, near misses, and corrective-action effectiveness.

112.4 GlobalWay example

GlobalWay monitors its recruitment-screening service for subgroup outcome drift, reviewer override patterns, supplier model changes, complaint trends, logging failures, security events, and changes to legal requirements. Threshold breaches trigger investigation and possible suspension.

112.5 Control activity

Each material AI system must have approved monitoring indicators, thresholds, owners, review frequency, data sources, escalation paths, and response actions. Monitoring evidence must be linked to the exact system and version and reviewed by accountable personnel.

112.6 Evidence

- monitoring plan and metric catalogue;
- dashboards and source-data records;
- threshold and alert configuration;
- review and escalation records;
- incidents, complaints, and near-miss records;
- supplier and regulatory-change monitoring;
- corrective actions and validation;
- periodic monitoring-effectiveness review.

112.7 Audit test

Select material AI systems. Verify that monitoring covers legal and operational risk, data is reliable and version-linked, thresholds are justified, alerts are reviewed promptly, escalations are documented, and identified issues result in appropriate action.

112.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable quality-management, risk-management, logging, deployer, provider, post-market-monitoring, serious-incident, corrective-action, and market-surveillance provisions.
- Current consolidated official texts control over older summaries.

113 Chapter 112 — Audit Planning

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 112 draft language.

113.1 Requirement

AI audit planning must be risk-based, independent, evidence-driven, and aligned to applicable legal duties, actor roles, system classifications, lifecycle stages, jurisdictions, suppliers, incidents, and prior findings. The audit universe must include systems and models rather than relying only on organizational processes.

113.2 Plain-English explanation

An effective audit plan answers what will be reviewed, why it matters, which legal and operational criteria apply, what evidence is needed, who will perform the work, and how coverage gaps will be managed.

113.3 Planning requirements

The audit plan should define:

1. the AI audit universe and system inventory linkage;
2. legal roles, classifications, jurisdictions, and applicable requirements;
3. inherent and residual risk, materiality, and prior assurance results;
4. scope, objectives, criteria, exclusions, and limitations;
5. lifecycle stages, versions, vendors, and data flows in scope;
6. required technical, legal, privacy, security, and operational competence;
7. independence, conflicts, and use of specialists;
8. sampling strategy, evidence sources, and testing methods;
9. schedule, milestones, reporting routes, and escalation triggers;
10. coordination with conformity assessment, regulatory review, privacy, security, and external assurance;
11. treatment of open issues, incidents, complaints, and regulatory change;
12. quality review and approval of the audit programme.

113.4 GlobalWay example

GlobalWay prioritizes audits of recruitment, traveler-assistance, and fraud-detection systems based on classification, affected-person impact, supplier

dependency, incident history, model change, and control maturity. The plan assigns legal, privacy, security, and data-science specialists where needed.

113.5 Control activity

Internal Audit must maintain a documented rolling AI audit programme approved by appropriate governance. Coverage decisions and deferrals must be justified, risk accepted where necessary, and revisited after major incidents, material changes, or legal developments.

113.6 Evidence

- AI audit universe;
- risk assessment and prioritization model;
- approved annual and rolling audit plans;
- engagement scope and criteria;
- competency and independence records;
- sampling and test strategy;
- coordination and reliance assessments;
- coverage-gap and deferral approvals.

113.7 Audit test

Review the audit planning process. Confirm that the universe is complete, prioritization reflects actual AI risk, scope links to legal criteria and system versions, required competence is available, exclusions are justified, and material gaps are escalated.

113.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable governance, quality-management, conformity, documentation, monitoring, incident, corrective-action, and authority-review provisions.
- Internal audit does not replace legally required conformity assessment, notified-body involvement, or competent-authority review.

114 Chapter 113 — Design Effectiveness Testing

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 113 draft language.

114.1 Requirement

Design effectiveness testing must determine whether each AI control, individually and collectively, is suitably designed to prevent, detect, correct,

or escalate the relevant legal and operational risk when implemented as intended.

114.2 Plain-English explanation

A control can exist on paper and still be incapable of achieving its purpose. Design testing examines whether the control has the right trigger, owner, authority, inputs, logic, frequency, evidence, escalation, and relationship to other controls.

114.3 Design-testing requirements

For each control, assess:

1. the legal duty, risk, or objective addressed;
2. scope across systems, models, versions, actors, and jurisdictions;
3. trigger, frequency, timing, and preventive or detective nature;
4. accountable owner, competence, authority, and segregation of duties;
5. required inputs, data quality, tools, and dependencies;
6. decision criteria, thresholds, exceptions, and escalation paths;
7. retained evidence and traceability;
8. linkage to upstream and downstream controls;
9. ability to address foreseeable misuse, change, failure, and incident conditions;
10. alignment with policies, technical documentation, contracts, and operating procedures.

114.4 GlobalWay example

GlobalWay tests the design of its high-risk recruitment-system release gate. The review confirms that classification, risk management, data governance, human oversight, testing, supplier evidence, and legal approval are mandatory inputs and that unresolved critical issues block deployment.

114.5 Control activity

Control owners must document control objectives and design attributes before implementation. Independent reviewers must challenge whether the control could achieve the intended outcome under normal, changed, and failure conditions.

114.6 Evidence

- control description and objective;
- legal and risk mapping;

- process flow and decision logic;
- RACI and competency requirements;
- thresholds and escalation design;
- evidence specification;
- dependency and failure-mode analysis;
- design review and approval.

114.7 Audit test

Select key controls. Trace each to the relevant legal duty and risk, inspect the documented design, walk through normal and exception scenarios, and determine whether the control could reasonably achieve its stated objective if operated as designed.

114.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable quality-management, risk-management, data-governance, documentation, human-oversight, accuracy, robustness, cybersecurity, monitoring, incident, and corrective-action provisions.
- Current consolidated official texts control over older summaries.

115 Chapter 114 — Operating Effectiveness Testing

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 114 draft language.

115.1 Requirement

Operating effectiveness testing must determine whether AI controls operated consistently, completely, accurately, timely, and by authorized competent personnel throughout the period under review.

115.2 Plain-English explanation

A well-designed control may fail in practice. Operating testing examines actual transactions, releases, decisions, incidents, changes, and records to confirm that the control worked repeatedly and that exceptions were handled properly.

115.3 Testing requirements

The tester should evaluate:

1. the defined review period and relevant population;
2. completeness and reliability of the population used for sampling;

3. evidence that the control operated at the required frequency;
4. timeliness, accuracy, and completeness of execution;
5. performer authorization, competence, and independence;
6. application of thresholds, approvals, and escalation rules;
7. treatment of exceptions, overrides, failures, and missing evidence;
8. consistency across systems, models, versions, vendors, and jurisdictions;
9. remediation and retesting of identified failures;
10. whether compensating controls operated where the primary control failed.

115.4 GlobalWay example

GlobalWay tests a sample of AI release approvals over six months. The tester verifies that every sampled release used the approved model version, completed required legal and technical reviews, resolved blocking issues, obtained authorized approval, and retained evidence before production deployment.

115.5 Control activity

Control owners must retain evidence sufficient to reconstruct operation. Independent testers must use reliable populations, defensible samples, clear exception criteria, and documented conclusions supported by the evidence reviewed.

115.6 Evidence

- population and completeness validation;
- sample-selection record;
- executed control evidence;
- timestamps, approvals, and reviewer identity;
- exception and escalation records;
- compensating-control evidence;
- remediation and retest results;
- testing conclusion and quality review.

115.7 Audit test

Select key controls and independently validate the population. Test a risk-based sample across the review period, document all deviations, assess whether failures are isolated or systemic, and determine whether the control operated effectively.

115.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable quality-management, documentation, recordkeeping, risk-management, monitoring, incident, corrective-action, and governance provisions.
- Current consolidated official texts control over older summaries.

116 Chapter 115 — Sampling and Evidence Evaluation

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 115 draft language.

116.1 Requirement

Organizations conducting internal audit, compliance testing, control assurance, conformity-readiness review, or regulatory-response testing should use a documented, risk-based sampling and evidence-evaluation methodology capable of producing sufficient, reliable, relevant, and reproducible support for their conclusions. Where sampling supports a statutory obligation, conformity assessment, notified-body review, competent-authority request, or other legally required assurance activity, the methodology must be appropriate to that purpose and must not restrict access to records required by law.

116.2 Plain-English explanation

A small or convenient sample can create false confidence. The reviewer must understand the full population, select items using a defensible method, evaluate evidence quality, and consider whether identified deviations indicate broader failure. The detailed sampling methods in this chapter are assurance practices; they are not presented as a standalone sampling formula imposed directly by the EU AI Act.

116.3 Sampling requirements

The methodology should address:

1. the audit objective, legal duty, control, and assertion being tested;
2. population definition, completeness, and accuracy;
3. period, systems, models, versions, roles, jurisdictions, suppliers, incidents, and known exceptions covered;

4. risk-based, statistical, random, targeted, or judgmental selection method;
5. sample size and rationale;
6. inclusion of high-risk, unusual, failed, changed, overridden, complained-about, or incident-related items;
7. treatment of missing, contradictory, altered, inaccessible, or unverifiable evidence;
8. extrapolation limits and evaluation of deviation rates;
9. expansion criteria when failures are found or population reliability cannot be established;
10. documentation sufficient for independent reperformance;
11. preservation of source evidence and version linkage;
12. escalation where the sample cannot support the intended conclusion.

116.4 Evidence-quality criteria

Evidence should be evaluated for source, authenticity, integrity, date, version linkage, completeness, consistency, reviewer independence, relevance to the control or legal statement tested, and reproducibility. Evidence retained for legal, conformity, incident, monitoring, or authority-access purposes must also satisfy the applicable recordkeeping, accessibility, retention, and confidentiality requirements.

116.5 GlobalWay example

GlobalWay tests human-oversight controls across recruitment decisions. The sample includes routine approvals, overrides, adverse outcomes, complaints, different model versions, multiple business units, and decisions made after a supplier update. When two exceptions reveal that a new model version bypassed the approved escalation rule, GlobalWay expands the sample, preserves the relevant logs, suspends the affected workflow, and initiates corrective action.

116.6 Control activity

Assurance teams must validate populations before sampling, document selection logic, preserve source evidence, and expand testing when exceptions suggest systemic weakness or when population reliability cannot be established. Sampling must never be used to avoid producing records that a competent authority, notified body, market-surveillance authority, or other legally entitled reviewer may require.

116.7 Evidence

- population definition and validation;

- sampling plan and rationale;
- selected-item list;
- source evidence and integrity checks;
- version and release linkage;
- exception and root-cause analysis;
- expanded testing where required;
- conclusion and reviewer sign-off;
- workpaper quality review;
- escalation and corrective-action records.

116.8 Audit test

Inspect a sample-based assurance engagement. Confirm that the population was complete, the selection method matched the risk and objective, evidence was reliable and version-linked, exceptions were evaluated and expanded appropriately, conclusions did not exceed the evidence, and the methodology did not limit legally required record access.

116.9 Primary legal references

- Regulation (EU) 2024/1689, as amended, including Articles 11, 12, 17, 18, 19, 43, 72, 74, 78, and 79, and Annex IV, as applicable to the actor, system, assurance activity, and legal trigger.
- Regulation (EU) 2026/1744, where its amendments affect the applicable AI Act obligations, dates, or procedures.
- Applicable conformity-assessment, notified-body, market-surveillance, competent-authority, privacy, cybersecurity, product-safety, employment, consumer-protection, and sector-specific requirements.
- The sampling methodology in this chapter is an assurance practice and is not a standalone statutory sampling formula prescribed by the AI Act.
- Current consolidated EUR-Lex text controls over older summaries and drafts.

117 Chapter 116 — Technical Validation

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 116 draft language.

117.1 Requirement

Providers of high-risk AI systems must establish and document validation and testing appropriate to the system's intended purpose and risks, including the information required by Article 11 and Annex IV and the performance, robustness, cybersecurity, and human-oversight requirements applicable to the system. Other organizations developing, procuring, integrating, or deploying material AI systems should apply proportionate technical validation before release and after material change so they can demonstrate that the production configuration operates within approved boundaries and that their own legal and operational duties can be met.

117.2 Plain-English explanation

The EU AI Act does not impose one universal validation procedure on every AI system and actor. The exact duty depends on classification and role. For high-risk AI systems, providers must maintain risk management, technical documentation, testing, accuracy, robustness, cybersecurity, and quality-management evidence. Deployers and other value-chain actors need sufficient validation evidence to use the system according to instructions, exercise oversight, monitor operation, and reassess changes. Validation should test the actual production configuration, not only a laboratory prototype.

117.3 Validation requirements

The validation plan should address, as applicable:

1. the regulated actor, classification, intended purpose, and legal trigger;
2. system, model, data, prompt, tool, software, firmware, and configuration version;
3. foreseeable misuse and reasonably foreseeable operating conditions;
4. accuracy, robustness, reliability, consistency, and error boundaries;
5. representative and context-appropriate test data and performance metrics;
6. subgroup, accessibility, and context-specific performance where relevant;
7. human-oversight, override, stop, escalation, and safe-failure controls;
8. cybersecurity, abuse, leakage, manipulation, and dependency resistance;
9. logging, traceability, monitoring, evidence capture, and version linkage;

10. integration, latency, availability, failover, and degraded-mode behaviour;
11. acceptance criteria, unresolved limitations, corrective action, and residual risk;
12. independent review and authorized release decision.

117.4 GlobalWay example

GlobalWay validates a travel-disruption recommendation system using production-equivalent data, degraded network conditions, unusual itineraries, multilingual inputs, human-override scenarios, and supplier-failure simulations. It records the provider and deployer roles, the production version tested, applicable instructions, limitations, acceptance criteria, unresolved deviations, and the basis for release.

117.5 Control activity

A high-risk AI system must not be released by its provider until the applicable risk-management, documentation, testing, conformity, and quality-management requirements are satisfied. GlobalWay must not place any material AI system into production until it has obtained and evaluated validation evidence sufficient for its actual role, intended use, oversight responsibilities, and risk. Material changes require proportionate reassessment and, where applicable, revalidation and renewed conformity activity.

117.6 Evidence

- legal-role and classification assessment;
- approved validation plan;
- version and configuration record;
- test data, representativeness rationale, and environment description;
- metrics, test results, logs, and defect records;
- acceptance criteria, limitations, and exceptions;
- independent review and approval;
- conformity and release evidence where applicable;
- post-release monitoring and revalidation records.

117.7 Audit test

Select released systems and significant changes. Confirm that validation covered the actual production version, matched the actor and classification, used appropriate data and metrics, tested relevant legal and operational

risks, documented limitations and deviations, and linked the results to conformity, release, monitoring, and reassessment decisions as applicable.

117.8 Primary legal references

- Regulation (EU) 2024/1689, as amended, including Articles 9–15, 16–18, 26, 43, 72, and Annex IV, as applicable.
- Regulation (EU) 2026/1744, where its amendments affect the relevant requirements, application dates, or procedures.
- Applicable harmonised standards and common specifications, when legally available and relevant; otherwise they must not be described as binding law merely because they are useful validation references.
- Current consolidated EUR-Lex text controls over older summaries and drafts.

118 Chapter 117 — Bias, Oversight, and Transparency Testing

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 117 draft language.

118.1 Requirement

Organizations must test bias, human oversight, and transparency to the extent required by their legal role, the AI system’s classification, intended purpose, affected persons, and applicable law. Providers of high-risk AI systems must address data-governance, risk-management, accuracy, human-oversight, transparency, and technical-documentation duties. Deployers must operate systems according to instructions, assign competent human oversight, monitor use, retain relevant logs where applicable, and meet any transparency, fundamental-rights, employment, equality, accessibility, consumer-protection, and data-protection obligations that apply to the use case.

118.2 Plain-English explanation

The EU AI Act does not create a single universal “bias test” for every AI system. It requires different controls depending on actor and risk. A system can appear accurate overall while performing poorly for particular groups or contexts. Human review may exist on paper but fail because reviewers lack time, authority, information, competence, or practical ability to intervene. Transparency can also fail if notices are inaccurate, late, inaccessible, or inconsistent with actual system behaviour.

118.3 Testing requirements

Test, as applicable:

1. the actor, classification, intended purpose, population, and legal trigger;
2. relevance, representativeness, completeness, and suitability of data and test populations;
3. overall and subgroup performance, error distribution, and context-specific failure;
4. proxy variables, indirect discrimination, accessibility barriers, and foreseeable disparate impact;
5. reviewer competence, workload, information, authority, automation bias, and conflicts;
6. override, escalation, stop, appeal, contestability, and safe-fallback mechanisms;
7. disclosure timing, wording, language, accessibility, and delivery channel;
8. consistency between notices, instructions for use, technical documentation, actual operation, and logs;
9. material limitations, foreseeable misuse, and unsupported uses;
10. remediation, retesting, residual-risk treatment, and release or continued-use decisions.

118.4 GlobalWay example

GlobalWay tests a recruitment-screening system across job families, languages, age ranges, disability-related accommodations, and relevant applicant groups. It also observes whether recruiters understand the system's limitations, challenge recommendations when appropriate, use the override and escalation routes, and provide applicants with legally appropriate information and a practical review process. GlobalWay separately evaluates whether GDPR, equality, employment, and accessibility requirements apply.

118.5 Control activity

Providers and deployers must perform the testing and monitoring necessary for their respective obligations. GlobalWay requires documented bias, oversight, and transparency testing before release or deployment of systems with material human or fundamental-rights impact and after significant changes to data, model, purpose, population, workflow, instructions, or notice design. A failed test must trigger containment, corrective action, reassessment, and retesting before release or continued use unless an authorized and legally supportable interim measure is documented.

118.6 Evidence

- legal-role, classification, and use-case assessment;
- test plan and population rationale;
- data-quality and representativeness evidence;
- overall, subgroup, and outcome metrics;
- oversight simulations and operating observations;
- notice, instruction, accessibility, and comprehension tests;
- limitations, exceptions, and complaints;
- remediation and retest results;
- approval, escalation, and residual-risk records.

118.7 Audit test

Select systems with material human or fundamental-rights impact. Confirm that testing matched the actor and legal trigger, used relevant populations and scenarios, assessed operating effectiveness rather than design alone, documented disparities and oversight failures, tested legally required transparency and accessibility, and verified remediation before release or continued use.

118.8 Primary legal references

- Regulation (EU) 2024/1689, as amended, including Articles 4, 9, 10, 13–15, 26, 27, 50, 72, and 86, as applicable.
- Regulation (EU) 2016/679, including Articles 5, 12–15, 21, 22, 25, and 35–36, where personal data, profiling, or automated decision-making is involved.
- Applicable equality, employment, accessibility, consumer-protection, and sector-specific law.
- Regulation (EU) 2026/1744, where its amendments affect the relevant AI Act obligations or application dates.
- Testing methods in this chapter are operational assurance practices and must not be misrepresented as one universal statutory testing formula.
- Current consolidated official texts control over older summaries and drafts.

119 Chapter 118 — Conformity Readiness Reviews

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 118 draft language.

119.1 Requirement

Providers of high-risk AI systems must complete the conformity-assessment procedure applicable to the system before placing it on the market or putting it into service, subject to the relevant application dates and transitional rules. Internal conformity-readiness reviews should verify that the provider has identified the correct legal route and assembled complete, current, version-linked evidence for the applicable high-risk requirements, quality-management system, technical documentation, declaration, registration, marking, post-market monitoring, and value-chain obligations.

119.2 Plain-English explanation

A readiness review is an internal control. It does not replace the legally required conformity assessment, notified-body involvement, product-sector procedure, market-surveillance review, or competent-authority decision. Its purpose is to identify gaps before formal assessment or release and to prevent a system from being presented as conforming when the applicable legal process has not been completed.

119.3 Review requirements

Confirm, as applicable:

1. provider identity, authorized representative, product manufacturer, importer, distributor, and other relevant actor roles;
2. intended purpose, system version, high-risk classification, and whether Article 6(1), Article 6(2), Annex I, or Annex III applies;
3. the applicable conformity route under Article 43, including whether sectoral product legislation or notified-body involvement applies;
4. the applicable date, transition, and amendment position under Article 113 and Regulation (EU) 2026/1744;
5. compliance with Articles 9–15 and the provider obligations in Articles 16–18, where applicable;
6. quality-management, risk-management, data-governance, technical-documentation, logging, instructions, oversight, accuracy, robustness, and cybersecurity evidence;
7. validation and testing evidence linked to the production version;
8. EU declaration of conformity, CE marking, and registration readiness where legally required;

9. post-market monitoring, serious-incident, corrective-action, and record-retention arrangements;
10. value-chain information, contractual support, and authorized-representative evidence;
11. unresolved nonconformities, deviations, corrective actions, and residual-risk decisions;
12. formal approval to submit for conformity assessment or release after completion of the legally required process.

119.4 GlobalWay example

Before releasing a high-risk employee-allocation system under its own name, GlobalWay confirms that it has assumed the provider role. It identifies whether the system falls under Annex III, confirms the applicable conformity route and date, verifies Annex IV documentation, QMS and testing evidence, completes registration and declaration steps where applicable, and establishes post-market monitoring before release.

119.5 Control activity

Compliance must operate a documented readiness gate before any high-risk system is submitted for conformity assessment or released. Missing mandatory evidence, an unresolved actor or classification question, an incorrect conformity route, or incomplete legally required assessment is a release blocker. Internal approval must not be described as certification or conformity assessment unless it has the legal status required by the applicable procedure.

119.6 Evidence

- actor, classification, and applicability analysis;
- conformity-route and application-date memorandum;
- readiness checklist;
- technical-documentation index and Annex IV mapping;
- QMS, risk-management, testing, and validation evidence;
- instructions, logs, oversight, and monitoring evidence;
- notified-body or sectoral-assessment records where applicable;
- declaration, registration, and marking records;
- gap log, corrective action, and closure evidence;
- release and post-market approval.

119.7 Audit test

Select high-risk releases. Confirm that the readiness review identified the correct actor, classification, route, and application date; did not substitute for required external or sectoral assessment; tested complete and version-linked evidence; and blocked release until mandatory gaps and conformity steps were resolved.

119.8 Primary legal references

- Regulation (EU) 2024/1689, as amended, including Articles 6, 9–18, 22, 43, 47–49, 71–73, 113, Annexes I, III, IV, VI, and VII, as applicable.
- Regulation (EU) 2026/1744, including amendments affecting application dates, scope, and procedures.
- Applicable Union harmonisation legislation listed in Annex I and related sectoral conformity-assessment requirements.
- Harmonised standards and common specifications must be identified by their actual legal status and availability; internal readiness criteria must not be presented as binding law by themselves.
- Current consolidated EUR-Lex text controls over older summaries and drafts.

120 Chapter 119 — Internal Audit

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 119 draft language.

120.1 Requirement

The EU AI Act does not impose a universal standalone internal-audit function on every organization. Organizations that maintain internal audit, independent assurance, or comparable third-line review should use it to provide risk-based assurance over AI governance, legal compliance, control design, operating effectiveness, evidence quality, issue management, and management reporting. Internal audit must remain independent of the activities it reviews and does not replace conformity assessment, notified-body involvement, competent-authority oversight, market-surveillance powers, provider or deployer obligations, or management accountability.

120.2 Plain-English explanation

Internal audit should test whether the AI control environment actually works, not merely whether policies exist. Its scope and sampling should reflect legal role, system classification, jurisdiction, lifecycle stage, supplier dependency, affected persons, incidents, complaints, changes, and prior findings. The existence of a strong internal-audit programme can support

governance and evidence quality, but it does not by itself prove legal conformity.

120.3 Audit requirements

Define, as appropriate:

1. an approved mandate, organizational independence, and unrestricted access to relevant evidence, subject to lawful confidentiality and privilege controls;
2. competent multidisciplinary staffing and access to technical, legal, privacy, security, accessibility, and sector specialists;
3. a risk-based AI audit universe and plan;
4. coverage of systems, models, versions, actor roles, jurisdictions, suppliers, and lifecycle stages;
5. design-effectiveness and operating-effectiveness methods;
6. population validation, defensible sampling, and evidence-quality criteria;
7. technical validation, reproducibility, and specialist review where needed;
8. issue grading, root-cause analysis, escalation, and management response;
9. remediation tracking and independent closure validation;
10. reporting to the board, audit committee, or other appropriate governance body;
11. follow-up, quality assurance, and periodic programme improvement;
12. escalation where management restricts scope, evidence access, or timely remediation.

120.4 GlobalWay example

GlobalWay Internal Audit samples high-risk recruitment, traveler-assistance, and fraud systems. It tests actor and classification decisions, provider and deployer controls, vendor evidence, human oversight, logging, monitoring, transparency, incidents, and corrective-action closure. It separately confirms that its work does not substitute for any required conformity assessment or authority review.

120.5 Control activity

The audit committee approves a risk-based AI audit plan and receives significant findings, overdue remediation, accepted residual risk, recurring

control-failure trends, scope limitations, and unresolved legal uncertainty. Management must preserve ownership of compliance and remediation even where Internal Audit provides assurance.

120.6 Evidence

- audit charter, independence statement, and plan;
- AI audit universe and risk assessment;
- competence, specialist-support, and conflict records;
- workpapers, population validation, and sampling rationale;
- findings, legal basis, and reports;
- management responses and action plans;
- remediation and independent closure validation;
- audit-committee or board reporting;
- scope-limitation and escalation records;
- internal quality-assurance review.

120.7 Audit test

Review the internal-audit programme. Confirm that its mandate and reporting line support independence, its scope reflects actual AI risks and regulated roles, its evidence and sampling are sufficient, its reviewers have appropriate competence, significant issues are escalated, and closure is independently validated. Confirm that reports do not describe internal audit as replacing conformity assessment, notified-body review, or regulatory oversight.

120.8 Primary legal references

- Regulation (EU) 2024/1689, as amended, including applicable provisions on quality management, technical documentation, recordkeeping, conformity assessment, post-market monitoring, corrective action, cooperation, and authority access.
- Regulation (EU) 2026/1744, where its amendments affect the relevant obligations, procedures, or dates.
- Professional internal-audit and assurance standards are non-binding unless incorporated through another binding legal, contractual, or sector requirement.
- The internal-audit framework in this chapter is a governance and assurance practice, not a universal standalone function expressly mandated by the AI Act.

- Current consolidated official texts control over older summaries and drafts.

121 Chapter 120 — Regulatory Examination Readiness

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 120 draft language.

121.1 Requirement

Organizations subject to the EU AI Act must be able to provide competent authorities, market-surveillance authorities, the AI Office, and other legally authorized bodies with the information, records, access, explanations, and cooperation required by applicable law. Examination-readiness practices in this chapter are governance measures that support those duties; they are not a separate statutory examination regime.

121.2 Plain-English explanation

A regulator may request documents, logs, technical evidence, incident records, risk assessments, explanations, access to systems, or cooperation with testing. The organization should be able to respond accurately, securely, consistently, and within the applicable legal timeframe without improvising or providing incomplete or contradictory evidence.

121.3 Readiness requirements

Maintain at minimum:

1. a current map of legal entities, AI roles, systems, models, versions, and jurisdictions;
2. named regulatory-response owners and alternates;
3. a verified index of technical documentation, logs, declarations, registrations, monitoring records, incidents, complaints, corrective actions, and contracts;
4. procedures for preserving privilege, confidentiality, trade secrets, personal data, and security-sensitive information while meeting disclosure duties;
5. evidence-integrity, chain-of-custody, version-control, and legal-hold procedures;
6. authority and identity verification before disclosure;
7. secure transfer, access, and audit-trail controls;

8. fact-checking, legal review, and executive approval of submissions where appropriate;
9. procedures for interviews, demonstrations, on-site access, testing, and follow-up questions;
10. issue escalation when records are missing, inconsistent, inaccessible, or potentially inaccurate;
11. post-examination corrective actions and lessons learned.

121.4 GlobalWay example

GlobalWay receives an information request concerning a high-risk employee-allocation system. Its response team verifies the authority, preserves relevant records, assembles the version-linked technical file, logs, monitoring results, incident history, supplier evidence, and release approvals, and documents every disclosure and follow-up action.

121.5 Control activity

Compliance and Legal must maintain a tested regulatory-response procedure and conduct periodic readiness exercises for material AI systems. Exercises must verify evidence availability, response ownership, secure disclosure, factual consistency, and escalation of unresolved gaps.

121.6 Evidence

- regulatory-response procedure and responsibility matrix;
- authority-verification record;
- evidence and disclosure index;
- legal-hold and preservation records;
- submission approvals and correspondence;
- secure-transfer and access logs;
- interview and demonstration preparation records;
- gap log, corrective actions, and lessons learned.

121.7 Audit test

Inspect prior authority requests and readiness exercises. Confirm that the organization verified authority, preserved and produced accurate version-linked evidence, protected legally sensitive information appropriately, met applicable deadlines, and remediated identified weaknesses.

121.8 Primary legal references

- Regulation (EU) 2024/1689, as amended by Regulation (EU) 2026/1744 where applicable: provisions on documentation, records, logs, registration, market surveillance, authority powers, access to data and documentation, testing, cooperation, investigations, and enforcement.
- Regulation (EU) 2016/679 and other applicable confidentiality, legal-professional-privilege, cybersecurity, employment, product-safety, and sector requirements.
- Current consolidated official texts control over older summaries.

122 Chapter 121 — Findings, Remediation, and Closure

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 121 draft language.

122.1 Requirement

Organizations must address identified nonconformities, control failures, incidents, complaints, authority observations, and other AI-related deficiencies through timely containment, root-cause analysis, proportionate remediation, validation, documentation updates, and accountable closure. The detailed workflow in this chapter is a governance and assurance practice unless a specific legal provision, authority decision, conformity-assessment obligation, contract, or sector rule makes a step mandatory.

122.2 Plain-English explanation

A finding is not closed merely because a task is marked complete. Closure requires evidence that the problem was contained, the cause was addressed, affected systems and people were considered, the correction worked, related documentation and controls were updated, and residual risk was accepted by the proper authority.

122.3 Remediation requirements

Each finding record should include:

1. source, date, severity, legal relevance, and affected obligation;
2. affected systems, models, versions, data, suppliers, decisions, people, and jurisdictions;
3. immediate containment and interim safeguards;
4. reportability, notification, withdrawal, recall, suspension, and affected-person analysis where applicable;

5. root cause and contributing factors;
6. corrective and preventive actions, owners, resources, and deadlines;
7. validation criteria, independent reviewer, and retest plan;
8. updates to risk assessments, technical documentation, logs, procedures, training, notices, contracts, and monitoring;
9. residual-risk and exception decision;
10. closure approval, monitoring period, and reopening criteria.

122.4 GlobalWay example

An audit finds that a recruitment system was operating with an unapproved model version. GlobalWay suspends automated recommendations, preserves evidence, assesses affected applicants, determines why change controls failed, restores the approved configuration, retests the system, updates documentation and supplier controls, and monitors the corrected release before closure.

122.5 Control activity

All material findings must be recorded in a controlled register, assigned to accountable owners, prioritized by risk, escalated when overdue, and closed only after evidence-based validation. High-risk and regulatory findings require independent closure review.

122.6 Evidence

- findings register;
- containment and impact records;
- root-cause analysis;
- remediation plan and approvals;
- validation and retest evidence;
- updated documentation and controls;
- residual-risk decision;
- closure approval and monitoring results.

122.7 Audit test

Select open, overdue, and closed findings. Confirm that severity was supportable, containment was timely, root cause and affected scope were complete, remediation addressed the cause, validation was independent where appropriate, related artifacts were updated, and closure did not occur before effectiveness was demonstrated.

122.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable provider, deployer, quality-management, monitoring, serious-incident, corrective-action, withdrawal, recall, market-surveillance, documentation, and authority-cooperation provisions.
- Applicable privacy, cybersecurity, product-safety, employment, consumer-protection, contractual, and sector requirements.
- Current consolidated official texts control over older summaries.

123 Chapter 122 — AI Office and National Authorities

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 122 draft language.

123.1 Requirement

Organizations must identify which EU and national authorities may have jurisdiction over their AI activities and must cooperate with those authorities to the extent required by applicable law. Internal authority-mapping and response procedures are governance practices that support legal compliance; they do not alter the statutory allocation of powers.

123.2 Plain-English explanation

Responsibility may involve the European Commission's AI Office, national competent authorities, market-surveillance authorities, data-protection authorities, product-safety regulators, sector regulators, labour authorities, consumer authorities, or courts. The correct authority depends on the AI role, system type, sector, jurisdiction, and issue.

123.3 Governance requirements

Maintain at minimum:

1. a jurisdiction and authority map for each material AI system;
2. identification of provider, deployer, importer, distributor, authorised representative, and GPAI roles;
3. named owners for regulatory correspondence and escalation;
4. procedures for verifying authority, mandate, and request scope;
5. coordination between Legal, Compliance, Privacy, Security, Product, HR, Procurement, and operational teams;
6. controls for consistent submissions across multiple authorities;

7. secure evidence preservation and disclosure;
8. tracking of deadlines, commitments, corrective actions, and follow-up requests;
9. procedures for conflicts of law, overlapping jurisdiction, and counsel escalation;
10. periodic review when laws, roles, products, or operating jurisdictions change.

123.4 GlobalWay example

GlobalWay maps responsibility for a recruitment system used in several Member States. It identifies the relevant national market-surveillance and labour authorities, data-protection authorities for personal-data issues, and the AI Office where GPAI-model obligations or Union-level coordination may be relevant.

123.5 Control activity

Legal and Compliance must maintain a current authority map and verify it before submitting notifications, registrations, incident reports, or responses. Uncertain jurisdiction must be escalated rather than guessed.

123.6 Evidence

- authority and jurisdiction register;
- legal-role assessments;
- regulatory-contact matrix;
- correspondence and submission log;
- authority-verification records;
- escalation and legal-advice records;
- corrective-action tracking;
- periodic review history.

123.7 Audit test

Select systems operating across multiple jurisdictions. Confirm that the organization identified relevant authorities based on actual roles and activities, routed submissions correctly, preserved consistent evidence, met applicable deadlines, and escalated uncertain or overlapping jurisdiction appropriately.

123.8 Primary legal references

- Regulation (EU) 2024/1689, as amended by Regulation (EU) 2026/1744 where applicable: provisions establishing the AI Office, European Artificial Intelligence Board, national competent authorities, market-surveillance functions, cooperation, supervision, and enforcement.
- Regulation (EU) 2019/1020 and other applicable Union and national supervisory frameworks.
- Current consolidated official texts and applicable national designation measures control over older summaries.

124 Chapter 123 — Market-Surveillance Authorities

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 123 draft language.

124.1 Requirement

Providers, deployers, importers, distributors, authorised representatives, and other relevant actors must cooperate with market-surveillance authorities to the extent required by the EU AI Act, Regulation (EU) 2019/1020, and applicable national law. Internal readiness controls in this chapter support those duties and do not limit an authority's statutory powers.

124.2 Plain-English explanation

Market-surveillance authorities may examine whether an AI system complies with applicable requirements, request records and information, obtain access, conduct evaluations or testing, require corrective action, restrict availability or use, or coordinate with other authorities. Organizations must be able to identify affected systems and versions, preserve evidence, and respond lawfully and accurately.

124.3 Readiness requirements

Maintain at minimum:

1. a current inventory of regulated AI systems and responsible economic operators;
2. applicable conformity, declaration, registration, marking, and post-market records;
3. technical documentation, logs, risk-management, QMS, monitoring, and incident evidence;
4. procedures for authority requests, access, testing, interviews, and site visits;

5. secure preservation and disclosure of records, including trade-secret and personal-data safeguards consistent with law;
6. rapid identification of affected models, system versions, customers, deployments, and jurisdictions;
7. corrective-action, suspension, withdrawal, recall, and communication procedures;
8. escalation for suspected noncompliance, serious incidents, or systemic risk;
9. tracking of authority directions, deadlines, commitments, and closure evidence;
10. coordination with notified bodies, suppliers, customers, and other authorities where legally relevant.

124.4 GlobalWay example

A national market-surveillance authority requests evidence for a high-risk employee-allocation system. GlobalWay verifies the request, preserves the relevant production version and logs, provides the technical file and monitoring evidence, coordinates with the provider and notified body where applicable, and tracks all corrective actions and deadlines.

124.5 Control activity

Compliance must maintain a tested market-surveillance response procedure. Material AI systems must have version-linked evidence packages and named response owners capable of supporting authority access, testing, corrective action, and communications.

124.6 Evidence

- system and economic-operator inventory;
- conformity and registration records;
- technical and post-market evidence index;
- authority correspondence and access logs;
- preservation and disclosure records;
- corrective-action and restriction records;
- customer and affected-person communications;
- closure and follow-up evidence.

124.7 Audit test

Inspect prior market-surveillance interactions or exercises. Confirm that affected systems and versions were identified, evidence was complete and accurate, disclosure was secure, authority directions were tracked, and corrective actions were implemented and validated within applicable timeframes.

124.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: market-surveillance, authority-access, testing, evaluation, cooperation, corrective-action, restriction, withdrawal, recall, and enforcement provisions.
- Regulation (EU) 2019/1020, as applicable.
- Current consolidated official texts and applicable national implementing or designation measures control over older summaries.

125 Chapter 124 — Investigations and Information Requests

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 124 draft language.

125.1 Requirement

Organizations must respond to legally valid investigations and information requests within the scope, manner, and timeframe required by applicable law. Internal investigation-response controls are governance practices that support accuracy, preservation, cooperation, confidentiality, and accountability; they do not narrow or expand an authority's statutory powers.

125.2 Plain-English explanation

An investigation may involve documents, logs, source information, model or system access, interviews, testing, explanations, incidents, complaints, contracts, or evidence about affected people. A rushed or uncoordinated response can create legal, factual, privacy, security, and credibility problems.

125.3 Response requirements

Maintain at minimum:

1. procedures to verify the requesting authority, legal basis, scope, deadline, and delivery method;
2. immediate preservation and legal-hold steps;

3. identification of affected systems, models, versions, data, suppliers, decisions, people, and jurisdictions;
4. a response team with Legal, Compliance, Privacy, Security, Technical, Records, and business representation;
5. fact collection, source verification, version control, and chain of custody;
6. controls for privilege, trade secrets, personal data, confidential business information, and security-sensitive material consistent with law;
7. secure disclosure, access logging, and submission approval;
8. procedures for interviews, demonstrations, technical testing, and follow-up questions;
9. escalation of missing, contradictory, inaccessible, or potentially inaccurate evidence;
10. tracking of commitments, corrective actions, deadlines, and post-investigation monitoring.

125.4 GlobalWay example

GlobalWay receives a request concerning alleged discrimination in a recruitment-screening system. It preserves the relevant model versions, applicant records, logs, human-review evidence, supplier documentation, complaints, and validation results; verifies the facts; coordinates lawful disclosure; and records every submission and follow-up action.

125.5 Control activity

Legal and Compliance must control all formal investigation responses. No employee may provide unverified technical, legal, or factual representations on behalf of the organization outside the approved response process.

125.6 Evidence

- request and authority-verification record;
- legal hold and preservation log;
- evidence collection and chain-of-custody record;
- fact and issue chronology;
- review and approval records;
- submission package and secure-transfer logs;
- interview and testing records;

- commitments, corrective actions, and closure evidence.

125.7 Audit test

Inspect prior investigations or simulated requests. Confirm that the organization verified authority and scope, preserved evidence promptly, produced accurate version-linked information, protected sensitive material appropriately, met applicable deadlines, and tracked commitments and remediation to closure.

125.8 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable authority powers, access to documentation and data, testing, investigation, cooperation, market-surveillance, monitoring, incident, corrective-action, and enforcement provisions.
- Regulation (EU) 2019/1020 and applicable national procedural law.
- Regulation (EU) 2016/679 and other applicable confidentiality, cybersecurity, privilege, employment, product-safety, and sector requirements.
- Current consolidated official texts control over older summaries.

126 Chapter 125 — Administrative Fines and Exposure

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 125 draft language.

126.1 Requirement

Organizations must understand and govern exposure to administrative fines and other enforcement consequences under the EU AI Act and related law. Fine exposure depends on the legal provision breached, the regulated actor, the facts, the organization's size and turnover, the seriousness and duration of the infringement, cooperation, corrective action, prior infringements, and other factors considered by the competent authority.

126.2 Plain-English explanation

Penalty ceilings are not automatic outcomes. Authorities assess the specific infringement and circumstances. Organizations should not reduce enforcement exposure to a single percentage or assume that paying a fine resolves other consequences such as corrective orders, withdrawal, recall, suspension, litigation, contractual claims, or reputational damage.

126.3 Exposure assessment requirements

Assess at minimum:

1. the legal provision and actor obligation potentially breached;
2. the applicable maximum fine category and calculation basis;
3. worldwide annual turnover and enterprise-group considerations where legally relevant;
4. seriousness, duration, scope, intent, negligence, and affected persons;
5. prior infringements and repeat-control failures;
6. cooperation, evidence preservation, notification, and remediation;
7. gains obtained or losses avoided;
8. overlap with GDPR, consumer, employment, cybersecurity, product-safety, competition, and sector enforcement;
9. non-monetary measures, including restriction, withdrawal, recall, suspension, or market-removal exposure;
10. insurance, contractual allocation, indemnity, and recovery limits;
11. accounting, disclosure, and legal-reserve implications;
12. board and executive escalation.

126.4 GlobalWay example

GlobalWay identifies that a high-risk recruitment system may have been deployed without complete conformity evidence. Legal assesses the applicable AI Act provisions, actor role, possible fine category, affected applicants, prior warnings, remediation status, related GDPR exposure, and the risk of suspension or corrective orders before advising executives.

126.5 Control activity

Legal and Compliance must maintain a current enforcement-exposure matrix tied to the AI inventory, actor role, applicable provisions, incident and deficiency records, and escalation thresholds. Estimated exposure must be clearly labelled as preliminary and must not be presented as a predicted authority decision.

126.6 Evidence

- legal-exposure assessment;
- applicable fine-category analysis;
- turnover and entity records;
- incident, complaint, and remediation evidence;

- authority correspondence;
- board and executive escalation;
- accounting and disclosure analysis;
- lessons learned and control updates.

126.7 Audit test

Select significant AI compliance issues and confirm that Legal identified the correct actor, provision, fine category, aggravating and mitigating factors, related enforcement regimes, non-monetary consequences, escalation, and remediation status.

126.8 Primary legal references

- Regulation (EU) 2024/1689, as amended, including Articles 99-101 and other applicable enforcement provisions.
- Regulation (EU) 2026/1744, including amendments affecting enforcement and application where applicable.
- Current consolidated EUR-Lex text controls over older summaries.
- Related legal regimes must be assessed separately; cumulative or parallel exposure depends on the facts and applicable law.

127 Chapter 126 — Executive Escalation

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 126 draft language.

127.1 Purpose

This chapter defines how material AI risks, incidents, compliance failures, regulatory matters, and unresolved control deficiencies should be escalated to senior management and the board.

AI may support human decision-making, but it must not remove human responsibility, judgment, or accountability.

127.2 Requirement

Organizations should operate a documented, risk-based executive-escalation process for material AI legal, safety, fundamental-rights, cybersecurity, operational, financial, and reputational issues. Executive escalation is a governance control that supports statutory duties but is not, by itself, a standalone EU AI Act obligation unless linked to a specific actor duty, quality-management process, incident-reporting requirement, corrective action, post-market-monitoring activity, conformity obligation, or authority request.

Escalation should occur early enough for authorized leaders to restrict, suspend, remediate, disclose, withdraw, recall, or accept risk before harm or noncompliance increases.

127.3 Plain-English explanation

Escalation is not simply forwarding an email. It is a controlled transfer of a material decision to a person with the authority, information, independence, and resources to act. Executives need timely, decision-ready information when an AI issue may require suspension, notification, remediation, withdrawal, recall, customer communication, regulatory engagement, or acceptance of significant residual risk.

Delayed, incomplete, or informal escalation can turn a manageable control issue into a serious incident or enforcement matter. Escalation must therefore be based on defined thresholds rather than informal judgment alone.

127.4 Escalation triggers

Escalate proportionately when there is:

- a suspected prohibited AI practice;
- a serious incident or credible risk of significant harm;
- a material fundamental-rights, safety, discrimination, privacy, or cybersecurity concern;
- high-risk classification uncertainty affecting deployment;
- failed conformity, validation, or technical-performance criteria;
- inability to provide required human oversight;
- significant model drift or unexpected behavior;
- material vendor failure or unapproved change;
- a regulatory inquiry, investigation, inspection, or urgent information request;
- a missed regulatory deadline or notification obligation;
- evidence destruction, concealment, falsification, or integrity concern;
- repeated or overdue high-severity findings;
- an exception outside approved risk appetite;
- potential material financial or reputational exposure.

127.5 Escalation levels

127.5.1 Operational escalation

Use operational escalation for issues that can be contained and resolved by the accountable product, technology, risk, compliance, or business owner within approved tolerances.

127.5.2 Executive escalation

Use executive escalation for material issues requiring cross-functional authority, additional resources, deployment restriction, customer remediation, legal strategy, significant risk acceptance, or regulatory engagement.

127.5.3 Board or committee escalation

Use board or committee escalation for matters involving enterprise risk appetite, serious incidents, prohibited practices, major regulatory exposure, significant financial impact, repeated management failure, or strategic decisions about continuation, withdrawal, or recall.

127.6 Minimum escalation requirements

Define at minimum:

1. severity and urgency thresholds;
2. legal, safety, rights, privacy, cybersecurity, financial, reputational, and operational triggers;
3. responsible executives and alternates;
4. required facts, uncertainties, and evidence;
5. affected systems, versions, actors, jurisdictions, suppliers, services, and persons;
6. immediate containment and stop-use authority;
7. notification, conformity, corrective-action, withdrawal, and recall implications;
8. decision deadlines and communication channels;
9. conflict-of-interest and independence safeguards;
10. decision, dissent, rationale, owner, and deadline records;
11. board or committee escalation criteria;
12. follow-up verification and closure requirements.

127.7 Required escalation package

Provide:

- a concise issue statement;
- system, model, version, owner, and jurisdictions;
- triggering event and timeline;
- people, rights, and business services affected;
- known facts, assumptions, uncertainties, and evidence gaps;
- applicable legal, policy, contractual, and risk-appetite obligations;
- current risk rating and potential consequences;
- containment already performed;
- decision options and trade-offs;
- recommended action;
- accountable owner and required deadline;
- communication and notification implications.

127.8 Decision options

Authorized leaders may:

- continue with enhanced monitoring;
- restrict users, data, geography, or functionality;
- require additional human review;
- suspend deployment or operation;
- roll back to a known-good version;
- notify affected people, customers, partners, insurers, or authorities;
- commission independent validation or investigation;
- terminate or replace a vendor;
- accept residual risk within delegated authority;
- withdraw or recall the system.

127.9 Communication discipline

Escalation records should be factual, concise, traceable, and candid about uncertainty. Avoid minimizing the issue, overstating certainty, or presenting a preferred outcome as the only option. Sensitive communications should follow legal, confidentiality, records-management, and privilege requirements.

No escalation may be closed solely because the issue was discussed. Closure requires documented decisions, completed actions, verified evidence, and accountable approval.

127.10 GlobalWay Travel Services example

GlobalWay detects that an employee-allocation system is producing unexplained adverse outcomes after a supplier update. The issue is escalated to Legal, Compliance, HR, Security, the accountable executive, and the risk committee. Automated recommendations are suspended pending impact analysis, supplier investigation, employee safeguards, and a documented release decision.

The executive committee receives the affected version, known facts, open questions, legal implications, containment status, decision options, and accountable deadlines. The matter remains open until corrective actions are independently validated and the committee approves any restart.

127.11 Control activities

- Define materiality thresholds and escalation levels.
- Assign decision rights and alternates.
- Maintain emergency pathways for severe matters.
- Require a standardized escalation package.
- Record decisions, rationale, conditions, and dissent.
- Track required actions and deadlines.
- Escalate overdue or ineffective remediation.
- Require verified evidence before closure.
- Review escalation performance after incidents and exercises.

127.12 Evidence

- escalation policy, standard, and thresholds;
- authority and decision-rights matrix;
- incident or deficiency record;

- escalation records and briefing packs;
- meeting minutes, decisions, and dissent records;
- restriction, suspension, rollback, withdrawal, or recall approvals;
- containment and communication evidence;
- executive and board reports;
- action owners and deadline trackers;
- notification decisions and regulator correspondence;
- closure and validation evidence;
- post-incident reviews;
- escalation exercises and training records.

127.13 Audit tests

1. Select material AI issues and confirm escalation occurred within defined thresholds and timelines.
2. Verify decision-makers had appropriate authority, independence, and sufficient information.
3. Confirm briefing packs distinguished facts, assumptions, uncertainties, and evidence gaps.
4. Trace decisions to containment, remediation, notification, withdrawal, recall, and closure evidence.
5. Confirm high-severity overdue findings were escalated.
6. Review whether board or committee reporting met established criteria.
7. Test emergency escalation paths through simulation or records.
8. Confirm closure was supported by verified evidence rather than discussion alone.
9. Confirm escalation lessons resulted in threshold, process, control, or training improvements.

127.14 Metrics

- time from detection to executive escalation;
- time from escalation to decision;

- material issues not escalated on time;
- overdue executive actions;
- systems restricted, suspended, withdrawn, or recalled;
- repeat issues after executive decision;
- board-reportable AI matters;
- emergency escalation exercises completed;
- escalations with incomplete evidence packages;
- escalations closed without independent validation.

127.15 Management checklist

- Are materiality thresholds clear and understood?
- Can urgent issues reach an authorized executive immediately?
- Does the escalation package distinguish facts, assumptions, and unknowns?
- Are leaders given realistic alternatives, including suspension, withdrawal, and recall?
- Are decisions, dissent, conditions, owners, and deadlines documented?
- Does the board receive matters that exceed management authority or risk appetite?
- Is closure supported by verified evidence?

127.16 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable governance, quality-management, risk-management, incident-reporting, corrective-action, post-market-monitoring, provider, deployer, conformity, and authority-cooperation provisions.
- Regulation (EU) 2026/1744 where applicable.
- Executive-escalation mechanics in this chapter are governance controls, not standalone statutory duties unless tied to a specific legal obligation.

127.17 Figure specification — AI Executive Escalation Ladder

Create an escalation ladder from operational owner to executive AI risk committee and board oversight. Show trigger severity, response time, required evidence, decision authority, containment options, notification decisions, remediation tracking, validation, and closure.

Alt text: AI executive escalation ladder moving material issues from operational ownership to executive and board decision-makers, with severity triggers, evidence, containment, notification, remediation, validation, and closure.

128 Chapter 127 — Regulatory Notification

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 127 draft language.

128.1 Purpose

This chapter explains how organizations should identify, assess, approve, and deliver regulatory notifications concerning serious incidents, noncompliance, corrective actions, market restrictions, and other reportable AI matters.

AI may support human decision-making, but it must not remove human responsibility, judgment, or accountability.

128.2 Requirement

Organizations must identify and meet all applicable EU AI Act and related-law notification duties. Notification obligations differ by regulated actor, event, provision, authority, timing rule, content requirement, and legal regime; there is no single universal AI notification deadline.

Organizations should maintain a documented notification process that identifies applicable authorities, legal triggers, reporting deadlines, required content, approval authority, communication channels, evidence-preservation requirements, and follow-up commitments. Potential notification duties should be assessed immediately when a material AI incident or compliance failure is identified.

128.3 Plain-English explanation

A material AI issue may trigger notification to a market-surveillance authority, the AI Office, another competent authority, a data-protection authority, a cybersecurity authority, customers, workers, affected persons, or other bodies. The organization must determine which duty applies, who must notify, when the clock starts, what information is required, and how updates will be managed.

The applicable obligation may depend on the organization's role, the system classification, the type and severity of harm, where the system is used, and which authority has jurisdiction. The organization must move quickly without submitting unverified or misleading information. Initial reports may be preliminary where the applicable law permits staged reporting, but they should clearly distinguish known facts, reasonable assessments, assumptions, and unresolved questions.

128.4 Potential notification triggers

Assess whether notification may be required after:

- a serious incident;
- death, serious injury, or significant risk to health or safety;
- serious and irreversible disruption of critical infrastructure;
- an infringement of obligations intended to protect fundamental rights;
- a suspected prohibited AI practice;
- material noncompliance involving a high-risk AI system;
- corrective action, restriction, suspension, recall, or withdrawal;
- cybersecurity compromise affecting AI safety, integrity, availability, or compliance;
- an authority request, investigation, inspection, or market-surveillance action;
- a substantial modification affecting regulatory status;
- a material vendor, model, data, or component failure;
- related privacy, consumer-protection, product-safety, employment, cybersecurity, or sector notification duties.

128.5 Notification assessment

For each potential notification, determine and document:

1. the legal regime and exact trigger;
2. the regulated actor responsible;
3. the competent recipient authority or affected party;
4. the deadline and event that starts the clock;
5. required initial facts and whether staged reporting is permitted;

6. serious-incident, safety, rights, privacy, security, conformity, or market-risk implications;
7. affected systems, models, versions, environments, jurisdictions, suppliers, and persons;
8. the event timeline and date of detection;
9. known and potential consequences;
10. evidence available, missing, preserved, or subject to privilege;
11. containment and corrective actions;
12. whether parallel notification regimes apply;
13. approval authority and submission channel;
14. supplemental, corrective, and closure updates;
15. records demonstrating timeliness, completeness, and delivery.

128.6 Authority and jurisdiction mapping

Maintain a current register of:

- competent national authorities;
- market-surveillance authorities;
- the AI Office where applicable;
- notifying authorities and notified bodies where relevant;
- data-protection, product-safety, consumer, employment, sector, and cybersecurity authorities;
- authority contact channels;
- language, format, and authentication requirements;
- legal-entity and actor responsibilities;
- escalation and external-counsel contacts;
- applicable notification deadlines and clock-start rules.

128.7 Notification content

A notification should include, as applicable and legally required:

- reporting organization and contact information;
- organization role in the AI value chain;

- affected AI system and intended purpose;
- system, model, and component versions;
- event date, detection date, and chronology;
- incident or noncompliance description;
- affected persons, locations, rights, and services;
- known or potential harm;
- immediate containment;
- technical and organizational analysis;
- vendors and dependencies involved;
- corrective-action plan;
- evidence limitations and open questions;
- planned updates and responsible contact.

128.8 Timeliness and staged reporting

Where full facts are not available before a deadline, submit an approved preliminary notification when legally appropriate and provide verified updates. Do not delay solely to achieve a perfect report. At the same time, do not speculate, conceal uncertainty, or make unsupported admissions.

Deadline calculations must identify the triggering event, the time zone, the responsible legal entity, weekends or public-holiday rules where applicable, and any obligation to provide interim or supplemental reports.

128.9 Coordination across regimes

An AI incident may also trigger obligations under data protection, cybersecurity, product safety, employment, consumer protection, contracts, insurance, or sector regulation. Coordinate messages, facts, timelines, and corrective actions so that submissions are consistent while respecting each regime's scope, privilege rules, recipient, and deadline.

Related notification duties must be assessed separately; compliance with one regime does not automatically satisfy another.

128.10 GlobalWay Travel Services example

GlobalWay receives evidence that a high-risk employee-management system may have contributed to a serious fundamental-rights impact after a supplier update. Legal determines the applicable AI Act actor and reporting route, assesses parallel GDPR and employment obligations, preserves logs,

system versions, and decision records, and restricts automated recommendations.

GlobalWay submits the required initial notification using verified facts, identifies open questions and containment measures, and provides supplemental reports as the investigation establishes affected populations, root cause, remediation, and evidence supporting any safe restart.

128.11 Control activities

- Maintain a notification decision tree and trigger matrix.
- Maintain an authority, jurisdiction, actor, and deadline register.
- Activate legal and executive review immediately after material events.
- Preserve system versions, logs, communications, and decision evidence.
- Use controlled templates and approval workflows.
- Separate verified facts from assumptions and unresolved questions.
- Coordinate related notification regimes.
- Track acknowledgements, regulator questions, supplemental reports, corrections, and commitments.
- Validate corrective action before closure.
- Review missed, late, rejected, or corrected notifications for process improvement.

128.12 Evidence

- notification policy, decision tree, and trigger matrix;
- authority, jurisdiction, actor, and deadline register;
- incident assessments and chronology;
- legal analyses and privilege records;
- system, model, log, and evidence-preservation records;
- draft and submitted notifications;
- approval records;
- delivery confirmations and acknowledgements;
- regulator correspondence;

- supplemental, corrective, and closure reports;
- corrective-action evidence;
- commitment and deadline trackers;
- lessons-learned records.

128.13 Audit tests

1. Select serious incidents and material compliance issues and verify notification duties were assessed promptly.
2. Confirm the legal trigger, actor, recipient, jurisdiction, deadline, and clock-start event were documented.
3. Recalculate deadlines and compare submission timestamps with delivery evidence.
4. Compare submitted facts with source evidence, system records, and incident timelines.
5. Verify preliminary reports identified uncertainty and follow-up obligations.
6. Review consistency across AI, privacy, cybersecurity, product, employment, consumer, and sector notifications.
7. Trace regulator questions and commitments through verified closure.
8. Confirm late, missed, rejected, or corrected notifications were escalated and remediated.
9. Verify closure was supported by completed corrective actions and retained evidence.

128.14 Metrics

- material incidents assessed for notification;
- time from detection to legal assessment;
- notifications submitted on time;
- late or missed notifications;
- preliminary reports awaiting update;
- inconsistent cross-regime submissions;
- overdue regulator commitments;
- notifications requiring correction or resubmission;

- time to validated closure;
- events where the notification clock start was disputed or unclear.

128.15 Management checklist

- Which legal regime, authority, actor, and legal entity are responsible?
- What deadline applies, and when did the clock begin?
- Are known facts separated from assumptions and unknowns?
- Have all relevant notification regimes been considered separately?
- Are containment and corrective actions clearly documented?
- Are submitted facts consistent with preserved source evidence?
- Are follow-up commitments owned and tracked?
- Is closure supported by regulator correspondence and verified remediation?

128.16 Primary legal references

- Regulation (EU) 2024/1689, as amended, including applicable serious-incident, corrective-action, market-surveillance, provider, deployer, GPAI, conformity, and authority-cooperation provisions.
- Regulation (EU) 2026/1744 where applicable.
- Related notification duties under data-protection, cybersecurity, product-safety, employment, consumer-protection, and sector law must be assessed separately.
- Current consolidated official texts control over older summaries.

128.17 Figure specification — AI Regulatory Notification Decision Flow

Create a decision flow from incident detection through severity and legal-trigger assessment, actor and jurisdiction mapping, authority identification, deadline calculation, evidence preservation, preliminary or final notification, parallel-regime coordination, follow-up reporting, corrective action, validation, and closure.

Alt text: AI regulatory-notification decision flow from incident detection and legal-trigger assessment through actor and authority mapping, deadline control, evidence preservation, submission, parallel-regime coordination, follow-up reporting, corrective action, validation, and closure.

129 Chapter 128 — Evidence Preservation and Legal Hold

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 128 draft language.

129.1 Purpose

This chapter explains how organizations should preserve AI-related evidence and implement legal holds when litigation, investigation, enforcement, a serious incident, a complaint, or a material dispute is reasonably anticipated.

AI may support human decision-making, but it must not remove human responsibility, judgment, or accountability.

129.2 Requirement

Organizations must preserve records required by the EU AI Act and other applicable law and should implement legal holds when litigation, investigation, enforcement, incident, complaint, or dispute is reasonably anticipated. A legal hold is a legal-process control, not a standalone EU AI Act obligation, but it supports compliance with documentation, logging, recordkeeping, authority-access, incident, corrective-action, and post-market-monitoring duties.

129.3 Plain-English explanation

AI evidence may be distributed across cloud services, model providers, source-code repositories, monitoring platforms, ticketing systems, business applications, employee communications, and third-party systems. Routine deletion, log rotation, model retirement, or supplier overwrite must stop when relevant evidence may be needed. Preservation must cover documents and technical artifacts together so that decisions, model behavior, system context, and human actions can be reconstructed.

129.4 Trigger events

Consider preservation or a legal hold after:

- a regulatory inquiry, inspection, or information request;
- threatened or filed litigation;
- a serious incident or credible allegation of harm;
- suspected use of a prohibited AI practice;
- a discrimination, privacy, safety, employment, or consumer complaint;
- a cybersecurity compromise affecting AI operation or evidence integrity;

- a whistleblower report or internal investigation;
- a material vendor dispute, outage, or model change;
- an executive- or board-directed review;
- an anticipated insurance claim;
- system restriction, suspension, recall, withdrawal, or major corrective action.

129.5 Preservation requirements

Define at minimum:

1. statutory, regulatory, contractual, and policy retention obligations;
2. legal-hold triggers, decision authority, and escalation routes;
3. custodians, systems, models, versions, repositories, environments, and suppliers in scope;
4. relevant logs, prompts, outputs, datasets, code, configuration, documentation, and communications;
5. preservation of metadata, authenticity, integrity, context, and chain of custody;
6. suspension of deletion, rotation, overwriting, archival disposal, and model retirement;
7. prompt capture of volatile, ephemeral, or externally controlled evidence;
8. third-party preservation notices, acknowledgements, and verification;
9. privacy, data-minimisation, confidentiality, privilege, security, and access controls;
10. collection, export, indexing, reproducibility, and review requirements;
11. periodic review, expansion, modification, and authorized release of the hold;
12. documentation of unavailable evidence, preservation gaps, compensating measures, and remediation;
13. secure disposition after lawful release.

129.6 Evidence scope

Preserve as relevant:

- AI inventory, ownership, role, and classification records;
- model binaries, weights, versions, identifiers, checksums, and release metadata where available;
- source code, scripts, prompts, system instructions, retrieval configuration, and tool definitions;
- training, tuning, validation, testing, and production data where lawful;
- data lineage, provenance, quality, representativeness, bias, and preprocessing records;
- logs, monitoring alerts, outputs, overrides, approvals, and user interactions;
- deployment, release, rollback, and change-management records;
- risk, impact, privacy, security, legal, and conformity assessments;
- technical documentation, instructions for use, and registration records;
- human-oversight instructions, reviewer actions, and decision records;
- vendor contracts, notices, attestations, incident records, and communications;
- complaints, tickets, investigations, corrective actions, and closure evidence;
- emails, messages, meeting minutes, executive decisions, and regulator correspondence.

129.7 AI-specific preservation challenges

Address:

- rapidly changing vendor models and inaccessible proprietary artifacts;
- ephemeral prompts, temporary sessions, and short log-retention periods;
- dynamic retrieval sources and continuously updated datasets;
- agent tool calls, external API actions, and downstream system changes;
- model nondeterminism and reproducibility limits;
- distributed cloud, regional storage, and cross-border restrictions;

- privacy constraints and special-category data;
- open-source component changes and dependency replacement;
- employee use of unapproved or personal AI tools.

129.8 Vendor preservation

Contracts and incident procedures should support prompt supplier preservation of relevant model versions, logs, documentation, subprocessors, service changes, and incident evidence. Record any limitation on the organization's ability to obtain or preserve supplier-controlled evidence and escalate material gaps.

129.9 Integrity and chain of custody

Maintain:

- source, custodian, and system of record;
- collection date, method, and collector;
- file, object, model, and version identifiers;
- hashes or other integrity checks where appropriate;
- original metadata and contextual relationships;
- secure storage location and access controls;
- access, transfer, export, and production history;
- transformations, redactions, or format conversions;
- reviewer, approval, and release records.

Preserve originals separately from working copies.

129.10 Privacy, confidentiality, and privilege

Preservation does not remove privacy, confidentiality, cybersecurity, professional-secrecy, or privilege obligations. Limit access, apply lawful collection boundaries, protect sensitive data, document redactions, and obtain legal and privacy review for cross-border transfers, special-category data, employee data, and supplier-controlled evidence.

129.11 GlobalWay Travel Services example

After travelers allege discriminatory blocking by GlobalWay's fraud-detection system, legal counsel issues a hold covering the deployed model version, feature configuration, transaction decisions, human overrides, subgroup tests, complaints, vendor change notices, and internal communications.

GlobalWay discovers that application logs normally rotate after 30 days. It suspends deletion, exports relevant logs with integrity checks, obtains preservation confirmation from the vendor, and documents that one historical proprietary model artifact is unavailable. The limitation is disclosed, escalated, and considered in the investigation and remediation plan.

129.12 Control activity

Legal must issue documented holds when required, and Technology, Records Management, Security, Privacy, HR, business owners, and suppliers must confirm implementation. The organization must test whether technically volatile AI evidence can actually be preserved, linked to the correct version, and reproduced sufficiently for investigation, audit, or authority review.

129.13 Evidence

- retention schedule and legal-hold procedure;
- evidence-source and system maps;
- hold notices, scope changes, and acknowledgements;
- custodian, repository, supplier, and system lists;
- preservation, collection, and export logs;
- hashes, metadata, and chain-of-custody records;
- supplier preservation confirmations and disclosed limitations;
- access, redaction, and production records;
- periodic hold reviews;
- exception, gap, and remediation records;
- hold-release and disposition approvals.

129.14 Audit test

Select legal holds involving AI systems. Confirm that triggers were identified promptly, scope included relevant technical and human evidence, deletion and overwrite were suspended, volatile and supplier-controlled evidence was addressed, integrity and custody were protected, privacy and privilege controls were applied, gaps were disclosed, and release was authorized and documented.

129.15 Metrics

- time from trigger to preservation action;

- custodians, systems, suppliers, and evidence sources under hold;
- missed or late acknowledgements;
- evidence lost before preservation;
- supplier-preservation gaps;
- log sources with inadequate retention;
- chain-of-custody exceptions;
- unauthorized access to held evidence;
- open holds by age;
- released holds awaiting verified disposition.

129.16 Management checklist

- Do we know where material AI evidence resides?
- Can we stop deletion, rotation, model retirement, and vendor overwrite quickly?
- Are model, prompt, data, log, configuration, and human-decision records preserved together?
- Can we demonstrate authenticity, integrity, context, and chain of custody?
- Are privacy, confidentiality, privilege, and cross-border restrictions protected?
- Are supplier limitations and evidence gaps disclosed and escalated?
- Is hold release controlled and verified?

129.17 Figure specification — AI Evidence Preservation Map

Create a map connecting trigger events to legal-hold activation, custodians, models, data, prompts, logs, code, vendors, communications, collection, integrity validation, secure storage, review, production, and authorized release.

Alt text: AI evidence-preservation map linking legal-hold triggers to custodians and technical evidence sources, followed by collection, integrity validation, secure storage, controlled review, production, and authorized release.

129.18 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable technical-documentation, logging, recordkeeping, quality-management, monitoring, incident, corrective-action, and authority-access provisions.
- Regulation (EU) 2016/679 and other applicable privacy, employment, evidentiary, and procedural law.
- Regulation (EU) 2026/1744 where applicable.
- Legal-hold duties depend on applicable procedural and substantive law and must not be presented as a universal standalone EU AI Act requirement.

130 Chapter 129 — First 30 Days

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 129 draft language.

130.1 Purpose

This chapter provides a practical first-30-day implementation plan for establishing control, visibility, accountability, and immediate risk reduction across an organization's AI activities.

130.2 Requirement

The first 30-day roadmap is implementation guidance, not a standalone EU AI Act requirement. Organizations should use this period to establish legal applicability, actor roles, immediately applicable prohibitions and duties, governance ownership, inventory completeness, risk triage, evidence preservation, and urgent remediation priorities.

130.3 Plain-English explanation

The first month should create control over scope and urgent exposure. It is not the time to declare full compliance. Management should know which AI systems and GPAI models exist, which uses may be prohibited or high risk, who owns them, what data they use, which vendors are involved, who may be affected, and where immediate restriction, suspension, or escalation is required.

130.4 Days 1-5: mobilize

- appoint an executive sponsor and accountable programme lead;
- establish a cross-functional steering group;
- define Legal, Compliance, Risk, Privacy, Security, Technology, Procurement, HR, Internal Audit, and business participation;

- approve an interim AI governance mandate;
- establish decision, escalation, stop-use, and notification authority;
- identify relevant legal entities, jurisdictions, sectors, and business services;
- confirm the current legal baseline and applicable dates;
- preserve critical existing records and decisions.

130.5 Days 6-10: discover

Launch a rapid inventory covering production systems, pilots, proofs of concept, shadow AI, embedded vendor features, employee generative-AI use, GPAI-enabled services, high-impact automated decisions, models, data sources, providers, dependencies, owners, affected groups, jurisdictions, incidents, complaints, and unresolved findings.

Use interviews, procurement records, software inventories, cloud and network logs, expense records, vendor registers, and business-unit attestations to improve completeness.

130.6 Days 11-15: triage

Prioritize suspected prohibited practices, employment and essential-service use cases, biometric or safety-related systems, systems affecting vulnerable groups, public-facing generative AI, sensitive-data processing, systems without meaningful human oversight, systems with incidents or material changes, and vendor services lacking adequate documentation or contractual assurance.

130.7 Days 16-20: stabilize

Apply interim measures such as suspension, functional or geographic restriction, mandatory human review, sensitive-data limits, temporary transparency notices, evidence preservation, blocking of unapproved tools, vendor escalation, change freezes, safe-stop procedures, and documented residual-risk decisions.

130.8 Days 21-25: establish minimum governance

Approve interim versions of the AI policy, acceptable-use rules, intake and approval process, inventory standard, prohibited-practice screen, actor-role and risk-classification methods, incident and notification procedures, vendor due diligence, evidence-retention expectations, AI-literacy requirements, and exception authority.

130.9 Days 26-30: plan the programme

Create prioritized 90-day and 12-month roadmaps covering legal and control gaps, system-specific remediation, regulatory dates, resource and competence needs, accountable owners, dependencies, assurance and

testing, reporting cadence, budget, technology requirements, and exit or suspension options.

130.10 GlobalWay Travel Services example

GlobalWay begins with a rapid inventory and discovers 42 AI use cases, including 11 not previously known to central governance. It identifies actor roles, suspends one unsupported workforce pilot, restricts a recruitment tool pending classification and bias review, adds AI notices to two traveler chatbots, preserves evidence for an open complaint, and freezes a vendor model upgrade until change assessment is complete.

By day 30, GlobalWay has an executive sponsor, programme office, triaged inventory, interim policy, urgent remediation tracker, documented stop-use decisions, and approved 90-day and 12-month roadmaps.

130.11 Control activity

The accountable executive must approve the first-30-day scope, owners, urgent decisions, unresolved legal questions, and transition into the 31-to-90-day plan. Progress reporting must distinguish verified completion and retained evidence from planned or partially completed work.

130.12 Evidence

- programme charter and governance appointments;
- current legal-baseline record;
- rapid inventory and business-unit attestations;
- actor-role, applicability, and prohibited-practice assessments;
- risk-triage criteria and results;
- suspension, restriction, and interim-control decisions;
- incident, complaint, and supplier reviews;
- evidence-preservation records;
- interim policies and procedures;
- urgent remediation register;
- executive and board reports;
- approved 90-day and 12-month roadmaps.

130.13 Audit test

Review the first-30-day programme. Confirm that it established a supportable inventory, identified urgent legal and operational risks, assigned accountable owners, documented interim safeguards and stop-use

decisions, preserved critical evidence, escalated material exposure, and did not misrepresent planned work as completed compliance.

130.14 Metrics

- AI systems and GPAI models identified;
- newly discovered shadow-AI use cases;
- business units completing attestations;
- urgent systems triaged;
- systems suspended, restricted, or frozen;
- systems without accountable owners;
- critical evidence and supplier-documentation gaps;
- overdue first-month actions;
- prohibited-practice and high-risk reviews pending;
- unresolved legal-classification decisions.

130.15 Management checklist

- Who is accountable for the programme and urgent decisions?
- Do we know where AI and GPAI-enabled services are being used?
- Which use cases require immediate suspension or restriction?
- Are critical logs, versions, decisions, and records preserved?
- Have actor roles, jurisdictions, affected groups, and vendors been identified?
- Are owners, deadlines, dependencies, and escalation paths assigned?
- Does the board understand the most material exposure and uncertainty?
- Are completed actions supported by evidence rather than status assertions?

130.16 Figure specification — First 30 Days AI Governance Sprint

Create a 30-day sprint divided into mobilize, discover, triage, stabilize, establish governance, and approve roadmap. Show executive sponsorship, evidence preservation, legal review, supplier escalation, and urgent stop-use authority as cross-cutting controls.

Alt text: Thirty-day AI governance sprint moving from mobilization and discovery through triage, stabilization, minimum governance, and an approved implementation roadmap, with executive oversight, legal review, evidence preservation, and urgent escalation throughout.

130.17 Primary legal references

- Regulation (EU) 2024/1689, as amended by Regulation (EU) 2026/1744 where applicable.
- Applicable AI Act provisions depend on actor role, system classification, intended purpose, use context, jurisdiction, and application date.
- This chapter is implementation guidance and does not replace legal analysis of exact statutory deadlines and duties.
- Current consolidated official text controls over older summaries.

131 Chapter 130 — Days 31-90

Legal status: Corrected English master for consolidation. This chapter is an implementation roadmap, not a statutory timetable. It controls over conflicting earlier Chapter 130 language.

131.1 Purpose

This chapter provides a practical implementation plan for days 31 through 90, moving from initial control and triage to repeatable governance, formal risk assessment, prioritized remediation, and measurable accountability.

131.2 Requirement

Organizations should use days 31-90 to convert initial AI triage into repeatable governance, risk assessment, control operation, remediation, training, and management reporting. The sequence must be adjusted to the organization's legal roles, applicable effective dates, existing control maturity, and risk profile.

131.3 Plain-English explanation

The EU AI Act does not require organizations to complete these activities within 90 days. The roadmap is a recommended implementation method. Binding duties arise from the Act, as amended, and from other applicable law—not from this internal schedule. The second and third months should stop reliance on one-time spreadsheets and informal decisions by embedding intake, classification, review, approval, monitoring, and escalation into normal business operations.

131.4 Days 31-45: validate scope and accountability

- reconcile the rapid inventory with procurement, cloud, software, security, data, HR, finance, and business records;
- confirm legal entities, systems, versions, intended purposes, suppliers, jurisdictions, and affected populations;
- assign business, technical, risk, data, privacy, security, and legal owners;
- document provider, deployer, importer, distributor, authorised-representative, and product-manufacturer roles where relevant;
- establish recurring inventory attestations and data-quality checks;
- restrict, suspend, or escalate ownerless and undocumented systems according to risk.

131.5 Days 46-60: assess and classify

Perform proportionate assessments covering:

- EU AI Act applicability and actor role;
- prohibited-practice screening;
- high-risk classification;
- transparency obligations;
- GPAI dependencies and downstream information needs;
- privacy and fundamental-rights impacts;
- cybersecurity, resilience, and operational risk;
- human oversight;
- third-party, concentration, and exit risk;
- substantial-modification risk.

Record uncertainty and require qualified legal or specialist review where conclusions are disputed.

131.6 Days 61-75: establish baseline controls

Implement and operationalize controls for:

- intake and approval;
- inventory and ownership;

- data governance;
- technical documentation;
- validation and testing;
- transparency notices;
- human oversight;
- logging and monitoring;
- incident and complaint management;
- supplier due diligence and contracting;
- change management;
- evidence retention and legal hold;
- exceptions and residual-risk acceptance.

Integrate key controls into procurement, development, release, privacy, security, HR, records-management, and third-party workflows.

131.7 Days 76-90: train, test, and report

- launch role-based AI-literacy activities;
- establish key risk, control, and compliance indicators;
- begin control self-assessments;
- identify and prioritize evidence gaps;
- test selected high-priority controls;
- define issue severity and remediation standards;
- establish executive and board dashboards;
- approve resource, budget, and technology needs;
- confirm the months 4-12 assurance plan.

131.8 Prioritization method

Prioritize remediation using:

- legal classification and effective date;
- potential safety or fundamental-rights impact;
- scale, sensitivity, and affected population;

- control weakness and evidence quality;
- incident, complaint, or enforcement history;
- system change velocity;
- supplier and concentration dependency;
- ease of immediate risk reduction;
- feasibility of safe restriction, suspension, or exit.

131.9 GlobalWay Travel Services example

During days 31–90, GlobalWay validates its 42-system inventory and identifies four additional embedded AI features. It completes role and risk assessments for critical systems, establishes intake and release gates, issues mandatory supplier clauses, trains product owners and travel-consultant supervisors, and begins monthly executive reporting.

Its recruitment tool remains restricted until bias, oversight, privacy, and supplier-documentation gaps are closed. The traveler assistant proceeds under enhanced monitoring and human-escalation controls.

131.10 Control activity

Management must approve the roadmap, assign accountable owners, prioritize binding obligations and material risks, document deviations from the schedule, and prevent roadmap milestones from being represented as statutory deadlines.

131.11 Evidence

- validated inventory and ownership records;
- role, applicability, and classification assessments;
- control library and overlays;
- approved procedures and workflow gates;
- supplier due-diligence and contracting files;
- training and competence records;
- control self-assessments and testing results;
- issue and remediation register;
- dashboards and governance minutes;
- approved assurance and resource plan.

131.12 Audit test

Confirm that the organization distinguished statutory deadlines from internal milestones, validated inventory completeness, supported role and classification decisions, embedded controls into actual workflows, trained relevant personnel, traced dashboard metrics to reliable source data, and assigned accountable remediation for material gaps.

131.13 Metrics

- inventory validation rate;
- systems with completed role and classification assessments;
- critical systems with mapped controls;
- overdue assessments;
- systems lacking required evidence;
- training completion by role;
- high-severity deficiencies;
- overdue remediation;
- supplier contracts missing required clauses;
- control-test pass rate.

131.14 Management checklist

- Is the inventory complete enough for legal and risk decisions?
- Are actor-role and risk-classification decisions approved?
- Are lifecycle controls operating in real workflows?
- Are relevant personnel trained for their responsibilities?
- Can management see material gaps, uncertainty, and overdue actions?
- Is the next assurance phase funded, owned, and scheduled?
- Are internal roadmap dates clearly separated from legal deadlines?

131.15 Figure specification — Days 31-90 Operating Model Build

Create a three-stage roadmap showing validate and assign, assess and classify, then implement, train, test, and report. Connect inventory, control library, workflow integration, remediation, and executive oversight.

Alt text: Days 31–90 AI implementation roadmap progressing from validated inventory and accountability through classification, control implementation, training, testing, remediation, and executive reporting.

131.16 Primary legal references

- Regulation (EU) 2024/1689, as amended by Regulation (EU) 2026/1744 where applicable.
- Applicable effective dates, transitional provisions, actor obligations, and sector-specific law control over this recommended roadmap.
- Current consolidated official texts control over older summaries.

132 Chapter 131 — Months 4-6

Legal status: Corrected English master for consolidation. This chapter is a recommended implementation roadmap, not a statutory timetable. It controls over conflicting earlier Chapter 131 language.

132.1 Purpose

This chapter provides a practical implementation plan for months 4 through 6, emphasizing operating-model stability, system-level control maturity, technical validation, evidence quality, remediation, supplier governance, and independent challenge.

AI may support human decision-making, but it must not remove human responsibility, judgment, or accountability.

132.2 Requirement

Organizations should use months 4–6 to stabilize the AI governance operating model, close high-priority gaps, expand assurance, improve evidence quality, and prepare affected systems for applicable legal, registration, notification, monitoring, and conformity obligations.

The EU AI Act does not require completion of these activities within six months. Binding duties arise from the organization’s actual regulated roles, system classifications, intended purposes, application dates, and other applicable law—not from this internal schedule.

132.3 Plain-English explanation

This phase moves the programme from initial implementation to repeatable operation. Policies, inventories, classifications, and control designs must now be tested against real systems, releases, incidents, suppliers, and business decisions. Weak controls should be corrected before they become normalized.

Internal milestones must remain aligned to the organization's actual legal roles, applicable effective dates, sector obligations, and evidence of operational readiness.

132.4 Month 4: deepen system-level implementation

For priority systems:

- finalize intended purpose, foreseeable misuse, and use restrictions;
- complete applicability, role, classification, risk, privacy, security, and fundamental-rights assessments;
- map binding obligations and internal requirements to controls;
- complete technical-documentation and evidence indexes;
- define and test human-oversight procedures;
- establish logging, monitoring, post-market monitoring, and incident triggers where applicable;
- confirm supplier evidence, audit rights, change notice, preservation, and exit provisions;
- document residual risk, compensating controls, approval authority, and review dates;
- formalize change-management and substantial-modification review.

132.5 Month 5: validate and test

Perform proportionate testing of:

- control design and operating effectiveness;
- accuracy, error rates, and acceptance criteria;
- subgroup performance, discrimination risk, and bias controls;
- robustness, cybersecurity, resilience, and misuse resistance;
- prompt-injection and agentic-tool abuse scenarios where relevant;
- transparency notices and affected-person communications;
- human-review effectiveness, intervention authority, override, and stop mechanisms;
- fallback, suspension, rollback, recovery, and continuity procedures;
- data quality, provenance, lineage, relevance, and representativeness;

- documentation, logging, evidence completeness, integrity, and reproducibility;
- supplier monitoring and version reconciliation.

Failed acceptance criteria must trigger documented remediation, restriction, suspension, rollback, or risk escalation. A failed test must not be closed merely because management discussed it or accepted an unsupported explanation.

132.6 Month 6: institutionalize assurance

- establish recurring control testing and monitoring;
- conduct targeted design and operating-effectiveness reviews;
- perform internal-audit or independent challenge of selected systems;
- validate evidence repositories, retention, preservation, and retrieval;
- conduct a regulatory-examination or authority-information-request simulation;
- test incident response, serious-incident assessment, regulatory-notification, and legal-hold procedures;
- assess readiness for conformity assessment, registration, declaration, CE marking, and authority access where applicable;
- review supplier concentration, dependency, auditability, portability, and exit readiness;
- validate executive and board reporting against reliable source evidence;
- report systemic deficiencies, overdue actions, and unresolved legal questions;
- refresh the implementation roadmap based on findings, legal developments, and business priorities.

A readiness review does not replace a legally required conformity assessment, registration, declaration, marking, notification, or other statutory process.

132.7 Remediation discipline

Each material deficiency should include:

- clear issue statement and root cause;

- affected systems, models, versions, persons, jurisdictions, and obligations;
- severity, exposure, and residual risk;
- immediate containment and interim controls;
- accountable owner and decision authority;
- target date and dependencies;
- validation and retesting method;
- escalation path and extension criteria;
- closure evidence and independent verification where appropriate.

Repeated extensions, exceptions, or failed retests should receive independent challenge and executive escalation.

132.8 GlobalWay Travel Services example

GlobalWay completes detailed assessments for its recruitment, fraud, disruption-assistance, and dynamic-pricing systems. Technical validation identifies weak abstention behavior in the disruption assistant, inconsistent subgroup performance in the fraud model, and incomplete supplier version evidence.

GlobalWay restricts the affected features, implements remediation, retests them, and submits the results to an independent review team. It also conducts a mock regulatory request and discovers that technical documentation and post-market monitoring evidence cannot yet be reconciled to the deployed vendor version. Management postpones one release until the documentation, monitoring, supplier-evidence, and human-oversight gaps are closed.

132.9 Control activities

- Complete system-level applicability, role, classification, and impact assessments.
- Implement and test lifecycle controls for priority systems.
- Validate technical and operational acceptance criteria before release or continued use.
- Maintain disciplined deficiency and corrective-action management.
- Strengthen supplier monitoring, evidence access, change notice, and exit readiness.

- Exercise incident, continuity, regulatory, notification, and preservation processes.
- Distinguish statutory obligations from internal programme milestones.
- Require evidence-based closure before restrictions or release blocks are removed.
- Escalate systemic themes to executives and the board.
- Refresh priorities based on testing, incidents, legal changes, and findings.

132.10 Evidence

- updated inventory and classification register;
- completed system assessments and obligation-to-control mappings;
- technical-documentation and evidence indexes;
- validation plans, acceptance criteria, and results;
- control-test workpapers and independent-review reports;
- remediation, restriction, suspension, rollback, and retest records;
- supplier monitoring, assurance, contract, and version evidence;
- training and competence records;
- exercise and simulation results;
- incident, notification, and legal-hold test records;
- conformity-readiness assessments where applicable;
- residual-risk and exception approvals;
- executive and board reporting;
- updated implementation roadmap.

132.11 Audit tests

1. Select priority systems and verify that applicability, role, classification, impact, and control assessments are complete, approved, and traceable.
2. Confirm validation criteria were defined before testing and reflect realistic failure, misuse, rights, safety, and security scenarios.

3. Trace failed tests to containment, restriction, remediation, retesting, and authorized release decisions.
4. Review evidence quality, integrity, retention, and reconciliation to the deployed system and supplier version.
5. Test whether supplier monitoring, audit rights, change notice, incident support, preservation, and exit controls are operating.
6. Inspect independent assurance for competence, scope, independence, and documented conclusions.
7. Confirm that readiness reviews did not substitute for legally required conformity or regulatory processes.
8. Verify that systemic findings changed governance, resource allocation, controls, or roadmap priorities.
9. Confirm that management reporting distinguishes completed evidence from planned or overdue work.

132.12 Metrics

- priority systems fully assessed;
- validation and control-test completion rate;
- failed acceptance criteria;
- systems restricted, suspended, rolled back, or awaiting retest;
- high-severity findings open and overdue;
- repeat control failures and repeated exceptions;
- systems with complete and current evidence indexes;
- critical suppliers with current assurance and version evidence;
- readiness reviews completed and unresolved gaps;
- exercises completed and corrective actions arising;
- average time to remediate and retest;
- overdue legal, conformity, notification, or monitoring actions.

132.13 Management checklist

- Are priority systems fully documented, classified, controlled, and traceable to production?

- Do technical tests reflect realistic failure, misuse, discrimination, security, and rights scenarios?
- Can failed criteria block, restrict, suspend, or roll back deployment?
- Are findings corrected and independently validated where material?
- Can required evidence be produced quickly and reconciled to the correct system and version?
- Are supplier, concentration, portability, and continuity risks adequately tested?
- Are statutory duties clearly distinguished from internal roadmap targets?
- Does executive and board reporting reflect actual evidence and unresolved exposure?

132.14 Figure specification — Months 4-6 Assurance Build

Create a roadmap showing system-level assessment, obligation-to-control mapping, control implementation, technical validation, independent testing, remediation, regulatory and incident exercises, executive reporting, and roadmap refresh. Show restriction, suspension, rollback, and retesting as required paths after failed criteria.

Alt text: Months 4-6 AI assurance roadmap moving from system-level assessments and controls through technical validation, independent testing, remediation, exercises, executive reporting, and refreshed priorities, with restriction and retesting after failed criteria.

132.15 Primary legal references

- Regulation (EU) 2024/1689, as amended, including applicable provider, deployer, high-risk, transparency, GPAI, quality-management, risk-management, documentation, logging, oversight, monitoring, incident, corrective-action, conformity, registration, and authority-cooperation provisions.
- Regulation (EU) 2026/1744 where applicable.
- Applicable effective dates, transitional provisions, conformity-assessment requirements, sector law, and actor obligations control over this recommended roadmap.
- Current consolidated official texts control over older summaries.

133 Chapter 132 — Months 7-12

Legal status: Corrected English master for consolidation. This chapter is a recommended implementation roadmap, not a statutory timetable. It controls over conflicting earlier Chapter 132 language.

133.1 Purpose

This chapter provides a practical implementation plan for months 7 through 12, focusing on enterprise-wide adoption, regulatory readiness, sustainable assurance, maturity improvement, and integration into normal business operations.

AI may support human decision-making, but it must not remove human responsibility, judgment, or accountability.

133.2 Requirement

Organizations should use months 7-12 to mature AI governance, complete priority remediation, extend assurance coverage, validate operating effectiveness, and institutionalize monitoring, reporting, regulatory response, and continuous improvement.

The EU AI Act does not require this roadmap to be completed within twelve months. Binding duties, effective dates, conformity requirements, registration, notification, monitoring, and authority expectations must be tracked separately according to the organization's actual legal roles, system classifications, intended purposes, and jurisdictions.

133.3 Plain-English explanation

The final six months of the first-year roadmap are about scale and durability. Governance must work across business units, legal entities, countries, technologies, and suppliers. The first year should end with a defensible operating model rather than a collection of disconnected projects or one-time remediation efforts.

Management should be able to demonstrate that the programme is supported by accountable ownership, current evidence, repeatable controls, independent challenge, tested escalation, and funded continuous improvement.

133.4 Months 7-8: scale and standardize

- extend the control baseline across material business units and legal entities;
- apply role, risk, sector, jurisdiction, technology, and population overlays;
- integrate intake, classification, approval, and change review into procurement and development tooling;

- standardize evidence repositories, identifiers, version linkage, and naming conventions;
- automate inventory, monitoring, and evidence collection only where reliability is tested;
- establish recurring business-unit and system-owner attestations;
- expand role-based AI-literacy activities and competence assessment;
- reconcile system inventories with procurement, cloud, security, data, HR, finance, and supplier records;
- confirm that material changes trigger reassessment and substantial-modification analysis where applicable.

133.5 Months 9-10: strengthen monitoring and assurance

- operationalize continuous compliance and control monitoring;
- define drift, performance, incident, complaint, supplier-change, model-change, and legal-change triggers;
- validate post-market monitoring, serious-incident assessment, complaint, and corrective-action processes where applicable;
- expand internal-audit and independent-assurance coverage;
- perform thematic reviews across multiple systems, entities, suppliers, or risk domains;
- assess control dependencies, concentration risk, portability, and exit readiness;
- test executive and board reporting quality against source evidence;
- conduct regulatory, incident, continuity, legal-hold, notification, and supplier-exit exercises;
- validate corrective-action closure and repeated-exception escalation;
- test human oversight, intervention, override, escalation, and stop-use authority in realistic operating conditions.

133.6 Months 11-12: demonstrate readiness and improve maturity

- perform an enterprise readiness and maturity assessment;
- refresh the AI inventory, actor-role map, classification register, and applicable-obligation register;

- confirm that high-risk, GPAI, transparency, prohibited-practice, monitoring, and other applicable obligations are addressed;
- reconcile system inventories, documentation, deployed versions, monitoring records, and supplier evidence;
- review regulatory deadlines, transitional provisions, and unresolved legal interpretations;
- assess residual risk, accepted exceptions, overdue remediation, and systemic themes;
- conduct internal audit or independent assurance over selected high-risk areas;
- validate readiness for applicable conformity assessment, registration, declaration, CE marking, notification, and authority interaction;
- approve year-two priorities, staffing, technology, training, assurance, and budget;
- refresh policies, controls, training, monitoring, and incident plans;
- report programme effectiveness, unresolved exposure, and decision needs to executives and the board.

A readiness assessment does not replace any legally required conformity assessment, registration, declaration, marking, notification, or authority process.

133.7 Sustainable operating model

The target operating model should include:

- an accountable executive and governing committee;
- central policy, methodology, and control ownership;
- distributed business, system, data, and technical accountability;
- embedded legal, compliance, privacy, security, data, procurement, HR, records, continuity, and audit participation;
- reliable inventory, role, applicability, and classification processes;
- lifecycle gates and change controls;
- technical validation, monitoring, and incident management;
- issue, exception, residual-risk, complaint, and corrective-action management;

- supplier oversight, evidence access, concentration management, and exit planning;
- independent assurance and regulatory-response capability;
- funded training, competence, technology, and continuous improvement.

133.8 Year-end readiness criteria

Confirm that:

- all material systems have accountable owners and current intended-purpose records;
- prohibited-practice screening is complete and unresolved questions are escalated;
- role, high-risk, GPAI, transparency, and other classifications are current;
- mandatory documentation, logs, assessments, and evidence are retrievable and version-linked;
- human oversight, incident, notification, preservation, continuity, and stop-use procedures are tested;
- critical suppliers are monitored and contractually controlled;
- material changes trigger reassessment;
- findings, exceptions, complaints, and residual risks are actively governed;
- executives and the board receive reliable and decision-useful reporting;
- year-two priorities address remaining legal, technical, operational, and control gaps.

133.9 GlobalWay Travel Services example

By month 12, GlobalWay has integrated AI intake into procurement and development workflows, implemented a centralized evidence register, expanded monitoring across all critical systems, and completed internal audits of recruitment and fraud-detection tools.

A year-end readiness review identifies inconsistent evidence retention in two business units, weaknesses in regional supplier documentation, and incomplete multilingual transparency notices. GlobalWay requires corrective action and delays broader deployment of one supplier model until monitoring, incident, version, and exit controls are validated. The remaining

items become funded year-two priorities, with documented interim controls and quarterly board reporting.

133.10 Control activities

- Scale governance across material entities and business units.
- Standardize reliable controls, evidence, identifiers, and version linkage.
- Automate inventory, monitoring, and evidence collection only after reliability testing.
- Expand monitoring, thematic review, internal audit, and independent assurance.
- Exercise regulatory, incident, notification, preservation, continuity, and supplier-exit readiness.
- Reconcile documentation and deployed-system versions.
- Validate corrective-action closure and repeated-exception escalation.
- Perform formal year-end readiness, maturity, and residual-risk assessments.
- Approve year-two resources and priorities.
- Report effectiveness, unresolved risk, overdue remediation, and decision needs to the board.

133.11 Evidence

- enterprise control-deployment records;
- updated inventory, role, classification, and obligation registers;
- business-unit and system-owner attestations;
- automated inventory, monitoring, and evidence-reliability test results;
- training and competence records;
- thematic, internal-audit, and independent-assurance reports;
- monitoring, incident, complaint, notification, change, and corrective-action records;
- supplier remediation, concentration, continuity, and exit evidence;
- regulatory, incident, legal-hold, and continuity exercise results;
- readiness and maturity assessments;

- year-end risk, exception, and remediation reports;
- board materials, decisions, and approvals;
- year-two roadmap, staffing plan, and budget.

133.12 Audit tests

1. Confirm governance and controls operate across material entities, business units, jurisdictions, and suppliers.
2. Test automated inventory, monitoring, or evidence outputs for completeness, accuracy, timeliness, and traceability.
3. Review thematic and independent assurance, including validation of corrective-action closure.
4. Reconcile selected production systems to approved intended purpose, classification, documentation, deployed version, monitoring, and supplier records.
5. Verify that significant model, data, purpose, supplier, or jurisdiction changes triggered reassessment.
6. Confirm readiness exercises identified realistic weaknesses and that corrective actions were completed and retested.
7. Assess maturity and year-end conclusions against current supporting evidence.
8. Confirm unresolved risk, overdue remediation, and accepted exceptions were escalated to the appropriate governance level.
9. Verify that readiness reviews did not substitute for legally required regulatory or conformity processes.
10. Confirm year-two priorities address identified legal, technical, supplier, evidence, and control weaknesses.

133.13 Metrics

- enterprise inventory and ownership coverage;
- current role and classification assessment rate;
- controls operating by entity and business unit;
- automated evidence coverage and reliability exceptions;
- high-risk or otherwise regulated systems with current readiness evidence;
- monitoring alerts, complaints, and incidents investigated on time;

- audit findings, repeat findings, and overdue corrective actions;
- regulatory, incident, continuity, and supplier-exit exercises completed;
- overdue exceptions and repeated extensions;
- maturity score by domain;
- unresolved supplier documentation and version gaps;
- year-two actions funded, assigned, and scheduled.

133.14 Management checklist

- Has AI governance become part of normal operations?
- Do controls scale across entities, jurisdictions, technologies, and suppliers?
- Can we demonstrate readiness with current, retrievable, version-linked evidence?
- Are monitoring and assurance identifying real problems and driving corrective action?
- Have significant changes triggered reassessment?
- Does the board understand residual risk, accepted exceptions, overdue actions, and unresolved gaps?
- Is the year-two programme funded and prioritized?
- Are statutory duties clearly distinguished from internal first-year milestones?

133.15 Figure specification — Twelve-Month AI Governance Transformation

Create a timeline from initial control and triage through validated inventory, control implementation, technical assurance, enterprise scaling, continuous monitoring, regulatory and incident exercises, year-end readiness, maturity review, and year-two planning. Show reassessment after significant changes and corrective-action loops after failed assurance.

Alt text: Twelve-month AI governance transformation timeline progressing from initial control and triage through system assessment, controls, assurance, enterprise scaling, continuous monitoring, regulatory exercises, year-end readiness, maturity review, and year-two planning, with reassessment and corrective-action loops.

133.16 Primary legal references

- Regulation (EU) 2024/1689, as amended, including applicable actor, high-risk, transparency, GPAI, quality-management, risk-management, documentation, logging, oversight, monitoring, incident, corrective-action, conformity, registration, and authority-cooperation provisions.
- Regulation (EU) 2026/1744 where applicable.
- Applicable effective dates, transitional provisions, sector law, conformity requirements, and actor duties control over this recommended roadmap.
- Current consolidated official texts control over older summaries.

134 Chapter 133 — High-Risk Readiness Roadmap

Legal status: Corrected English master for consolidation. This chapter is a recommended readiness roadmap. It does not replace the legally required conformity-assessment route, notified-body involvement, registration, declaration, marking, or authority oversight. It controls over conflicting earlier Chapter 133 language.

134.1 Purpose

This chapter provides a practical roadmap for organizations preparing AI systems that may qualify as high-risk under the EU AI Act.

AI may support human decision-making, but it must not remove human responsibility, judgment, or accountability.

134.2 Requirement

Organizations acting as providers, deployers, importers, distributors, authorised representatives, product manufacturers, or other regulated actors must identify potentially high-risk AI systems early, confirm the applicable legal classification and actor duties, assign accountable owners, implement required lifecycle controls, maintain complete technical and governance evidence, and verify readiness before placing a system on the market or putting it into service.

Provider and deployer duties differ. Conformity routes, registration, declaration, marking, monitoring, and reporting obligations also vary by system category, product-law interface, intended purpose, jurisdiction, release date, and applicable effective date.

134.3 Plain-English explanation

High-risk readiness is not a single approval or checklist. It is a coordinated programme covering classification, role analysis, risk management, data governance, technical documentation, records, transparency, human

oversight, accuracy, robustness, cybersecurity, quality management, conformity activities, registration, deployment controls, post-market monitoring, incidents, corrective action, and change.

Internal readiness reviews are useful, but they cannot substitute for a legally required conformity assessment, notified-body process, registration, declaration, CE marking, authority decision, or other statutory obligation.

134.4 Phase 1: identify and classify

- validate the AI inventory;
- determine the intended purpose, actual use, reasonably foreseeable misuse, and affected populations;
- map provider, deployer, importer, distributor, authorised-representative, product-manufacturer, and supplier roles;
- assess Article 6(1) and Annex I product or safety-component routes;
- assess Article 6(2) and Annex III use cases;
- document any Article 6(3) exception analysis and the profiling caveat;
- review exclusions, special conditions, and sector-specific legal overlays;
- identify legal entities, jurisdictions, release dates, and applicable effective dates;
- document legal rationale, assumptions, evidence, approvers, and reassessment triggers.

Potentially high-risk systems should remain subject to precautionary controls until classification uncertainty is resolved.

134.5 Phase 2: establish governance

- appoint accountable business, technical, legal, risk, data, security, compliance, privacy, procurement, and records owners;
- define decision, escalation, stop-use, release, and residual-risk authority;
- establish quality-management responsibilities where provider duties apply;
- approve the risk-management plan and assessment methodology;
- identify competent human-oversight personnel and alternates;
- define independent validation, conformity, audit, and assurance roles;

- establish supplier evidence, change-notice, incident-support, preservation, and audit-right expectations;
- create a high-risk readiness register with owners, dependencies, deadlines, and evidence status.

134.6 Phase 3: implement core controls

Implement and evidence, as applicable:

- continuous risk management;
- data and data-governance controls;
- technical documentation aligned to Annex IV requirements;
- automatic record keeping and logging;
- transparency information and instructions for use;
- human-oversight design, competence, intervention, override, and stop mechanisms;
- accuracy, robustness, resilience, safety, and cybersecurity controls;
- quality-management processes;
- change, configuration, release, rollback, and substantial-modification controls;
- supplier, component, open-source, cloud, and API governance;
- complaint, incident, serious-incident, corrective-action, withdrawal, recall, and authority-response processes;
- evidence retention, preservation, integrity, and version linkage.

134.7 Phase 4: validate readiness

Perform proportionate and documented:

- design-effectiveness review;
- operating-effectiveness testing;
- technical validation against predefined acceptance criteria;
- accuracy, error, subgroup, discrimination, and bias testing;
- human-oversight, escalation, override, and stop-use testing;
- cybersecurity, robustness, resilience, and foreseeable-misuse testing;
- data-quality, lineage, provenance, and representativeness review;

- documentation-to-production and model-version reconciliation;
- evidence completeness, integrity, retrievability, and reproducibility review;
- supplier-evidence and dependency review;
- conformity-readiness assessment without treating it as the conformity process itself.

Failed criteria must trigger remediation, restriction, suspension, rollback, or escalation. A failed criterion may not be waived without documented legal, technical, risk, and approval rationale.

134.8 Phase 5: complete applicable legal authorization steps

Before placing the system on the market or putting it into service, as applicable:

- determine the legally required conformity-assessment route;
- identify whether notified-body involvement is required;
- complete the applicable conformity assessment;
- complete registration where required;
- prepare and approve the EU declaration of conformity where applicable;
- apply CE marking where applicable;
- approve technical documentation and instructions for use;
- verify provider-to-deployer handoff and downstream information;
- confirm deployer readiness and applicable deployer duties;
- resolve or formally govern residual findings consistent with legal constraints;
- approve post-market monitoring, incident, notification, corrective-action, and change plans;
- record release authority, conditions, restrictions, and evidence.

No internal committee may waive a legally mandatory conformity, registration, declaration, marking, or notification requirement.

134.9 Phase 6: operate and monitor

After deployment:

- monitor performance, drift, incidents, complaints, overrides, and foreseeable misuse;
- validate continued effectiveness of human oversight;
- maintain required logs, documentation, evidence, and version records;
- operate post-market monitoring where applicable;
- assess and report serious incidents within applicable rules;
- investigate noncompliance and implement corrective action;
- reassess after material model, data, purpose, supplier, jurisdiction, or control changes;
- perform substantial-modification analysis where relevant;
- suspend, restrict, recall, withdraw, or stop use when necessary;
- support authority requests, inspections, market-surveillance activity, and regulatory follow-up;
- review whether deployer use remains consistent with instructions, intended purpose, and approved controls.

134.10 Deployer-specific readiness

Where the organization acts as a deployer, confirm as applicable:

- use according to instructions and approved purpose;
- competent human oversight;
- input-data relevance and appropriateness where under deployer control;
- monitoring and incident escalation;
- retention and access to logs under deployer control;
- worker or representative information obligations;
- fundamental-rights impact assessment obligations;
- data-protection impact assessment coordination;
- authority cooperation and information access;
- controls preventing unapproved purpose, population, or workflow expansion.

134.11 GlobalWay Travel Services example

GlobalWay treats its recruitment-screening system as potentially high-risk. It confirms the intended purpose, maps provider and deployer roles, documents the Annex III classification rationale, establishes a risk-management file, performs subgroup and oversight testing, and reconciles the deployed version to technical documentation.

A human-escalation test fails, and supplier documentation does not support the deployed model version. GlobalWay blocks release, requires remediation and retesting, updates the supplier evidence package, and confirms the applicable conformity and registration route before authorization. Post-release controls include monitoring, complaint handling, log retention, worker communication, change assessment, and serious-incident escalation.

134.12 Control activities

- Maintain a high-risk readiness register.
- Assign accountable owners, dependencies, deadlines, and escalation paths.
- Map every applicable legal duty to a control, evidence owner, and system version.
- Require qualified legal, technical, risk, and compliance validation before release.
- Prevent internal readiness reviews from substituting for statutory processes.
- Track unresolved findings, restrictions, and conditions of approval.
- Verify provider-to-deployer handoff and deployer readiness.
- Reassess after changes, incidents, complaints, supplier updates, or legal developments.
- Maintain post-market, incident, corrective-action, preservation, and regulatory-response readiness.

134.13 Evidence

- applicability, role, and high-risk classification assessments;
- intended-purpose and effective-date analysis;
- high-risk readiness plan and register;
- quality-management and risk-management records;
- data-governance evidence;

- technical documentation and version index;
- logging, transparency, instructions-for-use, and human-oversight evidence;
- validation, acceptance-criteria, and test reports;
- conformity-route decision and completed conformity records;
- notified-body records where applicable;
- registration, declaration, and CE-marking evidence where applicable;
- provider-to-deployer handoff records;
- release approval and conditions;
- post-market monitoring, incident, notification, complaint, and corrective-action records;
- change and substantial-modification assessments;
- deployer-control and FRIA evidence where applicable.

134.14 Audit tests

1. Verify classification is current, legally supported, and based on intended purpose and actual use.
2. Confirm the organization identified the correct regulated actor duties and effective dates.
3. Trace each applicable high-risk obligation to a control, evidence owner, and deployed version.
4. Confirm technical documentation and supplier evidence match the system placed on the market or put into service.
5. Review validation coverage for accuracy, discrimination risk, oversight, robustness, resilience, safety, cybersecurity, and foreseeable misuse.
6. Trace failed criteria to restriction, remediation, retesting, and authorized release decisions.
7. Verify the applicable conformity route was completed and not replaced by an internal review.
8. Confirm registration, declaration, marking, and notified-body requirements were satisfied where applicable.
9. Test provider-to-deployer handoff and deployer obligations.

10. Verify post-market monitoring, incident, complaint, corrective-action, and authority-response processes operate.
11. Confirm material changes trigger reassessment and substantial-modification analysis.

134.15 Metrics

- potentially high-risk systems identified;
- confirmed high-risk systems by actor role and route;
- classification and effective-date assessments complete;
- readiness controls complete;
- evidence and version-linkage gaps;
- failed validation criteria;
- systems blocked, restricted, suspended, or awaiting retest;
- conformity assessments complete;
- registration, declaration, and marking actions complete where applicable;
- deployment approvals with conditions;
- overdue remediation and repeated exceptions;
- material changes awaiting reassessment;
- monitoring, complaint, incident, and corrective-action items overdue.

134.16 Management checklist

- Have we identified every potentially high-risk system and the correct legal route?
- Is the classification legally defensible and based on current official text?
- Are provider, deployer, and other actor duties distinguished?
- Are all mandatory lifecycle controls implemented and evidenced?
- Does the deployed system match the approved technical and supplier documentation?
- Can failed criteria block deployment or continued use?
- Has the correct conformity process been completed?

- Are registration, declaration, marking, and notified-body requirements addressed where applicable?
- Are monitoring, incidents, complaints, corrective action, and changes governed after release?
- Can required evidence be produced promptly for an authority?

134.17 Figure specification — High-Risk AI Readiness Gate Model

Create sequential gates for applicability and classification, actor-role analysis, governance, control implementation, technical validation, conformity route, legal authorization steps, deployment approval, deployer handoff, and post-market monitoring. Show evidence completeness, version linkage, management accountability, and failed-criteria stop paths as cross-cutting requirements.

Alt text: High-risk AI readiness gates progressing from classification and actor roles through governance, controls, validation, conformity, registration and release, deployer handoff, and post-market monitoring, with evidence, version linkage, accountability, and stop paths after failed criteria.

134.18 Primary legal references

- Regulation (EU) 2024/1689, as amended, including Articles 6, 8-27, 43, 47-49, 72-73 and Annexes I, III, IV, VI, VII, and VIII, as applicable.
- Regulation (EU) 2026/1744 where applicable.
- Applicability of Chapter III Sections 1-3 must follow the current amended transitional timetable for the relevant Article 6 route.
- Product-safety, data-protection, employment, cybersecurity, consumer, and sector-specific law may impose additional duties.
- Current consolidated EUR-Lex text controls over older summaries.

135 Chapter 134 — GPAI Readiness Roadmap

Legal status: Corrected English master for consolidation. This chapter is a recommended readiness roadmap. It does not replace binding provider duties, systemic-risk obligations, AI Office supervision, or applicable codes and standards. It controls over conflicting earlier Chapter 134 language.

135.1 Purpose

This chapter provides a practical roadmap for organizations that develop, place on the market, modify, integrate, distribute, or rely on general-purpose AI models and systems.

AI may support human decision-making, but it must not remove human responsibility, judgment, or accountability.

135.2 Requirement

Organizations must determine their legal role in the GPAI value chain and implement controls proportionate to whether they are a GPAI model provider, downstream AI-system provider, deployer, importer, distributor, authorised representative, or provider of a GPAI model with systemic risk.

135.3 Plain-English explanation

GPAI obligations differ from high-risk-system obligations. An enterprise using a third-party model is not automatically the model provider, but fine-tuning, rebranding, substantial modification, downstream system development, or placing a model or system on the market under its own name can create additional duties. Systemic-risk designation creates enhanced evaluation, risk-management, cybersecurity, incident-reporting, and information obligations.

135.4 Phase 1: map the GPAI value chain

Document:

- model and system names, versions, providers, licences, and hosting arrangements;
- provider, downstream-provider, deployer, importer, distributor, and authorised-representative roles;
- open-source status and any limits on exemptions;
- jurisdictions, sectors, users, and affected persons;
- fine-tuning, retrieval, tool use, agents, plug-ins, and system integrations;
- branding, resale, substantial-modification, and white-label scenarios;
- critical business processes and downstream high-risk uses.

135.5 Phase 2: determine applicability and role

Assess:

1. whether the artifact is a GPAI model, an AI system using GPAI, or both;
2. which entity places the model or system on the EU market;
3. whether the organization has modified, rebranded, or substantially changed the model or system;

4. whether an open-source exemption is relevant and whether its conditions are met;
5. whether systemic-risk criteria or designation apply;
6. whether downstream high-risk, transparency, privacy, product-safety, or sector obligations also apply;
7. whether contractual allocation reflects the actual legal and operational roles.

135.6 Phase 3: documentation and downstream information

Maintain proportionate, version-controlled records covering:

- model capabilities, limitations, intended and foreseeable uses;
- technical model and system documentation;
- integration, configuration, fine-tuning, and retrieval architecture;
- evaluation, validation, and red-team results;
- information required for downstream providers;
- copyright-compliance policy and implementation evidence;
- required training-content summaries where applicable;
- security, incident, change, and release records;
- contacts and procedures for authorities, suppliers, and downstream partners.

135.7 Phase 4: risk and control assessment

Address:

- capability and foreseeable misuse risk;
- hallucination, unreliability, and inappropriate confidence;
- privacy, confidentiality, and data leakage;
- prompt injection, tool abuse, and agentic-action risk;
- cybersecurity and software-supply-chain exposure;
- bias, discrimination, and accessibility;
- intellectual-property and content risk;
- concentration, continuity, and vendor dependency;

- downstream use in high-risk or safety-relevant contexts;
- model, provider, licence, data, and integration changes.

135.8 Phase 5: systemic-risk readiness where applicable

For GPAI models with systemic risk, establish enhanced processes for:

- standardized model evaluations;
- adversarial testing and independent challenge;
- systemic-risk identification, assessment, and mitigation;
- serious-incident tracking and reporting;
- cybersecurity safeguards and resilience;
- energy and resource information where legally required;
- cooperation with the AI Office and competent authorities;
- executive and board oversight of material systemic risk.

135.9 Phase 6: downstream integration readiness

Before material deployment:

- validate provider information and contractual rights;
- assess intended and foreseeable uses;
- define prohibited uses and technical restrictions;
- test prompts, retrieval, tools, agents, and human escalation;
- implement logging, monitoring, and incident response;
- establish model-version and change controls;
- verify transparency and affected-person communications;
- assess high-risk, privacy, security, product, and sector overlays;
- maintain exit, substitution, portability, and continuity plans.

135.10 GlobalWay Travel Services example

GlobalWay integrates third-party GPAI models into a travel-consultant assistant and document-summarization service. It records model versions and suppliers, reviews downstream technical information, restricts sensitive traveler data, tests retrieval and tool calls, requires human approval for refunds and safety-sensitive decisions, and monitors provider changes.

Before offering the assistant to corporate clients under GlobalWay branding, Legal reassesses whether GlobalWay has become a downstream provider with additional documentation, transparency, contract, or system-level duties. Contracts require change notification, incident cooperation, evidence access, and exit support.

135.11 Control activities

- Maintain a complete GPAI model and integration register.
- Document and approve role and applicability assessments.
- Obtain, review, and retain provider and downstream documentation.
- Implement copyright, privacy, security, transparency, and data controls.
- Validate high-impact, agentic, and tool-enabled integrations.
- Monitor model, provider, licence, legal, and code-of-practice changes.
- Establish systemic-risk controls where applicable.
- Reassess material changes before release or continued use.
- Retain evidence supporting decisions, disclosures, and downstream information.

135.12 Evidence

- GPAI inventory and role assessment;
- model and integration documentation;
- provider and downstream information;
- copyright policy and training-content summary where applicable;
- open-source analysis;
- systemic-risk assessment or designation records;
- evaluation, adversarial-testing, cybersecurity, and incident evidence;
- supplier contracts and change notifications;
- monitoring, release, and reassessment records;
- AI Office, implementing-act, standard, and code-of-practice monitoring records.

135.13 Audit tests

1. Verify GPAI models and integrations are completely inventoried and versioned.
2. Review role determinations, branding, modification, and open-source assumptions.
3. Confirm required provider and downstream documentation is maintained and current.
4. Test copyright, privacy, security, transparency, and supplier controls.
5. Review evaluations for misuse, bias, reliability, prompt-injection, and tool-action risk.
6. Confirm model or integration changes trigger reassessment before release.
7. Verify enhanced systemic-risk controls where applicable.
8. Confirm non-binding codes or guidance are not represented as binding law.

135.14 Metrics

- GPAI models and integrations inventoried;
- role assessments current;
- provider-documentation gaps;
- high-impact integrations validated;
- model changes awaiting review;
- evaluation and red-team findings;
- incidents and misuse events;
- downstream information requests overdue;
- systemic-risk actions overdue;
- critical suppliers without tested exit plans.

135.15 Management checklist

- Do we know every material GPAI model and integration in use?
- Are our legal and supply-chain roles supported by evidence?
- Do we have current provider and technical documentation?

- Are copyright, privacy, security, and transparency controls operating?
- Have high-impact and agentic uses been technically validated?
- Do model, provider, licence, and integration changes trigger reassessment?
- Are systemic-risk issues escalated promptly where relevant?

135.16 Figure specification — GPAI Value-Chain Readiness Map

Create a map connecting upstream model providers, downstream system providers, deployers, importers, distributors, users, and affected persons. Show documentation, copyright, evaluation, security, transparency, systemic-risk, change, monitoring, incident, and exit controls across the chain.

Alt text: GPAI readiness map showing model providers, downstream system providers, deployers, importers, distributors, users, and affected persons connected by documentation, evaluation, security, transparency, change, monitoring, incident, and continuity controls.

135.17 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable GPAI provisions, including Articles 51–56 and related supervision and enforcement provisions, plus Annexes XI–XIII where applicable.
- Regulation (EU) 2026/1744 where applicable.
- Applicable AI Office decisions, implementing acts, harmonised standards, and codes of practice must be identified by legal status; non-binding material must not be represented as law.
- Current consolidated EUR-Lex text controls over older summaries.

136 Chapter 135 — Transparency Readiness Roadmap

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 135 draft language.

136.1 Purpose

This chapter provides a practical roadmap for identifying, designing, implementing, testing, and maintaining transparency obligations for AI systems and AI-generated or manipulated content.

AI may support human decision-making, but it must not remove human responsibility, judgment, or accountability.

136.2 Requirement

Organizations must identify which transparency duties apply to each system, actor, use case, output, and deployment context, then implement controls so required notices, disclosures, markings, and instructions are accurate, timely, accessible, understandable, technically effective, and consistent with actual system behaviour.

136.3 Plain-English explanation

Transparency is not satisfied by placing a generic statement in a privacy policy. Duties differ by role and use and may include informing people that they are interacting with AI, providing information and instructions for high-risk systems, informing workers or affected persons where required, marking AI-generated or manipulated content, disclosing deepfakes or certain public-interest text, and informing persons exposed to emotion-recognition or biometric-categorisation systems.

136.4 Phase 1: inventory transparency scenarios

Identify:

- systems that interact directly with natural persons;
- high-risk systems requiring instructions or deployer communications;
- emotion-recognition or biometric-categorisation uses;
- synthetic audio, image, video, and text generation;
- deepfake and manipulated-content scenarios;
- public-interest text and editorial-responsibility scenarios;
- employee, applicant, traveler, customer, supplier, and public interactions;
- channels, languages, jurisdictions, audience characteristics, and accessibility needs.

136.5 Phase 2: determine the legal trigger and responsible actor

For each use case, document:

1. the applicable legal or policy basis;
2. the responsible provider, deployer, importer, distributor, product manufacturer, or other actor;
3. the intended recipient or affected audience;
4. when the information must be delivered;

5. required content, format, and channel;
6. exceptions, exclusions, and effective dates;
7. machine-readable or technical marking requirements;
8. supplier and downstream-information dependencies;
9. accountable owner, legal reviewer, and approver;
10. required evidence, monitoring, and reassessment triggers.

136.6 Phase 3: design notices, disclosures, and instructions

Transparency measures should be:

- clear, concise, and factually accurate;
- distinguishable from unrelated terms and marketing language;
- presented early enough to influence the person's understanding or choice;
- appropriate to the audience and operating context;
- accessible to persons with disabilities;
- available in relevant languages and channels;
- consistent across interfaces, documents, and support channels;
- aligned with actual purpose, limitations, data use, oversight, and complaint routes;
- supported by a meaningful human-contact or escalation path where appropriate.

136.7 Phase 4: implement technical and release controls

Implement as applicable:

- visible AI-interaction notices;
- persistent or readily accessible disclosure indicators;
- machine-readable marking of synthetic content where legally required and technically feasible;
- metadata and provenance controls;
- deepfake and manipulated-content labels;

- affected-person and worker communications;
- human-support and escalation options;
- lawful logging of notice presentation and system version;
- release gates that prevent deployment without approved transparency controls.

136.8 Phase 5: test effectiveness

Test:

- notice timing, placement, and visibility;
- comprehension by intended audiences;
- accessibility and assistive-technology compatibility;
- language quality and localization accuracy;
- mobile, web, voice, document, and embedded-channel presentation;
- technical-marking persistence after normal processing or distribution;
- user ability to obtain human support or challenge where applicable;
- consistency between actual system behaviour and the approved disclosure;
- linkage between notices, markings, instructions, and the deployed version.

136.9 Phase 6: monitor and maintain

Reassess after:

- model, interface, purpose, or workflow changes;
- new content-generation or manipulation functions;
- expansion to new countries, populations, or languages;
- complaints, accessibility defects, or evidence of user confusion;
- supplier or platform changes;
- changes in legal requirements, implementing acts, or authoritative guidance;
- reclassification, substantial modification, or new high-risk use.

136.10 GlobalWay Travel Services example

GlobalWay maps its traveler chatbot, recruitment tool, synthetic marketing content, and call-centre emotion-analysis pilot. The chatbot displays an AI notice before the first response and provides a visible route to a human consultant. Applicant notices are reviewed against the actual recruitment workflow. Generated destination images receive required marking and disclosure controls.

Accessibility testing shows that one notice is not announced correctly by screen readers. Release is paused until the defect is corrected, retested, and linked to the approved production version. A supplier-change gate requires renewed transparency review whenever the underlying model or interface changes.

136.11 Control activities

- Maintain a transparency applicability matrix and notice library.
- Distinguish actor-specific duties and effective dates.
- Approve notices, instructions, and technical markings before release.
- Test timing, comprehension, accessibility, localization, and technical persistence.
- Reconcile disclosures with actual functions, limitations, data use, and oversight.
- Maintain supplier evidence and downstream information.
- Monitor complaints, confusion, and disclosure failures.
- Trigger reassessment after material change.
- Preserve approved versions, implementation evidence, and corrective actions.

136.12 Evidence

- transparency applicability matrix;
- legal-role and use-case analysis;
- approved notice, disclosure, and instruction text;
- user-interface, document, and content examples;
- accessibility, comprehension, and language tests;
- machine-readable marking and provenance test results;
- supplier and downstream documentation;

- deployment, release, and version records;
- human-escalation test results;
- change and reassessment history;
- complaint, defect, and remediation records.

136.13 Audit tests

1. Select AI systems and verify transparency applicability was assessed using the current legal text.
2. Confirm the correct actor, recipient, timing, channel, and effective date were identified.
3. Compare approved disclosures and instructions with actual system behaviour and limitations.
4. Review accessibility, language, localization, and comprehension testing.
5. Test synthetic-content marking and disclosure persistence where applicable.
6. Verify human-support or escalation functions operate as represented.
7. Confirm supplier and version changes trigger reassessment and approval.
8. Verify non-binding guidance is not represented as a binding transparency duty.

136.14 Metrics

- systems requiring transparency measures;
- approved notices and instructions implemented;
- accessibility, comprehension, or language defects;
- disclosure or marking failures;
- user complaints or documented confusion;
- systems changed without transparency reassessment;
- overdue remediation;
- human-escalation success rate;
- supplier changes awaiting review.

136.15 Management checklist

- Have all applicable AI interactions and synthetic-content uses been identified?
- Is the responsible actor and legal trigger clear?
- Are notices timely, accurate, accessible, understandable, and localized?
- Do disclosures and instructions match actual system behaviour?
- Are machine-readable markings implemented and tested where required?
- Can users obtain meaningful human support where appropriate?
- Are transparency controls retested after material change?

136.16 Figure specification — AI Transparency Readiness Journey

Create a journey from use-case identification and legal-trigger analysis through actor mapping, notice and instruction design, accessibility review, technical marking, implementation, production testing, release approval, user feedback, change review, and continuous monitoring.

Alt text: AI transparency readiness journey from identifying relevant interactions and content through actor analysis, approved notices and instructions, technical markings, accessibility testing, deployment, user feedback, change review, and ongoing monitoring.

136.17 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable transparency and information duties, including Articles 13, 26, and 50, together with relevant definitions, exceptions, effective dates, and Annex IV documentation requirements.
- Regulation (EU) 2026/1744 where applicable.
- Applicable accessibility, consumer-protection, employment, privacy, media, and sector-specific law.
- Current consolidated EUR-Lex text controls over older summaries.

137 Chapter 136 — Multijurisdictional Deployment

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 136 draft language.

137.1 Purpose

This chapter explains how organizations should govern AI systems deployed across multiple countries, legal entities, sectors, languages, populations, and regulatory regimes.

AI may support human decision-making, but it must not remove human responsibility, judgment, or accountability.

137.2 Requirement

Organizations deploying AI across multiple jurisdictions must determine which legal regimes, actor roles, sector rules, contractual duties, and local restrictions apply to each deployment, then implement a controlled method for resolving conflicts, applying local overlays, managing cross-border data and supplier dependencies, preserving consistent evidence, and preventing unauthorized expansion of use.

137.3 Plain-English explanation

A system approved in one country is not automatically lawful or operationally suitable in another. The same capability may have different classifications, prohibited-use rules, employment safeguards, transparency duties, privacy requirements, sector restrictions, language expectations, accessibility needs, and regulator contacts. The EU AI Act may also apply where a provider or deployer is outside the Union but the system or its output is used in the Union.

137.4 Global baseline and local overlays

Establish:

- a global AI governance policy and minimum control baseline;
- a common inventory, role, applicability, and classification method;
- minimum lifecycle, risk, data, security, privacy, oversight, monitoring, and evidence controls;
- jurisdiction-specific legal and regulatory overlays;
- sector, customer, workforce, and product overlays;
- documented criteria for applying stricter local requirements;
- a process for resolving conflicting obligations and escalating unresolved legal issues;
- technical controls capable of restricting or suspending deployment by jurisdiction.

137.5 Jurisdiction assessment

For each deployment, document:

1. countries, territories, markets, and establishments involved;
2. legal entities and accountable business and technical owners;
3. provider, deployer, importer, distributor, authorised representative, product manufacturer, employer, controller, processor, and other relevant roles;
4. intended purpose, actual use, users, and affected populations;
5. territorial and extraterritorial applicability;
6. applicable AI, privacy, employment, equality, consumer, safety, accessibility, cybersecurity, product, and sector law;
7. regulator, authority, notification, consultation, and worker-representation contacts;
8. data locations, transfer mechanisms, retention, access, and government-request risks;
9. local language, cultural, accessibility, and support requirements;
10. supplier, subprocessor, cloud, model, and infrastructure locations;
11. restrictions, approvals, launch conditions, and reassessment triggers.

137.6 Deployment decision model

Use controlled outcomes such as:

- approved under the global baseline;
- approved subject to local configuration, notice, consultation, or contract controls;
- approved only for limited users, data, purposes, or regions;
- pilot approved with enhanced monitoring and defined exit criteria;
- deferred pending legal, technical, supplier, or evidence remediation;
- prohibited or unavailable in the jurisdiction;
- suspended or withdrawn after legal change, incident, complaint, or control failure.

137.7 Data, infrastructure, and supplier considerations

Assess:

- lawful collection, use, and reuse of data;

- localization or residency requirements;
- international-transfer mechanisms;
- training, fine-tuning, and secondary-use restrictions;
- sensitive and special-category data;
- retention, deletion, preservation, and authority-access rules;
- regional cloud, model, and logging endpoints;
- sovereignty, government-access, and concentration risk;
- incident, monitoring, and evidence availability across regions;
- supplier-change, subprocessor, continuity, portability, and exit arrangements.

137.8 Localization and user protection

Validate:

- translated notices, disclosures, and instructions;
- accessibility and assistive-technology compatibility;
- local human-oversight competence and authority;
- cultural, linguistic, and context-specific performance;
- local bias, subgroup, and vulnerable-person risks;
- worker, applicant, customer, and affected-person communication duties;
- customer-support, complaint, appeal, and human-escalation channels;
- emergency, incident, regulator, and legal escalation;
- local fallback, rollback, and service-continuity arrangements.

137.9 Change management

Reassess deployment after:

- expansion to a new country, sector, legal entity, or customer population;
- a new language or affected group;
- model, provider, licence, cloud, or subprocessor change;
- new data source, purpose, transfer route, or retention model;

- local law, regulator decision, or authoritative guidance change;
- material incident, complaint, audit finding, or discrimination concern;
- acquisition, restructuring, or new contracting model;
- substantial modification, repurposing, or branding change.

137.10 GlobalWay Travel Services example

GlobalWay plans to deploy a traveler assistant and employee-allocation system in the EU, United Kingdom, United States, Colombia, and Mexico. It applies a common security, oversight, inventory, and evidence baseline, then creates jurisdiction overlays for worker consultation, privacy notices, automated-decision safeguards, data transfers, retention, accessibility, local-language testing, and regulator contacts.

Deployment in one country is delayed because the local-language escalation path and regional log-retention arrangement are incomplete. A geo-restriction remains active until Legal, Compliance, Technology, and the local business owner approve the corrected controls and evidence.

137.11 Control activities

- Maintain a jurisdiction, entity, legal-role, and deployment register.
- Define a global baseline and approved local overlays.
- Require country and population approval before production launch or expansion.
- Validate language, accessibility, bias, oversight, complaints, and support locally.
- Control cross-border data, logs, evidence, and supplier flows.
- Track regulator, notification, consultation, and worker-information requirements.
- Use geo-restriction, configuration, identity, or release controls where needed.
- Reassess after legal, technical, organizational, supplier, purpose, or geographic change.
- Block or suspend deployment where required local controls are incomplete.

137.12 Evidence

- jurisdiction and entity maps;
- applicability, territorial-scope, and role assessments;

- legal and sector obligation register;
- global control baseline and local overlays;
- privacy, data-flow, transfer, retention, and localization assessments;
- localized notices, instructions, consultations, and approvals;
- language, accessibility, subgroup, and oversight tests;
- country approvals, restrictions, and release records;
- supplier, subprocessor, infrastructure, and location records;
- regulator and escalation contact lists;
- geo-restriction and technical-enforcement evidence;
- monitoring, incident, legal-change, and reassessment history.

137.13 Audit tests

1. Select jurisdictions and verify territorial scope, entities, roles, purposes, and affected populations were assessed.
2. Confirm local legal and sector requirements are mapped to controls and retrievable evidence.
3. Review language, accessibility, oversight, complaint, and subgroup testing.
4. Verify data-transfer, localization, retention, and supplier-location controls.
5. Trace country launch or expansion approval to completed local readiness criteria.
6. Confirm legal, provider, model, purpose, and population changes trigger reassessment.
7. Review whether prohibited, deferred, or restricted deployments are technically enforced.
8. Verify unresolved conflicts and exceptions are escalated to authorized decision-makers.

137.14 Metrics

- jurisdictions with current assessments;
- deployments awaiting local approval;
- local control or evidence gaps;

- translation, accessibility, or localization defects;
- cross-border transfer exceptions;
- regional logging and evidence gaps;
- legal or regulatory changes awaiting assessment;
- deployments restricted, suspended, or withdrawn;
- multijurisdictional incidents, complaints, and overdue remediation.

137.15 Management checklist

- Do we know where each AI system operates and which entity is accountable?
- Is territorial and extraterritorial applicability documented?
- Is the global baseline strong enough, and are local overlays approved?
- Have language, accessibility, bias, oversight, and support been tested locally?
- Are cross-border data, evidence, and supplier flows lawful and controlled?
- Can deployment be blocked, restricted, or suspended by jurisdiction?
- Are legal conflicts and uncertain interpretations escalated appropriately?

137.16 Figure specification — Global AI Deployment Control Map

Create a central global-control baseline surrounded by jurisdiction overlays for legal roles, territorial scope, privacy, employment, sector rules, language, accessibility, data location, suppliers, regulators, local monitoring, and incident response. Show country launch gates, technical restrictions, and reassessment triggers.

Alt text: Global AI deployment control map with a common governance baseline, jurisdiction-specific legal and operational overlays, country launch gates, technical restrictions, and reassessment triggers for legal, technical, supplier, population, and geographic change.

137.17 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 2 territorial scope and applicable actor, prohibited-practice, high-risk, transparency, GPAI, monitoring, incident, and enforcement provisions.

- Regulation (EU) 2016/679 and other applicable national, regional, employment, equality, consumer-protection, accessibility, cybersecurity, product-safety, and sector law.
- Regulation (EU) 2026/1744 where applicable.
- Current consolidated official texts and applicable local law control over generalized summaries.

138 Chapter 137 — AI Governance Maturity Model

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 137 draft language.

138.1 Purpose

This chapter provides a practical maturity model for assessing how consistently, effectively, and sustainably an organization governs AI systems and meets applicable legal, contractual, technical, operational, and assurance obligations.

AI may support human decision-making, but it must not remove human responsibility, judgment, or accountability.

138.2 Requirement

An AI governance maturity model is a voluntary management tool, not a substitute for legal compliance. Organizations should use it to assess whether governance, risk, compliance, technical, operational, evidence, and assurance capabilities are consistently designed, implemented, measured, challenged, and improved.

138.3 Plain-English explanation

Legal duties apply regardless of an organization's maturity score. A maturity model helps management identify weak or inconsistent capabilities, prioritize investment, and track improvement, but it must not be used to justify noncompliance, postpone mandatory controls, or average away critical failures.

138.4 Maturity levels

138.4.1 Level 1 — Initial

Characteristics:

- AI use is decentralized or poorly understood;
- inventories and ownership are incomplete;
- decisions and controls are reactive and person-dependent;
- documentation and evidence are inconsistent;

- legal classification often occurs only after problems arise;
- incidents, complaints, and changes are handled informally.

138.4.2 Level 2 — Developing

Characteristics:

- governance roles and basic policies are emerging;
- priority systems are inventoried;
- intake, prohibited-practice, and high-risk screening have begun;
- controls exist for selected systems but are inconsistently operated;
- training is available but not fully role-based;
- remediation and assurance remain incomplete.

138.4.3 Level 3 — Defined

Characteristics:

- enterprise policy, roles, and decision rights are approved;
- material systems are inventoried and classified;
- lifecycle gates and evidence standards are standardized;
- control ownership and frequency are defined;
- privacy, security, data, supplier, transparency, and human-oversight controls are integrated;
- findings, exceptions, and residual risk are governed;
- management reporting and assurance planning are established.

138.4.4 Level 4 — Managed

Characteristics:

- controls operate consistently across material business units and jurisdictions;
- monitoring, thresholds, metrics, and escalation are used;
- model, data, supplier, purpose, and legal changes trigger reassessment;
- technical validation and operating-effectiveness testing are routine;
- evidence is version-linked, reliable, and retrievable;

- executives and the board receive supportable risk reporting;
- incident, regulatory, continuity, and supplier-exit readiness are exercised;
- repeat findings are actively reduced.

138.4.5 Level 5 — Optimizing

Characteristics:

- governance is embedded into strategy, procurement, design, development, release, and operations;
- reliable automation supports inventory, evidence, monitoring, and control testing;
- incidents, complaints, audits, affected-person feedback, and regulatory developments drive change;
- cross-system, systemic, concentration, and dependency risks are analyzed;
- controls are strengthened, simplified, or retired based on evidence;
- assurance is continuous and risk-responsive;
- the organization adapts rapidly without losing accountability, legal traceability, or evidence integrity.

138.5 Assessment domains

Assess maturity across at least:

- governance, accountability, and board oversight;
- AI inventory, ownership, and lifecycle intake;
- legal applicability, actor role, prohibited-practice, and high-risk classification;
- risk, safety, and fundamental-rights management;
- data governance, privacy, and lineage;
- secure development, technical documentation, validation, and change control;
- human oversight, transparency, accessibility, and affected-person communication;
- cybersecurity, resilience, continuity, and incident response;

- supplier, component, concentration, and dependency governance;
- monitoring, complaints, corrective action, and post-market processes;
- control design, evidence, recordkeeping, testing, and internal assurance;
- conformity and regulatory readiness;
- AI literacy and competence;
- multijurisdictional deployment;
- continuous improvement and horizon scanning.

138.6 Scoring principles

Use conservative scoring:

1. score each domain separately;
2. require objective and current evidence;
3. distinguish design maturity from operating maturity;
4. use the lowest reliably demonstrated level where practices vary materially;
5. record scope, assumptions, exceptions, limitations, and confidence;
6. do not average away critical legal or safety weaknesses;
7. do not allow strong documentation to compensate for ineffective operation;
8. assess critical systems and jurisdictions separately where needed;
9. report mandatory legal gaps independently from maturity ratings;
10. do not treat maturity scores as legal conclusions or compliance certification.

138.7 Evidence expectations

Evidence may include:

- approved policies, charters, and authority matrices;
- inventories, role assessments, and classification records;
- control registers and ownership assignments;
- completed risk, impact, privacy, security, and legal assessments;

- training and competence records;
- testing, monitoring, incident, complaint, and performance data;
- supplier, contract, audit-right, and continuity records;
- audit and assurance reports;
- findings, exceptions, remediation, and closure evidence;
- executive and board materials;
- regulatory correspondence and exercise results.

138.8 Gap analysis and target state

For each domain:

1. document the current level;
2. identify supporting evidence and confidence;
3. record mandatory legal or control gaps separately;
4. define the target level based on risk, obligations, scale, and complexity;
5. identify the gap and root cause;
6. assign accountable actions, resources, dependencies, and deadlines;
7. define measurable completion and validation criteria;
8. reassess after implementation or material change.

Not every domain needs Level 5. The target should be proportionate to legal duties, system risk, affected persons, scale, complexity, and organizational context.

138.9 GlobalWay Travel Services example

GlobalWay assesses its programme as Level 3 overall. Governance, inventory, and lifecycle approvals are defined, but monitoring and assurance vary across regions. Technical validation is Level 4 for recruitment and fraud systems, while supplier evidence and localized transparency remain Level 2 in several countries.

GlobalWay does not allow the overall average to conceal a critical weakness in recruitment-system oversight. The board receives domain-level ratings, legal gaps, evidence confidence, remediation owners, target dates, and independently validated improvement results.

138.10 Control activities

- Approve a maturity framework, domain definitions, and scoring criteria.
- Assess each domain using objective and current evidence.
- Separate design, implementation, and operating maturity.
- Apply conservative scoring and confidence ratings.
- Report mandatory legal gaps separately and escalate them by severity.
- Define risk-based target levels.
- Link gaps to funded, accountable remediation plans.
- Report critical weaknesses separately from averages.
- Use qualified reviewers and documented management challenge.
- Reassess periodically and after material change.

138.11 Evidence

- approved maturity methodology and domain criteria;
- assessor competence and independence records;
- evidence index and scoring worksheets;
- scoring rationale, confidence, and limitation records;
- legal-gap register;
- management challenge and approval;
- gap analysis and target-state approvals;
- funded improvement roadmap;
- executive and board reports;
- reassessment and trend results.

138.12 Audit tests

1. Verify maturity criteria are defined and consistently applied.
2. Trace selected ratings to objective and current evidence.
3. Confirm design, implementation, and operating maturity are distinguished.

4. Review whether critical legal, safety, rights, or security weaknesses were obscured by averaging.
5. Assess whether target levels are proportionate to risk and obligations.
6. Trace maturity gaps to accountable, funded, and measurable actions.
7. Confirm reported improvement was independently supportable.
8. Verify maturity ratings were not represented as legal compliance or certification.

138.13 Metrics

- maturity level by domain;
- domains below target;
- mandatory legal gaps by severity;
- high-risk domains at or above the approved target;
- maturity actions overdue;
- ratings with low evidence confidence;
- repeat weaknesses;
- business-unit and jurisdiction variation;
- time required to advance priority domains;
- improvements independently validated.

138.14 Management checklist

- Are maturity ratings supported by actual evidence?
- Are legal gaps reported separately from voluntary maturity improvements?
- Are design and operating effectiveness assessed separately?
- Are critical weaknesses visible despite overall scores?
- Are target levels tied to risk and legal obligations?
- Are improvement actions funded, assigned, and measurable?
- Does reassessment verify that maturity actually improved?

138.15 Figure specification — AI Governance Maturity Staircase

Create a five-level staircase from Initial through Developing, Defined, Managed, and Optimizing. Show governance domains progressing upward, with legal compliance, evidence, operating effectiveness, independent challenge, and continuous improvement as mandatory foundations.

Alt text: Five-level AI governance maturity staircase from initial and reactive practices through defined, managed, and continuously improving governance, supported by legal compliance, evidence, operating effectiveness, and independent assurance.

138.16 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable governance, quality-management, risk-management, documentation, monitoring, competence, corrective-action, and assurance duties.
- Regulation (EU) 2026/1744 where applicable.
- The maturity levels and scoring methodology in this chapter are recommended management practices and are not prescribed by the EU AI Act.
- Current consolidated official texts control over older summaries.

139 Chapter 138 — Continuous Improvement

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Chapter 138 draft language.

139.1 Purpose

This chapter explains how organizations should continuously improve AI governance, controls, technical safeguards, assurance, evidence, and regulatory readiness after the initial compliance programme has been implemented.

AI may support human decision-making, but it must not remove human responsibility, judgment, or accountability.

139.2 Requirement

Organizations should operate a documented continuous-improvement process that uses monitoring, incidents, complaints, audit findings, regulatory developments, technical changes, user feedback, performance data, and lessons learned to strengthen AI governance and compliance. Where the EU AI Act or other law requires corrective action, post-market monitoring, risk-management updates, quality-management updates, documentation changes, or authority cooperation, those duties are binding.

139.3 Plain-English explanation

AI governance cannot remain static. Models, data, suppliers, attack methods, business uses, legal requirements, and affected populations change. Improvement must therefore be systematic, evidence-based, risk-prioritized, and linked to accountable decisions rather than informal lessons or periodic policy refreshes.

A programme is not improved merely because a policy was revised. The organization must show that the change was implemented, tested, linked to the correct system and version, and effective in practice.

139.4 Improvement inputs

Use inputs from:

- legal and regulatory developments;
- official guidance, implementing acts, standards, and codes, identified by legal status;
- system, model, data, prompt, tool, interface, and infrastructure changes;
- new use cases, jurisdictions, sectors, and affected populations;
- monitoring, drift, error, abstention, override, and performance data;
- incidents, near misses, complaints, appeals, and adverse outcomes;
- audit, validation, conformity, and control-testing findings;
- supplier changes, concentration risk, outages, and supply-chain events;
- cybersecurity, privacy, safety, and fundamental-rights intelligence;
- employee, user, affected-person, and accessibility feedback;
- executive, board, regulator, auditor, and independent-review challenge;
- maturity assessments, benchmarking, and assurance trends.

139.5 Improvement cycle

The programme should:

1. identify the issue, opportunity, signal, or change;
2. determine whether it indicates nonconformity, emerging risk, substantial modification, changed intended purpose, or control weakness;

3. assess legal, safety, fundamental-rights, privacy, cybersecurity, operational, and business impact;
4. contain immediate risk and initiate legally required reporting or corrective action;
5. preserve evidence and define affected systems, versions, suppliers, jurisdictions, and persons;
6. perform root-cause and affected-scope analysis;
7. prioritize based on severity, urgency, legal deadline, and potential harm;
8. assign accountable ownership, decision authority, resources, and deadlines;
9. design corrective, preventive, or systemic action;
10. test the proposed change and assess unintended consequences;
11. approve and implement it through controlled change management;
12. update risk assessments, technical documentation, controls, instructions, notices, training, contracts, and monitoring where required;
13. validate operating effectiveness independently where appropriate;
14. share lessons across relevant systems, business units, suppliers, and jurisdictions;
15. measure whether outcomes and control effectiveness improved;
16. preserve version-linked evidence and management approval.

139.6 Prioritization

Prioritize improvements based on:

- actual or potential harm;
- prohibited-practice exposure;
- high-risk or GPAI obligations;
- statutory deadline, authority request, or regulatory commitment;
- control failure severity and duration;
- affected population, vulnerability, and scale;
- repeat incidents, complaints, findings, or exceptions;

- vendor concentration, dependency, or evidence limitations;
- cybersecurity, safety, resilience, and continuity impact;
- weakness in documentation, logs, testing, or traceability;
- implementation complexity and dependencies;
- opportunity to prevent recurrence across multiple systems.

139.7 Corrective and preventive action

Distinguish:

- **correction:** immediate action addressing a specific observed problem;
- **corrective action:** action removing or controlling the cause of an actual deficiency;
- **preventive action:** action reducing the likelihood or impact of a foreseeable deficiency;
- **systemic improvement:** action addressing common causes across systems, vendors, entities, jurisdictions, or control domains.

Do not close an item merely because a document was updated, a meeting occurred, or a supplier promised remediation. Confirm that the action operates effectively and that residual risk is explicitly governed.

139.8 Regulatory and legal change management

Maintain a process to:

- identify relevant legal and regulatory developments;
- distinguish binding law from drafts, guidance, standards, and voluntary codes;
- assess applicability, actor role, system classification, and effective dates;
- identify affected systems, models, entities, suppliers, jurisdictions, and controls;
- update obligation and article-to-control mappings;
- revise policies, contracts, notices, assessments, training, and evidence requirements;
- communicate changes to accountable personnel;
- test implementation before the applicable deadline;

- retain legal analysis, approvals, and implementation evidence.

139.9 Technical and supplier change management

Continuous improvement should respond to:

- model releases, deprecations, and changed capabilities;
- changed prompts, system instructions, tools, agents, or autonomy;
- new training, tuning, validation, or retrieval data;
- performance, subgroup, language, accessibility, or drift findings;
- new vulnerabilities, attack methods, or misuse patterns;
- supplier terms, locations, subprocessors, service levels, and documentation;
- logging, reproducibility, retention, and evidence limitations;
- infrastructure, architecture, cloud-region, and interface changes;
- open-source components and licence changes;
- changes affecting intended purpose, legal role, classification, or conformity status.

139.10 Learning from incidents and complaints

For material events:

- reconstruct the timeline and preserve evidence;
- identify technical, process, governance, supplier, and human causes;
- assess whether similar systems share the weakness;
- implement immediate containment;
- determine notification, corrective-action, withdrawal, recall, or suspension implications;
- assign corrective, preventive, and systemic actions;
- validate closure independently where risk warrants;
- update scenarios, training, controls, documentation, contracts, and monitoring;
- report material lessons and residual risk to executives and the board.

139.11 Control optimization

Periodically review whether controls are:

- legally aligned and current;
- clearly owned and competently performed;
- proportionate to risk and system context;
- consistently implemented across relevant entities and jurisdictions;
- supported by reliable, version-linked evidence;
- capable of detecting meaningful failure;
- duplicative, fragmented, or unnecessarily burdensome;
- integrated into business and technology workflows;
- resilient to system, supplier, and legal change;
- suitable for automation without reducing accountability, human judgment, or traceability.

Control simplification is appropriate only when it preserves or improves legal compliance, protection, evidence quality, and operating effectiveness.

139.12 GlobalWay Travel Services example

GlobalWay identifies repeated traveler-assistant escalation failures after supplier model updates. The company determines that the issue is systemic: supplier changes do not automatically trigger jurisdiction, transparency, human-oversight, regression-testing, and staffing reviews.

GlobalWay strengthens change notification, adds mandatory jurisdiction and affected-person impact checks, expands multilingual regression testing, improves human-oversight staffing and escalation, updates supplier clauses, and blocks release when required evidence is incomplete. Internal assurance validates effectiveness across languages and disruption scenarios before the corrective action is closed.

139.13 Control activities

- Maintain an approved continuous-improvement process and signal register.
- Collect inputs from legal, technical, operational, supplier, user, and assurance sources.
- Prioritize based on legal duties, potential harm, severity, recurrence, and deadlines.
- Distinguish correction, corrective action, preventive action, and systemic improvement.

- Preserve evidence and define affected scope before material changes are made.
- Apply controlled testing, legal review where needed, and approval before implementation.
- Validate operating effectiveness before closure.
- Update policies, controls, risk files, technical documentation, notices, contracts, training, and evidence.
- Track repeat issues, overdue actions, and ineffective remediation.
- Report material trends, systemic weaknesses, and residual risk to executives and the board.

139.14 Evidence

- legal and regulatory change register;
- monitoring and improvement signal register;
- incident, complaint, appeal, audit, and supplier records;
- risk, severity, priority, and affected-scope assessments;
- root-cause analyses;
- corrective, preventive, and systemic action plans;
- containment and change approvals;
- test, validation, regression, and independent-review results;
- updated risk, control, technical, contractual, training, and notice records;
- lessons-learned and cross-system review records;
- management review, residual-risk, and closure approvals;
- trend and effectiveness metrics;
- executive and board reporting.

139.15 Audit tests

1. Review whether relevant legal, technical, supplier, monitoring, incident, complaint, and assurance inputs enter the improvement process.
2. Trace selected improvements from identification through preservation, prioritization, implementation, validation, and closure.

3. Confirm root-cause and affected-scope analysis addressed systemic causes where appropriate.
4. Verify immediate containment, reporting, and corrective-action duties were assessed promptly.
5. Confirm actions were not closed solely on documentary evidence, discussion, or supplier assurance.
6. Assess whether changes triggered updates to risk files, controls, technical documentation, notices, training, contracts, and monitoring.
7. Review repeat findings and incidents for ineffective remediation or weak escalation.
8. Confirm material lessons and residual risk were reported to accountable management and the board.
9. Verify that control simplification or automation did not reduce accountability, evidence, or legal protection.

139.16 Metrics

- improvement actions opened, overdue, validated, and closed;
- repeat findings, incidents, complaints, and exceptions;
- time from signal detection to containment and accountable decision;
- time from remediation to validated closure;
- legal changes implemented before the applicable deadline;
- systemic issues identified across multiple systems or suppliers;
- controls simplified or automated with validated effectiveness;
- improvements producing measurable risk reduction;
- residual risks accepted after incomplete or unsuccessful remediation;
- actions closed without independent validation where required;
- supplier changes received and assessed on time.

139.17 Management checklist

- Are we learning from incidents, complaints, monitoring, audits, users, and suppliers?
- Are binding legal changes distinguished from non-binding material and implemented on time?

- Are root causes and affected scope addressed rather than symptoms alone?
- Is immediate risk contained while longer-term remediation proceeds?
- Are required artifacts, notices, controls, and training updated after change?
- Is effectiveness tested before closure?
- Are repeat problems visible and escalated?
- Does continuous improvement produce measurable risk reduction without weakening accountability?

139.18 Figure specification — AI Governance Continuous-Improvement Loop

Create a closed loop connecting regulatory change, monitoring, incidents, complaints, audits, supplier changes, user feedback, maturity assessments, prioritization, containment, corrective and preventive action, testing, implementation, validation, updated evidence, and renewed monitoring. Show executive and board oversight across the loop.

Alt text: Continuous-improvement loop for AI governance using legal change, monitoring, incidents, complaints, audits, supplier changes, user feedback, and maturity assessments to drive containment, prioritized action, testing, implementation, validation, updated evidence, and renewed executive and board oversight.

139.19 Primary legal references

- Regulation (EU) 2024/1689, as amended: Articles 9, 17, 20, 72, 73, and other applicable risk-management, quality-management, monitoring, incident, corrective-action, documentation, and authority-cooperation provisions.
- Regulation (EU) 2026/1744 where applicable.
- Applicable privacy, cybersecurity, product-safety, employment, consumer-protection, accessibility, equality, and sector-specific law.
- The broader continuous-improvement cycle in this chapter is a recommended management practice except where an applicable legal duty makes a particular action mandatory.
- Current consolidated official texts control over older summaries.

140 Appendices

141 Appendix A — AI Inventory Template

Legal status: Corrected English master. This is an organizational governance register. Specific fields become legally required only where a binding provision applies to the relevant actor, system, model, component, or use.

141.1 Purpose

Use this template to maintain a complete, current, version-linked, and auditable inventory of AI systems, GPAI models, embedded AI capabilities, components, integrations, pilots, and material use cases across the organization.

The inventory should support applicability, role, classification, risk, transparency, conformity, monitoring, incident, evidence, and change-management decisions. It must distinguish statutory classifications from organization-defined governance tiers.

141.2 Inventory record

Field	Required information
Inventory ID	Unique, persistent identifier
Record status	Draft, active, restricted, suspended, retired, archived
Legal entity	Entity developing, providing, importing, distributing, integrating, placing on the market, putting into service, or deploying the system/model
Actor role(s)	Provider, GPAI provider, downstream provider, deployer, importer, distributor, authorised representative, product manufacturer, other
System/model name	Official business, product, model, and technical names
Business owner	Accountable executive or process owner and alternate
Technical owner	Accountable engineering, architecture, data, or platform owner and alternate
Control owners	Legal, Compliance, Risk, Privacy, Security, Data, Procurement, HR,

Field	Required information
	Product, Audit, or other accountable functions
Lifecycle stage	Idea, intake, pilot, development, validation, pre-release, production, restricted, suspended, retired
Intended purpose	Approved purpose, decision context, expected users, beneficiaries, and affected persons
Prohibited or restricted purposes	Uses, populations, data, decisions, jurisdictions, or functions that are not permitted
Actual use	Current operational use, including deviations from approved intended purpose
Users	Employees, contractors, customers, public users, partners, authorities, or others
Affected persons	Individuals or groups materially affected, including workers, applicants, travelers, children, vulnerable persons, or protected groups
AI technique	Rules, machine learning, deep learning, generative AI, GPAI, agentic AI, biometric system, recommender, hybrid, other
System architecture	Major components, interfaces, retrieval, tools, agents, automation, fallback, and human-control points
Version/configuration	Production model, system, prompts, system instructions, tools, data, parameters, code, and release identifiers
Provider/vendor	Internal team or external supplier
Critical dependencies	Models, APIs, cloud services, datasets, software, open-source components, subprocessors, and infrastructure
Jurisdictions	Development, market placement, deployment, output use, hosting, support, and affected-person

Field	Required information
	locations
Sector/use context	Employment, education, credit, insurance, travel, health, public services, safety, law enforcement, migration, justice, consumer, other
EU AI Act applicability	In scope, partially in scope, out of scope, excluded/specially treated, uncertain, pending legal review
Article 5 screening	No concern, potential prohibited practice, prohibited, exception analysis required
High-risk classification	Article 6(1)/Annex I, Article 6(2)/Annex III, Article 6(3) exception considered, not high-risk, uncertain
Transparency classification	Article 13, Article 26, Article 50, other notice duty, none identified, uncertain
GPAI status	GPAI model, GPAI model with systemic risk, downstream system using GPAI, not applicable, uncertain
Governance risk tier	Organization-defined risk tier, clearly separated from statutory classification
Data sources	Training, tuning, validation, retrieval, input, operational, monitoring, and feedback data
Data characteristics	Personal, special-category, biometric, confidential, copyrighted, children's, synthetic, public, licensed, other
Data governance	Provenance, lineage, quality, representativeness, bias controls, retention, deletion, localization, and transfer information
Outputs/actions	Predictions, rankings, recommendations, content, scores, classifications, decisions, alerts, tool calls, or automated actions
Decision impact	Advisory, material influence,

Field	Required information
Human oversight	automated decision, safety-critical, rights-impacting, financial, employment, service-access, other Reviewer, competence, authority, override, stop, appeal, escalation, fallback, and staffing requirements
Required assessments	Applicability, role, prohibited practice, high-risk, FRIA, DPIA, security, data, vendor, conformity, transparency, substantial modification, other
Technical documentation	Index, owner, location, version, status, and applicable Annex IV mapping
Conformity/registration	Route, notified-body involvement, declaration, CE marking, registration, status, and evidence where applicable
Transparency duties	Notices, labels, instructions, disclosures, machine-readable markings, languages, and accessibility
Monitoring	Performance, accuracy, drift, subgroup outcomes, bias, security, robustness, incidents, complaints, overrides, and thresholds
Incident/notification duties	Serious-incident, corrective-action, privacy, cybersecurity, product, employment, consumer, or sector reporting considerations
Change triggers	Model, version, purpose, data, supplier, population, jurisdiction, interface, capability, or legal change
Evidence location	System of record and version-linked repository
Retention	Applicable statutory, contractual, operational, and legal-hold requirements
Application dates	Provision-specific effective dates and transitional rules

Field	Required information
Approval/status	Approved, conditional, restricted, suspended, rejected, retired
Open findings	Material deficiencies, exceptions, conditions, remediation, and due dates
Review history	Last review, next review, trigger, reviewer, decision, and rationale

141.3 Minimum control requirements

- Assign accountable business, technical, and control owners.
- Record material production systems, pilots, proofs of concept, embedded AI features, GPAI integrations, and externally supplied AI.
- Reconcile the inventory with procurement, finance, cloud, software, data, security, HR, product, legal, and vendor records.
- Link each entry to applicability, role, classification, risk, vendor, assessment, control, evidence, and approval records.
- Distinguish actual operation from intended purpose and record unauthorized or shadow-AI use.
- Preserve historical versions, role and classification decisions, restrictions, suspensions, substantial-modification reviews, and retirement evidence.
- Reassess after intended-purpose, actor-role, version, model, data, supplier, population, jurisdiction, incident, complaint, or legal change.
- Escalate ownerless, undocumented, prohibited, or materially uncertain systems according to severity.
- Current consolidated official legal texts control over older summaries.

141.4 Inventory quality checks

Confirm periodically that:

1. every material AI system and GPAI integration has a unique record;
2. production versions match approved documentation;
3. owners, suppliers, jurisdictions, and lifecycle status are current;
4. statutory classification and internal governance tier are not conflated;
5. required assessments and approvals are complete or explicitly pending;

6. evidence links are accessible, version-matched, and retained;
7. suspended and retired systems cannot continue unauthorized operation;
8. material changes trigger reassessment and approval.

141.5 GlobalWay Travel Services example

GlobalWay records its traveler chatbot, recruitment-screening system, fraud model, disruption assistant, pricing model, and employee productivity tools. The inventory identifies a third-party GPAI model used in two systems, links each deployment to the correct legal entity and jurisdiction, records human-oversight and transparency controls, and flags one recruitment-system supplier update for substantial-modification and high-risk reassessment.

141.6 Certification

Readable record format (4 source columns):

Record 1

- **Role:** Business owner
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Technical owner
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Legal/Compliance reviewer
- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Privacy/Security/Data reviewer, where applicable

- **Name:**
- **Decision:**
- **Date:**

Evidence references:

Conditions or exceptions:

Open findings and due dates:

Next review trigger/date:

Record version:

141.7 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable definitions, territorial scope, actor roles, prohibited practices, high-risk classification, GPAI, transparency, registration, documentation, monitoring, incident, and authority-access provisions.
- Regulation (EU) 2026/1744 where applicable.
- Regulation (EU) 2016/679 and applicable employment, consumer-protection, cybersecurity, product-safety, accessibility, equality, records-management, and sector law.
- The inventory fields in this template are governance controls unless a specific legal duty makes a field or record mandatory.

142 Appendix B — AI Intake Form

Legal status: Corrected English master. This is an organizational intake control. Mandatory legal conclusions must be tied to the relevant actor, system, model, use, jurisdiction, provision, and application date.

142.1 Purpose

Use this form before purchasing, developing, piloting, materially changing, branding, integrating, placing on the market, putting into service, or deploying an AI system or GPAI-enabled capability.

The intake must occur early enough to stop prohibited or unsupported activity, identify required reviews, preserve evidence, allocate ownership, and prevent release before legal, technical, operational, and supplier conditions are satisfied.

142.2 1. Request information

- Request title:
- Requesting business unit:
- Requestor:

- Executive sponsor:
- Business owner:
- Technical owner:
- Legal entity or entities:
- Countries and territories of intended development, market placement, deployment, output use, hosting, and support:
- Requested pilot date:
- Requested production launch date:
- Procurement, project, contract, or change reference:
- Related inventory ID, if existing:
- Existing system/model/version being changed, if applicable:

142.3 2. Use-case description

- Business problem:
- Intended purpose:
- Expected benefit:
- Users:
- Affected persons and groups:
- Vulnerable persons, children, workers, applicants, travelers, customers, or protected groups affected:
- Decisions, recommendations, rankings, content, or actions influenced:
- Degree of automation: advisory / material influence / automated decision / automated external action:
- Human decision-maker, if any:
- Consequences of error, misuse, delay, unavailability, or manipulation:
- Existing non-AI alternative:
- Proposed fallback or manual process:
- Foreseeable misuse:
- Prohibited or restricted uses:

- Whether the use differs from the supplier's stated intended purpose:

142.4 3. Technology and value chain

- Internal, external, or hybrid solution:
- Provider/vendor:
- Product, system, and model names:
- Current and proposed versions:
- Hosting and cloud regions:
- APIs, plugins, tools, agents, retrieval, or external actions:
- Open-source components and licences:
- Data providers, subprocessors, downstream providers, and critical dependencies:
- Fine-tuning, prompt engineering, retrieval, or custom model changes:
- Branding, resale, integration, or own-name placement:
- Expected model-update and change-notification process:
- Logging, reproducibility, and version-identification capabilities:
- Vendor documentation available:
- Known technical or evidence limitations:

142.5 4. Data

- Input data:
- Training, tuning, validation, retrieval, grounding, monitoring, and feedback data:
- Personal data involved:
- Special-category, biometric, children's, confidential, copyrighted, or regulated data:
- Data subjects or affected populations:
- Data sources and provenance:
- Lawful basis or authorized-use basis:
- Customer or user data used for supplier training or improvement:
- Data quality, representativeness, bias, and gap concerns:

- Data location, localization, and cross-border transfers:
- Retention, deletion, archival, and legal-hold requirements:
- Data minimization and access controls:

142.6 5. Preliminary legal and risk screening

Answer **Yes**, **No**, or **Uncertain** and cite evidence.

Readable record format (4 source columns):

Record 1

- **Question:** Does the current statutory AI-system definition apply?
- **Yes/No/Uncertain:**
- **Evidence or rationale:**
- **Owner:**

Record 2

- **Question:** Which legal entities and EU AI Act actor roles may apply?
- **Yes/No/Uncertain:**
- **Evidence or rationale:**
- **Owner:**

Record 3

- **Question:** Could an Article 5 prohibited practice be involved?
- **Yes/No/Uncertain:**
- **Evidence or rationale:**
- **Owner:**

Record 4

- **Question:** Could Article 6(1)/Annex I high-risk treatment apply?
- **Yes/No/Uncertain:**
- **Evidence or rationale:**
- **Owner:**

Record 5

- **Question:** Could Article 6(2)/Annex III high-risk treatment apply?
- **Yes/No/Uncertain:**
- **Evidence or rationale:**
- **Owner:**

Record 6

- **Question:** Could an Article 6(3) exception be relevant, and does profiling prevent reliance on it?
- **Yes/No/Uncertain:**
- **Evidence or rationale:**
- **Owner:**

Record 7

- **Question:** Could Article 13, Article 26, Article 50, or other transparency duties apply?
- **Yes/No/Uncertain:**
- **Evidence or rationale:**
- **Owner:**

Record 8

- **Question:** Is a GPAI model or GPAI model with systemic risk involved?
- **Yes/No/Uncertain:**
- **Evidence or rationale:**
- **Owner:**

Record 9

- **Question:** Could Article 27 FRIA duties apply?
- **Yes/No/Uncertain:**
- **Evidence or rationale:**
- **Owner:**

Record 10

- **Question:** Could GDPR DPIA, Article 22, privacy, employment, equality, accessibility, consumer, product-safety, cybersecurity, or sector duties apply?
- **Yes/No/Uncertain:**
- **Evidence or rationale:**
- **Owner:**

Record 11

- **Question:** Could own-brand placement, intended-purpose change, or substantial modification transfer provider duties?
- **Yes/No/Uncertain:**
- **Evidence or rationale:**
- **Owner:**

Record 12

- **Question:** Could the use affect safety, fundamental rights, access to services, employment, credit, insurance, education, healthcare, travel, law enforcement, migration, justice, or critical infrastructure?
- **Yes/No/Uncertain:**
- **Evidence or rationale:**
- **Owner:**

Record 13

- **Question:** Could people interact directly with AI?
- **Yes/No/Uncertain:**
- **Evidence or rationale:**
- **Owner:**

Record 14

- **Question:** Will the system generate or manipulate text, audio, images, or video?
- **Yes/No/Uncertain:**
- **Evidence or rationale:**

- **Owner:**

Record 15

- **Question:** Could the system infer emotions, sensitive traits, identity, or biometric categories?
- **Yes/No/Uncertain:**
- **Evidence or rationale:**
- **Owner:**

Record 16

- **Question:** Could the system act autonomously or trigger external actions?
- **Yes/No/Uncertain:**
- **Evidence or rationale:**
- **Owner:**

Record 17

- **Question:** Are provision-specific application dates or transitional rules material to the decision?
- **Yes/No/Uncertain:**
- **Evidence or rationale:**
- **Owner:**

142.7 6. Oversight, safeguards, and evidence

- Human reviewer role and competence:
- Approval, override, stop, rollback, or abstention mechanism:
- Challenge, appeal, complaint, and human-contact channel:
- Accuracy, bias, subgroup, robustness, misuse, and reliability testing:
- Security, privacy, and threat testing:
- Monitoring thresholds and escalation:
- Incident response and notification assessment:
- Fallback, suspension, recovery, and business-continuity method:

- User, worker, applicant, customer, or affected-person notice:
- Synthetic-content marking or disclosure:
- Accessibility and language requirements:
- AI literacy and role-based training required:
- Supplier evidence, audit rights, and incident cooperation:
- Evidence repository and retention:

142.8 7. Required reviews

Mark **Required**, **Completed**, **Not applicable**, or **Pending**.

Readable record format (5 source columns):

Record 1

- **Review:** AI inventory entry or update
- **Required?:**
- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 2

- **Review:** Applicability assessment
- **Required?:**
- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 3

- **Review:** Actor-role assessment
- **Required?:**
- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 4

- **Review:** Prohibited-practice screening
- **Required?:**
- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 5

- **Review:** High-risk classification
- **Required?:**
- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 6

- **Review:** GPAI/systemic-risk assessment
- **Required?:**
- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 7

- **Review:** Fundamental-rights impact assessment
- **Required?:**
- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 8

- **Review:** Data-protection impact assessment
- **Required?:**

- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 9

- **Review:** Data-governance assessment
- **Required?:**
- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 10

- **Review:** Security and threat assessment
- **Required?:**
- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 11

- **Review:** Technical validation
- **Required?:**
- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 12

- **Review:** Human-oversight plan
- **Required?:**
- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 13

- **Review:** Vendor due diligence
- **Required?:**
- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 14

- **Review:** Contract and audit-right review
- **Required?:**
- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 15

- **Review:** Transparency and marking review
- **Required?:**
- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 16

- **Review:** Accessibility and language review
- **Required?:**
- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 17

- **Review:** Substantial-modification assessment
- **Required?:**

- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 18

- **Review:** Conformity-readiness review
- **Required?:**
- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 19

- **Review:** Registration, declaration, or CE-marking review
- **Required?:**
- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 20

- **Review:** Post-market monitoring plan
- **Required?:**
- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 21

- **Review:** Incident and notification readiness
- **Required?:**
- **Owner:**
- **Status:**
- **Evidence/reference:**

Record 22

- **Review:** Executive or board approval
- **Required?:**
- **Owner:**
- **Status:**
- **Evidence/reference:**

142.9 8. Decision

- ☐ Approved
- ☐ Approved with conditions
- ☐ Restricted pilot only
- ☐ Deferred pending evidence
- ☐ Rejected
- ☐ Prohibited or suspended
- ☐ Qualified legal review required

Decision rationale:

Conditions and restrictions:

Unresolved assumptions or uncertainties:

Accountable remediation owners and due dates:

Evidence references:

Reassessment triggers:

Expiry or next review date:

142.10 9. Approval

Readable record format (4 source columns):

Record 1

- **Role:** Business owner
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Technical owner

- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Legal/Compliance
- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Risk/Privacy/Security/Data, as applicable
- **Name:**
- **Decision:**
- **Date:**

Record 5

- **Role:** Procurement/HR/Product, as applicable
- **Name:**
- **Decision:**
- **Date:**

Record 6

- **Role:** Executive or board authority, where required
- **Name:**
- **Decision:**
- **Date:**

142.11 GlobalWay Travel Services example

GlobalWay submits an intake for a new traveler-disruption assistant using a third-party GPAI model and automated rebooking tools. The intake identifies direct interaction with travelers, sensitive itinerary data, external tool actions, multilingual notices, supplier-version changes, and the need for human approval before refunds or safety-sensitive rebooking. The pilot is

approved with conditions: restricted data fields, human confirmation, enhanced monitoring, supplier change notification, and completion of the transparency, security, vendor, and substantial-modification reviews.

142.12 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable definitions, territorial scope, actor roles, prohibited practices, high-risk classification, transparency, GPAI, conformity, monitoring, incident, and authority-access provisions.
- Regulation (EU) 2026/1744 where applicable.
- Regulation (EU) 2016/679 and applicable employment, equality, accessibility, consumer-protection, cybersecurity, product-safety, records-management, intellectual-property, and sector law.
- Intake approval is an organizational governance decision and does not replace any legally required conformity assessment, registration, authority decision, consultation, notification, or qualified legal analysis.

143 Appendix C — Applicability Assessment

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Appendix C language. Applicability conclusions should be validated by qualified legal counsel where interpretation is uncertain or materially consequential.

143.1 Purpose

Use this worksheet to determine whether the EU AI Act applies to a legal entity, AI system, GPAI model, activity, deployment, output, product integration, or value-chain relationship. The assessment must identify the relevant territorial connection, subject matter, actor roles, classifications, effective dates, exclusions, and related legal regimes.

An applicability decision is not complete unless it is linked to facts, evidence, the current official legal text, and defined review triggers.

143.2 1. Assessment metadata

Field	Response
Legal entity assessed	
Related legal entities	
Business unit	
System or model	
Inventory ID	

Field	Response
Intended purpose	
Actual or proposed use	
Provider/vendor	
Product or service integration	
Countries involved	
Customers and users	
Affected persons and groups	
Assessment owner	
Legal reviewer	
Assessment date	
Source-text version/date	

143.3 2. Territorial and market-connection screening

Answer **Yes**, **No**, or **Uncertain** and cite evidence.

Question	Answer	Evidence or rationale
Is a provider placing an AI system on the Union market?		
Is a provider placing a GPAI model on the Union market?		
Is a provider putting an AI system into service in the Union?		
Is a deployer established or located in the Union?		
Is output produced by an AI system outside the Union used in the Union?		
Is an importer, distributor, authorised representative, product manufacturer, or downstream provider involved in Union-market activity?		
Is the AI system a		

Question	Answer	Evidence or rationale
safety component of, or itself, a regulated product entering the Union market?		
Are Union customers, workers, applicants, travelers, or other affected persons involved?		
Is there a contractual, operational, or distribution structure connecting the system or model to the Union market?		
Do not base the conclusion solely on headquarters, developer, server, or cloud-region location. Document the relevant legal entity, market activity, deployment, and use of output.		

143.4 3. Subject-matter screening

Question	Answer	Evidence or rationale
Does the capability meet the current statutory definition of an AI system?		
Is a GPAI model involved, separately from a downstream AI system?		
Is the capability only conventional software, automation, analytics, or rules that do not meet the statutory definition?		
Is the system or model part of a regulated product or safety component?		
Is research, development, testing, military, defence,		

Question	Answer	Evidence or rationale
national-security, personal non-professional, open-source, or another exclusion or special treatment claimed?		
Are all statutory conditions and scope limitations for the claimed treatment documented?		
Does sector-specific product, safety, employment, equality, accessibility, consumer, privacy, cybersecurity, health, financial-services, transport, or other law also apply?		
An exclusion or special treatment under one AI Act provision does not eliminate independently applicable obligations under the AI Act or other law.		

143.5 4. Actor-role screening

Assess every relevant legal entity and every potentially concurrent role:

- provider of an AI system;
- provider of a GPAI model;
- downstream provider;
- deployer;
- importer;
- distributor;
- authorised representative;
- product manufacturer;
- actor potentially acquiring provider obligations through own-brand placement, substantial modification, intended-purpose change, or other legally relevant conduct.

Readable record format (7 source columns):

- **Entity:**
- **Jurisdiction:**
- **Role:**
- **Factual basis:**
- **Applicable duties:**
- **Evidence:**
- **Legal uncertainty:**

Contract language is relevant evidence but does not override the factual legal role.

143.6 5. Prohibited-practice screening

Determine whether the use may involve any Article 5 concern, including manipulation, exploitation of vulnerability, social scoring, predictive policing, facial-image scraping, emotion recognition in restricted contexts, sensitive biometric categorisation, real-time remote biometric identification, or another prohibited practice as amended.

Readable record format (5 source columns):

- **Potential concern:**
- **Applies?:**
- **Facts and evidence:**
- **Exception or limitation considered:**
- **Legal reviewer:**

A potential Article 5 concern must be escalated immediately and may not proceed merely because the broader applicability assessment is incomplete.

143.7 6. High-risk screening

Determine whether the system may involve:

- Article 6(1) and Annex I product or safety-component treatment;
- Article 6(2) and Annex III use-case treatment;
- Article 6(3) exception analysis;

- the profiling caveat that may prevent reliance on the Article 6(3) exception;
- provider, deployer, importer, distributor, product-manufacturer, registration, conformity, documentation, monitoring, incident, or corrective-action duties.

Readable record format (5 source columns):

Record 1

- **Route or issue:** Article 6(1)/Annex I
- **Applies?:**
- **Legal and factual rationale:**
- **Evidence:**
- **Further review required:**

Record 2

- **Route or issue:** Article 6(2)/Annex III
- **Applies?:**
- **Legal and factual rationale:**
- **Evidence:**
- **Further review required:**

Record 3

- **Route or issue:** Article 6(3) exception
- **Applies?:**
- **Legal and factual rationale:**
- **Evidence:**
- **Further review required:**

Record 4

- **Route or issue:** Profiling caveat
- **Applies?:**
- **Legal and factual rationale:**

- **Evidence:**
- **Further review required:**

Record 5

- **Route or issue:** Sector/product overlay
- **Applies?:**
- **Legal and factual rationale:**
- **Evidence:**
- **Further review required:**

143.8 7. Transparency and GPAI screening

Determine whether the matter involves:

- Article 13 instructions or provider information;
- Article 26 deployer information or worker-related duties;
- Article 50 interaction, biometric, emotion-recognition, synthetic-content, deepfake, or public-interest text duties;
- a GPAI provider, downstream provider, deployer, open-source model, or systemic-risk GPAI model;
- copyright-policy, training-content summary, evaluation, cybersecurity, incident, or AI Office duties.

Readable record format (5 source columns):

Record 1

- **Obligation area:** Transparency
- **Applies?:**
- **Actor:**
- **Evidence:**
- **Application date:**

Record 2

- **Obligation area:** GPAI
- **Applies?:**

- **Actor:**
- **Evidence:**
- **Application date:**

Record 3

- **Obligation area:** Systemic-risk GPAI
- **Applies?:**
- **Actor:**
- **Evidence:**
- **Application date:**

143.9 8. Related legal regimes

Assess independently applicable obligations, including:

- GDPR and national privacy law;
- automated-decision and profiling rules;
- employment, worker-information, consultation, and collective-rights rules;
- equality and anti-discrimination law;
- accessibility law;
- cybersecurity and incident-reporting law;
- consumer-protection and unfair-commercial-practice law;
- product-safety and sector regulation;
- intellectual-property, copyright, confidentiality, and trade-secret obligations;
- records-management, litigation-hold, and evidence-preservation duties.

143.10 9. Timing and transitional treatment

Record the exact provision, applicable date, transition rule, system status, and official source. Do not assign one generic high-risk or GPAI date to every obligation.

Readable record format (5 source columns):

- **Provision or obligation:**

- **Applies?:**
- **Application date:**
- **Transition or legacy-system rule:**
- **Official source:**

143.11 10. Applicability outcome

Select one and explain:

- ☐ In scope
- ☐ Partially in scope
- ☐ Out of scope
- ☐ Excluded or specially treated, with every condition documented
- ☐ Uncertain — qualified legal review required

Conclusion:

Legal and factual rationale:

Applicable actors and obligations:

Non-applicable provisions and rationale:

Conditions, assumptions, and uncertainties:

Related-law obligations:

143.12 11. Required actions

- Complete or update the inventory record.
- Complete actor-role assessment.
- Complete prohibited-practice screening.
- Complete high-risk classification.
- Complete transparency and GPAI assessments.
- Identify exact effective dates and transition provisions.
- Map applicable duties to controls, evidence, owners, and deadlines.
- Identify conformity, registration, declaration, marking, monitoring, incident, or notification requirements where applicable.
- Identify competent authorities and response routes.
- Impose restrictions, conditions, or stop-use decisions where required.

Readable record format (5 source columns):

- **Action:**
- **Owner:**
- **Due date:**
- **Status:**
- **Evidence:**

143.13 12. Review triggers

Reassess after changes in:

- legal entity, establishment, distributor, importer, or representative;
- jurisdiction, market placement, deployment, or output use;
- branding, own-name placement, contractual arrangement, or product integration;
- intended purpose, actual use, affected population, or decision context;
- model, version, data, prompt, tool, agent, interface, capability, or autonomy;
- provider, supplier, licence, subprocessor, or open-source status;
- legal text, implementing act, authority decision, standard, code, or guidance;
- incident, complaint, enforcement matter, or material audit finding.

143.14 GlobalWay Travel Services example

GlobalWay assesses a U.S.-hosted employee-allocation system used by EU offices. Although development and hosting occur outside the Union, the deployer is established in the Union and workers in the Union are affected. GlobalWay identifies potential Annex III employment treatment, deployer and possible provider-role questions arising from customization, GDPR and employment-law overlays, and phased application dates. Deployment remains restricted until role, classification, worker-information, FRIA/DPIA, oversight, and supplier-evidence reviews are complete.

143.15 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Legal
- **Name:**

- **Decision:**
- **Date:**

Record 2

- **Role:** Compliance
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Business owner
- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Technical owner
- **Name:**
- **Decision:**
- **Date:**

Record 5

- **Role:** Privacy/Security/HR/Product, as applicable
- **Name:**
- **Decision:**
- **Date:**

Conditions or assumptions:

Evidence references:

Open legal questions:

Next review trigger or date:

Assessment version:

143.16 Primary legal references

- Regulation (EU) 2024/1689, as amended: Articles 2–4, Article 5, Article 6, actor definitions and duties, GPAI, transparency, conformity, registration, monitoring, incident, and enforcement provisions, together with applicable Annexes.
- Regulation (EU) 2026/1744 where applicable.
- Regulation (EU) 2016/679 and applicable national, employment, equality, accessibility, consumer-protection, cybersecurity, product-safety, intellectual-property, and sector law.
- Current consolidated EUR-Lex text and other official legal sources control over older summaries or internal interpretations.

144 Appendix D — Prohibited-Practice Checklist

Legal status: Corrected English master. Use the current consolidated Article 5 text, Regulation (EU) 2026/1744 where applicable, and any applicable national law. Every **Yes** or **Uncertain** answer requires qualified legal review. This checklist is an operational aid, not a substitute for the regulation, official consolidated text, authority interpretation, national law, or legal advice.

144.1 Purpose

Use this checklist before approval, procurement, development, piloting, deployment, material modification, repurposing, or geographic expansion to identify AI practices that may be prohibited.

Do not classify a use solely from a technology label, vendor description, or policy statement. Test every relevant legal element, deployment fact, exception, safeguard, affected population, and reasonably foreseeable route to circumvention.

144.2 Assessment information

Field	Response
System or use case	
Inventory ID	
Business owner	
Technical owner	
Provider/vendor	
Actor role or roles	
Legal entities	
Jurisdictions	

Field	Response
Intended purpose	
Actual and reasonably foreseeable use	
Affected persons and vulnerable groups	
Version, configuration, prompts, tools, and integrations	
Deployment context	
Current official legal source and application date	
Assessor and date	
Evidence repository	

144.3 Instructions

For every screening question:

1. answer **Yes**, **No**, or **Uncertain**;
2. identify the exact Article 5 point and legal element being tested;
3. cite supporting facts and evidence;
4. record any claimed exception, limitation, authorization, and supporting evidence;
5. identify the reviewer, date, decision, restriction, and follow-up action;
6. assess proxy, workflow, configuration, and foreseeable repurposing routes.

A **No** answer must be supported by verified facts. “Vendor says compliant” is not sufficient evidence.

144.4 A. Subliminal, purposefully manipulative, or deceptive techniques

Question	Yes/No/Uncertain	Evidence and rationale
Does the system use subliminal techniques beyond a person’s consciousness, purposefully manipulative techniques, or		

Question	Yes/No/Uncertain	Evidence and rationale
deceptive techniques?		
Does the technique have the objective or effect of materially distorting behaviour?		
Does it appreciably impair the ability to make an informed decision?		
Could it cause a person to take a decision they would not otherwise have taken?		
Does the use cause, or is it reasonably likely to cause, significant harm?		
Have persuasion, recommendation, personalization, interface design, and deceptive manipulation been distinguished factually?		
Have vulnerable-user, accessibility, dark-pattern, and coercive-design risks been tested?		

Evidence examples: design records, prompts, interfaces, behavioural testing, harm analysis, user research, accessibility review, legal analysis.

144.5 B. Exploitation of vulnerabilities

Question	Yes/No/Uncertain	Evidence and rationale
Does the system exploit vulnerability due to age, disability, or a specific social or economic situation?		
What feature, message, ranking, timing, targeting, or		

Question	Yes/No/Uncertain	Evidence and rationale
interaction mechanism performs the exploitation?		
Could the use materially distort behaviour?		
Does the use cause, or is it reasonably likely to cause, significant harm?		
Have legitimate accessibility, assistance, accommodation, protection, or age-appropriate design been distinguished from exploitation?		
Evidence examples: population analysis, segmentation logic, targeting rules, accessibility review, harm scenarios, safeguards, user research.		

144.6 C. Social scoring

Question	Yes/No/Uncertain	Evidence and rationale
Does the system evaluate or classify natural persons or groups over time based on social behaviour or known, inferred, or predicted personal or personality characteristics?		
Does the score lead to detrimental or unfavourable treatment?		
Is the treatment in a context unrelated to the context in which the data were generated or collected?		
Is the treatment		

Question	Yes/No/Uncertain	Evidence and rationale
unjustified or disproportionate to the social behaviour or its gravity?		
Are loyalty, fraud, safety, reputation, eligibility, or risk scores reused across contexts?		
Can affected persons understand, challenge, and correct the score or underlying data?		
Evidence examples: feature inventory, scoring logic, original data context, downstream-use map, proportionality analysis, adverse-impact tests, appeal records.		

144.7 D. Individual criminal-offence risk prediction

Question	Yes/No/Uncertain	Evidence and rationale
Is the system used to assess or predict the risk that a natural person will commit a criminal offence?		
Is the prediction based solely on profiling or assessment of personality traits or characteristics?		
If AI supports a human assessment, is that assessment already based on objective and verifiable facts directly linked to criminal activity?		
Are area, group, event, or operational analytics being used as a proxy for individual criminal-risk prediction?		
Are the role of AI and		

Question	Yes/No/Uncertain	Evidence and rationale
the independent human assessment documented in decision logs?		
Evidence examples: input features, intended purpose, objective-fact records, human workflow, profiling analysis, decision logs.		

144.8 E. Untargeted facial-image scraping

Question	Yes/No/Uncertain	Evidence and rationale
Does the system create or expand a facial-recognition database?		
Are facial images obtained through untargeted scraping from the internet?		
Are facial images obtained through untargeted scraping from closed-circuit television footage?		
Are collection method, targeting criteria, scale, source, and database function documented?		
Has the organization independently verified supplier representations about training and reference-image sources?		
Evidence examples: source register, acquisition method, crawler configuration, supplier evidence, technical testing, biometric-data assessment.		

144.9 F. Emotion recognition in workplaces and educational institutions

Question	Yes/No/Uncertain	Evidence and rationale
Does the system infer emotions of natural persons?		

Question	Yes/No/Uncertain	Evidence and rationale
Is it deployed in a workplace?		
Is it deployed in an educational institution?		
Is a medical or safety exception claimed?		
Is the claimed medical or safety purpose genuine, necessary, proportionate, narrow, and documented?		
Could a system labelled sentiment, engagement, fatigue, attention, stress, or behavioural analytics perform emotion inference in practice?		
If the use is not prohibited, have high-risk, transparency, employment, education, privacy, consultation, and discrimination obligations been assessed?		
Evidence examples: capability description, deployment context, exception analysis, necessity assessment, worker/student consultation, transparency controls.		

144.10 G. Biometric categorisation using protected or sensitive characteristics

Question	Yes/No/Uncertain	Evidence and rationale
Does the system categorise natural persons individually based on biometric data?		
Does it deduce or infer a protected or sensitive characteristic listed in		

Question	Yes/No/Uncertain	Evidence and rationale
the current legal text?		
Have biometric verification, identification, and categorisation been distinguished?		
Is an exception claimed for labelling or filtering lawfully acquired biometric datasets in an applicable law-enforcement context?		
Is the claimed treatment documented narrowly rather than treated as a general exemption?		
If not prohibited, have high-risk classification and special-category-data restrictions been assessed?		
Evidence examples: biometric data flow, inferred-category list, outputs, downstream actions, exception analysis, GDPR assessment, fairness testing.		

144.11 H. Real-time remote biometric identification in publicly accessible spaces for law enforcement

Question	Yes/No/Uncertain	Evidence and rationale
Does the system perform remote biometric identification?		
Is the operation real-time rather than post-event?		
Is it used in a publicly accessible space?		
Is it used for law-enforcement purposes?		
Is one of the narrowly permitted statutory objectives claimed?		

Question	Yes/No/Uncertain	Evidence and rationale
Is strict necessity documented?		
Are seriousness, probability, and scale of harm documented?		
Are effects on rights and freedoms assessed?		
Are temporal, geographic, and personal limits defined?		
Is prior judicial or independent administrative authorization documented, subject only to the narrow emergency framework?		
Are registration, fundamental-rights assessment, national-law conditions, logging, and post-use review complete?		
Evidence examples: operational concept, purpose, authorization, necessity and proportionality analysis, watchlist governance, accuracy testing, complete logs.		

144.12 I. Additional prohibitions introduced by Regulation (EU) 2026/1744

Application-date control: Assess adoption and application separately. Use the official amended text and verify the applicable **2 December 2026** date before relying on this checklist.

Question	Yes/No/Uncertain	Evidence and rationale
Does the system generate non-consensual sexually explicit or intimate content involving an identifiable person?		

Question	Yes/No/Uncertain	Evidence and rationale
Does the system generate child sexual abuse material within the amended statutory wording?		
Are the two prohibited categories analysed separately?		
Are consent, identity, age, source material, output purpose, and foreseeable misuse documented where relevant?		
Does the product include technical, contractual, reporting, and enforcement controls preventing prohibited generation?		
Is the use blocked rather than merely warned when the statutory prohibition is met?		
Evidence examples: use-policy controls, model and filter tests, consent records where relevant, age and identity controls, blocked-output logs, incident response.		

144.13 J. Proxy, repurposing, and circumvention review

Question	Yes/No/Uncertain	Evidence and rationale
Does the design indirectly achieve a prohibited outcome through proxies, combined features, workflow integration, or downstream use?		
Could configuration, fine-tuning, prompt templates, plugins, agents, or user instructions enable a		

Question	Yes/No/Uncertain	Evidence and rationale
prohibited practice?		
Could a lawful pilot be repurposed into a prohibited deployment context?		
Has the supplier contractually restricted prohibited uses and provided enforceable technical controls?		
Are attempted workarounds detected, logged, investigated, and blocked?		
Can geographic, user, data, or feature restrictions be technically enforced?		

144.14 Evidence reviewed

- intended-purpose statement;
- actual and reasonably foreseeable-use assessment;
- system, model, prompt, tool, and agent documentation;
- data sources, lineage, and feature list;
- user interfaces, instructions, workflows, and demonstrations;
- supplier documentation, testing rights, contracts, and change notices;
- independent testing and observed behaviour;
- deployment context and affected-population analysis;
- legal and fundamental-rights analysis;
- exceptions, authorizations, necessity, and proportionality records;
- monitoring, misuse, proxy, repurposing, and circumvention controls.

144.15 Decision

- ☐ No prohibited practice identified on verified facts
- ☐ Additional evidence required

- ☐ Qualified legal review required
- ☐ Use must be redesigned or restricted
- ☐ Deployment prohibited
- ☐ Existing deployment suspended, withdrawn, or decommissioned

Article point and exact elements assessed:

Decision rationale:

Exception, limitation, or authorization claimed:

Supporting evidence:

Restrictions or required redesign:

Residual uncertainty:

144.16 Mandatory escalation triggers

Escalate and do not approve when:

- any statutory element cannot be resolved from verified facts;
- a claimed exception, limitation, authorization, or safeguard lacks evidence;
- the provider will not disclose relevant functionality, data sources, or observed limitations;
- marketing descriptions conflict with observed capability;
- children, workers, students, migrants, criminal suspects, or other vulnerable groups are affected;
- national law may be stricter or impose separate conditions;
- the system could be repurposed into a prohibited practice;
- technical restrictions cannot reliably block prohibited use;
- a material change affects purpose, context, population, data, geography, capability, actor role, or output use.

144.17 Required controls

- Record the exact legal basis, factual findings, and decision rationale.
- Apply technical, contractual, organizational, and access restrictions.
- Block prohibited configurations, workflows, users, jurisdictions, and outputs.
- Prevent unauthorized repurposing and detect circumvention attempts.

- Train developers, procurement, users, approvers, support, and incident personnel.
- Monitor for misuse, workarounds, material changes, and supplier updates.
- Preserve rejection, suspension, withdrawal, decommissioning, testing, and incident evidence.
- Reassess after changes to purpose, data, features, geography, provider, actor role, affected population, or law.

144.18 GlobalWay Travel Services example

GlobalWay reviews an employee “engagement” tool that claims to measure fatigue and sentiment from voice and video. Testing shows that it infers emotional states in a workplace context. GlobalWay suspends the pilot, preserves supplier and test evidence, and escalates for qualified legal review. The supplier’s general compliance assurance is rejected as insufficient because the observed capability and deployment facts control the analysis.

144.19 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Qualified legal reviewer
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Compliance reviewer
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Technical reviewer
- **Name:**
- **Decision:**

- **Date:**

Record 4

- **Role:** Business owner
- **Name:**
- **Decision:**
- **Date:**

Record 5

- **Role:** Privacy/HR/Security reviewer, where applicable
- **Name:**
- **Decision:**
- **Date:**

Conditions:

Actions and due dates:

Next review date or trigger:

Evidence repository:

Assessment version:

144.20 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 5 and all applicable definitions, exceptions, safeguards, effective dates, and national-law conditions.
- Regulation (EU) 2026/1744 where applicable.
- Regulation (EU) 2016/679 and applicable employment, equality, accessibility, criminal-procedure, consumer-protection, child-protection, cybersecurity, product-safety, and national law.
- Current consolidated official texts control over this checklist and all earlier summaries.

145 Appendix E — High-Risk Classification Worksheet

Legal status: Corrected English master. This file controls over earlier Appendix E language. Classification must be based on the current consolidated EU AI Act, the actor's actual conduct, the system's intended purpose, the relevant Annex route, and the applicable application date.

Qualified legal review is required for uncertain or materially consequential classifications.

145.1 Purpose

Use this worksheet to determine whether an AI system is high-risk under Article 6 and Annex I or Annex III, whether an Article 6(3) exception is claimed, whether profiling prevents reliance on that exception, and which legal and operational consequences follow.

Complete the assessment before production deployment or market placement and repeat it after material changes, repurposing, new jurisdictions, new affected populations, changed human oversight, supplier changes, or legal developments.

145.2 1. Assessment record

Field	Response
System name	
Inventory ID	
Legal entity assessed	
Actor role or roles	
Business owner	
Technical/product owner	
Provider/vendor	
Product integration	
Version, configuration, prompts, tools, and data assessed	
Intended purpose	
Actual or proposed use	
Users and affected persons	
Jurisdictions	
Assessment owner and date	
Legal reviewer	
Current consolidated legal source and date	

145.3 2. Intended-purpose and decision-context analysis

Document:

- the approved intended purpose;

- actual and reasonably foreseeable use;
- the business or public process supported;
- decisions, recommendations, predictions, classifications, rankings, or actions produced;
- whether the system makes, materially influences, prepares, supports, or merely records a decision;
- users, decision-makers, affected persons, and vulnerable groups;
- consequences of error, bias, delay, misuse, unavailability, or manipulation;
- human-review authority, timing, competence, and ability to override;
- whether the use affects employment, education, credit, insurance, essential services, healthcare, safety, law enforcement, migration, justice, democratic processes, or another material opportunity or right.

145.4 3. Article 6(1) and Annex I pathway

Question	Yes/No/Uncertain	Evidence and rationale
Is the AI system itself a product covered by Annex I legislation?		
Is it a safety component of a product covered by Annex I legislation?		
Is the product required to undergo third-party conformity assessment under the applicable Annex I legislation?		
Which legal entity is the relevant provider or product manufacturer?		
Which product legislation, conformity route, and notified-body requirements apply?		
Does failure of the AI		

Question	Yes/No/Uncertain	Evidence and rationale
component create a material health or safety risk?		
What application date, legacy-system rule, or transitional provision controls?		
Article 6(1) conclusion:		
Applicable Annex I legislation:		
Conformity implications:		

145.5 4. Article 6(2) and Annex III pathway

For each Annex III category, record the exact point, intended use, affected persons, decision or process influenced, evidence, and conclusion.

Readable record format (5 source columns):

Record 1

- **Annex III area:** Biometrics
- **In scope?:**
- **Exact point:**
- **Intended use and affected persons:**
- **Rationale and evidence:**

Record 2

- **Annex III area:** Critical infrastructure
- **In scope?:**
- **Exact point:**
- **Intended use and affected persons:**
- **Rationale and evidence:**

Record 3

- **Annex III area:** Education and vocational training
- **In scope?:**
- **Exact point:**

- **Intended use and affected persons:**
- **Rationale and evidence:**

Record 4

- **Annex III area:** Employment, recruitment, worker management, or access to self-employment
- **In scope?:**
- **Exact point:**
- **Intended use and affected persons:**
- **Rationale and evidence:**

Record 5

- **Annex III area:** Essential private and public services and benefits
- **In scope?:**
- **Exact point:**
- **Intended use and affected persons:**
- **Rationale and evidence:**

Record 6

- **Annex III area:** Law enforcement
- **In scope?:**
- **Exact point:**
- **Intended use and affected persons:**
- **Rationale and evidence:**

Record 7

- **Annex III area:** Migration, asylum, and border control
- **In scope?:**
- **Exact point:**
- **Intended use and affected persons:**
- **Rationale and evidence:**

Record 8

- **Annex III area:** Administration of justice and democratic processes
- **In scope?:**
- **Exact point:**
- **Intended use and affected persons:**
- **Rationale and evidence:**

Do not infer Annex III status from a sector label alone. Match the actual intended use to the exact listed category and point.

145.6 5. Material-influence and human-review analysis

Question	Response and evidence
Does the system make or materially influence a decision?	
Is the output presented as a recommendation but routinely followed?	
Is meaningful human review performed before the decision takes effect?	
Can the reviewer understand the basis, limitations, and uncertainty of the output?	
Can the reviewer challenge, disregard, override, or stop the system without penalty or automation bias?	
Is sufficient time, staffing, competence, and information available for review?	
Are affected persons exposed to legal, economic, safety, service-access, employment, educational, or fundamental-rights consequences?	
Are overrides, appeals, and disagreements logged and monitored?	
Human participation does not automatically remove high-risk status.	

145.7 6. Article 6(3) exception analysis

An Annex III-listed system is not excluded merely because a human participates or the provider characterizes the function as administrative. Test every statutory condition and document the facts.

Test	Response	Evidence
Does the system pose a significant risk of harm to health, safety, or fundamental rights?		
Does it materially influence the outcome of decision-making?		
Is the system limited to a narrow procedural task?		
Does it improve the result of a previously completed human activity without replacing or materially influencing that result?		
Does it detect decision-making patterns or deviations without replacing or influencing the prior human assessment?		
Does it perform a preparatory task that does not materially influence the outcome?		
Does the system perform profiling of natural persons?		
Are all relied-upon facts, safeguards, and limitations stable in production?		

Profiling caveat: Where the system performs profiling of natural persons within the statutory rule, do not rely on the Article 6(3) exception without qualified legal confirmation.

Claimed exception basis:

Facts supporting the exception:

Residual risk and safeguards:

Legal conclusion:

145.8 7. Classification conclusion

- ☐ High-risk under Article 6(1)/Annex I
- ☐ High-risk under Article 6(2)/Annex III
- ☐ Annex III system meeting every documented Article 6(3) exception condition
- ☐ Not high-risk on the verified facts
- ☐ Outside current scope
- ☐ Uncertain — additional evidence required
- ☐ Uncertain — qualified legal review required

145.8.1 Final rationale

Document the exact legal route, facts, intended purpose, actor role, affected persons, application date, assumptions, uncertainties, and evidence supporting the conclusion.

145.9 8. Consequence mapping

Record applicable duties by actor and date.

Readable record format (6 source columns):

Record 1

- **Obligation:** Quality-management system
- **Actor:**
- **Applies?:**
- **Application date:**
- **Owner:**
- **Evidence/status:**

Record 2

- **Obligation:** Risk-management system
- **Actor:**

- **Applies?:**
- **Application date:**
- **Owner:**
- **Evidence/status:**

Record 3

- **Obligation:** Data and data governance
- **Actor:**
- **Applies?:**
- **Application date:**
- **Owner:**
- **Evidence/status:**

Record 4

- **Obligation:** Technical documentation
- **Actor:**
- **Applies?:**
- **Application date:**
- **Owner:**
- **Evidence/status:**

Record 5

- **Obligation:** Logging and recordkeeping
- **Actor:**
- **Applies?:**
- **Application date:**
- **Owner:**
- **Evidence/status:**

Record 6

- **Obligation:** Transparency and instructions for use

- **Actor:**
- **Applies?:**
- **Application date:**
- **Owner:**
- **Evidence/status:**

Record 7

- **Obligation:** Human oversight
- **Actor:**
- **Applies?:**
- **Application date:**
- **Owner:**
- **Evidence/status:**

Record 8

- **Obligation:** Accuracy, robustness, cybersecurity, and resilience
- **Actor:**
- **Applies?:**
- **Application date:**
- **Owner:**
- **Evidence/status:**

Record 9

- **Obligation:** Conformity assessment
- **Actor:**
- **Applies?:**
- **Application date:**
- **Owner:**
- **Evidence/status:**

Record 10

- **Obligation:** Notified-body involvement
- **Actor:**
- **Applies?:**
- **Application date:**
- **Owner:**
- **Evidence/status:**

Record 11

- **Obligation:** EU declaration of conformity
- **Actor:**
- **Applies?:**
- **Application date:**
- **Owner:**
- **Evidence/status:**

Record 12

- **Obligation:** CE marking
- **Actor:**
- **Applies?:**
- **Application date:**
- **Owner:**
- **Evidence/status:**

Record 13

- **Obligation:** Registration
- **Actor:**
- **Applies?:**
- **Application date:**
- **Owner:**
- **Evidence/status:**

Record 14

- **Obligation:** Deployer monitoring and log retention
- **Actor:**
- **Applies?:**
- **Application date:**
- **Owner:**
- **Evidence/status:**

Record 15

- **Obligation:** Worker information or consultation
- **Actor:**
- **Applies?:**
- **Application date:**
- **Owner:**
- **Evidence/status:**

Record 16

- **Obligation:** Fundamental-rights impact assessment
- **Actor:**
- **Applies?:**
- **Application date:**
- **Owner:**
- **Evidence/status:**

Record 17

- **Obligation:** Data-protection impact assessment
- **Actor:**
- **Applies?:**
- **Application date:**
- **Owner:**

- **Evidence/status:**

Record 18

- **Obligation:** Post-market monitoring
- **Actor:**
- **Applies?:**
- **Application date:**
- **Owner:**
- **Evidence/status:**

Record 19

- **Obligation:** Serious-incident reporting
- **Actor:**
- **Applies?:**
- **Application date:**
- **Owner:**
- **Evidence/status:**

Record 20

- **Obligation:** Corrective action, restriction, recall, or withdrawal
- **Actor:**
- **Applies?:**
- **Application date:**
- **Owner:**
- **Evidence/status:**

Record 21

- **Obligation:** Authority cooperation and access
- **Actor:**
- **Applies?:**
- **Application date:**

- **Owner:**
- **Evidence/status:**

145.10 9. Required follow-up

Readable record format (5 source columns):

- **Action:**
- **Owner:**
- **Due date:**
- **Status:**
- **Closure evidence:**

No internal readiness decision may substitute for a legally required conformity assessment, registration, declaration, CE marking, notified-body process, authority decision, or sector approval.

145.11 10. Review triggers

Reassess after:

- intended-purpose or actual-use change;
- actor-role, branding, own-name placement, or legal-entity change;
- model, version, data, prompt, tool, workflow, interface, or autonomy change;
- new provider, vendor, subprocessor, or open-source component;
- change in human oversight, staffing, authority, or decision process;
- new affected population, sector, product, or jurisdiction;
- incident, complaint, bias finding, audit issue, or failed acceptance criterion;
- substantial modification or repurposing;
- conformity-route or product-law change;
- legal, regulatory, implementing-act, authority, standard, or code change.

145.12 GlobalWay Travel Services example

GlobalWay assesses an employee-allocation system used to rank workers for assignments. The intended use maps to an Annex III employment category. Although managers approve final assignments, testing shows that the

ranking materially influences decisions and is rarely overridden. The supplier also performs profiling. GlobalWay classifies the system as high-risk, blocks release until the applicable provider and deployer duties are mapped, and initiates documentation, testing, oversight, FRIA/DPIA, conformity, monitoring, and supplier-remediation work.

145.13 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Qualified legal reviewer
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Compliance/risk
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Business owner
- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Technical/product owner
- **Name:**
- **Decision:**
- **Date:**

Record 5

- **Role:** Product-safety or sector specialist, where applicable

- **Name:**
- **Decision:**
- **Date:**

Assumptions and uncertainty:

Evidence references:

Conditions or restrictions:

Next review trigger/date:

Assessment version:

145.14 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 6, Annex I, Annex III, relevant definitions, actor duties, high-risk requirements, conformity, registration, monitoring, incident, corrective-action, and enforcement provisions.
- Regulation (EU) 2026/1744 where applicable, including amended timing and transitional treatment.
- Applicable Annex I product legislation and national or sector law.
- Current consolidated EUR-Lex text and official product-law sources control over internal summaries.

146 Appendix F — Role-Assessment Worksheet

Legal status: Corrected English master for consolidation. This file controls over conflicting earlier Appendix F language. Role classification must reflect actual conduct, market activity, branding, modification, integration, and operational control—not merely contractual labels.

146.1 Purpose

Use this worksheet to determine each legal entity’s role for an AI system, GPAI model, product integration, and jurisdiction. Role classification drives applicable obligations, evidence requirements, contracts, accountability, conformity activities, monitoring, incident duties, and authority relationships.

An entity may hold multiple roles at the same time or different roles in different jurisdictions, products, versions, or transactions.

146.2 1. Assessment information

Field	Response
System or model	
Inventory ID	

Field	Response
Version/configuration assessed	
Legal entity assessed	
Related legal entities	
Jurisdiction	
Intended purpose	
Actual or proposed use	
Business owner	
Technical owner	
Upstream and downstream actors	
Product or service integration	
Assessment owner and date	
Legal reviewer	
Official legal source/version	

146.3 2. Value-chain map

Identify who develops, commissions, brands, markets, places on the market, puts into service, imports, distributes, integrates, deploys, modifies, monitors, supports, suspends, recalls, or withdraws the system or model.

Readable record format (6 source columns):

Record 1

- **Activity:** Development or commissioned development
- **Entity:**
- **Jurisdiction:**
- **Contractual position:**
- **Actual conduct:**
- **Evidence:**

Record 2

- **Activity:** GPAI model provision
- **Entity:**
- **Jurisdiction:**

- **Contractual position:**
- **Actual conduct:**
- **Evidence:**

Record 3

- **Activity:** AI-system provision
- **Entity:**
- **Jurisdiction:**
- **Contractual position:**
- **Actual conduct:**
- **Evidence:**

Record 4

- **Activity:** Branding or own-name placement
- **Entity:**
- **Jurisdiction:**
- **Contractual position:**
- **Actual conduct:**
- **Evidence:**

Record 5

- **Activity:** Union-market placement
- **Entity:**
- **Jurisdiction:**
- **Contractual position:**
- **Actual conduct:**
- **Evidence:**

Record 6

- **Activity:** Putting into service
- **Entity:**

- **Jurisdiction:**
- **Contractual position:**
- **Actual conduct:**
- **Evidence:**

Record 7

- **Activity:** Import
- **Entity:**
- **Jurisdiction:**
- **Contractual position:**
- **Actual conduct:**
- **Evidence:**

Record 8

- **Activity:** Distribution
- **Entity:**
- **Jurisdiction:**
- **Contractual position:**
- **Actual conduct:**
- **Evidence:**

Record 9

- **Activity:** Product or safety-component integration
- **Entity:**
- **Jurisdiction:**
- **Contractual position:**
- **Actual conduct:**
- **Evidence:**

Record 10

- **Activity:** Deployment and operational use

- **Entity:**
- **Jurisdiction:**
- **Contractual position:**
- **Actual conduct:**
- **Evidence:**

Record 11

- **Activity:** Configuration and access control
- **Entity:**
- **Jurisdiction:**
- **Contractual position:**
- **Actual conduct:**
- **Evidence:**

Record 12

- **Activity:** Fine-tuning, modification, or repurposing
- **Entity:**
- **Jurisdiction:**
- **Contractual position:**
- **Actual conduct:**
- **Evidence:**

Record 13

- **Activity:** Data, prompt, tool, or agent control
- **Entity:**
- **Jurisdiction:**
- **Contractual position:**
- **Actual conduct:**
- **Evidence:**

Record 14

- **Activity:** Monitoring and incident support
- **Entity:**
- **Jurisdiction:**
- **Contractual position:**
- **Actual conduct:**
- **Evidence:**

Record 15

- **Activity:** Authority communications
- **Entity:**
- **Jurisdiction:**
- **Contractual position:**
- **Actual conduct:**
- **Evidence:**

Record 16

- **Activity:** Suspension, recall, withdrawal, or exit
- **Entity:**
- **Jurisdiction:**
- **Contractual position:**
- **Actual conduct:**
- **Evidence:**

146.4 3. Role tests

146.4.1 Provider of an AI system

Indicator	Yes/No/Uncertain	Evidence and rationale
Develops or has the AI system developed		
Places it on the market under its name or trademark		
Puts it into service under its name or		

Indicator	Yes/No/Uncertain	Evidence and rationale
trademark		
Acquires provider obligations through own-brand placement		
Makes a substantial modification		
Changes intended purpose in a legally material way		
Integrates components into a system it provides under its own responsibility		
Controls provider documentation, release, conformity, registration, or post-market obligations		

146.4.2 Provider of a GPAI model

Indicator	Yes/No/Uncertain	Evidence and rationale
Develops or has the GPAI model developed		
Places the GPAI model on the Union market under its name or trademark		
Controls model-provider documentation and downstream information		
Controls the copyright-compliance policy and training-content summary where applicable		
Controls systemic-risk evaluation, mitigation, cybersecurity, incident, or reporting duties where applicable		

Indicator	Yes/No/Uncertain	Evidence and rationale
Makes changes that may create or transfer GPAI-provider responsibilities		

146.4.3 Downstream provider

Indicator	Yes/No/Uncertain	Evidence and rationale
Integrates a GPAI model into an AI system it develops or provides		
Controls the downstream system's intended purpose, design, release, or branding		
Relies on upstream documentation to meet downstream duties		
Fine-tunes, adapts, or combines models in a way that changes responsibilities		

146.4.4 Deployer

Indicator	Yes/No/Uncertain	Evidence and rationale
Uses the system under its authority		
Uses it in a professional or organizational context		
Controls operational configuration, access, workflow, or human oversight		
Uses outputs to make or influence decisions affecting workers, applicants, customers, travelers, or others		
Monitors operation, retains logs, or		

Indicator	Yes/No/Uncertain	Evidence and rationale
responds to incidents in the deployment context		

146.4.5 Importer

Indicator	Yes/No/Uncertain	Evidence and rationale
Is established or located in the Union as required by the statutory definition		
Places on the Union market a system bearing the name or trademark of a non-Union provider		
Performs pre-market verification, documentation, registration, or authority-cooperation tasks associated with import		

146.4.6 Distributor

Indicator	Yes/No/Uncertain	Evidence and rationale
Makes an AI system available on the Union market		
Is neither the provider nor importer for that activity		
Controls supply-chain distribution, availability, storage, or onward provision		

146.4.7 Authorised representative

Indicator	Yes/No/Uncertain	Evidence and rationale
Is established in the Union		
Has accepted a written mandate from the		

Indicator	Yes/No/Uncertain	Evidence and rationale
provider		
Performs only the specified mandated tasks		
Maintains required documentation or cooperates with authorities within the mandate		

146.4.8 Product manufacturer

Indicator	Yes/No/Uncertain	Evidence and rationale
Integrates AI into a regulated product or safety component		
Markets or puts the resulting product into service under its name or trademark		
Holds conformity responsibilities under applicable product legislation		
Controls product release, safety documentation, or notified-body interaction		

146.5 4. Provider-role transfer and change triggers

Escalate every **Yes** or **Uncertain** answer.

Readable record format (5 source columns):

Record 1

- **Trigger:** Own-name or own-trademark placement or service
- **Answer:**
- **Evidence:**
- **Potential consequence:**
- **Legal conclusion:**

Record 2

- **Trigger:** Substantial modification
- **Answer:**
- **Evidence:**
- **Potential consequence:**
- **Legal conclusion:**

Record 3

- **Trigger:** Intended-purpose change
- **Answer:**
- **Evidence:**
- **Potential consequence:**
- **Legal conclusion:**

Record 4

- **Trigger:** New product or safety-component integration
- **Answer:**
- **Evidence:**
- **Potential consequence:**
- **Legal conclusion:**

Record 5

- **Trigger:** New affiliate, importer, distributor, representative, or jurisdiction
- **Answer:**
- **Evidence:**
- **Potential consequence:**
- **Legal conclusion:**

Record 6

- **Trigger:** Material branding, white-label, resale, contract, or control change

- **Answer:**
- **Evidence:**
- **Potential consequence:**
- **Legal conclusion:**

Record 7

- **Trigger:** Fine-tuning, model combination, new tools, agents, or autonomy
- **Answer:**
- **Evidence:**
- **Potential consequence:**
- **Legal conclusion:**

Record 8

- **Trigger:** Supplier withdrawal, model replacement, or unsupported version
- **Answer:**
- **Evidence:**
- **Potential consequence:**
- **Legal conclusion:**

146.6 5. Contractual and operational reality

Document who actually controls:

- intended purpose and prohibited uses;
- model and system selection;
- branding and market placement;
- training, tuning, retrieval, and operational data;
- prompts, tools, agents, interfaces, and configuration;
- user access and affected populations;
- technical documentation, validation, and release;
- human oversight, appeals, and complaint handling;

- monitoring, logs, incidents, and notifications;
- conformity assessment, registration, declaration, and CE marking where applicable;
- suspension, rollback, recall, withdrawal, and exit;
- evidence retention and authority response.

Where the contract and actual conduct conflict, escalate and base the role conclusion on the applicable legal facts.

146.7 6. Multiple-role conclusion

Record each role separately by entity, jurisdiction, version, and activity.

Readable record format (7 source columns):

- **Entity:**
- **Jurisdiction:**
- **System/model role:**
- **Factual basis:**
- **Applicable obligations:**
- **Accountable owner:**
- **Approver:**

146.8 7. Additional legal roles

Readable record format (5 source columns):

Record 1

- **Regime:** Data protection
- **Role:** Controller / processor / joint controller / other
- **Entity:**
- **Evidence:**
- **Obligations/owner:**

Record 2

- **Regime:** Employment
- **Role:** Employer / agency / service provider / other

- **Entity:**
- **Evidence:**
- **Obligations/owner:**

Record 3

- **Regime:** Consumer protection
- **Role:** Trader / platform / intermediary / other
- **Entity:**
- **Evidence:**
- **Obligations/owner:**

Record 4

- **Regime:** Cybersecurity
- **Role:** Essential/important entity, provider, service operator, other
- **Entity:**
- **Evidence:**
- **Obligations/owner:**

Record 5

- **Regime:** Product safety
- **Role:** Manufacturer / importer / distributor / other
- **Entity:**
- **Evidence:**
- **Obligations/owner:**

Record 6

- **Regime:** Sector regulation
- **Role:**
- **Entity:**
- **Evidence:**
- **Obligations/owner:**

Record 7

- **Regime:** Intellectual property
- **Role:** Licensor / licensee / content provider / other
- **Entity:**
- **Evidence:**
- **Obligations/owner:**

A role under another legal regime does not automatically determine the EU AI Act role, but the roles must be coordinated.

146.9 8. Contract and operating-model controls

Confirm that contracts and procedures address:

- required technical, model, system, and compliance information;
- intended purpose, prohibited uses, and instructions for use;
- role allocation and notice of role-changing events;
- model, version, data, supplier, and functionality changes;
- monitoring, complaints, incidents, notification, and corrective-action cooperation;
- audit, testing, assurance, and evidence-access rights;
- authority communications and response deadlines;
- documentation, logs, retention, preservation, and legal hold;
- suspension, rollback, withdrawal, recall, decommissioning, and exit;
- privacy, security, employment, equality, consumer, product, and intellectual-property responsibilities.

146.10 9. Ambiguity and escalation

Unresolved issue:

Alternative interpretations:

Evidence needed:

Interim restrictions or controls:

Legal owner:

Resolution deadline:

Decision authority:

Do not permit role uncertainty to delay immediate containment, evidence preservation, or compliance with duties that clearly apply.

146.11 10. Review triggers

Reassess after any change in:

- legal entity, corporate structure, acquisition, or restructuring;
- jurisdiction, market placement, importer, distributor, or representative;
- provider, model, system, open-source component, or licence;
- intended purpose, actual use, affected population, or sector;
- branding, white-labeling, resale, or own-name placement;
- product integration or safety-component status;
- substantial modification, fine-tuning, tools, agents, or autonomy;
- operational control, human oversight, monitoring, or incident response;
- contract, supplier, conformity route, or applicable law.

146.12 GlobalWay Travel Services example

GlobalWay licenses a third-party GPAI model and integrates it into a traveler-assistance system branded and offered to corporate clients under GlobalWay's name. The upstream company remains the GPAI model provider, while GlobalWay may be the downstream AI-system provider and deployer. GlobalWay documents both roles, obtains upstream model information, assumes downstream system documentation and monitoring duties, and triggers new review before fine-tuning or selling the system through an EU affiliate.

146.13 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Qualified legal reviewer
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Compliance
- **Name:**

- **Decision:**
- **Date:**

Record 3

- **Role:** Procurement/vendor management
- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Business owner
- **Name:**
- **Decision:**
- **Date:**

Record 5

- **Role:** Technical/product owner
- **Name:**
- **Decision:**
- **Date:**

Record 6

- **Role:** Product-safety or sector reviewer, where applicable
- **Name:**
- **Decision:**
- **Date:**

Role conclusion and rationale:

Unresolved interpretation:

Interim controls or restrictions:

Evidence references:

Next review trigger or date:

Assessment version:

146.14 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable definitions and duties for providers, GPAI providers, downstream providers, deployers, importers, distributors, authorised representatives, product manufacturers, and actors acquiring provider obligations through legally relevant conduct.
- Regulation (EU) 2026/1744 where applicable.
- Applicable Annex I product legislation, Regulation (EU) 2016/679, and relevant employment, consumer, cybersecurity, product-safety, intellectual-property, and sector law.
- Current consolidated official texts control over contractual labels and internal summaries.

147 Appendix G — Fundamental-Rights Impact Assessment

Legal status: Corrected English master. This file distinguishes the statutory Article 27 fundamental-rights impact assessment from a voluntary or organization-required rights-impact review. Qualified legal review is required to confirm whether Article 27 applies, whether an exception exists, and what authority submission or notification process is current.

147.1 Purpose

Use this assessment to identify, evaluate, mitigate, document, and monitor actual or potential effects of an AI system on dignity, autonomy, equality, privacy, safety, access to opportunities and services, working conditions, due process, and effective remedy.

The assessment should be completed before first use where Article 27 applies and before approval under organizational policy where a voluntary review is required. It must be updated when material facts, risks, populations, safeguards, or legal requirements change.

147.2 1. Applicability gate

Question	Response	Evidence or rationale
Legal entity assessed		
EU AI Act deployer role		
System and inventory ID		
Version/configuration assessed		
High-risk classification		

Question	Response	Evidence or rationale
and exact Annex III point		
Is the deployer a body governed by public law?		
Is the deployer a private entity providing public services?		
Is the deployer otherwise covered by Article 27?		
Does a statutory exception or special treatment apply?		
Is Article 27 legally required, voluntarily applied, contractually required, or required by organizational policy?		
What provision-specific application date and transitional rule applies?		
Current official legal source		
Applicability conclusion:		
Qualified legal reviewer:		
Uncertainty or conditions:		

147.3 2. System, use, and deployment context

Field	Response
System/model and version	
Intended purpose	
Actual or proposed use	
Decision or process supported	
Period and frequency of use	
Jurisdictions	
Users and decision-makers	
Categories of affected natural	

Field	Response
persons and groups	
Vulnerable, underrepresented, or protected groups	
Scale, duration, reversibility, and cumulative effect	
Degree of automation and human involvement	
Data categories and sources	
Supplier and critical dependencies	
Foreseeable misuse and repurposing	
Existing non-AI alternative	

147.4 3. Affected-person experience

Describe:

- how people encounter the system;
- whether participation is voluntary, avoidable, or practically unavoidable;
- what information and notice they receive;
- whether they can obtain meaningful human review;
- how they can challenge, appeal, complain, correct data, or seek remedy;
- whether language, disability, age, culture, economic situation, or digital access affects their ability to understand or respond;
- whether errors or adverse outcomes can be reversed;
- whether multiple systems or decisions create cumulative harm.

147.5 4. Rights and interests analysis

Readable record format (7 source columns):

Record 1

- **Right or interest:** Human dignity and autonomy
- **Impact pathway:**

- **Persons/groups affected:**
- **Severity:**
- **Likelihood:**
- **Existing safeguard:**
- **Residual risk:**

Record 2

- **Right or interest:** Privacy and data protection
- **Impact pathway:**
- **Persons/groups affected:**
- **Severity:**
- **Likelihood:**
- **Existing safeguard:**
- **Residual risk:**

Record 3

- **Right or interest:** Equality and non-discrimination
- **Impact pathway:**
- **Persons/groups affected:**
- **Severity:**
- **Likelihood:**
- **Existing safeguard:**
- **Residual risk:**

Record 4

- **Right or interest:** Accessibility and rights of persons with disabilities
- **Impact pathway:**
- **Persons/groups affected:**
- **Severity:**
- **Likelihood:**

- **Existing safeguard:**
- **Residual risk:**

Record 5

- **Right or interest:** Rights of children
- **Impact pathway:**
- **Persons/groups affected:**
- **Severity:**
- **Likelihood:**
- **Existing safeguard:**
- **Residual risk:**

Record 6

- **Right or interest:** Employment and working conditions
- **Impact pathway:**
- **Persons/groups affected:**
- **Severity:**
- **Likelihood:**
- **Existing safeguard:**
- **Residual risk:**

Record 7

- **Right or interest:** Education and vocational access
- **Impact pathway:**
- **Persons/groups affected:**
- **Severity:**
- **Likelihood:**
- **Existing safeguard:**
- **Residual risk:**

Record 8

- **Right or interest:** Access to essential private or public services
- **Impact pathway:**
- **Persons/groups affected:**
- **Severity:**
- **Likelihood:**
- **Existing safeguard:**
- **Residual risk:**

Record 9

- **Right or interest:** Consumer protection
- **Impact pathway:**
- **Persons/groups affected:**
- **Severity:**
- **Likelihood:**
- **Existing safeguard:**
- **Residual risk:**

Record 10

- **Right or interest:** Freedom of expression and information
- **Impact pathway:**
- **Persons/groups affected:**
- **Severity:**
- **Likelihood:**
- **Existing safeguard:**
- **Residual risk:**

Record 11

- **Right or interest:** Freedom of assembly or association, where relevant
- **Impact pathway:**

- **Persons/groups affected:**
- **Severity:**
- **Likelihood:**
- **Existing safeguard:**
- **Residual risk:**

Record 12

- **Right or interest:** Due process, effective remedy, and fair procedure
- **Impact pathway:**
- **Persons/groups affected:**
- **Severity:**
- **Likelihood:**
- **Existing safeguard:**
- **Residual risk:**

Record 13

- **Right or interest:** Health and safety
- **Impact pathway:**
- **Persons/groups affected:**
- **Severity:**
- **Likelihood:**
- **Existing safeguard:**
- **Residual risk:**

Record 14

- **Right or interest:** Other applicable rights
- **Impact pathway:**
- **Persons/groups affected:**
- **Severity:**
- **Likelihood:**

- **Existing safeguard:**
- **Residual risk:**

147.6 5. Impact pathways

Evaluate risks arising from:

- inaccurate, unreliable, fabricated, or unstable outputs;
- biased data, underrepresentation, or subgroup performance disparities;
- proxy discrimination or cumulative disadvantage;
- automation bias, rubber-stamping, or inadequate human oversight;
- opaque reasoning, insufficient notice, or inaccessible explanations;
- inability to challenge, correct, appeal, or obtain timely human intervention;
- excessive surveillance, monitoring, data collection, or function creep;
- security compromise, data leakage, prompt injection, or malicious misuse;
- changed intended purpose, repurposing, or unauthorized population expansion;
- supplier, model, documentation, or audit-access limitations;
- language, cultural, disability, or accessibility failures;
- system interaction with other automated or human decision processes;
- outages, fallback failure, or loss of access to essential services;
- disparate exposure to false positives, false negatives, delays, or burdens.

147.7 6. Article 27 minimum elements where applicable

Document at minimum:

- the deployer's process in which the high-risk system will be used;
- the period and frequency of intended use;
- categories of natural persons and groups likely to be affected;
- the specific risks of harm to fundamental rights;

- human-oversight measures;
- measures to be taken if risks materialize;
- governance, complaint, remedy, escalation, restriction, suspension, and rollback arrangements;
- coordination with the DPIA where applicable;
- required notification, submission, or registration with the competent authority using the current statutory process;
- the date, recipient, acknowledgement, and follow-up obligations.

147.8 7. Stakeholder and affected-person input

Readable record format (5 source columns):

- **Stakeholder or group:**
- **Why relevant:**
- **Method:**
- **Key concerns or evidence:**
- **Organization response:**

Consider, where proportionate or legally required:

- affected persons and representative organizations;
- workers and worker representatives;
- accessibility and disability specialists;
- equality, civil-rights, and child-rights experts;
- domain professionals;
- Legal, Compliance, Privacy, Security, HR, Product, and Risk;
- independent reviewers or ethics bodies.

Where consultation is not performed, document the legal and proportionality rationale and any alternative evidence used.

147.9 8. Existing safeguards

Document and test:

- data-governance and minimization controls;
- validation, bias, subgroup, language, and accessibility testing;

- human-oversight competence, authority, staffing, override, and stop controls;
- transparency notices, explanations, instructions, and affected-person communication;
- appeal, complaint, correction, and remedy mechanisms;
- security, privacy, access, logging, and evidence controls;
- monitoring, incident, notification, and corrective-action processes;
- supplier, contract, audit-right, change-notification, and exit controls;
- restrictions on purpose, population, jurisdiction, data, automation, and repurposing;
- fallback, business continuity, and manual alternatives.

147.10 9. Residual impact evaluation

Readable record format (7 source columns):

- **Impact:**
- **Inherent risk:**
- **Safeguards:**
- **Safeguard effectiveness:**
- **Residual risk:**
- **Acceptable?:**
- **Owner:**

Residual risk acceptance must not override a prohibition or permit noncompliance with a binding legal duty.

147.11 10. Necessity, proportionality, and alternatives

Document:

- the legitimate objective;
- why AI is necessary or materially beneficial;
- less intrusive or non-AI alternatives considered;
- whether scope, population, data, automation, or duration can be reduced;
- whether benefits are supported by evidence rather than assumption;

- whether burdens and risks fall disproportionately on particular groups;
- the conditions required to maintain proportionality over time.

147.12 11. Decision

- ☐ Statutory Article 27 FRIA complete
- ☐ Voluntary or organizational rights review complete
- ☐ Approved
- ☐ Approved with conditions
- ☐ Restricted pilot with enhanced monitoring
- ☐ Deferred pending remediation or evidence
- ☐ Use restricted or suspended
- ☐ Prohibited or withdrawn
- ☐ Escalated to executive, board, authority, or qualified legal review

147.12.1 Decision rationale

Document the legal basis, benefits, necessity, proportionality, alternatives, stakeholder evidence, unresolved uncertainty, safeguards, residual risk, approval conditions, and authority-process status.

147.13 12. Action plan

Readable record format (7 source columns):

- **Action:**
- **Owner:**
- **Due date:**
- **Priority:**
- **Status:**
- **Validation method:**
- **Closure evidence:**

147.14 13. Monitoring and reassessment

Define:

- performance, error, bias, subgroup, language, accessibility, and override metrics;

- complaint, appeal, correction, and remedy trends;
- incidents, near misses, and notification triggers;
- supplier and model changes;
- affected-population or jurisdiction changes;
- residual-risk thresholds;
- suspension, rollback, restriction, or withdrawal criteria;
- reporting recipients and frequency;
- reassessment owner and schedule.

147.15 14. Review triggers

Reassess after:

- intended-purpose, actual-use, or decision-context change;
- new population, vulnerable group, jurisdiction, language, or service;
- model, version, data, prompt, tool, interface, or autonomy change;
- changed human oversight, staffing, appeal, or remedy mechanism;
- significant complaint, adverse outcome, incident, or drift;
- new supplier, subprocessor, contract, or evidence limitation;
- high-risk reclassification, substantial modification, or conformity change;
- relevant legal, authority, or guidance change.

147.16 GlobalWay Travel Services example

GlobalWay performs an Article 27 applicability review for an AI employee-allocation system used by an EU public-sector travel client. The assessment identifies risks to equality, working conditions, dignity, privacy, accessibility, and effective remedy. Worker representatives report that managers rarely override rankings. GlobalWay strengthens human-review authority, explanation and appeal processes, subgroup testing, accessibility, supplier evidence, and monitoring. Deployment remains restricted until the competent-authority process and closure validation are complete.

147.17 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Qualified legal reviewer
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Compliance/risk
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Business owner
- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Privacy/data protection
- **Name:**
- **Decision:**
- **Date:**

Record 5

- **Role:** Technical/product owner
- **Name:**
- **Decision:**
- **Date:**

Record 6

- **Role:** Affected-domain or worker representative, where applicable
- **Name:**

- **Decision:**
- **Date:**

Record 7

- **Role:** Executive or board authority, where required
- **Name:**
- **Decision:**
- **Date:**

Authority notification/submission status, where applicable:

DPIA coordination status:

Evidence references:

Conditions and restrictions:

Next review trigger/date:

Assessment version:

147.18 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 27, applicable high-risk and deployer provisions, human-oversight, transparency, monitoring, incident, corrective-action, and authority provisions.
- Regulation (EU) 2026/1744 where applicable.
- Charter of Fundamental Rights of the European Union, Regulation (EU) 2016/679, and applicable employment, equality, accessibility, consumer-protection, child-protection, public-law, and sector rules.
- Current consolidated official legal texts and competent-authority procedures control over this template.

148 Appendix H — AI Risk Assessment

Legal status: Corrected English master. Inherent and residual risk ratings are enterprise risk-management concepts. They are not statutory EU AI Act classifications and must not replace Article 5, Article 6, GPAI, transparency, actor-role, conformity, incident, or notification analysis.

148.1 Purpose

Use this assessment to identify, analyse, evaluate, treat, monitor, communicate, and reassess risks arising from an AI system throughout its lifecycle.

The assessment should connect risk scenarios to affected persons, legal obligations, system versions, controls, evidence, acceptance criteria,

monitoring thresholds, and accountable decisions. Planned or untested controls must not be treated as effective.

148.2 1. Assessment context

Field	Response
System/model	
Version/configuration	
Inventory ID	
Legal entity and actor role	
Intended purpose	
Actual or proposed use	
Users and affected persons	
Jurisdictions	
Statutory classification	
Lifecycle stage	
Provider/vendor and dependencies	
Current legal source and application dates	
Business owner	
Technical owner	
Risk assessor	
Assessment date and version	

148.3 2. Risk context

Describe:

- business objective and expected benefit;
- decision or process supported;
- affected persons, vulnerable groups, assets, and services;
- system boundaries, interfaces, tools, agents, and dependencies;
- model, data, infrastructure, cloud, and supplier components;
- legal classification and organizational role;
- decision criticality and degree of automation;
- human oversight and appeal mechanisms;
- assumptions, limitations, uncertainty, and evidence gaps;

- foreseeable misuse, repurposing, and abuse;
- fallback, continuity, suspension, rollback, and exit arrangements.

148.4 3. Risk categories

Assess each applicable category.

Readable record format (8 source columns):

Record 1

- **Category:** Legal and regulatory
- **Risk scenario:**
- **Existing controls:**
- **Likelihood:**
- **Impact:**
- **Inherent risk:**
- **Residual risk:**
- **Evidence/uncertainty:**

Record 2

- **Category:** Fundamental rights
- **Risk scenario:**
- **Existing controls:**
- **Likelihood:**
- **Impact:**
- **Inherent risk:**
- **Residual risk:**
- **Evidence/uncertainty:**

Record 3

- **Category:** Safety and health
- **Risk scenario:**
- **Existing controls:**

- **Likelihood:**
- **Impact:**
- **Inherent risk:**
- **Residual risk:**
- **Evidence/uncertainty:**

Record 4

- **Category:** Accuracy and reliability
- **Risk scenario:**
- **Existing controls:**
- **Likelihood:**
- **Impact:**
- **Inherent risk:**
- **Residual risk:**
- **Evidence/uncertainty:**

Record 5

- **Category:** Bias and discrimination
- **Risk scenario:**
- **Existing controls:**
- **Likelihood:**
- **Impact:**
- **Inherent risk:**
- **Residual risk:**
- **Evidence/uncertainty:**

Record 6

- **Category:** Transparency and explainability
- **Risk scenario:**
- **Existing controls:**

- **Likelihood:**
- **Impact:**
- **Inherent risk:**
- **Residual risk:**
- **Evidence/uncertainty:**

Record 7

- **Category:** Human oversight and automation bias
- **Risk scenario:**
- **Existing controls:**
- **Likelihood:**
- **Impact:**
- **Inherent risk:**
- **Residual risk:**
- **Evidence/uncertainty:**

Record 8

- **Category:** Privacy and data protection
- **Risk scenario:**
- **Existing controls:**
- **Likelihood:**
- **Impact:**
- **Inherent risk:**
- **Residual risk:**
- **Evidence/uncertainty:**

Record 9

- **Category:** Cybersecurity, misuse, and abuse
- **Risk scenario:**
- **Existing controls:**

- **Likelihood:**
- **Impact:**
- **Inherent risk:**
- **Residual risk:**
- **Evidence/uncertainty:**

Record 10

- **Category:** Robustness, resilience, and continuity
- **Risk scenario:**
- **Existing controls:**
- **Likelihood:**
- **Impact:**
- **Inherent risk:**
- **Residual risk:**
- **Evidence/uncertainty:**

Record 11

- **Category:** Vendor, supply chain, and concentration
- **Risk scenario:**
- **Existing controls:**
- **Likelihood:**
- **Impact:**
- **Inherent risk:**
- **Residual risk:**
- **Evidence/uncertainty:**

Record 12

- **Category:** Data quality, provenance, and lineage
- **Risk scenario:**
- **Existing controls:**

- **Likelihood:**
- **Impact:**
- **Inherent risk:**
- **Residual risk:**
- **Evidence/uncertainty:**

Record 13

- **Category:** Change, drift, and substantial modification
- **Risk scenario:**
- **Existing controls:**
- **Likelihood:**
- **Impact:**
- **Inherent risk:**
- **Residual risk:**
- **Evidence/uncertainty:**

Record 14

- **Category:** Operational and financial
- **Risk scenario:**
- **Existing controls:**
- **Likelihood:**
- **Impact:**
- **Inherent risk:**
- **Residual risk:**
- **Evidence/uncertainty:**

Record 15

- **Category:** Reputational
- **Risk scenario:**
- **Existing controls:**

- **Likelihood:**
- **Impact:**
- **Inherent risk:**
- **Residual risk:**
- **Evidence/uncertainty:**

Record 16

- **Category:** Environmental and resource
- **Risk scenario:**
- **Existing controls:**
- **Likelihood:**
- **Impact:**
- **Inherent risk:**
- **Residual risk:**
- **Evidence/uncertainty:**

Record 17

- **Category:** Societal and cumulative impact
- **Risk scenario:**
- **Existing controls:**
- **Likelihood:**
- **Impact:**
- **Inherent risk:**
- **Residual risk:**
- **Evidence/uncertainty:**

148.5 4. Scenario analysis

For each material risk, document:

- initiating event;
- threat, error, misuse, or failure mechanism;

- exposed person, group, asset, process, or service;
- potential consequence and legal implication;
- affected population and scale;
- duration, detectability, reversibility, and cumulative effect;
- control dependencies and single points of failure;
- credible worst case;
- current evidence and uncertainty;
- immediate containment and escalation requirement;
- monitoring signal that would indicate risk materialization.

Readable record format (8 source columns):

- **Scenario ID:**
- **Initiating event:**
- **Failure mechanism:**
- **Affected scope:**
- **Consequence:**
- **Existing controls:**
- **Evidence:**
- **Owner:**

148.6 5. Risk-rating method

Use the organization's approved methodology. Define at minimum:

- likelihood scale and time horizon;
- impact scale across rights, safety, legal, operational, financial, and reputational dimensions;
- aggregation method;
- treatment and escalation thresholds;
- criteria and authority for residual-risk acceptance;
- treatment deadlines by severity;
- confidence or evidence-quality rating;

- treatment of low-frequency, high-impact events;
- treatment of uncertainty and missing evidence.

Do not use a numerical score as a substitute for professional judgment, legal analysis, or verified evidence. Do not average away severe rights, safety, or legal blockers.

148.7 6. Inherent risk

Assess exposure before controls.

Readable record format (8 source columns):

- **Scenario:**
- **Cause:**
- **Affected persons/assets:**
- **Likelihood:**
- **Impact:**
- **Inherent rating:**
- **Confidence:**
- **Evidence/uncertainty:**

148.8 7. Controls and effectiveness

Readable record format (8 source columns):

- **Control:**
- **Owner:**
- **Status:**
- **Evidence:**
- **Design result:**
- **Operating result:**
- **Limitation:**
- **Dependency:**

Do not reduce risk for controls that are planned, incomplete, unapproved, untested, inconsistently operated, unsupported by evidence, or dependent on unavailable supplier information.

148.9 8. Residual risk and legal blockers

Readable record format (7 source columns):

- **Risk:**
- **Residual rating:**
- **Legal blocker?:**
- **Treatment:**
- **Owner:**
- **Due date:**
- **Validation requirement:**

A risk-acceptance decision cannot:

- authorize a prohibited practice;
- waive a statutory obligation;
- replace a required conformity assessment, registration, declaration, marking, consultation, notification, or authority decision;
- permit operation outside an approved intended purpose or legal role;
- prevent required incident reporting, corrective action, restriction, recall, or withdrawal;
- override applicable privacy, employment, safety, consumer, accessibility, equality, or sector law.

148.10 9. Risk treatment

Select one or more:

- avoid or prohibit the use;
- reduce through technical controls;
- reduce through process, staffing, or human oversight;
- reduce through data, interface, or scope changes;
- transfer or allocate through contract or insurance, without transferring legal accountability that remains with the organization;
- limit purpose, population, geography, data, capability, or degree of automation;
- pilot with enhanced monitoring and exit criteria;

- accept residual risk through authorized approval;
- suspend, restrict, roll back, withdraw, or decommission pending remediation.

Readable record format (7 source columns):

- **Treatment action:**
- **Owner:**
- **Due date:**
- **Priority:**
- **Status:**
- **Validation method:**
- **Closure evidence:**

148.11 10. Key risk indicators and thresholds

Readable record format (6 source columns):

- **Indicator:**
- **Threshold:**
- **Data source:**
- **Frequency:**
- **Owner:**
- **Escalation action:**

Consider:

- error and abstention rates;
- subgroup and language disparities;
- override, disagreement, appeal, and complaint rates;
- incidents, near misses, and notification triggers;
- security alerts and misuse attempts;
- model, data, prompt, tool, or supplier changes;
- unavailable logs, evidence, or documentation;
- drift, unexpected behaviour, and failed regression tests;

- overdue findings and repeated exceptions;
- service continuity and fallback failures.

148.12 11. Residual-risk decision

- ☐ Acceptable within approved tolerance
- ☐ Acceptable with conditions and enhanced monitoring
- ☐ Executive risk acceptance required
- ☐ Board escalation required
- ☐ Remediation required before approval
- ☐ Restricted pilot only
- ☐ Deployment blocked or suspended
- ☐ Prohibited, withdrawn, or decommissioned
- ☐ Qualified legal review required

148.12.1 Decision rationale

Document:

- expected benefits and supporting evidence;
- less risky alternatives considered;
- control design and operating effectiveness;
- legal blockers and mandatory obligations;
- uncertainty and evidence limitations;
- affected persons and vulnerable groups;
- residual-risk conditions, duration, and monitoring;
- acceptance authority and rationale;
- criteria requiring suspension, rollback, or reassessment.

148.13 12. Monitoring and reassessment

Define:

- indicators, thresholds, and source systems;
- affected-person, subgroup, language, and accessibility outcomes;
- human-oversight, override, appeal, and complaint monitoring;

- incident, near-miss, and notification triggers;
- model, vendor, data, prompt, tool, and jurisdiction changes;
- review frequency and reporting recipients;
- suspension, rollback, restriction, withdrawal, and exit criteria;
- evidence-retention and version-linking requirements.

148.14 13. Reassessment triggers

Reassess after:

- model, data, prompt, tool, agent, architecture, or interface change;
- intended-purpose, actual-use, population, sector, or degree-of-automation change;
- deployment in a new jurisdiction or legal entity;
- material incident, complaint, appeal, adverse outcome, or near miss;
- performance, bias, subgroup, language, accessibility, or security drift;
- vendor, contract, subprocessor, licence, or critical-dependency change;
- security vulnerability, threat intelligence, or misuse pattern;
- legal, regulatory, authority, standard, or code development;
- audit, validation, conformity, or control-testing finding;
- substantial modification, repurposing, or role change.

148.15 GlobalWay Travel Services example

GlobalWay assesses a traveler-disruption assistant that recommends itinerary changes and can initiate rebooking tools. Material scenarios include inaccurate safety advice, unauthorized refunds, privacy leakage, prompt injection, vendor outages, language disparities, and automation bias. GlobalWay requires human confirmation for external actions, restricts sensitive data, adds multilingual regression testing, monitors override and complaint rates, and defines immediate suspension thresholds. Residual risk is approved only for a restricted pilot pending supplier evidence and independent validation.

148.16 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Business owner
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Technical owner
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Risk owner
- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Legal/Compliance
- **Name:**
- **Decision:**
- **Date:**

Record 5

- **Role:** Privacy/Security/Data, as applicable
- **Name:**
- **Decision:**
- **Date:**

Record 6

- **Role:** Executive or board, where required
- **Name:**

- **Decision:**
- **Date:**

Evidence references:

Accepted assumptions and uncertainty:

Conditions, restrictions, and expiry:

Open actions and due dates:

Next review trigger/date:

Assessment version:

148.17 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable risk-management, high-risk, GPAI, transparency, human-oversight, accuracy, robustness, cybersecurity, monitoring, incident, corrective-action, and authority provisions.
- Regulation (EU) 2026/1744 where applicable.
- Regulation (EU) 2016/679 and applicable employment, equality, accessibility, cybersecurity, product-safety, consumer-protection, intellectual-property, environmental, and sector law.
- Enterprise risk ratings in this template are governance tools and do not alter statutory classifications or legal duties.

149 Appendix I — Data-Governance Assessment

Legal status: Corrected English master. This file distinguishes Article 10 duties for providers of high-risk AI systems from broader organizational data-governance, privacy, security, quality, intellectual-property, and records-management controls.

149.1 Purpose

Use this assessment to evaluate whether data used to train, fine-tune, validate, test, retrieve for, operate, monitor, or improve an AI system is suitable, lawful, secure, representative, traceable, and governed for the documented intended purpose and affected population.

The assessment must be version-linked and repeated when source, population, purpose, model, feature, label, transformation, supplier, jurisdiction, or legal conditions change.

149.2 1. Applicability and scope

Field	Response
System/model	
Inventory ID	

Field	Response
Version/configuration	
Legal entity and actor role	
High-risk classification and legal basis	
Dataset/source name and version	
Data owner and steward	
Intended purpose and lifecycle use	
Affected persons and populations	
Jurisdictions	
Article 10 applies?	
Related DPIA/FRIA/security assessment	
Current legal source and application date	
Assessment owner/date	

149.3 2. Dataset and lifecycle use

Record each use separately.

Readable record format (6 source columns):

Record 1

- **Data use:** Training
- **Dataset/version:**
- **Purpose:**
- **Population/context:**
- **Owner:**
- **Evidence location:**

Record 2

- **Data use:** Validation
- **Dataset/version:**
- **Purpose:**

- **Population/context:**
- **Owner:**
- **Evidence location:**

Record 3

- **Data use:** Testing
- **Dataset/version:**
- **Purpose:**
- **Population/context:**
- **Owner:**
- **Evidence location:**

Record 4

- **Data use:** Fine-tuning
- **Dataset/version:**
- **Purpose:**
- **Population/context:**
- **Owner:**
- **Evidence location:**

Record 5

- **Data use:** Retrieval/grounding
- **Dataset/version:**
- **Purpose:**
- **Population/context:**
- **Owner:**
- **Evidence location:**

Record 6

- **Data use:** Operational input
- **Dataset/version:**

- **Purpose:**
- **Population/context:**
- **Owner:**
- **Evidence location:**

Record 7

- **Data use:** Feedback/continuous learning
- **Dataset/version:**
- **Purpose:**
- **Population/context:**
- **Owner:**
- **Evidence location:**

Record 8

- **Data use:** Monitoring
- **Dataset/version:**
- **Purpose:**
- **Population/context:**
- **Owner:**
- **Evidence location:**

Record 9

- **Data use:** Synthetic or augmented data
- **Dataset/version:**
- **Purpose:**
- **Population/context:**
- **Owner:**
- **Evidence location:**

149.4 3. Purpose and data requirements

Document:

- intended use and prohibited or restricted uses;
- lifecycle stage supported;
- expected contribution to system behaviour and performance;
- required population, geographic, temporal, language, class, and rare-event coverage;
- operational environment and decision context;
- affected populations and vulnerable groups;
- assumptions about what the data measure or represent;
- required quality, quantity, statistical, and lineage characteristics;
- known limitations and acceptable-use conditions.

149.5 4. Provenance, acquisition, and rights

Question	Response	Evidence
Is the source known and documented?		
Are collection and acquisition lawful?		
Are licences, permissions, contracts, and intellectual-property rights documented?		
Are scraping, reuse, training, fine-tuning, redistribution, and downstream restrictions understood?		
Are data-subject, community, customer, or supplier impacts understood?		
Are vendor representations independently verified where proportionate?		
Are provenance gaps or unverifiable sources		

Question	Response	Evidence
identified and escalated?		

149.6 5. Article 10 and governance criteria

Assess, as applicable:

- relevant design choices;
- data collection processes and origin;
- preparation, annotation, labelling, cleaning, enrichment, and aggregation;
- formulation of assumptions about what data measure and represent;
- prior assessment of availability, quantity, suitability, and required characteristics;
- examination for possible bias affecting health, safety, fundamental rights, or prohibited discrimination;
- measures to detect, prevent, reduce, and mitigate bias;
- identification of gaps, shortcomings, and remediation;
- representativeness for the intended population and context;
- appropriate statistical properties;
- geographic, contextual, behavioural, functional, language, and accessibility setting;
- versioning, lineage, integrity, security, and reproducibility.

149.7 6. Relevance and representativeness

Assess:

- relevance to intended purpose;
- population and subgroup coverage;
- geographic and cultural coverage;
- temporal currency;
- class balance and rare-event coverage;
- intersectional representation;

- differences between training, validation, testing, and production conditions;
- coverage of realistic failure, misuse, and edge cases;
- representativeness of feedback and monitoring data.

Readable record format (5 source columns):

Record 1

- **Criterion:** Population coverage
- **Method:**
- **Result:**
- **Limitation:**
- **Action:**

Record 2

- **Criterion:** Geographic/contextual coverage
- **Method:**
- **Result:**
- **Limitation:**
- **Action:**

Record 3

- **Criterion:** Temporal currency
- **Method:**
- **Result:**
- **Limitation:**
- **Action:**

Record 4

- **Criterion:** Class/rare-event coverage
- **Method:**
- **Result:**

- **Limitation:**
- **Action:**

Record 5

- **Criterion:** Subgroup/intersectional coverage
- **Method:**
- **Result:**
- **Limitation:**
- **Action:**

Record 6

- **Criterion:** Production alignment
- **Method:**
- **Result:**
- **Limitation:**
- **Action:**

149.8 7. Quality assessment

Readable record format (5 source columns):

Record 1

- **Quality dimension:** Accuracy
- **Rating/result:**
- **Evidence:**
- **Threshold:**
- **Remediation:**

Record 2

- **Quality dimension:** Completeness
- **Rating/result:**
- **Evidence:**
- **Threshold:**

- **Remediation:**

Record 3

- **Quality dimension:** Consistency
- **Rating/result:**
- **Evidence:**
- **Threshold:**
- **Remediation:**

Record 4

- **Quality dimension:** Timeliness
- **Rating/result:**
- **Evidence:**
- **Threshold:**
- **Remediation:**

Record 5

- **Quality dimension:** Validity
- **Rating/result:**
- **Evidence:**
- **Threshold:**
- **Remediation:**

Record 6

- **Quality dimension:** Uniqueness/deduplication
- **Rating/result:**
- **Evidence:**
- **Threshold:**
- **Remediation:**

Record 7

- **Quality dimension:** Label/annotation quality

- **Rating/result:**
- **Evidence:**
- **Threshold:**
- **Remediation:**

Record 8

- **Quality dimension:** Noise and outliers
- **Rating/result:**
- **Evidence:**
- **Threshold:**
- **Remediation:**

Record 9

- **Quality dimension:** Missingness
- **Rating/result:**
- **Evidence:**
- **Threshold:**
- **Remediation:**

Record 10

- **Quality dimension:** Integrity and corruption
- **Rating/result:**
- **Evidence:**
- **Threshold:**
- **Remediation:**

Record 11

- **Quality dimension:** Reproducibility
- **Rating/result:**
- **Evidence:**
- **Threshold:**

- **Remediation:**

149.9 8. Bias and discrimination risk

Evaluate:

- historical and structural bias;
- proxy variables and correlated features;
- differential missingness;
- label and annotation bias;
- sampling, selection, survivorship, and measurement bias;
- subgroup and intersectional performance;
- language, disability, age, and geographic effects;
- feedback-loop and cumulative bias;
- mitigation trade-offs and unintended consequences;
- whether monitoring data can detect emerging disparities.

Readable record format (6 source columns):

- **Bias risk:**
- **Affected group:**
- **Detection method:**
- **Result:**
- **Mitigation:**
- **Residual limitation:**

149.10 9. Privacy, sensitivity, and special-category data

Document:

- personal, special-category, biometric, children's, confidential, proprietary, or regulated data;
- purpose limitation and minimisation;
- lawful processing basis;
- de-identification, pseudonymisation, and re-identification risk;
- access controls and segregation;

- international transfers and localization;
- retention, deletion, archival, and legal hold;
- restrictions on training, secondary use, supplier improvement, or onward disclosure;
- privacy notices, rights handling, and data-subject impacts.

Where special-category personal data are processed for bias monitoring, detection, or correction, record the exact legal basis, strict necessity, access limits, safeguards, pseudonymisation, deletion, documentation, and qualified privacy/legal approval. Do not treat the AI Act as a general permission to process sensitive data.

149.11 10. Preparation and transformation

Record:

- cleaning and normalization;
- feature engineering and selection;
- deduplication;
- labelling and annotation;
- augmentation or synthetic-data generation;
- filtering, exclusions, and outlier treatment;
- missing-data treatment;
- quality thresholds and rejection criteria;
- transformation code, approvals, and reproducibility;
- version control and rollback.

Readable record format (6 source columns):

- **Transformation:**
- **Method/tool:**
- **Version:**
- **Owner:**
- **Validation:**
- **Evidence:**

149.12 11. Lineage and traceability

Element	Location or identifier
Original source	
Acquisition/licence record	
Ingestion record	
Transformation pipeline	
Dataset version/checksum	
Approval	
Training/validation/test run	
Production system/model version	
Retention location	
Access history	
Disposal record	

149.13 12. Security and integrity

Assess:

- source authenticity and integrity;
- unauthorized alteration, poisoning, contamination, and leakage;
- access control and segregation;
- encryption and secure transfer;
- supplier and pipeline security;
- backup, recovery, and availability;
- audit logging and anomaly detection;
- secure disposal.

149.14 13. Decision

- ☐ Approved for the documented use
- ☐ Approved with conditions
- ☐ Limited use or pilot only
- ☐ Remediation required before use
- ☐ Prohibited from use
- ☐ Qualified legal/privacy interpretation required

Decision rationale:

Residual limitations:

Restricted or prohibited uses:

Monitoring requirements:

149.15 14. Action plan

Readable record format (6 source columns):

- **Action:**
- **Owner:**
- **Due date:**
- **Status:**
- **Validation method:**
- **Closure evidence:**

149.16 15. Change and reassessment triggers

Reassess after changes in:

- source, licence, provider, subprocessor, or acquisition method;
- intended purpose, affected population, jurisdiction, or sector;
- feature, label, annotation, transformation, or synthetic-data method;
- model, prompt, retrieval, feedback, or continuous-learning process;
- quality, bias, performance, privacy, or security results;
- data retention, transfer, location, or access;
- legal basis, consent, contract, authority position, or applicable law.

149.17 GlobalWay Travel Services example

GlobalWay evaluates booking, disruption, and traveler-profile data used by a fraud model. The assessment finds underrepresentation of certain regional travel patterns, inconsistent labels, and supplier reuse of customer data for model improvement. GlobalWay restricts the dataset, corrects labels, expands representative testing, prohibits supplier training without authorization, and links the approved dataset version to the deployed model and monitoring thresholds.

149.18 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Data owner/steward
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Provider/technical owner
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Privacy/legal
- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Risk/compliance
- **Name:**
- **Decision:**
- **Date:**

Record 5

- **Role:** Security, where applicable
- **Name:**
- **Decision:**
- **Date:**

Evidence references:

Residual limitations:

Conditions/restrictions:

Next review trigger/date:

Assessment version:

149.19 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 10 and applicable risk-management, technical-documentation, logging, monitoring, incident, and high-risk provisions.
- Regulation (EU) 2026/1744 where applicable.
- Regulation (EU) 2016/679 and applicable intellectual-property, database, copyright, confidentiality, cybersecurity, records-management, employment, equality, and sector law.
- Current consolidated official texts control over this template.

150 Appendix J — Human-Oversight Plan

Legal status: Corrected English master. This file distinguishes provider design duties under Article 14 from deployer duties to assign competent natural persons and operate the system according to applicable instructions. Human oversight must be meaningful in practice and cannot be reduced to nominal approval or after-the-fact review.

150.1 Purpose

Use this plan to define how qualified people will understand, supervise, challenge, disregard, override, interrupt, stop, suspend, and escalate the operation of an AI system.

The plan must link oversight objectives, roles, decision points, information, authority, competence, workload, fallback, evidence, testing, monitoring, and review triggers to the approved system version and intended purpose.

150.2 1. Applicability record

Field	Response
System/model	
Version/configuration	
Inventory ID	
Legal entity and actor role	
High-risk classification and legal basis	
Intended purpose	
Actual or proposed use	
Users and affected persons	
Provider instructions	

Field	Response
reviewed	
Related FRIA/DPIA/risk assessment	
Current legal source and application date	
Plan owner/date/version	

150.3 2. Oversight objectives

Define the risks oversight is intended to prevent or reduce, including:

- unsafe or unlawful outcomes;
- automation bias and over-reliance;
- inaccurate, unreliable, discriminatory, or manipulated outputs;
- use outside intended purpose or approved population;
- failure to recognize uncertainty, abnormal behaviour, drift, or model limitations;
- inappropriate autonomous action or tool use;
- delayed incident, complaint, or escalation response;
- inability of affected persons to obtain human review, correction, appeal, or remedy;
- inadequate fallback during outages, attacks, supplier failures, or unexpected conditions.

150.4 3. Provider-designed oversight measures

Record design capabilities enabling natural persons to:

- understand relevant capacities, limitations, assumptions, and foreseeable misuse;
- remain aware of automation bias and performance limits;
- correctly interpret outputs in context;
- access relevant inputs, source information, confidence or uncertainty indicators where meaningful, and prior actions;
- disregard, override, reverse, or correct outputs;
- prevent or approve external actions;

- interrupt or stop operation safely;
- detect anomalies, drift, misuse, and abnormal conditions;
- escalate incidents, rights concerns, safety risks, and control failures;
- use logs, explanations, version information, and evidence needed for review.

Readable record format (6 source columns):

- **Measure:**
- **Design owner:**
- **System feature or procedure:**
- **Version:**
- **Test evidence:**
- **Limitation:**

150.5 4. Deployer operating model

Readable record format (7 source columns):

- **Role:**
- **Responsibilities:**
- **Decision authority:**
- **Required competence:**
- **Workload/time:**
- **Backup:**
- **Escalation route:**

Confirm that oversight personnel:

- are natural persons;
- have the necessary competence, training, authority, independence, time, tools, and support;
- understand the intended purpose, instructions, limitations, and relevant risks;
- can override or stop the system without retaliation or conflicting performance pressure;

- have access to specialists and emergency contacts;
- are not assigned workloads that make meaningful review impossible;
- are supported by alternates and continuity arrangements.

150.6 5. Decision points and interventions

Readable record format (7 source columns):

- **Lifecycle/process step:**
- **AI output or action:**
- **Human review required:**
- **Information available:**
- **Override/stop method:**
- **Escalation threshold:**
- **Evidence created:**

Include pre-release approval, real-time operation, exceptions, appeals, incident response, rollback, restoration, and retirement where applicable.

150.7 6. Information available to reviewers

Confirm reviewers receive:

- intended purpose, approved use, and prohibited or restricted use;
- input and output context;
- relevant source, retrieval, tool, and action information;
- confidence, uncertainty, abstention, or warning indicators where meaningful;
- known accuracy, bias, subgroup, language, accessibility, security, and robustness limitations;
- applicable legal, policy, and decision criteria;
- prior overrides, disagreements, incidents, complaints, and appeals;
- instructions for challenge, correction, override, suspension, stop, escalation, and fallback;
- version and change information;
- contact and support routes.

150.8 7. Authority, independence, and incentives

Document whether reviewers can:

- disregard, reverse, or correct the output;
- require additional evidence or a second review;
- defer or refuse a decision;
- obtain legal, technical, clinical, HR, safety, or domain advice;
- stop, suspend, roll back, or isolate the system;
- escalate without retaliation;
- record dissent and unresolved uncertainty;
- protect affected persons while investigation proceeds.

Assess whether production targets, speed metrics, staffing, incentives, or management pressure undermine meaningful review.

150.9 8. Automation-bias controls

Use proportionate controls such as:

- independent analysis before displaying the AI recommendation;
- staged presentation of source evidence and AI output;
- mandatory rationale for acceptance and override in material decisions;
- randomized quality review;
- reviewer rotation and second-level review;
- alerts for unusually high acceptance or low override rates;
- scenario-based training and challenge exercises;
- separation of production targets from oversight-quality measures;
- monitoring of disagreement, appeal, and reversal patterns;
- periodic blind testing of reviewer judgment.

150.10 9. Competence and training

Readable record format (6 source columns):

Record 1

- **Training/competence topic:** Intended purpose and limitations

- **Audience:**
- **Frequency:**
- **Completion evidence:**
- **Competence test:**
- **Refresher trigger:**

Record 2

- **Training/competence topic:** Interpretation and uncertainty
- **Audience:**
- **Frequency:**
- **Completion evidence:**
- **Competence test:**
- **Refresher trigger:**

Record 3

- **Training/competence topic:** Automation bias
- **Audience:**
- **Frequency:**
- **Completion evidence:**
- **Competence test:**
- **Refresher trigger:**

Record 4

- **Training/competence topic:** Rights, safety, privacy, and discrimination risks
- **Audience:**
- **Frequency:**
- **Completion evidence:**
- **Competence test:**
- **Refresher trigger:**

Record 5

- **Training/competence topic:** Override, stop, fallback, and escalation
- **Audience:**
- **Frequency:**
- **Completion evidence:**
- **Competence test:**
- **Refresher trigger:**

Record 6

- **Training/competence topic:** Incident and evidence preservation
- **Audience:**
- **Frequency:**
- **Completion evidence:**
- **Competence test:**
- **Refresher trigger:**

Record 7

- **Training/competence topic:** Accessibility and affected-person communication
- **Audience:**
- **Frequency:**
- **Completion evidence:**
- **Competence test:**
- **Refresher trigger:**

Training completion alone does not demonstrate competence. Use observation, simulation, testing, and performance evidence.

150.11 10. Override and escalation procedure

1. Identify the questionable output, action, or operating condition.
2. Prevent or contain immediate harm and use approved fallback where needed.

3. Preserve relevant inputs, outputs, prompts, tools, versions, logs, decisions, and context.
4. Apply the approved alternative or manual process.
5. Record the reviewer's decision, evidence, rationale, and uncertainty.
6. Notify affected persons or responsible functions where required.
7. Escalate material, repeated, systemic, legal, safety, rights, or security issues.
8. Trigger incident, risk, change, supplier, notification, or corrective-action processes where required.
9. Validate remediation and restoration before normal operation resumes.
10. Communicate outcomes and lessons learned.

150.12 11. Validation

Test:

- reviewer comprehension of system purpose and limitations;
- access to required information;
- authority to disregard, override, interrupt, stop, and escalate;
- technical effectiveness of override and stop mechanisms;
- manual fallback and continuity;
- workload, staffing, fatigue, and response time;
- resistance to automation bias and management pressure;
- language and accessibility support;
- detection of abnormal conditions, misuse, drift, and uncertainty;
- escalation and incident-response effectiveness;
- evidence creation and retrievability.

Readable record format (6 source columns):

- **Test scenario:**
- **Acceptance criterion:**
- **Result:**

- **Defect:**
- **Owner:**
- **Retest evidence:**

150.13 12. Monitoring

Track:

- acceptance, override, correction, and reversal rates;
- reviewer disagreement and second-review outcomes;
- time to review and escalation;
- unusually high reliance or low challenge rates;
- quality defects, false positives, false negatives, and abstentions;
- subgroup, language, disability, and accessibility differences;
- complaints, appeals, remedies, and affected-person outcomes;
- reviewer workload, fatigue, turnover, and staffing gaps;
- training and competence status;
- failed interventions, stop failures, and fallback failures;
- repeat issues after corrective action.

Readable record format (6 source columns):

- **Indicator:**
- **Threshold:**
- **Source:**
- **Frequency:**
- **Owner:**
- **Required action:**

150.14 13. Failure and fallback

Document:

- safe suspension and stop criteria;
- manual or alternative process;
- emergency and specialist contacts;

- continuity, recovery, and restoration arrangements;
- evidence preservation;
- communication to affected persons, customers, workers, or authorities;
- restrictions during degraded operation;
- approval and validation required before restoration.

150.15 14. Decision

- ☐ Oversight design and operating model approved
- ☐ Approved with conditions
- ☐ Restricted pilot only
- ☐ Remediation and retesting required
- ☐ Deployment blocked or suspended
- ☐ Qualified legal or specialist review required

Decision rationale:

Residual limitations:

Conditions and restrictions:

Open actions and due dates:

150.16 15. Review triggers

Reassess after:

- model, data, prompt, tool, agent, interface, threshold, or workflow change;
- intended-purpose, population, jurisdiction, or automation change;
- provider instruction or supplier change;
- staffing, workload, competence, incentive, or authority change;
- incident, complaint, appeal, adverse outcome, or failed intervention;
- performance, bias, language, accessibility, or security drift;
- substantial modification, reclassification, or legal change.

150.17 GlobalWay Travel Services example

GlobalWay's traveler-disruption assistant recommends rebooking and refund actions. The oversight plan requires a travel consultant to confirm safety-sensitive changes and all external financial actions. Consultants

receive itinerary context, supplier rules, uncertainty warnings, and prior tool actions. Monitoring detects unusually high acceptance rates during severe weather. GlobalWay reduces workload, adds independent review for high-impact actions, retrain staff, and blocks automatic execution until override and escalation tests pass.

150.18 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Provider/technical owner
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Deployer/business owner
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Oversight owner
- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Legal/Compliance
- **Name:**
- **Decision:**
- **Date:**

Record 5

- **Role:** Risk/Privacy/Security/HR, as applicable

- **Name:**
- **Decision:**
- **Date:**

Evidence references:

Residual limitations:

Next review trigger/date:

Plan version:

150.19 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 14 and applicable provider, deployer, risk-management, transparency, logging, monitoring, incident, corrective-action, and authority provisions.
- Regulation (EU) 2026/1744 where applicable.
- Applicable employment, equality, accessibility, privacy, safety, consumer-protection, and sector law.
- Current consolidated official texts and provider instructions control over this template.

151 Appendix K — Technical-Documentation Index

Legal status: Corrected English master. For providers of high-risk AI systems, use this index to support Article 11 and Annex IV documentation. For other actors or systems, use it as governance evidence and do not represent it as statutory Annex IV documentation unless the legal trigger applies.

151.1 Purpose

Use this index to organize, control, reconcile, and evidence the technical documentation needed to explain an AI system’s design, development, data, operation, testing, risk controls, oversight, monitoring, changes, and conformity status.

The index must be linked to the exact production version and updated before release, after material change, and whenever legal or conformity requirements change.

151.2 1. Applicability and document control

Field	Response
System/model	
Inventory ID	
Legal entity and actor role	

Field	Response
High-risk legal basis	
Intended purpose	
Production version/configuration	
Provider/vendor	
Annex IV applies?	
Applicable conformity route	
Current legal source and application date	
Documentation owner	
Repository/system of record	
Index version and review date	

151.3 2. Annex IV crosswalk where applicable

Readable record format (7 source columns):

Record 1

- **Annex IV area:** General description
- **Required content:** System name, provider, version, intended purpose, users, operating context, interfaces, hardware/software dependencies
- **Document/evidence reference:**
- **Owner:**
- **Version:**
- **Status:**
- **Gap/action:**

Record 2

- **Annex IV area:** System elements and development process
- **Required content:** Design decisions, methods, tools, environments, architecture, components, computation resources, dependencies
- **Document/evidence reference:**
- **Owner:**
- **Version:**

- **Status:**
- **Gap/action:**

Record 3

- **Annex IV area:** Design specifications and assumptions
- **Required content:** Design choices, assumptions, trade-offs, limitations, foreseeable misuse, prohibited uses
- **Document/evidence reference:**
- **Owner:**
- **Version:**
- **Status:**
- **Gap/action:**

Record 4

- **Annex IV area:** Data and data governance
- **Required content:** Sources, provenance, collection, preparation, annotation, quality, representativeness, bias, lineage, retention
- **Document/evidence reference:**
- **Owner:**
- **Version:**
- **Status:**
- **Gap/action:**

Record 5

- **Annex IV area:** Training, tuning, and development
- **Required content:** Methods, parameters, runs, resources, versioning, reproducibility
- **Document/evidence reference:**
- **Owner:**
- **Version:**
- **Status:**

- **Gap/action:**

Record 6

- **Annex IV area:** Validation and testing
- **Required content:** Metrics, scenarios, acceptance criteria, subgroup, language, accessibility, robustness, misuse, and security testing
- **Document/evidence reference:**
- **Owner:**
- **Version:**
- **Status:**
- **Gap/action:**

Record 7

- **Annex IV area:** Accuracy, robustness, cybersecurity, and resilience
- **Required content:** Performance, uncertainty, stress, attack, recovery, continuity, and fallback evidence
- **Document/evidence reference:**
- **Owner:**
- **Version:**
- **Status:**
- **Gap/action:**

Record 8

- **Annex IV area:** Human oversight
- **Required content:** Roles, competence, information, authority, override, stop, fallback, escalation, and test evidence
- **Document/evidence reference:**
- **Owner:**
- **Version:**
- **Status:**
- **Gap/action:**

Record 9

- **Annex IV area:** Transparency and instructions
- **Required content:** Instructions for use, limitations, notices, disclosure, accessibility, language, user information
- **Document/evidence reference:**
- **Owner:**
- **Version:**
- **Status:**
- **Gap/action:**

Record 10

- **Annex IV area:** Logging and recordkeeping
- **Required content:** Events captured, retention, access, integrity, version linkage, and export
- **Document/evidence reference:**
- **Owner:**
- **Version:**
- **Status:**
- **Gap/action:**

Record 11

- **Annex IV area:** Risk-management system
- **Required content:** Hazards, scenarios, controls, residual risks, decisions, and updates
- **Document/evidence reference:**
- **Owner:**
- **Version:**
- **Status:**
- **Gap/action:**

Record 12

- **Annex IV area:** Quality-management system
- **Required content:** Policies, procedures, ownership, release, supplier, incident, corrective action, and change control
- **Document/evidence reference:**
- **Owner:**
- **Version:**
- **Status:**
- **Gap/action:**

Record 13

- **Annex IV area:** Predetermined changes and version history
- **Required content:** Approved change plan, release history, modifications, reassessment, rollback
- **Document/evidence reference:**
- **Owner:**
- **Version:**
- **Status:**
- **Gap/action:**

Record 14

- **Annex IV area:** Standards and conformity
- **Required content:** Harmonised standards, common specifications, conformity route, notified-body records, declarations, registration, marking
- **Document/evidence reference:**
- **Owner:**
- **Version:**
- **Status:**
- **Gap/action:**

Record 15

- **Annex IV area:** Post-market monitoring
- **Required content:** Monitoring plan, metrics, thresholds, complaints, incidents, trends, corrective action
- **Document/evidence reference:**
- **Owner:**
- **Version:**
- **Status:**
- **Gap/action:**

Record 16

- **Annex IV area:** Supplier and component evidence
- **Required content:** Contracts, model/system cards, attestations, licences, dependencies, change notices, audit evidence
- **Document/evidence reference:**
- **Owner:**
- **Version:**
- **Status:**
- **Gap/action:**

Record 17

- **Annex IV area:** Incident and remediation
- **Required content:** Incident chronology, notification, containment, root cause, corrective action, validation, lessons learned
- **Document/evidence reference:**
- **Owner:**
- **Version:**
- **Status:**
- **Gap/action:**

151.4 3. Supporting governance documentation

Where relevant, index:

- applicability, role, prohibited-practice, and high-risk assessments;
- FRIA, DPIA, data-governance, security, vendor, and risk assessments;
- control and evidence registers;
- release, residual-risk, exception, and executive approvals;
- deployer handoff, instructions, training, and competence evidence;
- authority, notified-body, auditor, customer, and supplier correspondence.

151.5 4. Production-version reconciliation

Readable record format (6 source columns):

Record 1

- **Production component:** Model
- **Production version/checksum:**
- **Documentation version:**
- **Evidence location:**
- **Match?:**
- **Resolution/owner:**

Record 2

- **Production component:** System code
- **Production version/checksum:**
- **Documentation version:**
- **Evidence location:**
- **Match?:**
- **Resolution/owner:**

Record 3

- **Production component:** Prompts/system instructions
- **Production version/checksum:**
- **Documentation version:**
- **Evidence location:**

- **Match?:**
- **Resolution/owner:**

Record 4

- **Production component:** Tools/agents/integrations
- **Production version/checksum:**
- **Documentation version:**
- **Evidence location:**
- **Match?:**
- **Resolution/owner:**

Record 5

- **Production component:** Datasets/retrieval sources
- **Production version/checksum:**
- **Documentation version:**
- **Evidence location:**
- **Match?:**
- **Resolution/owner:**

Record 6

- **Production component:** Configuration/thresholds
- **Production version/checksum:**
- **Documentation version:**
- **Evidence location:**
- **Match?:**
- **Resolution/owner:**

Record 7

- **Production component:** User interface/notices
- **Production version/checksum:**
- **Documentation version:**

- **Evidence location:**
- **Match?:**
- **Resolution/owner:**

Record 8

- **Production component:** Monitoring/logging configuration
- **Production version/checksum:**
- **Documentation version:**
- **Evidence location:**
- **Match?:**
- **Resolution/owner:**

No release may rely on documentation that describes a materially different system, model, dataset, configuration, or oversight process.

151.6 5. Evidence-quality checks

For each indexed item, confirm:

- authentic and attributable to an accountable owner;
- complete for the applicable legal purpose;
- current, approved, and linked to the deployed version;
- internally consistent with other documentation;
- supported by source evidence and reproducible where required;
- protected from unauthorized alteration;
- accessible only to authorized persons while available to auditors, notified bodies, and authorities as legally required;
- retrievable within required timeframes;
- retained under the applicable legal, contractual, operational, and legal-hold schedule;
- available in the required language and format.

151.7 6. Gaps and release decision

Readable record format (7 source columns):

- **Gap:**

- **Legal/operational impact:**
- **Interim control:**
- **Owner:**
- **Due date:**
- **Validation:**
- **Release blocker?:**
 - ☐ Complete for applicable legal purpose
 - ☐ Complete with approved conditions
 - ☐ Governance index only; Annex IV not applicable
 - ☐ Incomplete — release or conformity review blocked
 - ☐ Qualified legal or conformity review required

Decision rationale:

Open conditions:

Conformity implications:

151.8 7. Change and review triggers

Update after:

- model, system, code, prompt, tool, data, threshold, or infrastructure change;
- intended-purpose, actor-role, population, jurisdiction, or product change;
- supplier, component, licence, or dependency change;
- validation, monitoring, incident, complaint, or audit finding;
- predetermined change-plan use or substantial modification;
- conformity, registration, declaration, marking, authority, or legal development;
- suspension, rollback, withdrawal, recall, or retirement.

151.9 GlobalWay Travel Services example

GlobalWay reconciles the technical documentation for an employee-allocation system against production. The review finds that the deployed supplier model and multilingual interface differ from the documented versions. Release remains blocked until the model version, data tests,

oversight instructions, transparency notices, monitoring thresholds, and conformity evidence are updated and independently reconciled.

151.10 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Provider/technical owner
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Quality/Compliance
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Legal/conformity owner
- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Security/Data/Privacy, as applicable
- **Name:**
- **Decision:**
- **Date:**

Evidence references:

Residual gaps and restrictions:

Next review trigger/date:

Index version:

151.11 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 11, Annex IV, and applicable risk-management, data, logging, transparency, oversight, accuracy, robustness, cybersecurity, quality-management, conformity, monitoring, incident, and authority-access provisions.
- Regulation (EU) 2026/1744 where applicable.
- Applicable Annex I product legislation and conformity requirements.
- Current consolidated official texts control over this index.

152 Appendix L — Conformity-Readiness Checklist

Legal status: Corrected English master. This internal readiness review does not replace the conformity-assessment procedure, notified-body involvement, product-sector procedure, declaration, registration, CE marking, or authority decision required by law.

152.1 Purpose

Use this checklist to determine whether an AI system and its supporting governance, documentation, controls, testing, and evidence are ready to enter the applicable conformity procedure.

Readiness must be assessed against the exact provider role, high-risk route, intended purpose, system version, product legislation, application date, and conformity procedure. An internal “ready” decision is not legal conformity or market authorization.

152.2 1. Applicability and route

Field	Response
Provider/legal entity	
System name and inventory ID	
Version/configuration assessed	
Intended purpose	
Users and affected persons	
Article 6(1)/Annex I or Article 6(2)/Annex III pathway	
Exact Annex I legislation or Annex III point	
Applicable product legislation	
Article 43 conformity route	

Field	Response
Internal-control route available?	
Notified body required?	
Harmonised standards/common specifications relied upon	
Current application date/transitional rule	
Legal/conformity owner	
Assessment date/version	

152.3 2. Governance and accountability

- ☐ Legal role and high-risk classification are documented and current.
- ☐ Accountable provider, technical, quality, legal, risk, data, security, and business owners are assigned.
- ☐ Quality-management procedures are approved and operating.
- ☐ Risk-management responsibilities and acceptance authority are defined.
- ☐ Design, development, validation, release, and change activities are controlled.
- ☐ Supplier, component, importer, distributor, representative, and product-manufacturer responsibilities are documented.
- ☐ Findings, exceptions, deviations, and corrective actions are tracked.
- ☐ Independence and competence requirements are defined for validation and conformity work.

152.4 3. High-risk requirement readiness

Readable record format (5 source columns):

Record 1

- **Area:** Article 9 risk-management system
- **Applicable?:**
- **Ready?:**
- **Evidence:**
- **Gap/action:**

Record 2

- **Area:** Article 10 data and data governance
- **Applicable?:**
- **Ready?:**
- **Evidence:**
- **Gap/action:**

Record 3

- **Area:** Article 11 technical documentation
- **Applicable?:**
- **Ready?:**
- **Evidence:**
- **Gap/action:**

Record 4

- **Area:** Article 12 recordkeeping/logging
- **Applicable?:**
- **Ready?:**
- **Evidence:**
- **Gap/action:**

Record 5

- **Area:** Article 13 transparency and instructions for use
- **Applicable?:**
- **Ready?:**
- **Evidence:**
- **Gap/action:**

Record 6

- **Area:** Article 14 human oversight
- **Applicable?:**

- **Ready?:**
- **Evidence:**
- **Gap/action:**

Record 7

- **Area:** Article 15 accuracy, robustness, cybersecurity, and resilience
- **Applicable?:**
- **Ready?:**
- **Evidence:**
- **Gap/action:**

Record 8

- **Area:** Quality-management system
- **Applicable?:**
- **Ready?:**
- **Evidence:**
- **Gap/action:**

Record 9

- **Area:** Provider obligations and accountability
- **Applicable?:**
- **Ready?:**
- **Evidence:**
- **Gap/action:**

Record 10

- **Area:** Value-chain information and supplier controls
- **Applicable?:**
- **Ready?:**
- **Evidence:**
- **Gap/action:**

Record 11

- **Area:** Post-market monitoring
- **Applicable?:**
- **Ready?:**
- **Evidence:**
- **Gap/action:**

Record 12

- **Area:** Serious-incident reporting
- **Applicable?:**
- **Ready?:**
- **Evidence:**
- **Gap/action:**

Record 13

- **Area:** Corrective action, restriction, recall, and withdrawal
- **Applicable?:**
- **Ready?:**
- **Evidence:**
- **Gap/action:**

Record 14

- **Area:** Authority cooperation and access
- **Applicable?:**
- **Ready?:**
- **Evidence:**
- **Gap/action:**

Record 15

- **Area:** Product-law requirements
- **Applicable?:**

- **Ready?:**
- **Evidence:**
- **Gap/action:**

152.5 4. Risk-management readiness

- ☐ Foreseeable risks are identified across the lifecycle.
- ☐ Safety, fundamental-rights, privacy, cybersecurity, operational, and misuse scenarios are assessed.
- ☐ Risk controls are implemented and tested.
- ☐ Acceptance criteria were approved before validation.
- ☐ Residual risks, limitations, and required user information are documented.
- ☐ Risk evidence matches the assessed and production versions.
- ☐ Monitoring and reassessment triggers are defined.
- ☐ Legal blockers cannot be overridden by internal risk acceptance.

152.6 5. Data-governance readiness

- ☐ Data sources, provenance, rights, licences, and acquisition are documented.
- ☐ Relevance, suitability, quality, representativeness, and statistical properties are assessed.
- ☐ Bias and subgroup risks are evaluated and mitigated.
- ☐ Preparation, annotation, transformation, and versioning are reproducible.
- ☐ Privacy, minimisation, retention, access, transfer, and security controls operate.
- ☐ Dataset versions are linked to training, validation, testing, and production.
- ☐ Special-category-data use has qualified legal and privacy approval where applicable.

152.7 6. Technical-documentation readiness

- ☐ Annex IV applicability is confirmed.
- ☐ System architecture, components, interfaces, resources, and dependencies are current.

- ☐ Model, configuration, prompts, tools, agents, data, and version information are complete.
- ☐ Intended purpose, prohibited uses, limitations, and foreseeable misuse are clear.
- ☐ Development, training, tuning, validation, testing, and change history are documented.
- ☐ Accuracy, robustness, cybersecurity, and resilience evidence is available.
- ☐ Human-oversight design and deployer information are documented.
- ☐ Documentation is internally consistent and reconciled to production.

152.8 7. Logging and traceability readiness

- ☐ Required events are logged automatically where required.
- ☐ Log retention, integrity, access, confidentiality, and export are controlled.
- ☐ Inputs, outputs, overrides, tool actions, warnings, errors, and incidents are traceable.
- ☐ Production and documentation versions can be reconciled.
- ☐ Evidence is version-linked and retrievable within required timeframes.
- ☐ Supplier-controlled logs and evidence are contractually and operationally accessible.

152.9 8. Transparency and human-oversight readiness

- ☐ Instructions for use are complete and accurate.
- ☐ Intended purpose, performance, limitations, risks, and oversight requirements are disclosed.
- ☐ Required notices, labels, disclosures, languages, and accessibility are implemented.
- ☐ Human reviewers are competent, trained, authorized, supported, and adequately staffed.
- ☐ Override, stop, fallback, escalation, appeal, and complaint mechanisms operate.
- ☐ Automation-bias controls are implemented and tested.

- ☐ Deployer handoff and training evidence are complete.

152.10 9. Validation and testing readiness

- ☐ Acceptance criteria are approved and risk-based.
- ☐ Design effectiveness and operating effectiveness are tested.
- ☐ Performance is tested under expected, edge, adverse, and misuse conditions.
- ☐ Relevant subgroups, languages, jurisdictions, and accessibility scenarios are evaluated.
- ☐ Accuracy, uncertainty, robustness, security, resilience, fallback, and recovery are tested.
- ☐ Human oversight, override, stop, and escalation are tested.
- ☐ Test datasets, methods, environments, limitations, defects, and retest evidence are documented.
- ☐ Unresolved defects are governed as release blockers or approved conditions.

152.11 10. Quality-management readiness

Confirm that the QMS addresses:

- compliance strategy and responsibility;
- design and development control;
- validation and acceptance;
- data governance;
- technical documentation and records;
- supplier and component governance;
- release, configuration, and change control;
- post-market monitoring;
- incidents, complaints, and corrective action;
- authority, notified-body, and customer cooperation;
- competence, training, and internal assurance;
- document retention and version control.

152.12 11. Post-market and incident readiness

- ☐ Monitoring indicators, thresholds, frequency, and owners are defined.
- ☐ Complaints, appeals, incidents, drift, overrides, and supplier changes are reviewed.
- ☐ Serious-incident assessment and notification routes are documented.
- ☐ Corrective-action, restriction, rollback, recall, withdrawal, and restoration processes are tested.
- ☐ Regulatory commitments and authority communications are tracked.
- ☐ Monitoring and incident evidence is linked to the production version.

152.13 12. Conformity route and formal outputs

Confirm, as applicable:

- ☐ internal-control or notified-body route selected correctly;
- ☐ product-sector conformity procedure identified;
- ☐ notified-body engagement and scope complete;
- ☐ harmonised standards or common specifications identified, including limitations;
- ☐ Annex IV documentation complete;
- ☐ technical and quality documentation available for review;
- ☐ EU declaration of conformity prepared and approved;
- ☐ CE marking requirements satisfied;
- ☐ EU database registration complete;
- ☐ authorised representative, importer, distributor, and product-manufacturer duties complete;
- ☐ conformity, declaration, registration, marking, and version evidence preserved.

152.14 13. Production-version reconciliation

Readable record format (5 source columns):

Record 1

- **Component:** Model
- **Production version:**
- **Assessed/documentated version:**
- **Match?:**
- **Resolution:**

Record 2

- **Component:** System/code
- **Production version:**
- **Assessed/documentated version:**
- **Match?:**
- **Resolution:**

Record 3

- **Component:** Data/retrieval
- **Production version:**
- **Assessed/documentated version:**
- **Match?:**
- **Resolution:**

Record 4

- **Component:** Prompts/tools/agents
- **Production version:**
- **Assessed/documentated version:**
- **Match?:**
- **Resolution:**

Record 5

- **Component:** Configuration/thresholds
- **Production version:**
- **Assessed/documentated version:**

- **Match?:**
- **Resolution:**

Record 6

- **Component:** Interface/notices
- **Production version:**
- **Assessed/documentated version:**
- **Match?:**
- **Resolution:**

Record 7

- **Component:** Logging/monitoring
- **Production version:**
- **Assessed/documentated version:**
- **Match?:**
- **Resolution:**

152.15 14. Final readiness status

Readable record format (5 source columns):

Record 1

- **Area:** Governance and QMS
- **Ready:**
- **Partially ready:**
- **Not ready:**
- **Evidence reference:**

Record 2

- **Area:** Risk management
- **Ready:**
- **Partially ready:**
- **Not ready:**

- **Evidence reference:**

Record 3

- **Area:** Data governance
- **Ready:**
- **Partially ready:**
- **Not ready:**
- **Evidence reference:**

Record 4

- **Area:** Technical documentation
- **Ready:**
- **Partially ready:**
- **Not ready:**
- **Evidence reference:**

Record 5

- **Area:** Logging and traceability
- **Ready:**
- **Partially ready:**
- **Not ready:**
- **Evidence reference:**

Record 6

- **Area:** Transparency and instructions
- **Ready:**
- **Partially ready:**
- **Not ready:**
- **Evidence reference:**

Record 7

- **Area:** Human oversight

- **Ready:**
- **Partially ready:**
- **Not ready:**
- **Evidence reference:**

Record 8

- **Area:** Validation and testing
- **Ready:**
- **Partially ready:**
- **Not ready:**
- **Evidence reference:**

Record 9

- **Area:** Post-market monitoring
- **Ready:**
- **Partially ready:**
- **Not ready:**
- **Evidence reference:**

Record 10

- **Area:** Incident and corrective action
- **Ready:**
- **Partially ready:**
- **Not ready:**
- **Evidence reference:**

Record 11

- **Area:** Formal conformity outputs
- **Ready:**
- **Partially ready:**
- **Not ready:**

- **Evidence reference:**

152.16 15. Readiness decision

- ☐ Ready to enter the applicable conformity procedure
- ☐ Ready subject to listed conditions
- ☐ Not ready — remediation required
- ☐ Release or market placement blocked
- ☐ Route or classification uncertain — qualified legal or conformity review required

Decision rationale:

Formal conformity status:

Notified-body status:

Conditions and release blockers:

Readiness approval must not be described as completed conformity, authorization, certification, or permission to place the system on the market or put it into service.

152.17 16. Open actions

Readable record format (7 source columns):

- **Action:**
- **Owner:**
- **Due date:**
- **Legal impact:**
- **Priority:**
- **Validation:**
- **Closure evidence:**

152.18 17. Review triggers

Reassess after:

- classification, role, intended-purpose, product, or conformity-route change;
- model, system, data, prompt, tool, agent, interface, or infrastructure change;
- predetermined change-plan use or substantial modification;

- supplier, importer, distributor, representative, or product-manufacturer change;
- failed test, incident, complaint, audit, notified-body, or authority finding;
- new harmonised standard, common specification, legal amendment, or application date;
- suspension, rollback, recall, withdrawal, or restoration.

152.19 GlobalWay Travel Services example

GlobalWay prepares an employee-allocation system for conformity review. The readiness assessment confirms completed risk, data, oversight, validation, QMS, and post-market work but finds that the production supplier model differs from the documented version and that registration evidence is incomplete. GlobalWay blocks release, updates the technical documentation, repeats validation, resolves the registration issue, and only then approves entry into the applicable formal conformity process.

152.20 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Provider/business owner
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Technical owner
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Quality/Compliance
- **Name:**
- **Decision:**

- **Date:**

Record 4

- **Role:** Legal/conformity owner
- **Name:**
- **Decision:**
- **Date:**

Record 5

- **Role:** Product-safety/sector owner, where applicable
- **Name:**
- **Decision:**
- **Date:**

Evidence references:

Residual limitations:

Next review trigger/date:

Assessment version:

152.21 Primary legal references

- Regulation (EU) 2024/1689, as amended: Articles 8-17, Article 43, Articles 47-49, provider and value-chain duties, post-market monitoring, incident, corrective-action, authority, and applicable Annexes IV, VI, VII, and VIII.
- Regulation (EU) 2026/1744 where applicable.
- Applicable Annex I product legislation, harmonised standards, common specifications, and notified-body requirements.
- Current consolidated official texts and the applicable formal conformity procedure control over this checklist.

153 Appendix M — Post-Market Monitoring Plan

Legal status: Corrected English master. For providers of high-risk AI systems, this plan supports Article 72. For deployers and other actors, monitoring may be required by other AI Act provisions, other law, contract, or organizational policy and must be identified separately.

153.1 Purpose

Use this plan to define how an AI system will be monitored after market placement or deployment for performance, safety, fundamental-rights impacts, cybersecurity, complaints, incidents, misuse, supplier changes, control failures, and continued compliance.

The plan must be active, systematic, proportionate, version-linked, integrated with risk and quality management, and capable of triggering timely investigation, restriction, suspension, notification, corrective action, withdrawal, or recall.

153.2 1. Applicability record

Field	Response
Legal entity and actor role	
System/model and inventory ID	
Production version/configuration	
Intended purpose	
High-risk classification/legal basis	
Article 72 applies?	
Other monitoring duties	
Jurisdictions	
Provider/vendor and dependencies	
Current legal source/application date	
Monitoring owner	
Plan version/date	

153.3 2. Monitoring objectives

Define objectives for:

- accuracy, reliability, and performance;
- subgroup, language, accessibility, and fairness outcomes;
- safety, health, and fundamental-rights risk;
- human-oversight effectiveness, overrides, and escalation;
- cybersecurity, misuse, abuse, prompt injection, and tool/agent actions;

- transparency, instructions, disclosure, complaints, and appeals;
- drift, data, model, supplier, and infrastructure changes;
- resilience, fallback, continuity, and recovery;
- legal, conformity, registration, and regulatory commitments;
- corrective-action effectiveness and repeat failures.

153.4 3. Indicators and thresholds

Readable record format (8 source columns):

- **Indicator:**
- **Baseline:**
- **Warning threshold:**
- **Critical threshold:**
- **Data source:**
- **Frequency:**
- **Owner:**
- **Required action:**

Indicators should be risk-based and include where relevant:

- accuracy, error, abstention, and reliability;
- false-positive and false-negative rates;
- subgroup and intersectional disparities;
- language and accessibility defects;
- override, disagreement, appeal, and complaint rates;
- incidents, near misses, and adverse outcomes;
- security alerts, misuse attempts, and anomalous tool actions;
- drift and out-of-distribution conditions;
- supplier/model/version changes;
- missing logs, evidence, or documentation;
- fallback, outage, and recovery failures;

- overdue findings and repeated corrective actions.

153.5 4. Data collection and evidence

Document collection and governance for:

- production logs and telemetry;
- sampled inputs and outputs;
- prompts, retrieval sources, tool calls, and agent actions;
- human-review, override, stop, and escalation records;
- complaints, appeals, corrections, and remedies;
- incidents, near misses, and notifications;
- security alerts and threat intelligence;
- supplier notices, releases, outages, and documentation changes;
- drift, performance, bias, language, accessibility, and robustness tests;
- internal audit, conformity, notified-body, and authority findings;
- change, rollback, suspension, withdrawal, recall, and restoration records.

Apply privacy, minimisation, confidentiality, access, integrity, retention, legal-hold, and cross-border controls.

153.6 5. Review cadence

Readable record format (5 source columns):

Record 1

- **Review:** Operational monitoring
- **Frequency:**
- **Participants:**
- **Inputs:**
- **Output:**

Record 2

- **Review:** Technical validation
- **Frequency:**

- **Participants:**
- **Inputs:**
- **Output:**

Record 3

- **Review:** Risk and compliance review
- **Frequency:**
- **Participants:**
- **Inputs:**
- **Output:**

Record 4

- **Review:** Fundamental-rights/privacy review
- **Frequency:**
- **Participants:**
- **Inputs:**
- **Output:**

Record 5

- **Review:** Security review
- **Frequency:**
- **Participants:**
- **Inputs:**
- **Output:**

Record 6

- **Review:** Supplier review
- **Frequency:**
- **Participants:**
- **Inputs:**
- **Output:**

Record 7

- **Review:** Executive/board reporting
- **Frequency:**
- **Participants:**
- **Inputs:**
- **Output:**

Record 8

- **Review:** Independent assurance
- **Frequency:**
- **Participants:**
- **Inputs:**
- **Output:**

153.7 6. Trigger and response matrix

Readable record format (6 source columns):

Record 1

- **Trigger:** Serious incident or credible harm allegation
- **Required action:**
- **Actor/owner:**
- **Deadline/legal source:**
- **Escalation:**
- **Evidence:**

Record 2

- **Trigger:** Significant performance degradation
- **Required action:**
- **Actor/owner:**
- **Deadline/legal source:**
- **Escalation:**

- **Evidence:**

Record 3

- **Trigger:** Subgroup, language, or accessibility disparity
- **Required action:**
- **Actor/owner:**
- **Deadline/legal source:**
- **Escalation:**
- **Evidence:**

Record 4

- **Trigger:** Material complaint or appeal trend
- **Required action:**
- **Actor/owner:**
- **Deadline/legal source:**
- **Escalation:**
- **Evidence:**

Record 5

- **Trigger:** Security compromise or misuse
- **Required action:**
- **Actor/owner:**
- **Deadline/legal source:**
- **Escalation:**
- **Evidence:**

Record 6

- **Trigger:** Supplier model, service, data, or contract change
- **Required action:**
- **Actor/owner:**
- **Deadline/legal source:**

- **Escalation:**
- **Evidence:**

Record 7

- **Trigger:** Intended-purpose, population, or jurisdiction change
- **Required action:**
- **Actor/owner:**
- **Deadline/legal source:**
- **Escalation:**
- **Evidence:**

Record 8

- **Trigger:** Missing logs or evidence
- **Required action:**
- **Actor/owner:**
- **Deadline/legal source:**
- **Escalation:**
- **Evidence:**

Record 9

- **Trigger:** Legal or regulatory development
- **Required action:**
- **Actor/owner:**
- **Deadline/legal source:**
- **Escalation:**
- **Evidence:**

Record 10

- **Trigger:** Material audit, conformity, or control finding
- **Required action:**
- **Actor/owner:**

- **Deadline/legal source:**
- **Escalation:**
- **Evidence:**

Record 11

- **Trigger:** Potential substantial modification
- **Required action:**
- **Actor/owner:**
- **Deadline/legal source:**
- **Escalation:**
- **Evidence:**

Possible actions include investigation, evidence preservation, enhanced oversight, configuration change, scope restriction, user communication, retraining, supplier escalation, suspension, rollback, withdrawal, recall, conformity reassessment, documentation update, and notification where legally required.

153.8 7. Incident and corrective-action integration

For material signals:

1. preserve relevant evidence and identify affected versions;
2. contain immediate risk;
3. assess serious-incident and parallel notification duties;
4. identify affected persons, jurisdictions, suppliers, and systems;
5. perform root-cause and affected-scope analysis;
6. define corrective and preventive actions;
7. update risk, technical, QMS, instructions, notices, and monitoring records;
8. validate remediation before restoration or closure;
9. share lessons across similar systems.

153.9 8. Supplier and dependency monitoring

Monitor:

- model releases, deprecations, changed capabilities, and known limitations;
- data-source, subprocessor, hosting, and location changes;
- service levels, outages, security events, and incident notices;
- licensing, open-source, copyright, and contractual changes;
- audit, documentation, logging, and evidence-access limitations;
- concentration, continuity, portability, and exit risk.

153.10 9. Reporting and escalation

Readable record format (5 source columns):

- **Condition:**
- **Recipient:**
- **Deadline:**
- **Required content/evidence:**
- **Decision authority:**

Reports must distinguish facts, assumptions, uncertainty, legal duties, current controls, residual risk, and required decisions.

153.11 10. Evidence retention

Retain monitoring data, analyses, decisions, approvals, complaints, incident records, notifications, authority correspondence, supplier notices, test results, and corrective-action evidence under the applicable statutory, contractual, operational, privacy, and legal-hold schedule.

153.12 11. Decision

- ☐ Article 72 provider plan approved
- ☐ Other-actor monitoring plan approved
- ☐ Approved with conditions
- ☐ Restricted pilot monitoring only
- ☐ Remediation required
- ☐ Deployment blocked or suspended

Decision rationale:

Conditions and thresholds:

Retention basis:

Open actions:

153.13 12. Review triggers

Review after:

- model, system, data, prompt, tool, agent, supplier, or infrastructure change;
- new purpose, population, jurisdiction, or affected-person context;
- incident, complaint, appeal, drift, or failed control;
- monitoring threshold breach;
- substantial modification or conformity change;
- legal, authority, standard, or code development;
- suspension, rollback, withdrawal, recall, or restoration.

153.14 GlobalWay Travel Services example

GlobalWay monitors a traveler-disruption assistant for incorrect rebooking, safety-sensitive advice, subgroup and language disparities, unauthorized tool actions, override rates, complaints, supplier changes, and outages. A supplier update increases incorrect recommendations in severe-weather cases. Critical thresholds trigger feature restriction, evidence preservation, human-only rebooking, supplier escalation, regression testing, and legal review before restoration.

153.15 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Provider/technical owner
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Monitoring owner
- **Name:**
- **Decision:**

- **Date:**

Record 3

- **Role:** Quality/Compliance
- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Legal
- **Name:**
- **Decision:**
- **Date:**

Record 5

- **Role:** Risk/Privacy/Security, as applicable
- **Name:**
- **Decision:**
- **Date:**

Evidence references:

Retention basis:

Next review trigger/date:

Plan version:

153.16 Primary legal references

- Regulation (EU) 2024/1689, as amended: Article 72 and applicable provider, deployer, risk-management, quality-management, logging, monitoring, incident, corrective-action, authority, and high-risk provisions.
- Regulation (EU) 2026/1744 where applicable.
- Applicable privacy, cybersecurity, product-safety, employment, consumer-protection, and sector law.
- Current consolidated official texts control over this plan.

154 Appendix N — Serious-Incident Report

Legal status: Corrected English master. Reporting duties are actor-, event-, provision-, authority-, and date-specific. There is no universal AI incident deadline. Assess AI Act, privacy, cybersecurity, product-safety, employment, consumer, and sector obligations separately.

154.1 Purpose

Use this form to document, assess, escalate, investigate, report, remediate, and close a serious incident or potentially reportable AI event.

The form must distinguish internal severity from the legal serious-incident test, preserve evidence promptly, identify the responsible actor and authority, control reporting deadlines, and prevent restart before corrective actions are validated.

154.2 1. Incident and legal context

Field	Response
Incident ID	
System/model and inventory ID	
Version/configuration	
Legal entity and actor role	
Intended purpose/classification	
Date/time occurred	
Date/time detected	
Date/time confirmed or escalated	
Reporter	
Business/provider/deployer owner	
Incident lead	
Jurisdictions	
Affected persons, systems, and services	
Provider/vendor and dependencies	
Current legal source/application date	

154.3 2. Initial event description

Describe:

- verified facts and known uncertainty;
- how the event was detected;
- affected systems, models, versions, persons, groups, assets, and processes;
- actual and potential consequences;
- scale, duration, reversibility, and continuing exposure;
- current operational status;
- supplier, subprocessor, tool, data, or infrastructure involvement;
- related complaints, appeals, security alerts, or prior warnings.

154.4 3. Immediate containment

Readable record format (5 source columns):

Record 1

- **Action:** Restrict, suspend, isolate, roll back, or stop system
- **Owner:**
- **Time completed:**
- **Status:**
- **Evidence:**

Record 2

- **Action:** Protect and support affected persons
- **Owner:**
- **Time completed:**
- **Status:**
- **Evidence:**

Record 3

- **Action:** Activate fallback/manual process
- **Owner:**
- **Time completed:**
- **Status:**

- **Evidence:**

Record 4

- **Action:** Preserve logs, versions, prompts, data, outputs, decisions, and communications
- **Owner:**
- **Time completed:**
- **Status:**
- **Evidence:**

Record 5

- **Action:** Issue legal hold where required
- **Owner:**
- **Time completed:**
- **Status:**
- **Evidence:**

Record 6

- **Action:** Notify internal Legal, Compliance, Security, Privacy, Risk, and executives
- **Owner:**
- **Time completed:**
- **Status:**
- **Evidence:**

Record 7

- **Action:** Contact provider/vendor and require preservation
- **Owner:**
- **Time completed:**
- **Status:**
- **Evidence:**

Record 8

- **Action:** Prevent recurrence in similar systems
- **Owner:**
- **Time completed:**
- **Status:**
- **Evidence:**

154.5 4. Serious-incident legal test

Use the current statutory definition and reporting rules. Do not infer reportability solely from an internal severity rating.

Readable record format (4 source columns):

Record 1

- **Statutory element or other trigger:** Death or serious damage to health
- **Met?:**
- **Evidence and rationale:**
- **Reviewer:**

Record 2

- **Statutory element or other trigger:** Serious and irreversible disruption of critical infrastructure
- **Met?:**
- **Evidence and rationale:**
- **Reviewer:**

Record 3

- **Statutory element or other trigger:** Breach of Union-law obligations intended to protect fundamental rights
- **Met?:**
- **Evidence and rationale:**
- **Reviewer:**

Record 4

- **Statutory element or other trigger:** Serious damage to property or the environment
- **Met?:**
- **Evidence and rationale:**
- **Reviewer:**

Record 5

- **Statutory element or other trigger:** Other applicable AI Act trigger
- **Met?:**
- **Evidence and rationale:**
- **Reviewer:**

Record 6

- **Statutory element or other trigger:** Privacy/data-protection breach
- **Met?:**
- **Evidence and rationale:**
- **Reviewer:**

Record 7

- **Statutory element or other trigger:** Cybersecurity incident
- **Met?:**
- **Evidence and rationale:**
- **Reviewer:**

Record 8

- **Statutory element or other trigger:** Product-safety or sector trigger
- **Met?:**
- **Evidence and rationale:**
- **Reviewer:**

Record 9

- **Statutory element or other trigger:** Employment, equality, consumer, contractual, or insurance trigger
- **Met?:**
- **Evidence and rationale:**
- **Reviewer:**

Legal conclusion:

Responsible actor:

Clock-start event:

Qualified reviewer:

154.6 5. Notification matrix

Readable record format (8 source columns):

- **Regime/provision:**
- **Responsible actor:**
- **Recipient:**
- **Clock-start event:**
- **Deadline:**
- **Initial report:**
- **Follow-up/final report:**
- **Status/evidence:**

Record:

- authority and contact channel;
- permitted preliminary or phased reporting;
- incomplete-information treatment;
- facts, uncertainty, containment, and planned updates;
- approval authority;
- delivery acknowledgement;
- rationale for non-notification;
- consistency across parallel notifications.

154.7 6. Evidence preserved

Preserve as applicable:

- model, system, code, prompt, tool, agent, and configuration versions;
- inputs, outputs, retrieval results, tool actions, warnings, and logs;
- human-review, override, stop, and escalation records;
- relevant data, lineage, transformations, and dataset versions;
- release, deployment, rollback, and change records;
- monitoring, security, and system telemetry;
- supplier communications, notices, contracts, and evidence;
- complaints, witness information, affected-person communications, and support records;
- legal analyses, authority communications, and reporting decisions.

Readable record format (6 source columns):

- **Evidence item:**
- **Source/custodian:**
- **Collection time:**
- **Integrity/checksum:**
- **Storage:**
- **Access restrictions:**

154.8 7. Investigation and affected scope

Document:

- event chronology;
- technical, model, data, process, governance, supplier, and human causes;
- affected versions, jurisdictions, populations, customers, and services;
- whether similar systems share the weakness;
- failed or absent controls;
- prior signals, complaints, findings, or exceptions;

- intended-purpose, role, classification, conformity, or substantial-modification implications;
- root cause, contributing factors, and uncertainty;
- legal, safety, rights, privacy, cybersecurity, financial, and reputational impact.

154.9 8. Corrective and preventive action

Readable record format (7 source columns):

- **Action:**
- **Type:** Correction / corrective / preventive / systemic
- **Owner:**
- **Due date:**
- **Legal consequence:**
- **Status:**
- **Validation evidence:**

Required updates may include risk files, technical documentation, QMS, data controls, human oversight, instructions, notices, contracts, monitoring, training, conformity evidence, and similar-system reviews.

154.10 9. Restart, restriction, or withdrawal decision

- ☐ Continue operation
- ☐ Restricted operation with conditions
- ☐ Limited monitored restart
- ☐ Remain suspended
- ☐ Withdraw or recall
- ☐ Decommission
- ☐ Qualified legal, conformity, or authority review required

154.10.1 Decision rationale

Document:

- validated containment and remediation;
- unresolved risk and uncertainty;
- affected-person safeguards;

- required authority or customer approval;
- monitoring thresholds;
- rollback or stop criteria;
- accountable approval and expiry of conditions.

154.11 10. Closure criteria

Confirm:

- all required initial, follow-up, and final reports are complete;
- authority questions and commitments are resolved or tracked;
- affected persons received required support, communication, correction, or remedy;
- evidence is retained and legal-hold obligations are satisfied;
- root cause and affected scope are approved;
- corrective and preventive actions are validated;
- similar systems were assessed;
- policies, controls, documentation, contracts, training, and monitoring were updated;
- restart or permanent withdrawal was formally approved;
- lessons learned were communicated to management and the board where material.

154.12 GlobalWay Travel Services example

GlobalWay discovers that a supplier update caused its fraud model to block a geographic group of travelers disproportionately. The company restricts the feature, activates manual review, preserves the affected model, data, outputs, overrides, and supplier communications, and evaluates AI Act, GDPR, consumer, and contractual reporting duties separately. Restart is approved only after root-cause analysis, subgroup retesting, updated monitoring, supplier controls, and validated remediation.

154.13 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Incident lead
- **Name:**

- **Decision:**
- **Date:**

Record 2

- **Role:** Provider/deployer/business owner
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Legal/Compliance
- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Technical/Security
- **Name:**
- **Decision:**
- **Date:**

Record 5

- **Role:** Privacy/Risk/Product, as applicable
- **Name:**
- **Decision:**
- **Date:**

Record 6

- **Role:** Executive or board, where required
- **Name:**
- **Decision:**
- **Date:**

Evidence references:
Retention/legal-hold basis:
Notification status:
Open actions and commitments:
Next action/review:
Report version:

154.14 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable serious-incident, post-market monitoring, provider, deployer, corrective-action, authority-cooperation, and high-risk provisions.
- Regulation (EU) 2026/1744 where applicable.
- Regulation (EU) 2016/679 and applicable cybersecurity, product-safety, employment, equality, consumer-protection, environmental, insurance, contractual, and sector law.
- Current consolidated official texts and competent-authority instructions control over this report.

155 Appendix O — AI Vendor Questionnaire

Legal status: Corrected English master. Vendor responses are assertions until supported by current, scope-matched, version-matched evidence. Contract labels do not determine statutory actor roles.

155.1 Purpose

Use this questionnaire to assess an AI vendor’s governance, legal role, system and model evidence, data practices, safety, security, resilience, transparency, monitoring, incident response, supply chain, contractual commitments, and ability to support compliance throughout the relationship.

155.2 1. Vendor and service identity

Field	Response
Vendor legal name and jurisdiction	
Contracting entity	
Product/service	
System/model/version	
Intended purpose and supported uses	
Hosting and support locations	
Model providers	

Field	Response
Subprocessors and critical dependencies	
Primary legal/compliance contact	
Security/incident contact	
Technical/product contact	
Evidence repository/data room	

155.3 2. Role, classification, and legal scope

Request evidence for:

- provider, GPAI-provider, downstream-provider, deployer, importer, distributor, authorised-representative, product-manufacturer, and other roles;
- intended purpose, actual supported use, prohibited use, and foreseeable misuse;
- Article 5 screening;
- Article 6/Annex I or Annex III classification;
- Article 50 and other transparency duties;
- GPAI and systemic-risk treatment;
- application dates and transitional rules;
- conformity route, notified-body status, declaration, registration, CE marking, and authority status where applicable;
- supported jurisdictions and sector restrictions.

Readable record format (5 source columns):

Record 1

- **Claim:** Actor role
- **Vendor response:**
- **Evidence:**
- **Version/scope match:**
- **Internal conclusion:**

Record 2

- **Claim:** Statutory classification
- **Vendor response:**
- **Evidence:**
- **Version/scope match:**
- **Internal conclusion:**

Record 3

- **Claim:** Conformity/registration status
- **Vendor response:**
- **Evidence:**
- **Version/scope match:**
- **Internal conclusion:**

Record 4

- **Claim:** Applicable dates
- **Vendor response:**
- **Evidence:**
- **Version/scope match:**
- **Internal conclusion:**

155.4 3. Intended purpose and use restrictions

Ask the vendor to provide:

- formal intended-purpose statement;
- supported use cases and populations;
- prohibited, unsupported, or high-risk uses;
- known limitations and failure modes;
- configuration and access restrictions;
- controls preventing repurposing or circumvention;
- instructions for safe integration, deployment, oversight, and fallback;

- geographic, language, accessibility, and sector limitations.

155.5 4. System and model information

Request:

- architecture and material dependencies;
- model type, provider, version, configuration, and release history;
- prompts, system instructions, tools, agents, retrieval, and external actions;
- evaluation methods, metrics, datasets, limitations, and known defects;
- accuracy, uncertainty, abstention, subgroup, language, and accessibility results;
- robustness, misuse, red-team, and adversarial-test evidence;
- release, deprecation, rollback, and change-notification process;
- ability to preserve, identify, reproduce, and support prior versions;
- technical documentation and model/system cards appropriate to the role.

155.6 5. Data governance and intellectual property

Request evidence for:

- sources and provenance of training, tuning, validation, evaluation, retrieval, and monitoring data;
- lawful acquisition, licences, permissions, and intellectual-property controls;
- scraping and data-source restrictions;
- quality, relevance, representativeness, and bias methods;
- subgroup and intersectional testing;
- customer-data use for training, improvement, or feedback;
- personal, special-category, biometric, children's, confidential, and regulated data;
- retention, deletion, localization, transfer, and access controls;
- synthetic-data use and labelling;

- copyright-compliance policy and training-content summary where applicable;
- dataset and model lineage, versioning, and reproducibility.

155.7 6. Safety, security, and resilience

Request:

- secure-development lifecycle and governance;
- threat models and misuse cases;
- adversarial, penetration, prompt-injection, tool-abuse, and supply-chain testing;
- vulnerability identification, remediation, disclosure, and timelines;
- access control, encryption, secrets, and tenant isolation;
- logging, telemetry, anomaly detection, and evidence export;
- incident history and lessons learned;
- availability, backup, recovery, fallback, continuity, and disaster recovery;
- concentration, portability, replacement, and exit support;
- independent security, safety, and resilience assurance.

155.8 7. Human oversight, transparency, and affected-person support

Request evidence for:

- instructions for use and known limitations;
- information needed for human interpretation and oversight;
- override, stop, rollback, and escalation capabilities;
- automation-bias safeguards;
- transparency notices, disclosures, and synthetic-content marking;
- accessibility and language support;
- complaint, appeal, correction, and remedy support;
- worker, applicant, customer, or public-service use considerations;
- training and competence materials.

155.9 8. Monitoring, changes, and incidents

Define and request evidence for:

- post-deployment monitoring and performance/drift thresholds;
- subgroup, language, accessibility, security, complaint, and override monitoring;
- serious-incident identification, notification, and cooperation;
- regulator, notified-body, auditor, and customer support;
- model, service, data, hosting, subprocessor, and contractual changes;
- affected-version identification and evidence preservation;
- corrective action, restriction, rollback, withdrawal, recall, and restoration;
- deprecation and end-of-support notices.

155.10 9. Evidence and audit rights

Confirm availability of:

- technical documentation;
- validation and evaluation reports;
- data-governance evidence;
- risk and safety assessments;
- security test results;
- audit reports, certifications, or attestations;
- incident and complaint records;
- release and change history;
- logs and affected-version evidence;
- regulator-facing information;
- customer audit, inspection, testing, and authority-cooperation support.

Readable record format (6 source columns):

- **Claim:**
- **Evidence supplied:**

- **Current?:**
- **Version/scope match:**
- **Independently validated?:**
- **Limitation/gap:**

155.11 10. Supply chain and concentration

Readable record format (7 source columns):

- **Dependency:**
- **Provider:**
- **Location:**
- **Function:**
- **Criticality:**
- **Evidence/access limitation:**
- **Exit or substitution option:**

Assess single points of failure, hidden subprocessors, proprietary evidence gaps, cross-border dependencies, licence restrictions, unsupported versions, and substitution time.

155.12 11. Contractual commitments

Confirm willingness to support:

- accurate role, classification, and intended-purpose information;
- evidence access, audit, inspection, and testing rights;
- model, version, functionality, data, location, licence, and subprocessor change notice;
- incident, vulnerability, complaint, and regulatory notice;
- data-use restrictions, confidentiality, privacy, retention, deletion, and return;
- evidence preservation and legal hold;
- authority, notified-body, auditor, customer, and affected-person cooperation;
- remediation, retesting, service credits, suspension, and termination;
- rollback, portability, continuity, transition, and exit;

- liability, indemnification, insurance, and allocation appropriate to risk;
- flow-down of requirements to subprocessors and upstream providers;
- survival of evidence, incident, deletion, and cooperation duties after termination.

155.13 12. Risk conclusion

- ☐ Approved
- ☐ Approved with conditions
- ☐ Restricted pilot only
- ☐ Remediation or evidence required
- ☐ Not approved
- ☐ Qualified legal, security, privacy, or technical review required

Decision rationale:

Unverified assertions:

Material evidence gaps:

Conditions and restrictions:

Exit/continuity concerns:

155.14 13. Open actions

Readable record format (7 source columns):

- **Action:**
- **Vendor owner:**
- **Internal owner:**
- **Due date:**
- **Risk/legal impact:**
- **Status:**
- **Closure evidence:**

155.15 14. Review triggers

Reassess after:

- model, system, version, data, capability, or intended-purpose change;
- new subprocessor, model provider, location, licence, or dependency;
- incident, vulnerability, complaint, outage, or audit finding;

- contract renewal, material amendment, acquisition, or financial deterioration;
- legal, conformity, authority, or classification change;
- expansion to a new jurisdiction, population, language, or sector;
- deprecation, end of support, or exit planning.

155.16 GlobalWay Travel Services example

GlobalWay evaluates a GPAI vendor for a traveler-assistance system. The vendor supplies current model documentation and security testing but cannot provide version-specific subgroup evidence, guarantees only 30 days' notice for model changes, and reserves broad rights to use customer prompts for improvement. GlobalWay permits only a restricted pilot after obtaining data-use restrictions, stronger change notice, evidence-preservation duties, incident cooperation, rollback support, and completion of independent multilingual and tool-action testing.

155.17 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Vendor owner/Procurement
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Legal/Compliance
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Security/Privacy/Technical
- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Business owner
- **Name:**
- **Decision:**
- **Date:**

Record 5

- **Role:** Risk/Data/Product, as applicable
- **Name:**
- **Decision:**
- **Date:**

Evidence references:

Unverified assertions:

Conditions and remediation:

Next review trigger/date:

Questionnaire version:

155.18 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable value-chain, provider, GPAI, downstream, importer, distributor, representative, product-manufacturer, high-risk, transparency, monitoring, incident, corrective-action, and authority provisions.
- Regulation (EU) 2026/1744 where applicable.
- Regulation (EU) 2016/679 and applicable cybersecurity, product-safety, employment, consumer-protection, accessibility, intellectual-property, contract, and sector law.
- Current consolidated official texts and verified evidence control over vendor assertions.

156 Appendix P — AI Contract-Clause Checklist

Legal status: Corrected English master. Contracts allocate operational responsibilities, evidence, cooperation, risk, and remedies but do not change statutory actor roles, remove legal duties, transfer non-transferable accountability, or make an unlawful use lawful.

156.1 Purpose

Use this checklist when procuring, licensing, integrating, hosting, distributing, white-labelling, modifying, or supporting an AI system or GPAI-enabled service.

Contract terms should reflect actual conduct, intended purpose, system and model versions, supplier dependencies, applicable legal roles, required evidence, monitoring, incidents, changes, authority cooperation, continuity, and exit.

156.2 1. Parties, service, and roles

Document:

Field	Response
Contracting entities	
Service/product	
System/model/version	
Intended purpose and approved uses	
Prohibited/restricted uses	
Jurisdictions, sectors, users, and affected persons	
Branding/white-label arrangements	
Modification, fine-tuning, tool, agent, and configuration rights	
AI Act roles based on actual conduct	
Data-protection roles	
Product-safety/sector roles	
Critical dependencies/subprocessors	
Role-change and reassessment triggers	

156.3 2. Scope and permitted use

- ☐ Intended purpose is precise and version-linked.
- ☐ Approved, unsupported, restricted, and prohibited uses are listed.
- ☐ Users, populations, jurisdictions, sectors, data types, and decision contexts are defined.

- ☐ Degree of automation and external-action authority are controlled.
- ☐ Customer configuration, fine-tuning, prompt, retrieval, tool, and agent rights are defined.
- ☐ White-label, branding, resale, and own-name implications are addressed.
- ☐ Repurposing and circumvention are prohibited and technically controlled where possible.
- ☐ Supplier instructions, limitations, and customer operating duties are incorporated.

156.4 3. Actor roles and responsibility schedule

- ☐ Each party's EU AI Act role is documented based on facts.
- ☐ GPAI-provider and downstream-provider responsibilities are addressed.
- ☐ Provider-role transfer triggers are identified.
- ☐ Importer, distributor, authorised-representative, and product-manufacturer duties are addressed where relevant.
- ☐ Responsibility for intended purpose, substantial modification, conformity, registration, declaration, marking, monitoring, incidents, and corrective action is allocated.
- ☐ Data-protection, employment, consumer, cybersecurity, product, intellectual-property, and sector roles are separately defined.
- ☐ The contract requires prompt notice of facts that could change a statutory role.

156.5 4. Documentation and evidence

- ☐ Current technical documentation is provided and maintained.
- ☐ Model/system cards, instructions, limitations, and intended-purpose records are supplied.
- ☐ Validation, performance, bias, language, accessibility, robustness, misuse, and security evidence is available.
- ☐ Data provenance, lawful acquisition, quality, representativeness, and lineage evidence is available.
- ☐ Logging, traceability, version identification, export, and retention support are defined.

- ☐ Conformity, notified-body, declaration, registration, marking, and certification evidence is provided where applicable.
- ☐ Evidence is version- and scope-matched.
- ☐ Evidence can be supplied to customers, auditors, notified bodies, and authorities within required timeframes.
- ☐ Trade-secret and confidentiality terms permit lawful compliance and authority access.

156.6 5. Data, privacy, and intellectual property

- ☐ Data ownership, control, access, permitted use, and restrictions are defined.
- ☐ Customer data is not used for training, fine-tuning, evaluation, or service improvement without explicit authorization.
- ☐ Prompt, output, retrieval, feedback, telemetry, and derived-data use is addressed.
- ☐ Personal, special-category, biometric, children's, confidential, and regulated data protections are included.
- ☐ Lawful basis, data-subject rights, notices, minimisation, and purpose limitation are supported.
- ☐ Retention, deletion, return, portability, archival, and legal hold are addressed.
- ☐ Data location, localization, transfer, government-access, and subprocessor controls are specified.
- ☐ Licences and intellectual-property rights are sufficient for intended use.
- ☐ Copyright, training-data, open-source, model-output, infringement, and provenance risks are allocated.
- ☐ Post-termination deletion and evidence-survival duties are enforceable.

156.7 6. Security, safety, and resilience

- ☐ Secure-development, architecture, and configuration requirements are defined.
- ☐ Threat modelling, adversarial testing, prompt-injection, tool-abuse, vulnerability, and patch obligations are included.

- ☐ Access control, encryption, segregation, secrets, and tenant protections are addressed.
- ☐ Security and safety incidents have defined notification triggers, clocks, deadlines, and content.
- ☐ Logging, forensic support, evidence preservation, and affected-version identification are required.
- ☐ Availability, backup, recovery, fallback, business continuity, and disaster recovery are addressed.
- ☐ Service restrictions, emergency disablement, rollback, and restoration validation are supported.
- ☐ Exit, transition, substitution, portability, and continuity support are included.

156.8 7. Model, service, and value-chain changes

- ☐ Advance notice is required for material changes.
- ☐ Model, version, provider, data, feature, capability, prompt, tool, agent, subprocessor, hosting, location, licence, policy, and intended-purpose changes are covered.
- ☐ Notice periods are proportionate to risk and permit assessment before implementation.
- ☐ Customer approval, delay, rollback, restriction, or termination rights are defined.
- ☐ Prior versions, documentation, logs, and evidence can be preserved where necessary.
- ☐ Predetermined change plans and substantial-modification implications are addressed.
- ☐ Deprecation, end of support, migration, and replacement support are specified.
- ☐ Upstream changes are flowed down promptly.

156.9 8. Performance, monitoring, and human oversight

- ☐ Performance, drift, subgroup, language, accessibility, and reliability monitoring duties are assigned.
- ☐ Metrics, thresholds, data access, and reporting frequency are defined.

- ☐ User instructions, limitations, uncertainty, and performance ranges are supplied.
- ☐ Human-review, override, stop, escalation, fallback, and appeal functionality is supported.
- ☐ Automation-bias and affected-person safeguards are addressed.
- ☐ Transparency notices, synthetic-content marking, localization, and accessibility support are defined.
- ☐ Customer complaints, appeals, corrections, and remedies receive supplier support.

156.10 9. Incidents, complaints, and corrective action

- ☐ Serious-incident, security, privacy, safety, and service-event cooperation is required.
- ☐ Notification clauses identify the event starting the clock, deadline, recipient, initial content, and updates.
- ☐ Evidence preservation and legal-hold obligations are included.
- ☐ Root-cause, affected-scope, and similar-system investigation support is required.
- ☐ Corrective action, retesting, documentation updates, and closure validation are defined.
- ☐ Suspension, restriction, rollback, withdrawal, recall, and decommissioning support is included.
- ☐ Authority and affected-person communications are coordinated.
- ☐ Incident obligations survive termination where necessary.

156.11 10. Audit, testing, and regulatory cooperation

- ☐ Audit, inspection, evidence-access, and testing rights are proportionate and enforceable.
- ☐ Independent reports and attestations are supplied with scope and version information.
- ☐ Customer testing does not void support or contractual protection when performed safely.
- ☐ Regulatory inquiries, inspections, information requests, notified-body reviews, and enforcement matters are supported.

- ☐ Required records can be produced within legally required timeframes.
- ☐ Subprocessor and upstream-provider compliance is flowed down.
- ☐ Remediation deadlines and escalation for evidence gaps are defined.
- ☐ Confidentiality terms do not obstruct lawful disclosure.

156.12 11. Liability, insurance, and remedies

- ☐ Warranties align with documented capability, intended purpose, performance, and limitations.
- ☐ Warranties address authority, licences, data rights, security, documentation, and compliance representations.
- ☐ Indemnities address data, privacy, intellectual property, security, regulatory, product, and third-party claims as appropriate.
- ☐ Liability caps and exclusions reflect material AI risk and do not neutralize essential remedies.
- ☐ Insurance requirements are proportionate and current.
- ☐ Service credits do not replace remediation, suspension, termination, indemnity, or damages where appropriate.
- ☐ Termination rights exist for noncompliance, serious incidents, evidence failure, unsupported changes, or repeated defects.
- ☐ Transition and exit assistance is enforceable.

156.13 12. Clause-effectiveness review

Readable record format (6 source columns):

Record 1

- **Clause area:** Roles and intended purpose
- **Required?:**
- **Included?:**
- **Operational owner:**
- **Evidence/test:**
- **Gap/action:**

Record 2

- **Clause area:** Documentation/evidence
- **Required?:**
- **Included?:**
- **Operational owner:**
- **Evidence/test:**
- **Gap/action:**

Record 3

- **Clause area:** Data/privacy/IP
- **Required?:**
- **Included?:**
- **Operational owner:**
- **Evidence/test:**
- **Gap/action:**

Record 4

- **Clause area:** Security/resilience
- **Required?:**
- **Included?:**
- **Operational owner:**
- **Evidence/test:**
- **Gap/action:**

Record 5

- **Clause area:** Changes/subprocessors
- **Required?:**
- **Included?:**
- **Operational owner:**
- **Evidence/test:**
- **Gap/action:**

Record 6

- **Clause area:** Monitoring/oversight/transparency
- **Required?:**
- **Included?:**
- **Operational owner:**
- **Evidence/test:**
- **Gap/action:**

Record 7

- **Clause area:** Incidents/corrective action
- **Required?:**
- **Included?:**
- **Operational owner:**
- **Evidence/test:**
- **Gap/action:**

Record 8

- **Clause area:** Audit/regulatory cooperation
- **Required?:**
- **Included?:**
- **Operational owner:**
- **Evidence/test:**
- **Gap/action:**

Record 9

- **Clause area:** Continuity/exit
- **Required?:**
- **Included?:**
- **Operational owner:**
- **Evidence/test:**

- **Gap/action:**

Record 10

- **Clause area:** Liability/remedies
- **Required?:**
- **Included?:**
- **Operational owner:**
- **Evidence/test:**
- **Gap/action:**

Confirm that operational owners understand and can exercise the clauses. A contractual right that cannot be invoked, tested, or enforced is not an effective control.

156.14 13. Decision

- ☐ Approved
- ☐ Approved with deviations and compensating controls
- ☐ Restricted pilot only
- ☐ Negotiation required
- ☐ Not approved
- ☐ Qualified legal or specialist review required

Decision rationale:

Approved deviations:

Compensating controls:

Unresolved risks:

Termination/exit readiness:

156.15 14. Open actions

Readable record format (6 source columns):

- **Action:**
- **Owner:**
- **Due date:**
- **Risk/legal impact:**
- **Status:**

- **Closure evidence:**

156.16 15. Review triggers

Reassess after:

- renewal, amendment, assignment, acquisition, or restructuring;
- model, service, data, feature, subprocessor, hosting, licence, or policy change;
- role, classification, intended-purpose, conformity, or jurisdiction change;
- incident, vulnerability, complaint, outage, audit finding, or authority request;
- deprecation, end of support, supplier deterioration, or exit event;
- legal, regulatory, standard, code, or authority development.

156.17 GlobalWay Travel Services example

GlobalWay negotiates a traveler-assistance GPAI service. The initial contract permits unannounced model changes, broad training use of prompts, limited evidence access, and no rollback obligation. GlobalWay requires explicit data-use restrictions, advance change notice, version preservation, audit and regulator cooperation, incident notice, multilingual testing support, rollback, continuity, and exit assistance before approving a restricted pilot.

156.18 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Legal
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Procurement/Vendor Management
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Security/Privacy/Technical
- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Business owner
- **Name:**
- **Decision:**
- **Date:**

Record 5

- **Role:** Risk/Compliance
- **Name:**
- **Decision:**
- **Date:**

Record 6

- **Role:** Data/Product/HR, as applicable
- **Name:**
- **Decision:**
- **Date:**

Approved deviations:

Evidence references:

Compensating controls:

Reassessment trigger/date:

Checklist version:

156.19 Primary legal references

- Regulation (EU) 2024/1689, as amended: applicable value-chain, provider, GPAI, downstream, importer, distributor, representative, product-manufacturer, high-risk, transparency, monitoring, incident, corrective-action, authority, and evidence provisions.

- Regulation (EU) 2026/1744 where applicable.
- Regulation (EU) 2016/679 and applicable cybersecurity, product-safety, employment, equality, accessibility, consumer-protection, intellectual-property, contract, competition, and sector law.
- Current consolidated official texts control over contractual summaries.

157 Appendix Q — AI-Literacy Matrix

Legal status: Corrected English master. Article 4 requires providers and deployers to take measures, to their best extent, to ensure a sufficient level of AI literacy for relevant staff and other persons dealing with AI systems on their behalf. The Act does not prescribe one universal curriculum, frequency, examination, or certificate.

157.1 Purpose

Use this matrix to define, deliver, test, and track the knowledge, practical competence, and role-based support required for people who develop, procure, integrate, deploy, oversee, audit, govern, or otherwise deal with AI systems on behalf of the organization.

157.2 1. Applicability and programme scope

Field	Response
Legal entities and provider/deployer roles	
Systems/models and jurisdictions	
Personnel and other persons in scope	
Knowledge, experience, education, training, and use context considered	
Persons/groups on whom systems are used considered	
Current legal source/application date	
Programme owner	
Programme version/review date	

157.3 2. Role matrix

Readable record format (7 source columns):

Record 1

- **Role:** Board and executives
- **Legal/operational responsibilities:** Strategy, accountability, risk appetite, oversight, escalation, resources
- **Required knowledge:** AI capabilities and limitations, material legal exposure, systemic risk, governance duties
- **Practical competence:** Challenge management, approve risk decisions, oversee remediation
- **Delivery method:** Briefing, scenario exercise, board workshop
- **Frequency/trigger:** On appointment, annual, and event-driven
- **Evidence:** Attendance, minutes, exercise results

Record 2

- **Role:** Business/system owners
- **Legal/operational responsibilities:** Intended purpose, ownership, approval, monitoring, change, residual risk
- **Required knowledge:** Classification, affected persons, control obligations, supplier limits
- **Practical competence:** Approve use, manage controls, interpret reports, escalate
- **Delivery method:** Role workshop and case exercise
- **Frequency/trigger:** Before ownership, annual, and after material change
- **Evidence:** Assessment, attestation, decision records

Record 3

- **Role:** Developers, engineers, and data teams
- **Legal/operational responsibilities:** Design, data, testing, documentation, secure development, monitoring
- **Required knowledge:** Data quality, bias, robustness, cybersecurity, technical documentation, human oversight
- **Practical competence:** Build, test, document, validate, remediate, preserve evidence
- **Delivery method:** Technical modules and practical labs

- **Frequency/trigger:** Before assignment and recurring
- **Evidence:** Practical test, code/review evidence, project records

Record 4

- **Role:** Human-oversight personnel
- **Legal/operational responsibilities:** Review, challenge, override, stop, escalate, record decisions
- **Required knowledge:** Intended purpose, limitations, automation bias, abnormal behavior, affected-person safeguards
- **Practical competence:** Interpret output, challenge recommendations, apply fallback, preserve evidence
- **Delivery method:** Scenario-based training and supervised practice
- **Frequency/trigger:** Before assignment, recurring, after incidents/changes
- **Evidence:** Competence test, observed exercise, override quality

Record 5

- **Role:** Procurement and vendor management
- **Legal/operational responsibilities:** Due diligence, contracting, monitoring, exit
- **Required knowledge:** Actor roles, evidence sufficiency, change and incident clauses, dependency risk
- **Practical competence:** Assess vendors, negotiate controls, track remediation, invoke exit rights
- **Delivery method:** Role workshop and vendor case study
- **Frequency/trigger:** Before role, annual, and before critical procurement
- **Evidence:** Completed questionnaire, contract review, assessment

Record 6

- **Role:** Legal, compliance, privacy, and security
- **Legal/operational responsibilities:** Applicability, interpretation, controls, notifications, investigations, assurance

- **Required knowledge:** AI Act provisions, GDPR and related law, security, evidence, authority interaction
- **Practical competence:** Advise, review, test, investigate, escalate, maintain traceability
- **Delivery method:** Specialist training and legal-change briefings
- **Frequency/trigger:** Continuous updates and assignment-specific
- **Evidence:** Review records, exercises, continuing-education evidence

Record 7

- **Role:** Internal audit and assurance
- **Legal/operational responsibilities:** Independent planning, testing, reporting, closure validation
- **Required knowledge:** Control design, evidence reliability, technical assurance concepts, legal distinction
- **Practical competence:** Scope audits, sample, test, challenge, report, validate
- **Delivery method:** Audit-specific training and technical briefings
- **Frequency/trigger:** Annual and before assignment
- **Evidence:** Workpapers, competence assessment, QA review

Record 8

- **Role:** General users and contractors
- **Legal/operational responsibilities:** Approved use, confidentiality, output checking, incident reporting
- **Required knowledge:** Approved tools, prohibited use, limitations, privacy, security, transparency
- **Practical competence:** Use safely, verify outputs, avoid sensitive inputs, report issues
- **Delivery method:** Onboarding, microlearning, role examples
- **Frequency/trigger:** Before access, annual, and after policy/system changes
- **Evidence:** Quiz, attestation, access record

157.4 3. Curriculum selection

Select proportionately from:

- AI concepts, capabilities, limitations, uncertainty, and hallucination;
- intended purpose, approved use, prohibited or restricted use, and foreseeable misuse;
- legal roles, statutory classifications, application dates, and organizational controls;
- data protection, confidentiality, intellectual property, and customer-data restrictions;
- bias, equality, accessibility, fundamental rights, children, and vulnerable persons;
- human oversight, automation bias, override, stop, fallback, appeal, and escalation;
- cybersecurity, prompt injection, tool misuse, agentic action, and incident reporting;
- transparency, notices, synthetic-content marking, and affected-person communication;
- documentation, evidence, logging, change management, and legal hold;
- vendor risk, monitoring, complaints, corrective action, and regulatory cooperation.

157.5 4. Accessibility and delivery

Provide relevant languages, disability accommodations, accessible formats, role-based examples, realistic scenarios, practical exercises, supervised practice where needed, and refresher material after incidents, findings, legal changes, supplier changes, or material system changes.

157.6 5. Competence and completion tracker

Readable record format (8 source columns):

- **Person/group:**
- **Role:**
- **Required modules:**
- **Completion:**
- **Competence result:**

- **Restriction/interim supervision:**
- **Renewal/trigger:**
- **Exceptions:**

Completion alone does not establish competence. High-impact roles should include scenario-based or practical validation.

157.7 6. Effectiveness measures

Track, as appropriate:

- completion and overdue rates;
- assessment and practical-exercise results;
- unsafe-use incidents and policy violations;
- reviewer override and escalation quality;
- repeated audit findings or control failures;
- employee confidence in identifying and reporting risk;
- accessibility and language defects;
- performance improvement after targeted remediation;
- personnel restricted from duties pending competence.

157.8 7. Exception and remediation management

Document temporary exceptions, reasons, risk, interim supervision or access restrictions, remediation owner, due date, validation method, and approval authority. Do not allow an exception to waive a binding duty or permit an unqualified person to perform high-impact oversight without adequate safeguards.

157.9 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Programme owner
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** HR/learning
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Legal/compliance
- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Executive sponsor
- **Name:**
- **Decision:**
- **Date:**

Evidence references:

Exceptions/interim controls:

Next review trigger/date:

158 Appendix R — Transparency Notice Templates

Legal status: Corrected English master. Select only the notice module triggered by the actor, system, use, output, and applicable provision. A generic AI notice does not satisfy every Article 13, Article 26, Article 50, privacy, employment, consumer, accessibility, or sector duty.

158.1 Purpose

Use these templates to identify the applicable transparency trigger, prepare accurate and accessible notices, link them to the approved system version, test whether they work in the real user context, and retain evidence of approval and deployment.

158.2 1. Applicability record

Field	Response
System/model, inventory ID, version/configuration	

Field	Response
Legal entity and actor role	
Intended use, output, audience, and affected persons	
Jurisdiction and language	
Triggering provision or other legal basis	
Application date, exception, or exclusion	
Notice owner and approver	
Delivery channel and timing	

158.3 2. Module A — Human interaction with AI

State clearly and at the appropriate time that the person is interacting with an AI system, unless this is obvious to a reasonably well-informed, observant, and circumspect person in the circumstances or another statutory exception applies.

Suggested fields:

- responsible organization;
- purpose of the interaction;
- whether a human is available;
- how to request human assistance;
- material limitations relevant to the interaction;
- privacy, complaint, accessibility, and incident contacts.

158.4 3. Module B — High-risk instructions and deployer information

Provide or operationalize applicable instructions, capabilities, limitations, expected accuracy, intended purpose, input requirements, human-oversight measures, logging, maintenance, foreseeable misuse, and other information required for the relevant provider/deployer relationship.

Confirm that the deployer-facing information matches the released system and is available to the people responsible for operation, oversight, monitoring, incident response, and affected-person communication.

158.5 4. Module C — AI-generated or manipulated content

Record:

- provider marking capability;
- machine-readable format;
- technical feasibility, robustness, reliability, and interoperability;
- content type and output channel;
- deployer disclosure duty;
- visibility and timing of disclosure;
- persistence after ordinary processing;
- statutory exceptions or editorial-responsibility treatment.

Distinguish deepfake, public-interest text, and other synthetic-content cases. Do not assume one label satisfies every output and use context.

158.6 5. Module D — Emotion recognition or biometric categorisation

Inform exposed natural persons where the statutory trigger applies. Coordinate the notice with:

- prohibited-practice screening;
- high-risk classification;
- privacy and special-category-data analysis;
- employment, worker-consultation, education, equality, and sector duties;
- accessibility and language requirements;
- complaint and remedy routes.

158.7 6. Core plain-language notice fields

Include only what is accurate and applicable:

158.7.1 AI involvement

Explain whether the person is interacting with AI or whether AI supports a process or decision affecting them.

158.7.2 Purpose

Explain what the system does, why it is being used, which decisions, recommendations, classifications, content, or actions it supports, and whether a human makes or reviews the final outcome.

158.7.3 Information used

Describe the main categories of information used and provide the relevant privacy notice or other data-use information.

158.7.4 Material limitations

Explain foreseeable errors, uncertainty, known performance limits, language or accessibility limitations, unsupported uses, and circumstances in which the system should not be relied upon.

158.7.5 Human review and remedy

State whether human review is available or required and explain how to:

- request review or correction;
- challenge or appeal an outcome;
- contact a person rather than an automated service;
- request accessibility support or accommodation;
- submit a complaint or report an incident.

158.7.6 Contact table

Contact purpose	Details
General questions	
Human review, challenge, or appeal	
Privacy request	
Accessibility or language support	
Complaint or incident	

158.8 7. Quality and evidence checklist

- ☐ Delivered before or at the legally and operationally appropriate time.
- ☐ Clear, concise, understandable, and not hidden among unrelated terms.
- ☐ Accessible to persons with disabilities and available in relevant languages.

- ☐ Consistent with actual system behavior, intended purpose, and limitations.
- ☐ Does not overstate accuracy, capability, human involvement, or legal status.
- ☐ Complaint, review, appeal, and human-contact routes function in practice.
- ☐ Machine-readable marking works and persists where applicable.
- ☐ Approved notice is linked to the deployed version and channel.
- ☐ Changes trigger reassessment and reapproval.

158.9 8. Testing record

Readable record format (6 source columns):

Record 1

- **Test:** Timing and visibility
- **Audience/channel:**
- **Method:**
- **Result:**
- **Defect/action:**
- **Evidence:**

Record 2

- **Test:** Readability and comprehension
- **Audience/channel:**
- **Method:**
- **Result:**
- **Defect/action:**
- **Evidence:**

Record 3

- **Test:** Accessibility and assistive technology
- **Audience/channel:**

- **Method:**
- **Result:**
- **Defect/action:**
- **Evidence:**

Record 4

- **Test:** Translation and localization
- **Audience/channel:**
- **Method:**
- **Result:**
- **Defect/action:**
- **Evidence:**

Record 5

- **Test:** Technical marking and persistence
- **Audience/channel:**
- **Method:**
- **Result:**
- **Defect/action:**
- **Evidence:**

Record 6

- **Test:** Human-contact and appeal route
- **Audience/channel:**
- **Method:**
- **Result:**
- **Defect/action:**
- **Evidence:**

Record 7

- **Test:** Legal and operational consistency

- **Audience/channel:**
- **Method:**
- **Result:**
- **Defect/action:**
- **Evidence:**

158.10 9. Approval

- ☐ Applicable statutory module approved
- ☐ Voluntary/organizational notice approved
- ☐ Approved with conditions
- ☐ Notice not required — rationale documented
- ☐ Qualified legal review required

Readable record format (4 source columns):

Record 1

- **Role:** Business/product owner
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Legal/compliance
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Privacy
- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Accessibility/communications
- **Name:**
- **Decision:**
- **Date:**

Evidence references:

Exception/non-applicability rationale:

Next review trigger/date:

159 Appendix S — Model-Change Assessment

Legal status: Corrected English master. This assessment distinguishes ordinary controlled change, material operational change, intended-purpose change, provider-role change, and potential substantial modification. It does not itself determine legal status.

159.1 Purpose

Use this assessment before implementing a new model version, provider change, fine-tuning update, prompt or tool change, retrieval change, data change, configuration change, safety-filter change, hosting change, or material capability change.

159.2 1. Change record

Field	Response
System/inventory ID	
Current and proposed model/version/configuration	
Legal entity and actor role	
Intended purpose before/after	
Change owner and planned date	
Jurisdictions and affected populations	
Current legal source/application date	
Related release/change ticket	

159.3 2. Change description and scope

Describe:

- what is changing and why;
- expected benefit and affected business process;
- provider/model, architecture, prompts, system instructions, tools, agents, retrieval, data, thresholds, safety filters, hosting, subprocessors, interfaces, and autonomous capability affected;
- affected users, reviewers, customers, workers, or other persons;
- whether intended purpose, actual use, branding, distribution, or operational control changes;
- whether prior versions can be preserved and restored.

159.4 3. Legal and operational screening

Readable record format (6 source columns):

Record 1

- **Area:** Intended purpose
- **No impact:**
- **Minor:**
- **Material:**
- **Legal review required:**
- **Evidence/rationale:**

Record 2

- **Area:** Actor role or own-brand placement
- **No impact:**
- **Minor:**
- **Material:**
- **Legal review required:**
- **Evidence/rationale:**

Record 3

- **Area:** Article 5 prohibited-practice risk
- **No impact:**

- **Minor:**
- **Material:**
- **Legal review required:**
- **Evidence/rationale:**

Record 4

- **Area:** Article 6/Annex I or III classification
- **No impact:**
- **Minor:**
- **Material:**
- **Legal review required:**
- **Evidence/rationale:**

Record 5

- **Area:** Article 6(3) exception assumptions
- **No impact:**
- **Minor:**
- **Material:**
- **Legal review required:**
- **Evidence/rationale:**

Record 6

- **Area:** Potential substantial modification
- **No impact:**
- **Minor:**
- **Material:**
- **Legal review required:**
- **Evidence/rationale:**

Record 7

- **Area:** Conformity, registration, declaration, or marking

- **No impact:**
- **Minor:**
- **Material:**
- **Legal review required:**
- **Evidence/rationale:**

Record 8

- **Area:** Data governance, privacy, and lawful use
- **No impact:**
- **Minor:**
- **Material:**
- **Legal review required:**
- **Evidence/rationale:**

Record 9

- **Area:** Accuracy, reliability, bias, safety, and fundamental rights
- **No impact:**
- **Minor:**
- **Material:**
- **Legal review required:**
- **Evidence/rationale:**

Record 10

- **Area:** Human oversight and transparency
- **No impact:**
- **Minor:**
- **Material:**
- **Legal review required:**
- **Evidence/rationale:**

Record 11

- **Area:** Cybersecurity, logging, monitoring, and incident response
- **No impact:**
- **Minor:**
- **Material:**
- **Legal review required:**
- **Evidence/rationale:**

Record 12

- **Area:** Vendor, dependency, portability, and continuity
- **No impact:**
- **Minor:**
- **Material:**
- **Legal review required:**
- **Evidence/rationale:**

Record 13

- **Area:** Accessibility, language, and jurisdictional deployment
- **No impact:**
- **Minor:**
- **Material:**
- **Legal review required:**
- **Evidence/rationale:**

159.5 4. Required validation

Select and define acceptance criteria before release:

- ☐ Regression testing
- ☐ Performance and reliability testing
- ☐ Subgroup, bias, and fairness testing
- ☐ Security, misuse, prompt-injection, and tool-abuse testing
- ☐ Human-oversight, override, stop, and escalation validation

- ☐ Transparency, notice, and marking review
- ☐ Data-governance and privacy review
- ☐ Resilience, fallback, rollback, and continuity testing
- ☐ Jurisdiction, language, and accessibility testing
- ☐ Logging, evidence, and monitoring validation
- ☐ Documentation-to-production version reconciliation

Readable record format (6 source columns):

- **Test:**
- **Acceptance criterion:**
- **Result:**
- **Limitation/defect:**
- **Owner:**
- **Evidence:**

159.6 5. Documentation and control updates

Readable record format (5 source columns):

Record 1

- **Document or control:** Inventory and role assessment
- **Update required?:**
- **Owner:**
- **Status:**
- **Evidence:**

Record 2

- **Document or control:** Applicability/high-risk classification
- **Update required?:**
- **Owner:**
- **Status:**
- **Evidence:**

Record 3

- **Document or control:** Risk assessment and FRIA/DPIA
- **Update required?:**
- **Owner:**
- **Status:**
- **Evidence:**

Record 4

- **Document or control:** Technical documentation and version history
- **Update required?:**
- **Owner:**
- **Status:**
- **Evidence:**

Record 5

- **Document or control:** Human-oversight plan and training
- **Update required?:**
- **Owner:**
- **Status:**
- **Evidence:**

Record 6

- **Document or control:** Transparency notice, instructions, and markings
- **Update required?:**
- **Owner:**
- **Status:**
- **Evidence:**

Record 7

- **Document or control:** Vendor, contract, and dependency records

- **Update required?:**
- **Owner:**
- **Status:**
- **Evidence:**

Record 8

- **Document or control:** Post-market monitoring plan and thresholds
- **Update required?:**
- **Owner:**
- **Status:**
- **Evidence:**

Record 9

- **Document or control:** Incident, fallback, continuity, and legal-hold procedures
- **Update required?:**
- **Owner:**
- **Status:**
- **Evidence:**

Record 10

- **Document or control:** Conformity, declaration, registration, or marking evidence
- **Update required?:**
- **Owner:**
- **Status:**
- **Evidence:**

159.7 6. Decision

- ☐ Approved as ordinary controlled change
- ☐ Approved with enhanced monitoring
- ☐ Restricted pilot

- ☐ Deferred pending testing or evidence
- ☐ Rejected
- ☐ Escalated for substantial-modification/provider-role review
- ☐ Conformity reassessment required

159.8 7. Rollback and contingency

Record rollback version, rollback triggers, decision authority, responsible personnel, evidence preservation, affected-person protections, communications, fallback process, and restoration criteria.

159.9 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Business owner
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Technical/product owner
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Legal/compliance
- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Risk/conformity owner
- **Name:**

- **Decision:**
- **Date:**

Evidence references:

Residual limitations:

Next review trigger/date:

160 Appendix T — Substantial-Modification Assessment

Legal status: Corrected English master. Use the current statutory definition and actor-specific rules. A material operational change is not automatically a substantial modification, and a substantial modification can transfer provider responsibilities and trigger renewed conformity obligations.

160.1 Purpose

Use this assessment to determine whether a proposed or completed change may constitute a substantial modification, alter intended purpose, change legal role or classification, or require conformity reassessment and other pre-deployment actions.

160.2 1. System and change record

Field	Response
System name, inventory ID, and version	
Current provider and actor roles	
Entity making the change	
Current intended purpose	
Proposed change	
High-risk classification/legal basis	
Jurisdictions and affected populations	
Assessment owner/date	
Current legal source/application date	

160.3 2. Change description

Document:

- model, provider, architecture, data, prompts, tools, agentic capability, interfaces, hosting, subprocessors, thresholds, and safeguards affected;
- business reason and expected outcome;
- new users, affected persons, decision contexts, sectors, or jurisdictions;
- branding, own-name placement, distribution, integration, and operational control;
- whether the change was planned in the original conformity documentation or predetermined change plan;
- whether safeguards, oversight, transparency, logging, or monitoring are altered.

160.4 3. Threshold test

Assess whether the change was unforeseen or not planned in the initial conformity assessment and whether it affects compliance with applicable requirements or changes the intended purpose.

Question	Yes/No/Uncertain	Evidence/rationale
Was the change predetermined and documented in the original technical documentation or approved change plan?		
Does the change alter intended purpose or reasonably foreseeable use?		
Does it introduce a new affected population, decision context, sector, or jurisdiction?		
Does it affect compliance with Articles 9–15 or other applicable requirements?		
Does it change Article 5 or Article 6 analysis, product integration, or		

Question	Yes/No/Uncertain	Evidence/rationale
conformity route?		
Does it materially affect performance, bias, safety, fundamental rights, data governance, oversight, transparency, robustness, or cybersecurity?		
Does it introduce a new model, provider, architecture, data source, autonomous capability, tool, or agent?		
Does it remove, weaken, bypass, or materially change safeguards?		
Does it affect logging, traceability, monitoring, incident response, or evidence retention?		
Does it require new registration, declaration, marking, instructions, or authority interaction?		

160.5 4. Provider-role and value-chain consequence

Determine whether the modifying deployer, distributor, importer, product manufacturer, integrator, or other third party becomes the provider under the applicable value-chain rule. Record separately:

- own-name or own-trademark placement;
- intended-purpose change;
- substantial modification;
- rebranding or white labeling;
- product integration;

- contractual allocation versus actual conduct;
- upstream and downstream notification duties.

Readable record format (6 source columns):

- **Entity:**
- **Current role:**
- **Potential new role:**
- **Factual basis:**
- **Obligations triggered:**
- **Legal conclusion:**

160.6 5. Evidence reviewed

- original technical documentation and conformity file;
- predetermined change plan;
- model-change assessment;
- validation, regression, subgroup, security, and resilience results;
- risk, FRIA, DPIA, and data-governance assessments;
- vendor notices and contract terms;
- release, configuration, version, and rollback records;
- legal, product, and conformity analysis.

160.7 6. Required legal and control actions

Readable record format (6 source columns):

Record 1

- **Action:** Provider-role reassessment
- **Applies?:**
- **Owner:**
- **Due date:**
- **Status:**
- **Evidence:**

Record 2

- **Action:** Article 5/Article 6 reassessment
- **Applies?:**
- **Owner:**
- **Due date:**
- **Status:**
- **Evidence:**

Record 3

- **Action:** Risk-management and impact-assessment update
- **Applies?:**
- **Owner:**
- **Due date:**
- **Status:**
- **Evidence:**

Record 4

- **Action:** Technical-documentation and version update
- **Applies?:**
- **Owner:**
- **Due date:**
- **Status:**
- **Evidence:**

Record 5

- **Action:** Validation/regression/security testing
- **Applies?:**
- **Owner:**
- **Due date:**
- **Status:**

- **Evidence:**

Record 6

- **Action:** Conformity assessment or reassessment
- **Applies?:**
- **Owner:**
- **Due date:**
- **Status:**
- **Evidence:**

Record 7

- **Action:** Declaration, CE marking, or registration update
- **Applies?:**
- **Owner:**
- **Due date:**
- **Status:**
- **Evidence:**

Record 8

- **Action:** Instructions, transparency, accessibility, and training update
- **Applies?:**
- **Owner:**
- **Due date:**
- **Status:**
- **Evidence:**

Record 9

- **Action:** Post-market monitoring and incident-process update
- **Applies?:**
- **Owner:**
- **Due date:**

- **Status:**
- **Evidence:**

Record 10

- **Action:** Contract, supplier, customer, or authority notification
- **Applies?:**
- **Owner:**
- **Due date:**
- **Status:**
- **Evidence:**

Record 11

- **Action:** Release block, restriction, suspension, or rollback
- **Applies?:**
- **Owner:**
- **Due date:**
- **Status:**
- **Evidence:**

160.8 7. Conclusion

- ☐ Not a substantial modification
- ☐ Predetermined change within the documented conformity framework
- ☐ Potentially substantial — additional evidence required
- ☐ Substantial modification
- ☐ Provider-role transfer or other Article 25 consequence
- ☐ Conformity reassessment required
- ☐ Qualified legal or external conformity advice required

160.8.1 Rationale

Document the facts, assumptions, legal interpretation, uncertainty, and evidence supporting the conclusion.

160.9 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Legal/compliance
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Technical/product owner
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Business owner
- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Quality/conformity owner
- **Name:**
- **Decision:**
- **Date:**

Rationale and assumptions:

Evidence references:

Next review trigger/date:

161 Appendix U — AI Control Register

Legal status: Corrected English master. The register must identify whether each control implements binding law, contract, organizational

policy, a standard, recommended governance practice, or an optional enhancement. A control must not be labelled legally required unless the cited provision applies to the recorded actor, system, use, jurisdiction, and application date.

161.1 Purpose

Use this register to document AI controls, their legal or governance basis, scope, ownership, operating frequency, evidence, testing, effectiveness, remediation, and review triggers.

161.2 Control register

Readable record format (19 source columns):

- **Control ID:**
- **Control title/objective:**
- **Source type:**
- **Exact source/provision:**
- **Actor:**
- **Systems/versions in scope:**
- **Risk addressed:**
- **Owner:**
- **Performer:**
- **Trigger/frequency:**
- **Preventive/detective:**
- **Manual/automated:**
- **Procedure:**
- **Evidence:**
- **Retention basis:**
- **Test method:**
- **Last tested/result:**
- **Status:**
- **Gap/action:**

161.3 Source types

- Binding statutory or regulatory duty
- Contractual duty
- Organization-imposed policy or control
- Harmonised standard, common specification, or other recognized standard
- Recommended governance or assurance practice
- Optional enhancement

161.4 Minimum control domains

- governance, accountability, and board oversight;
- inventory, intake, ownership, and lifecycle status;
- applicability, actor-role, and statutory classification;
- prohibited-practice screening;
- risk, safety, and fundamental-rights assessment;
- data governance, privacy, and intellectual-property controls;
- technical documentation, version control, and evidence management;
- accuracy, robustness, cybersecurity, resilience, and misuse controls;
- transparency, instructions, accessibility, and human oversight;
- logging, traceability, monitoring, and recordkeeping;
- vendor, contract, dependency, and supply-chain governance;
- change, release, intended-purpose, and substantial-modification controls;
- conformity, registration, declaration, marking, and regulatory readiness where applicable;
- post-market monitoring, incidents, complaints, and corrective action;
- AI literacy, competence, internal audit, findings, and continuous improvement.

161.5 Control-design fields

For each control, record:

- scope, actor, system, version, jurisdiction, and application date;

- trigger and required inputs;
- detailed procedure and decision criteria;
- authority, segregation of duties, and escalation path;
- preventive or detective character;
- manual or automated operation and automation dependencies;
- evidence generated and system of record;
- retention basis and confidentiality restrictions;
- test method, acceptance criteria, and operating result;
- control dependencies, fallback, and compensating controls;
- failure consequences and required response;
- change and reassessment triggers.

161.6 Control status

Use one:

- Designed
- Implemented
- Operating
- Partially effective
- Ineffective
- Not applicable, with documented rationale
- Suspended
- Retired

Do not rate a control as operating or effective solely because a policy or procedure exists. The status must reflect current, version-linked evidence of performance.

161.7 Testing and remediation

Readable record format (10 source columns):

- **Control ID:**
- **Test period/sample:**

- **Design result:**
- **Operating result:**
- **Deficiency severity:**
- **Interim control:**
- **Remediation owner:**
- **Due date:**
- **Closure evidence:**
- **Independent validation:**

Repeated failures, unsupported exceptions, or overdue high-severity actions must be escalated according to the approved governance model.

161.8 Review triggers

Reassess after legal, actor-role, intended-purpose, system/model/version, data, supplier, jurisdiction, incident, complaint, audit, control-failure, conformity, or application-date changes.

161.9 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Register owner
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Legal/compliance
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Risk/control owner
- **Name:**

- **Decision:**
- **Date:**

Record 4

- **Role:** Internal audit/assurance, where applicable
- **Name:**
- **Decision:**
- **Date:**

Approval version:

Evidence repository:

Open material limitations:

Next review trigger/date:

162 Appendix V — AI Evidence Register

Legal status: Corrected English master. Evidence and retention requirements are provision-, actor-, system-, version-, event-, contract-, and jurisdiction-specific. The EU AI Act does not impose one universal retention period for all AI records.

162.1 Purpose

Use this register to identify, locate, control, retain, validate, and produce evidence supporting AI governance, statutory duties, conformity activities, contractual obligations, internal controls, audits, investigations, and management decisions.

162.2 Evidence register

Readable record format (17 source columns):

- **Evidence ID:**
- **Evidence title:**
- **Category:**
- **System/model/version:**
- **Actor/entity:**
- **Requirement/control:**
- **Exact source/provision:**
- **Period/event:**

- **Owner/source:**
- **Approval status:**
- **Repository location:**
- **Integrity control:**
- **Confidentiality:**
- **Retention basis/period:**
- **Legal hold:**
- **Last review:**
- **Gap/action:**

162.3 Evidence-quality criteria

Evidence should be:

- relevant to the stated legal, control, conformity, audit, or management purpose;
- complete for the applicable period, event, actor, system, and version;
- accurate, timely, and attributable to an accountable source;
- authentic and protected from unauthorized alteration or deletion;
- version-linked and reproducible where appropriate;
- understandable without unsupported assumptions;
- internally consistent and reconciled with related records;
- accessible to authorized reviewers while protecting confidentiality, privacy, intellectual property, and trade secrets;
- retrievable within the applicable contractual, regulatory, audit, or incident-response timeframe;
- retained and disposed of according to a documented legal and business basis.

A policy title, certificate, screenshot, vendor statement, or live webpage is not sufficient by itself unless scope, version, period, source, and supporting detail are established.

162.4 Evidence categories

- inventory, ownership, applicability, actor role, and classification;

- prohibited-practice, risk, FRIA, DPIA, safety, and rights assessments;
- data provenance, governance, quality, privacy, and lineage;
- architecture, technical documentation, configuration, and version history;
- validation, testing, accuracy, robustness, cybersecurity, accessibility, and subgroup results;
- conformity route, notified-body, declaration, registration, marking, and product-law records where applicable;
- transparency notices, instructions, human oversight, training, and competence;
- logging, monitoring, incidents, complaints, appeals, and corrective action;
- vendor, contract, dependency, change-notification, and exit records;
- authority correspondence, regulatory submissions, legal holds, litigation, and investigations;
- internal control testing, audit, assurance, findings, exceptions, and management approvals.

162.5 Evidence validation

Readable record format (9 source columns):

- **Evidence ID:**
- **Scope/version match:**
- **Authenticity verified:**
- **Completeness result:**
- **Consistency result:**
- **Retrievability test:**
- **Reviewer:**
- **Review date:**
- **Limitation/action:**

Do not treat evidence as current when it relates to a superseded model, configuration, jurisdiction, supplier, control period, or legal framework.

162.6 Retention and legal hold

For each record, identify the controlling legal, regulatory, contractual, conformity, litigation, investigation, employment, privacy, product-safety, or organizational basis. Record the clock-start event, retention period, disposal method, suspension of disposal, and legal-hold owner.

162.7 Gap management

Readable record format (9 source columns):

- **Gap ID:**
- **Missing or weak evidence:**
- **Legal/control impact:**
- **Interim control:**
- **Owner:**
- **Due date:**
- **Status:**
- **Closure evidence:**
- **Independent validation:**

Material evidence gaps affecting a legal duty, conformity route, incident investigation, authority request, release decision, or accepted residual risk must be escalated and may require restriction or suspension.

162.8 Review triggers

Update after system, model, data, actor-role, supplier, jurisdiction, legal, control, or retention changes; incidents or complaints; audits or conformity activity; authority requests; anticipated litigation or investigation; legal holds; and evidence-quality failures.

162.9 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Register owner
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Legal/compliance
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Records/privacy/security, as applicable
- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Audit/assurance, where applicable
- **Name:**
- **Decision:**
- **Date:**

Approval version:

Evidence repository:

Open material limitations:

Next review trigger/date:

163 Appendix W — Internal-Audit Programme

Legal status: Corrected English master. The EU AI Act does not impose a universal standalone internal-audit function on every organization. Internal audit is a voluntary or organization-required assurance practice and does not replace management accountability, conformity assessment, notified-body involvement, or authority oversight.

163.1 Purpose

Use this programme to plan risk-based internal-audit coverage of AI governance, systems, controls, evidence, legal readiness, and programme effectiveness.

163.2 1. Programme information

Field	Response
Audit period	
Chief audit executive or programme owner	
Approval authority	
Scope entities and jurisdictions	
Independence and access rights	
Current legal and policy baseline	
Available technical/legal specialists	

163.3 2. AI audit universe

Include, as applicable:

- enterprise AI governance, accountability, and board oversight;
- inventories, intake, ownership, lifecycle status, and shadow AI;
- applicability, actor-role, Article 5, Article 6, Article 50, GPAI, and sector classifications;
- high-risk and other material AI systems, models, versions, and deployments;
- risk, fundamental-rights, privacy, safety, and data-governance processes;
- technical documentation, version reconciliation, validation, robustness, cybersecurity, and resilience;
- human oversight, transparency, accessibility, complaints, and appeals;
- critical vendors, model providers, subprocessors, contracts, and concentration risk;
- change management, intended-purpose changes, substantial modification, and release controls;
- conformity readiness, registration, declarations, marking, and product-law interfaces where applicable;

- monitoring, incidents, corrective action, legal holds, evidence preservation, and authority response;
- AI literacy, competence, control testing, exceptions, remediation, and continuous improvement.

163.4 3. Risk assessment and annual plan

Readable record format (7 source columns):

- **Auditable area:**
- **Legal/operational significance:**
- **Inherent risk:**
- **Control maturity:**
- **Prior findings/incidents:**
- **Change level:**
- **Planned priority:**

Readable record format (8 source columns):

- **Audit engagement:**
- **Objective:**
- **Scope:**
- **Timing:**
- **Lead:**
- **Skills required:**
- **Estimated effort:**
- **Status:**

Prioritization should consider statutory deadlines, prohibited-practice exposure, high-risk and GPAI obligations, affected populations, incidents, complaints, significant changes, vendor dependency, weak evidence, and overdue remediation.

163.5 4. Engagement design

Each audit must define:

- objective, criteria, scope, period, entities, jurisdictions, systems, models, and versions;

- relevant actor roles, intended purposes, legal provisions, contracts, policies, and standards;
- exclusions, assumptions, evidence limitations, and reliance on other assurance;
- sampling strategy and population completeness;
- required technical, legal, privacy, security, data, accessibility, and domain expertise;
- independence, conflicts, management access, confidentiality, and quality review;
- reporting, escalation, corrective-action, and closure-validation methods.

163.6 5. Core audit objectives

- assess governance, accountability, decision rights, and board reporting;
- test inventory completeness, ownership, applicability, actor roles, and statutory classification;
- evaluate prohibited-practice controls and legally supported exceptions;
- test risk, rights, privacy, data, safety, and accessibility governance;
- reconcile technical documentation, evidence, configurations, and production versions;
- test accuracy, subgroup performance, robustness, cybersecurity, logging, oversight, and transparency controls;
- review vendor evidence, contract enforceability, dependency management, and exit readiness;
- test monitoring, incidents, complaints, legal holds, regulatory response, and corrective action;
- assess conformity readiness without representing internal audit as conformity assessment;
- determine whether findings, exceptions, and accepted risks are accurately escalated and sustainably remediated.

163.7 6. Testing methods

Use as appropriate:

- inquiry and observation;
- document and record inspection;
- walkthrough and reperformance;
- data analytics and population reconciliation;
- configuration, code, prompt, model, and control review;
- risk-based sampling;
- technical validation and adversarial testing by qualified specialists;
- tabletop exercises and regulatory simulations;
- third-party evidence and contract review;
- production-version and evidence-repository reconciliation.

Inquiry alone is not sufficient evidence of control operation.

163.8 7. Independence and competence

Document auditor independence, conflicts, technical competence, specialist involvement, legal consultation, quality review, access limitations, and any management restrictions. Auditors should not validate work for which they held incompatible design or operating responsibility without appropriate safeguards.

163.9 8. Finding classification

Readable record format (5 source columns):

Record 1

- **Rating:** Critical
- **Criteria:**
- **Legal/operational consequence:**
- **Escalation:**
- **Target remediation:**

Record 2

- **Rating:** High
- **Criteria:**
- **Legal/operational consequence:**

- **Escalation:**
- **Target remediation:**

Record 3

- **Rating:** Moderate
- **Criteria:**
- **Legal/operational consequence:**
- **Escalation:**
- **Target remediation:**

Record 4

- **Rating:** Low
- **Criteria:**
- **Legal/operational consequence:**
- **Escalation:**
- **Target remediation:**

Separate internal severity from legal reportability or statutory nonconformity. An internal rating does not determine whether notification, withdrawal, recall, corrective action, or authority cooperation is required.

163.10 9. Follow-up and closure

Readable record format (8 source columns):

- **Finding ID:**
- **Severity:**
- **Legal relevance:**
- **Owner:**
- **Due date:**
- **Interim control:**
- **Validation method:**
- **Closure date/status:**

Closure requires evidence that remediation operates effectively. Repeated extensions, unsupported risk acceptance, and recurring findings must be escalated.

Internal closure does not replace legally required correction, withdrawal, recall, reporting, notification, conformity activity, or authority action.

163.11 10. Reporting

Report scope, criteria, systems and versions tested, evidence limitations, findings, systemic themes, overdue actions, repeated failures, residual risk, management acceptance, legal implications, and matters requiring executive, board, audit-committee, conformity, or authority attention.

163.12 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Chief audit executive/programme owner
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Audit committee/board, where applicable
- **Name:**
- **Decision:**
- **Date:**

Evidence references:

Independence or scope limitations:

Unresolved high-risk matters:

Next plan review:

164 Appendix X — Corrective-Action Plan

Legal status: Corrected English master. This internal remediation workflow supports but does not replace legally required corrective measures, withdrawal, recall, suspension, incident reporting, authority cooperation, or affected-person remedies.

164.1 Purpose

Use this plan to remediate AI governance, legal, technical, operational, vendor, or evidence deficiencies and to validate sustainable closure. Closure requires evidence that the remediation operates effectively, not merely that documentation was updated.

164.2 1. Issue and legal context

Field	Response
Finding/incident/issue ID	
Source and date	
System/model/version and jurisdictions	
Legal entity and actor role	
Requirement/control affected	
Expected state and actual condition	
Severity, risk, and affected persons	
Date identified	
Issue owner and executive sponsor	
Evidence repository	

164.3 2. Issue statement

Describe the verified condition, applicable requirement or control, expected state, actual state, affected systems, models, versions, entities, jurisdictions, people, evidence, uncertainty, and legal or operational consequences.

164.4 3. Immediate containment or correction

Readable record format (6 source columns):

- **Action:**
- **Owner:**
- **Deadline:**
- **Legal/operational purpose:**
- **Status:**
- **Evidence:**

Assess and document, as applicable:

- suspension, restriction, disablement, withdrawal, or recall;
- manual fallback and protection of affected persons;
- evidence preservation and legal hold;
- vendor or value-chain escalation;
- regulatory, customer, worker, data-subject, or other notification;
- temporary monitoring, review, or access controls;
- prevention of recurrence while permanent remediation is pending.

164.5 4. Root-cause and affected-scope analysis

Assess:

- governance, accountability, and decision authority;
- process or control design;
- technical architecture, model, configuration, prompts, tools, or interfaces;
- data quality, provenance, labeling, lineage, or representativeness;
- human factors, workload, incentives, training, or competence;
- vendor, subprocessor, or dependency contribution;
- resource, scheduling, or segregation-of-duties weaknesses;
- monitoring, detection, escalation, or incident-response failure;
- documentation, version control, retention, or evidence weakness;
- whether similar systems, models, versions, jurisdictions, business units, or controls share the deficiency.

164.5.1 Root-cause conclusion

Document why the deficiency occurred, the evidence supporting the conclusion, alternative explanations considered, uncertainty, and the confirmed affected scope.

164.6 5. Corrective, preventive, and systemic actions

Readable record format (8 source columns):

- **Action:**
- **Type:** Correction / corrective / preventive / systemic
- **Owner:**

- **Due date:**
- **Dependency:**
- **Success criteria:**
- **Status:**
- **Validation evidence:**

Distinguish:

- **correction** — immediate action addressing the observed condition;
- **corrective action** — action removing the cause of an actual deficiency;
- **preventive action** — action reducing the likelihood of a foreseeable deficiency;
- **systemic action** — action addressing a common cause across systems, vendors, entities, or control domains.

164.7 6. Legal consequence mapping

Readable record format (6 source columns):

Record 1

- **Duty:** Corrective measure
- **Actor:**
- **Applies?:**
- **Deadline or source:**
- **Owner:**
- **Status and evidence:**

Record 2

- **Duty:** Incident or regulatory notification
- **Actor:**
- **Applies?:**
- **Deadline or source:**
- **Owner:**

- **Status and evidence:**

Record 3

- **Duty:** Withdrawal, recall, restriction, or suspension
- **Actor:**
- **Applies?:**
- **Deadline or source:**
- **Owner:**
- **Status and evidence:**

Record 4

- **Duty:** Risk-management or QMS update
- **Actor:**
- **Applies?:**
- **Deadline or source:**
- **Owner:**
- **Status and evidence:**

Record 5

- **Duty:** Technical-documentation or conformity update
- **Actor:**
- **Applies?:**
- **Deadline or source:**
- **Owner:**
- **Status and evidence:**

Record 6

- **Duty:** Registration, declaration, marking, or authority update
- **Actor:**
- **Applies?:**
- **Deadline or source:**

- **Owner:**
- **Status and evidence:**

Record 7

- **Duty:** Affected-person, customer, worker, or data-subject remedy
- **Actor:**
- **Applies?:**
- **Deadline or source:**
- **Owner:**
- **Status and evidence:**

Record 8

- **Duty:** Contractual or supplier action
- **Actor:**
- **Applies?:**
- **Deadline or source:**
- **Owner:**
- **Status and evidence:**

164.8 7. Risk during remediation

Document interim controls, residual risk, approved conditions or exceptions, reporting frequency, monitoring thresholds, escalation triggers, suspension criteria, and the authority permitted to accept temporary exposure. Risk acceptance cannot waive binding law or authorize prohibited or nonconforming use.

164.9 8. Validation plan

Readable record format (6 source columns):

- **Validation step:**
- **Independent tester:**
- **Evidence required:**
- **Planned date:**
- **Result:**

- **Limitation or follow-up:**

Validation should confirm design adequacy, implementation, operating effectiveness, version linkage, affected-scope coverage, absence of material unintended consequences, and sustainability over an appropriate period.

164.10 9. Closure decision

- ☐ Closed and effective
- ☐ Closed with ongoing monitoring
- ☐ Partially complete
- ☐ Reopened after failed validation
- ☐ Remain open because legal or operational duties are incomplete
- ☐ Risk accepted only within lawful authority

164.11 10. Lessons learned and programme updates

Record required updates to policies, controls, technical standards, models, data, training, monitoring, contracts, supplier oversight, assessments, documentation, evidence requirements, incident scenarios, and related systems.

164.12 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Issue owner
- **Name:**
- **Decision:**
- **Date:**

Record 2

- **Role:** Independent validator
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Legal/compliance/risk

- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Technical or product owner
- **Name:**
- **Decision:**
- **Date:**

Record 5

- **Role:** Executive sponsor, where required
- **Name:**
- **Decision:**
- **Date:**

Evidence references:

Residual risk and limitations:

Required external or authority closure:

Next monitoring or review date:

165 Appendix Y — Board Dashboard

Legal status: Corrected English master. Board or governing-body reporting is a governance practice unless a specific law, corporate-governance duty, sector rule, or organizational mandate requires it. Dashboard metrics do not by themselves demonstrate legal compliance.

165.1 Purpose

Use this dashboard to provide the board or governing body with concise, evidence-based oversight of AI risk, compliance, incidents, readiness, remediation, dependencies, and strategic decisions. Report legal conclusions, management targets, and maturity indicators separately.

165.2 1. Reporting scope and reliability

Field	Response
Reporting entity and period	
Systems, models, versions, jurisdictions, and business units	

Field	Response
covered	
Data owner and validation status	
Source systems and cut-off date	
Known exclusions, limitations, and uncertainty	
Current legal baseline and application dates	
Independent validation or assurance performed	

165.3 2. Executive status

Readable record format (6 source columns):

Record 1

- **Area:** Governance and ownership
- **Status:**
- **Trend:**
- **Evidence/source:**
- **Key message:**
- **Decision required:**

Record 2

- **Area:** Legal application dates and readiness
- **Status:**
- **Trend:**
- **Evidence/source:**
- **Key message:**
- **Decision required:**

Record 3

- **Area:** Prohibited-practice exposure
- **Status:**
- **Trend:**

- **Evidence/source:**
- **Key message:**
- **Decision required:**

Record 4

- **Area:** High-risk systems and conformity
- **Status:**
- **Trend:**
- **Evidence/source:**
- **Key message:**
- **Decision required:**

Record 5

- **Area:** GPAI and transparency duties
- **Status:**
- **Trend:**
- **Evidence/source:**
- **Key message:**
- **Decision required:**

Record 6

- **Area:** Fundamental rights, safety, privacy, and accessibility
- **Status:**
- **Trend:**
- **Evidence/source:**
- **Key message:**
- **Decision required:**

Record 7

- **Area:** Security, resilience, and vendors
- **Status:**

- **Trend:**
- **Evidence/source:**
- **Key message:**
- **Decision required:**

Record 8

- **Area:** Incidents, complaints, and regulatory matters
- **Status:**
- **Trend:**
- **Evidence/source:**
- **Key message:**
- **Decision required:**

Record 9

- **Area:** Assurance, findings, and remediation
- **Status:**
- **Trend:**
- **Evidence/source:**
- **Key message:**
- **Decision required:**

Record 10

- **Area:** AI literacy and competence
- **Status:**
- **Trend:**
- **Evidence/source:**
- **Key message:**
- **Decision required:**

Record 11

- **Area:** Strategic opportunities and constraints

- **Status:**
- **Trend:**
- **Evidence/source:**
- **Key message:**
- **Decision required:**

165.4 3. Portfolio profile

Readable record format (5 source columns):

Record 1

- **Metric:** Total inventoried AI systems and GPAI integrations
- **Current:**
- **Prior period:**
- **Target or threshold:**
- **Data quality/status:**

Record 2

- **Metric:** Inventory coverage estimate
- **Current:**
- **Prior period:**
- **Target or threshold:**
- **Data quality/status:**

Record 3

- **Metric:** Confirmed or potentially high-risk systems
- **Current:**
- **Prior period:**
- **Target or threshold:**
- **Data quality/status:**

Record 4

- **Metric:** Systems awaiting role or classification decision

- **Current:**
- **Prior period:**
- **Target or threshold:**
- **Data quality/status:**

Record 5

- **Metric:** Systems with overdue assessments or controls
- **Current:**
- **Prior period:**
- **Target or threshold:**
- **Data quality/status:**

Record 6

- **Metric:** Systems suspended, restricted, rejected, or retired
- **Current:**
- **Prior period:**
- **Target or threshold:**
- **Data quality/status:**

Record 7

- **Metric:** Systems in conformity or registration preparation
- **Current:**
- **Prior period:**
- **Target or threshold:**
- **Data quality/status:**

Record 8

- **Metric:** Critical vendors and concentration dependencies
- **Current:**
- **Prior period:**
- **Target or threshold:**

- **Data quality/status:**

Record 9

- **Metric:** Material model or supplier changes awaiting review
- **Current:**
- **Prior period:**
- **Target or threshold:**
- **Data quality/status:**

165.5 4. Legal and compliance exposure

Readable record format (5 source columns):

Record 1

- **Indicator:** Suspected prohibited practices
- **Status:**
- **Applicable source/date:**
- **Threshold:**
- **Management action:**

Record 2

- **Indicator:** Unresolved high-risk classification issues
- **Status:**
- **Applicable source/date:**
- **Threshold:**
- **Management action:**

Record 3

- **Indicator:** Overdue binding obligations
- **Status:**
- **Applicable source/date:**
- **Threshold:**
- **Management action:**

Record 4

- **Indicator:** Conformity, registration, declaration, or marking gaps
- **Status:**
- **Applicable source/date:**
- **Threshold:**
- **Management action:**

Record 5

- **Indicator:** High residual risks or unlawful blockers
- **Status:**
- **Applicable source/date:**
- **Threshold:**
- **Management action:**

Record 6

- **Indicator:** Material evidence gaps
- **Status:**
- **Applicable source/date:**
- **Threshold:**
- **Management action:**

Record 7

- **Indicator:** Regulatory commitments or authority requests
- **Status:**
- **Applicable source/date:**
- **Threshold:**
- **Management action:**

Record 8

- **Indicator:** Accepted exceptions or compensating controls
- **Status:**

- **Applicable source/date:**
- **Threshold:**
- **Management action:**

Do not describe internal readiness, maturity, risk acceptance, or board approval as legal conformity or authorization.

165.6 5. Performance and human impact

Report, with affected systems, versions, populations, jurisdictions, and trends:

- material accuracy, reliability, robustness, or security deterioration;
- subgroup disparities, discrimination indicators, and intersectional effects;
- human-review, override, disagreement, and appeal trends;
- accessibility, language, and accommodation failures;
- safety and fundamental-rights concerns;
- complaints, adverse outcomes, and vulnerable-group impacts;
- automation-bias, workload, or ineffective-oversight indicators;
- evidence of improvement or continued uncertainty.

165.7 6. Incidents and resilience

Readable record format (6 source columns):

Record 1

- **Metric or event:** Serious incidents or reportability assessments
- **Current:**
- **Severity:**
- **Trend:**
- **Required action:**
- **Owner/date:**

Record 2

- **Metric or event:** Security or privacy events
- **Current:**

- **Severity:**
- **Trend:**
- **Required action:**
- **Owner/date:**

Record 3

- **Metric or event:** Service disruptions or failed fallback
- **Current:**
- **Severity:**
- **Trend:**
- **Required action:**
- **Owner/date:**

Record 4

- **Metric or event:** Vendor or model-provider failures
- **Current:**
- **Severity:**
- **Trend:**
- **Required action:**
- **Owner/date:**

Record 5

- **Metric or event:** Failed continuity, incident, or regulatory exercises
- **Current:**
- **Severity:**
- **Trend:**
- **Required action:**
- **Owner/date:**

Record 6

- **Metric or event:** Open withdrawals, recalls, suspensions, or restrictions
- **Current:**
- **Severity:**
- **Trend:**
- **Required action:**
- **Owner/date:**

165.8 7. Assurance and remediation

Readable record format (5 source columns):

Record 1

- **Metric:** Open critical findings
- **Current:**
- **Target:**
- **Trend:**
- **Evidence/limitation:**

Record 2

- **Metric:** Open high findings
- **Current:**
- **Target:**
- **Trend:**
- **Evidence/limitation:**

Record 3

- **Metric:** Overdue corrective actions
- **Current:**
- **Target:**
- **Trend:**
- **Evidence/limitation:**

Record 4

- **Metric:** Repeat findings or incidents
- **Current:**
- **Target:**
- **Trend:**
- **Evidence/limitation:**

Record 5

- **Metric:** Validated closure rate
- **Current:**
- **Target:**
- **Trend:**
- **Evidence/limitation:**

Record 6

- **Metric:** Audit or assurance-plan completion
- **Current:**
- **Target:**
- **Trend:**
- **Evidence/limitation:**

Record 7

- **Metric:** Controls tested for operating effectiveness
- **Current:**
- **Target:**
- **Trend:**
- **Evidence/limitation:**

Record 8

- **Metric:** Findings with management risk acceptance
- **Current:**
- **Target:**

- **Trend:**
- **Evidence/limitation:**

Internal closure does not replace required correction, withdrawal, recall, reporting, notification, or authority action.

165.9 8. AI literacy and competence

Report completion, competence results, overdue high-risk roles, temporary restrictions, failed scenario exercises, recurring unsafe-use patterns, and whether staffing, workload, authority, or incentives undermine effective oversight.

165.10 9. Decisions required from the board

Readable record format (6 source columns):

- **Decision:**
- **Management recommendation:**
- **Legal/risk consequence of delay:**
- **Alternatives:**
- **Required date:**
- **Board decision:**

Potential decisions include funding, risk appetite, suspension or restriction, remediation priority, vendor exit, independent review, regulatory response, staffing, and approval of the next programme roadmap.

165.11 10. Management attestation

Management must disclose:

- scope, methodology, source systems, and reporting cut-off;
- unvalidated metrics and known data-quality issues;
- unresolved legal, technical, or operational uncertainty;
- material exclusions or blind spots;
- metrics based on vendor assertions rather than verified evidence;
- matters omitted for lawful privilege, confidentiality, security, or trade-secret reasons;
- whether reported trends are statistically and operationally meaningful.

165.12 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Executive sponsor
- **Name:**
- **Decision or attestation:**
- **Date:**

Record 2

- **Role:** Risk/compliance owner
- **Name:**
- **Decision or attestation:**
- **Date:**

Record 3

- **Role:** Legal or regulatory owner, where applicable
- **Name:**
- **Decision or attestation:**
- **Date:**

Record 4

- **Role:** Board or committee chair
- **Name:**
- **Decision or attestation:**
- **Date:**

Evidence references:

Known limitations and uncertainty:

Actions or decisions carried forward:

Next reporting date:

166 Appendix Z — AI-Governance Implementation Roadmap

Legal status: Corrected English master. The 30-day, 90-day, and monthly phases below are recommended internal programme milestones, not statutory EU AI Act deadlines. Binding application dates and transitional rules must be maintained in a separate current legal-date register.

166.1 Purpose

Use this roadmap to plan, sequence, assign, fund, monitor, and report implementation of an AI-governance and EU AI Act readiness programme. Internal milestones must never obscure earlier binding dates, actor-specific duties, conformity dependencies, or required authority action.

166.2 1. Programme and legal baseline

Field	Response
Executive sponsor	
Programme owner	
Scope entities, systems, models, and jurisdictions	
Start date and internal target dates	
Current consolidated legal source	
Binding provision and application-date register location	
Budget, staffing, and resource owner	
Legal, conformity, and assurance advisers	
Evidence repository	

166.3 2. Immediate legal-date control

Before using the roadmap, identify each applicable provision, actor, system or model, application date, transitional rule, conformity dependency, authority interaction, and responsible owner. Internal milestones must be accelerated where a binding date occurs earlier.

Readable record format (7 source columns):

- **Provision or obligation:**
- **Actor:**

- **System/model:**
- **Application date:**
- **Transition/dependency:**
- **Owner:**
- **Status/evidence:**

166.4 3. Phase 1 — First 30 days: establish control

Recommended actions:

Readable record format (6 source columns):

Record 1

- **Action:** Establish governance, decision rights, and escalation
- **Owner:**
- **Internal due date:**
- **Legal dependency:**
- **Status:**
- **Evidence:**

Record 2

- **Action:** Verify the current legal baseline and effective dates
- **Owner:**
- **Internal due date:**
- **Legal dependency:**
- **Status:**
- **Evidence:**

Record 3

- **Action:** Identify, block, restrict, or escalate prohibited and unresolved uses
- **Owner:**
- **Internal due date:**
- **Legal dependency:**

- **Status:**
- **Evidence:**

Record 4

- **Action:** Create the initial AI-system and GPAI inventory
- **Owner:**
- **Internal due date:**
- **Legal dependency:**
- **Status:**
- **Evidence:**

Record 5

- **Action:** Assign legal-entity, actor-role, system, technical, data, and risk owners
- **Owner:**
- **Internal due date:**
- **Legal dependency:**
- **Status:**
- **Evidence:**

Record 6

- **Action:** Triage high-risk, transparency, GPAI, privacy, security, accessibility, employment, consumer, product, and sector exposure
- **Owner:**
- **Internal due date:**
- **Legal dependency:**
- **Status:**
- **Evidence:**

Record 7

- **Action:** Establish immediate incident, complaint, evidence-preservation, legal-hold, and qualified-review processes

- **Owner:**
- **Internal due date:**
- **Legal dependency:**
- **Status:**
- **Evidence:**

Record 8

- **Action:** Begin proportionate AI-literacy measures
- **Owner:**
- **Internal due date:**
- **Legal dependency:**
- **Status:**
- **Evidence:**

Record 9

- **Action:** Define urgent release blocks and interim controls
- **Owner:**
- **Internal due date:**
- **Legal dependency:**
- **Status:**
- **Evidence:**

166.5 4. Phase 2 — Days 31-90: operationalize

Recommended actions:

Readable record format (6 source columns):

Record 1

- **Action:** Reconcile inventory, actor roles, intended purposes, and classifications
- **Owner:**
- **Internal due date:**
- **Dependency:**

- **Status:**
- **Evidence:**

Record 2

- **Action:** Complete priority applicability, prohibited-practice, high-risk, FRIA/DPIA, risk, and vendor assessments
- **Owner:**
- **Internal due date:**
- **Dependency:**
- **Status:**
- **Evidence:**

Record 3

- **Action:** Establish control, evidence, legal-date, issue, and exception registers
- **Owner:**
- **Internal due date:**
- **Dependency:**
- **Status:**
- **Evidence:**

Record 4

- **Action:** Review critical vendors, contracts, model providers, subprocessors, and exit dependencies
- **Owner:**
- **Internal due date:**
- **Dependency:**
- **Status:**
- **Evidence:**

Record 5

- **Action:** Approve lifecycle intake, release, change, and substantial-modification gates
- **Owner:**
- **Internal due date:**
- **Dependency:**
- **Status:**
- **Evidence:**

Record 6

- **Action:** Approve human oversight, transparency, accessibility, monitoring, complaint, incident, and corrective-action processes
- **Owner:**
- **Internal due date:**
- **Dependency:**
- **Status:**
- **Evidence:**

Record 7

- **Action:** Remediate urgent documentation, security, data, logging, accessibility, language, and contract gaps
- **Owner:**
- **Internal due date:**
- **Dependency:**
- **Status:**
- **Evidence:**

Record 8

- **Action:** Establish management and board reporting
- **Owner:**
- **Internal due date:**
- **Dependency:**

- **Status:**
- **Evidence:**

166.6 5. Phase 3 — Months 4-6: stabilize and validate

Recommended actions:

Readable record format (6 source columns):

Record 1

- **Action:** Implement applicable high-risk and GPAI control baselines
- **Owner:**
- **Internal due date:**
- **Dependency:**
- **Status:**
- **Evidence:**

Record 2

- **Action:** Complete priority technical documentation and version reconciliation
- **Owner:**
- **Internal due date:**
- **Dependency:**
- **Status:**
- **Evidence:**

Record 3

- **Action:** Perform performance, subgroup, robustness, cybersecurity, oversight, and misuse testing
- **Owner:**
- **Internal due date:**
- **Dependency:**
- **Status:**
- **Evidence:**

Record 4

- **Action:** Operationalize change, release, supplier, and substantial-modification management
- **Owner:**
- **Internal due date:**
- **Dependency:**
- **Status:**
- **Evidence:**

Record 5

- **Action:** Test continuity, serious-incident, legal-hold, and regulatory-response workflows
- **Owner:**
- **Internal due date:**
- **Dependency:**
- **Status:**
- **Evidence:**

Record 6

- **Action:** Begin independent design and operating-effectiveness assurance
- **Owner:**
- **Internal due date:**
- **Dependency:**
- **Status:**
- **Evidence:**

Record 7

- **Action:** Close critical findings and independently validate remediation
- **Owner:**
- **Internal due date:**

- **Dependency:**
- **Status:**
- **Evidence:**

Record 8

- **Action:** Review conformity, registration, declaration, marking, and authority-access readiness where applicable
- **Owner:**
- **Internal due date:**
- **Dependency:**
- **Status:**
- **Evidence:**

166.7 6. Phase 4 — Months 7-12: scale and mature

Recommended actions:

Readable record format (6 source columns):

Record 1

- **Action:** Scale governance across entities, business units, languages, and jurisdictions
- **Owner:**
- **Internal due date:**
- **Dependency:**
- **Status:**
- **Evidence:**

Record 2

- **Action:** Improve reliable monitoring, evidence collection, and version linkage
- **Owner:**
- **Internal due date:**
- **Dependency:**

- **Status:**
- **Evidence:**

Record 3

- **Action:** Complete applicable conformity-readiness and formal statutory processes
- **Owner:**
- **Internal due date:**
- **Dependency:**
- **Status:**
- **Evidence:**

Record 4

- **Action:** Expand internal audit, thematic review, and operating-effectiveness testing
- **Owner:**
- **Internal due date:**
- **Dependency:**
- **Status:**
- **Evidence:**

Record 5

- **Action:** Conduct regulatory-response, incident, continuity, and vendor-exit simulations
- **Owner:**
- **Internal due date:**
- **Dependency:**
- **Status:**
- **Evidence:**

Record 6

- **Action:** Perform maturity and residual-risk assessment without treating maturity as compliance
- **Owner:**
- **Internal due date:**
- **Dependency:**
- **Status:**
- **Evidence:**

Record 7

- **Action:** Approve the next roadmap, budget, staffing, technology, and continuous-improvement plan
- **Owner:**
- **Internal due date:**
- **Dependency:**
- **Status:**
- **Evidence:**

Record 8

- **Action:** Report unresolved legal exposure, overdue remediation, and accepted risk to appropriate governance bodies
- **Owner:**
- **Internal due date:**
- **Dependency:**
- **Status:**
- **Evidence:**

166.8 7. Workstream tracker

Track at minimum:

- governance and accountability;
- legal applicability, territorial scope, actor roles, and application dates;
- inventory, intended purpose, and classification;

- prohibited-practice controls;
- high-risk and GPAI readiness;
- risk, fundamental-rights, privacy, safety, and accessibility assessment;
- data governance and lineage;
- technical documentation, validation, logging, robustness, and cybersecurity;
- human oversight, transparency, complaints, and remedies;
- vendor, contract, concentration, continuity, and exit management;
- change, release, intended-purpose, and substantial-modification controls;
- post-market monitoring, incidents, corrective action, and authority response;
- conformity, registration, declaration, marking, and regulatory readiness;
- AI literacy and competence;
- evidence, retention, legal hold, audit, remediation, and continuous improvement.

Readable record format (7 source columns):

- **Workstream:**
- **Binding obligation/date:**
- **Internal milestone:**
- **Owner:**
- **Dependency:**
- **Status:**
- **Evidence:**

166.9 8. Milestones and dependencies

Readable record format (6 source columns):

- **Milestone:**
- **Dependency:**

- **Target date:**
- **Owner:**
- **Status:**
- **Evidence:**

Dependencies may include legal interpretation, supplier evidence, product-law conformity, notified-body capacity, data remediation, technical validation, local consultation, accessibility, staffing, procurement, budget, and authority processes.

166.10 9. Risk and issue log

Readable record format (8 source columns):

- **Risk or issue:**
- **Legal/operational impact:**
- **Likelihood:**
- **Mitigation or interim control:**
- **Owner:**
- **Due date:**
- **Escalation:**
- **Status:**

166.11 10. Programme metrics

Track metrics with defined sources, owners, thresholds, cut-off dates, and limitations, including:

- inventory and ownership coverage;
- actor-role and classification completion;
- prohibited-use reviews and blocked uses;
- high-risk and GPAI systems with current evidence;
- applicable obligations completed before binding dates;
- conformity and registration status;
- overdue controls, exceptions, and remediation;
- critical-vendor evidence, incidents, and concentration exposure;

- AI-literacy completion and competence results;
- complaints, appeals, incidents, and affected-person outcomes;
- audit findings, repeat failures, and independently validated closure;
- readiness and maturity indicators clearly labelled as internal measures.

166.12 11. Governance cadence

Readable record format (5 source columns):

Record 1

- **Forum:** Working group
- **Frequency:**
- **Purpose:**
- **Required reporting:**
- **Decision authority:**

Record 2

- **Forum:** AI governance or risk committee
- **Frequency:**
- **Purpose:**
- **Required reporting:**
- **Decision authority:**

Record 3

- **Forum:** Executive committee
- **Frequency:**
- **Purpose:**
- **Required reporting:**
- **Decision authority:**

Record 4

- **Forum:** Board or board committee
- **Frequency:**

- **Purpose:**
- **Required reporting:**
- **Decision authority:**

Record 5

- **Forum:** Risk, audit, legal, or conformity forum
- **Frequency:**
- **Purpose:**
- **Required reporting:**
- **Decision authority:**

166.13 12. Completion rule

Programme completion requires:

- current legal and application-date mapping;
- defensible actor-role and classification decisions;
- accountable ownership and funded resources;
- implemented and operating controls;
- current, version-linked, retrievable evidence;
- tested human oversight, escalation, fallback, incident, and regulatory-response processes;
- completed statutory conformity and authority processes where applicable;
- validated remediation and sustainable monitoring;
- a funded continuous-improvement plan.

Documents, checklists, internal approvals, readiness reviews, or maturity scores alone do not establish legal compliance.

166.14 Approval

Readable record format (4 source columns):

Record 1

- **Role:** Executive sponsor
- **Name:**

- **Decision:**
- **Date:**

Record 2

- **Role:** Programme owner
- **Name:**
- **Decision:**
- **Date:**

Record 3

- **Role:** Legal/compliance
- **Name:**
- **Decision:**
- **Date:**

Record 4

- **Role:** Technical/product leadership
- **Name:**
- **Decision:**
- **Date:**

Record 5

- **Role:** Risk/audit/conformity, as applicable
- **Name:**
- **Decision:**
- **Date:**

Evidence references:

Unresolved legal, technical, supplier, or conformity dependencies:

Approved deviations and interim controls:

Next review trigger or date: